전자금융감독규정 해설

2025. 8.

FSS
www.fss.or.kr
FINANCIAL SUPERVISORY SERVICE

금융감독원

※ 동 해설서는 전자금융감독규정 및 동 규정 시행세칙의 내용을 관련 업무 종사자가 이해하기 쉽게 만든 내용으로, 개별 사안에 따라 행정관청의 유권해석은 본 해설서 내용과 상이할 수 있음을 알려드립니다.

※ 비조치의견서는 행정해석의 일종으로 최종 법적구속력은 없으며, 유권해석과는 달리 특정행위에 대해 해당 회사의 상황을 고려한 검토결과로써 일반적 효력을 가지지 아니하므로 참고자료로만 활용하시기 바랍니다.

머 리 말

최근 인공지능·클라우드 등 新기술에 의한 디지털 전환이 점차 가속화되면서, 금융권은 새로운 혁신의 가능성을 마주하고 있으며 소비자도 다양한 금융서비스를 편리하게 이용할 수 있게 되었습니다. 특히, 생성형 AI의 도입은 금융회사의 업무 효율성을 한층 제고하고, 소비자에게 보다 높은 수준의 금융 경험을 제공할 수 있을 것입니다.

금융위원회와 금융감독원은 이러한 환경 변화에 대응하여 전자금융거래법 등의 규제 체계를 지속적으로 보완함으로써, 디지털금융 발전을 지원하는 동시에 금융소비자 보호에서도 사각지대가 발생하지 않도록 노력해 왔습니다.

예컨대, 금융 분야에서 클라우드를 활발히 이용할 수 있도록 제도를 개선(2018년, 2022년)하였으며, 선불업에 대한 규제를 강화하여 고객 자금 보호장치를 마련(2024년)하였고, 지급결제 시장의 경쟁 촉진 및 소비자 편의성 향상을 위해 소액후불결제업(BNPL)을 정식 제도화(2024년)하였습니다.

나아가, 금융회사 등이 생성형 AI 등의 연구 · 개발 목적으로 망분리 규제 예외 적용시 가명처리된 개인신용정보도 활용할 수 있도록 허용(2024년)하였으며, 금융회사 등이 급변하는 IT 환경과 보안 위험에 유연하게 적응할 수 있도록 규제 체계를 원칙 중심으로 합리화(2025년)하였습니다.

이에 그간의 제도 및 규제 변화를 반영하고, 법령해석, 비조치의견서 및 조치사례 등을 망라하여 전자금융감독규정 해설서를 전면 개정하였습니다.

본 해설서가 디지털금융이라는 새로운 물결 속에서 금융회사 등의 업무 수행에 실질적인 도움이 될 수 있는 나침반이 되기를 기대합니다.

2025년 8월

금융감독원 디지털 · IT 부원장보 **이 종 오**

목 차

제 1 장 주요내용

1. 연혁 ····· 2
2. 기본개념 ····· 3

제 2 장 총 칙

1. 규정 목적 ····· 15
2. 용어의 정의 ····· 16
3. 전자금융보조업자 ····· 21

제 3 장 전자금융거래 당사자의 권리와 의무

1. 확인에 필요한 구체적인 거래 내용 ····· 26
2. 전자금융사고 책임이행을 위한 보험 등의 가입에 관한 기준 ····· 28
3. 추심이체 출금동의의 방법 ····· 31
4. 정보보호최고책임자(CISO)의 지정대상 ····· 37

제 4 장 전자금융거래의 안전성 확보 및 이용자 보호

제1절 통칙 ····· 42

1. 전자금융거래 종류별 안전성 기준 ····· 42

제2절 인력, 조직 및 예산 부문 ····· 43

1. 인력, 조직, 교육 및 예산 ····· 43
2. 정보보호위원회의 운영 ····· 45
3. 직무의 분리 ····· 48

목 차

제3절 시설 부문 ····· 49
1. 건물에 관한 사항 ····· 49
2. 전원, 공조 등 설비에 관한 사항 ····· 50
3. 전산실 등에 관한 사항 ····· 50

제4절 정보기술부문 ····· 52
1. 단말기 보호대책 ····· 52
2. 전산자료 보호대책 ····· 55
3. 정보처리시스템 보호대책 ····· 60
4. 클라우드컴퓨팅서비스 이용절차 ····· 63

제5절 정보보호부문 ····· 78
1. 해킹 등 방지대책 ····· 78
※ 금융회사등의 망분리
※ 금융분야 망분리 개선 로드맵 연구·개발망 관련 Q&A
2. 악성코드 감염 방지대책 ····· 113
3. 홈페이지 등 공개용 웹서버 관리대책 ····· 115
4. IP주소 관리대책 ····· 119
5. 암호프로그램 및 키 관리 통제 ····· 121
6. 사용자 인증수단 관리 ····· 122

제6절 사업부문 ····· 123
1. 정보처리시스템 구축 및 전자금융거래 관련 사업 추진 ····· 123
2. 정보처리시스템 구축 및 전자금융거래 관련 계약 ····· 124
3. 정보처리시스템 감리 ····· 126

제7절 업무지속성 부문 ····· 128
1. 비상대책 ····· 128
2. 비상대응훈련 ····· 134
3. 정보처리시스템의 성능관리 ····· 136

제8절 정보기술부문 내부통제 ····· 138
1. 전산원장 통제 ····· 138
2. 거래통제 ····· 140
3. 프로그램 통제 ····· 141
4. 일괄작업에 대한 통제 ····· 144

제9절 전자금융업무 ····· 145
1. 전자금융거래 시 준수사항 ····· 145
2. 인증방법 사용기준 ····· 149
3. 이용자 비밀번호 관리 ····· 151
4. 이용자 유의사항 공지 ····· 155
5. 자체 보안성심의 ····· 156
6. 정보기술부문 계획서 ····· 161

제10절 취약점 분석 및 사고 대응 등 ····· 164
1. 전자금융기반시설의 취약점 분석·평가주기, 내용 등 ····· 164
2. 전자금융기반시설의 취약점 분석·평가 전문기관의 지정 등 ····· 170
3. 침해사고 통지의 방법 ····· 171
4. 정보기술부문 및 전자금융 사고보고 ····· 172
5. 침해사고대응기관 지정 및 업무범위 ····· 180
6. 금융위가 정하는 보관자료 및 거래기록 등 ····· 182
7. 전자지급수단의 이용한도 ····· 183
8. 약관교부 방법 및 관련 보고 ····· 185

제 5 장 전자금융업의 허가와 등록 및 업무

1. 개요 ····· 192
2. 허가 대상 업무 및 면제요건 ····· 192

목 차

제1절 허가 및 등록의 대상과 절차 ····· 193
1. 발행잔액 및 연간 총 발행액의 산정방법 등 ····· 193
2. 허가 등 절차의 구분 ····· 195
3. 예비허가 등 ····· 195
4. 허가 등 ····· 196
5. 등록 ····· 198
6. 기재가 생략되는 출자자의 범위 ····· 199

제2절 허가 및 등록의 세부요건 ····· 202
1. 인력 및 물적 시설 세부요건 ····· 202
2. 국외 사이버몰을 위한 전자지급결제대행업 ····· 206
3. 재무건전성 세부기준 및 계산방법 ····· 208
4. 사업계획에 관한 요건 ····· 211
5. 주요출자자에 관한 요건 ····· 212
6. 허가 및 등록신청 결격자 ····· 212
7. 신청에 따른 등록말소 및 이용자보호조치 ····· 217

제3절 전자금융업의 업무 ····· 218
1. 전자화폐 발행업자의 겸업가능 업무 ····· 218
2. 선불업자의 소액후불결제업무 겸영 ····· 219
3. 수수료 및 준수사항 등의 고지방법 ····· 219

제 6 장 전자금융업무의 감독

1. 금융회사의 정보기술부문 실태평가 ····· 222
2. 외부주문등에 대한 기준 ····· 227
3. 전자금융보조업자의 자료제출 ····· 244
4. 업무보고서 ····· 245
5. 전자금융업자 경영지도기준 ····· 247
6. 전자금융업자 적기시정조치 ····· 250

제1장 주요내용

FSS
FINANCIAL SUPERVISORY
SERVICE

제1장 주요내용

1. 연혁

2000.12. 금융기관 전자금융업무감독규정(금융감독위원회공고 제2000-117호) 제정
2001. 4. 금융기관 전자금융업무 감독규정 및 동 시행세칙 시행
2006.12. 전자금융감독규정(금융감독위원회공고 제2006-88호) 전부개정
2007. 1. 전자금융거래법(법률 제7929호, 2006.4.28. 제정) 시행
2007. 6. 전자금융감독규정(금융감독위원회공고 제2007-42호) 일부개정
2007. 9. 전자금융감독규정(금융감독위원회공고 제2007-120호) 일부개정
2008. 1. 전자금융감독규정(금융감독위원회공고 제2008-4호) 일부개정
2008. 4. 전자금융감독규정(금융위원회고시 제2008-8호) 일부개정
2008. 7. 전자금융감독규정(금융위원회고시 제2008-21호) 일부개정
2009. 8. 전자금융감독규정(금융위원회고시 제2009-50호) 타법개정
2010. 6. 전자금융감독규정(금융위원회고시 제2010-18호) 일부개정
2011.10. 전자금융감독규정(금융위원회고시 제2011-18호) 전부개정
2012.10. 전자금융감독규정(금융위원회고시 제2012-26호) 일부개정
2013. 6. 전자금융감독규정(금융위원회고시 제2013-20호) 일부개정
2013.12. 전자금융감독규정(금융위원회고시 제2013-39호) 일부개정
2013.12. 전자금융감독규정(금융위원회고시 제2013-44호) 일부개정
2015. 2. 전자금융감독규정(금융위원회고시 제2015-3호) 일부개정
2015. 3. 전자금융감독규정(금융위원회고시 제2015-7호) 일부개정
2015. 6. 전자금융감독규정(금융위원회고시 제2015-18호) 일부개정
2016. 6. 전자금융감독규정(금융위원회고시 제2016-24호) 일부개정
2016.10. 전자금융감독규정(금융위원회고시 제2016-37호) 일부개정
2018.12. 전자금융감독규정(금융위원회고시 제2018-36호) 일부개정
2022.11. 전자금융감독규정(금융위원회고시 제2022-44호) 일부개정
2024. 9. 전자금융감독규정(금융위원회고시 제2024-44호) 일부개정
2024.12. 전자금융감독규정(금융위원회고시 제2024-60호) 일부개정
2025. 2. 전자금융감독규정(금융위원회고시 제2025-4호) 일부개정

2. 기본개념

가. 전자금융거래의 정의 및 개념 요소

- 전자금융거래법은 전자금융거래를 '이용자가 전자금융업무(금융회사 또는 전자금융업자가 전자적 장치를 통하여 금융상품 및 서비스를 제공하는 것)를 비대면의 자동화된 방식으로 이용하는 거래'로 정의(제2조 제1호)

※ 관계 법령

법

제2조(정의) 이 법에서 사용하는 용어의 정의는 다음과 같다.

1. "전자금융거래"라 함은 금융회사 또는 전자금융업자가 전자적 장치를 통하여 금융상품 및 서비스를 제공(이하 "전자금융업무"라 한다.)하고, 이용자가 금융회사 또는 전자금융업자의 종사자와 직접 대면하거나 의사소통을 하지 아니하고 자동화된 방식으로 이를 이용하는 거래를 말한다.

- 전자금융거래가 성립하기 위해서는 (ㄱ)금융회사 또는 전자금융업자가 전자적 장치를 통하여 금융상품 및 서비스를 제공("전자금융업무")하고 (ㄴ)이용자가 비대면의 자동화된 방식으로 이를 이용하여야 함
  - '전자금융업자'란 전자화폐의 발행 및 관리, 전자자금이체, 직불전자지급수단의 발행 및 관리, 선불전자지급수단의 발행 및 관리, 전자지급결제대행, 결제대금예치, 전자고지결제 등의 업무를 행하고자 금융위원회의 허가를 받거나 금융위원회에 등록을 한 사업자(금융회사 제외)를 말함

- 전자금융업무의 형태 : 금융상품 및 금융서비스를 '전자적 장치'를 통하여 제공
  - 전자적 장치를 '통하여 제공'한다는 의미
    - 금융상품 및 서비스를 전자적 장치를 통하여 제공한다는 것은 이용자가 비대면으로 전자적 장치를 통하여 금융상품 및 서비스에 직접 접근할 수 있게 하는 정도에 이르러야 함을 의미
    - 단순히 전자적 장치를 금융회사 또는 전자금융업자의 업무에 활용하는 것만으로는 전자적 장치를 통한 제공에 해당되지 않음
    - 예컨대 이용자가 금융회사 종사자와 대면하여 자금이체 지시를 한 경우에 금융회사 종사자가 거래지시 이행을 위하여 전자적 장치를 활용하는 경우 이를 전자적 장치를 통한 제공이라 할 수 없음

※ 법령해석('19.06.18.)-180408

질의

- 당사가 도입 검토 중인 [모바일을 통한 약정서 제출 및 본인인증] 방식이 전자금융거래법 제2조 비대면과 자동화를 속성으로 하는 전자금융거래에 해당되는지 여부

회신

- 질의상에 [모바일을 통한 약정서 제출 및 본인인증] 방식은 이용자가 전자금융업자의 종사자와 직접 대면한 상황에서 약정서를 제출하고 본인인증을 하는 경우로, 전자금융거래에 해당하지 않습니다.

이유

- 「전자금융거래법」 제2조 제1호는 "전자금융거래라 함은 금융회사 또는 전자금융업자가 전자적 장치를 통하여 금융상품 및 서비스를 제공하고, 이용자가 금융회사 또는 전자금융 업자의 종사자와 직접 대면하거나 의사소통을 하지 아니하고 자동화된 방식으로 이를 이용하는 거래"로 정의하고 있습니다.

※ 관계 법령

법

제2조(정의) 이 법에서 사용하는 용어의 정의는 다음과 같다.

8. "전자적 장치"라 함은 전자금융거래정보를 전자적 방법으로 전송하거나 처리하는데 이용되는 장치로서 현금자동지급기, 자동입출금기, 지급용단말기, 컴퓨터, 전화기 그 밖에 전자적 방법으로 정보를 전송하거나 처리하는 장치를 말한다.

전자금융업무의 객체: 금융상품 및 서비스

- 전자금융거래법은 '금융회사' 및 '전자금융업자'만을 정의하고 '금융상품 서비스'개념에 대해 별도로 정하고 있지 않음
- '금융상품 및 서비스'에 대하여 다음과 같은 견해가 있을 수 있음
  - '금융'의 개념을 중시하여 금융회사 또는 전자금융업자가 자금의 융통과 관계된 상품 또는 서비스를 제공하는 경우에 국한하는 견해(협의의 개념)
  - 금융상품 및 서비스에 대한 정의를 별도로 하지 않은 점을 감안, '금융상품 및 서비스'란 금융회사 또는 전자금융업자가 제공하는 금융 관련상품 및 서비스 일반을 의미한다고 해석하는 견해(광의의 개념)
- 전자금융업무의 범위는 전자금융거래의 대중화, 다양화 및 이용자 보호 등을 고려할 때 광의의 개념으로 보는 것이 타당함
  - 따라서 인터넷을 통한 신용정보, 자산보유 또는 거래내역 조회 서비스 제공도 전자금융업무에 해당함

- 금융상품의 제공 과정에서 수반되거나 밀접한 관련을 가지고 이용자에게 제공되는 '서비스'로서 개인정보 · 신용정보 · 전자금융거래기록 등을 비롯한 일체의 정보 처리 업무 등(예 : 스마트뱅킹 이용 전 정보처리업무 – 이용자의 비밀번호 등록)도 전자금융업무에 해당함 (법령해석 200273)

※ 법령해석('20.8.25.)-200273

질의

■ 통상적으로 은행 영업점을 이용하여 스마트뱅킹을 신청할 경우 창구에 비치된 핀패드를 이용하여 고객이 직접 임시비밀번호를 등록하고, 이후 전자적 장치를 통해 고객이 설정한 이용자ID와 임시비밀번호를 입력하는 과정을 거쳐 스마트뱅킹 정식 비밀번호를 지정하도록 함

* 해당 스마트 뱅킹 시스템에서는 이용자 ID 및 임시비밀번호 입력시에는 최초 비밀번호등록 화면으로 이동하여 비밀번호의 등록절차까지만 진행될 뿐, 해당 시스템을 통한 고객정보의 조회 등을 위해서는 등록한 최초 비밀번호를 이용하여 별도의 로그인 절차를 거쳐야할 뿐만 아니라, 송금 · 이체 등을 위해서는 공인인증서 · ARS 등 추가인증이 필요

■ 만약 이러한 과정에서 영업점 직원이 고객의 이용자ID와 임시비밀번호를 이용하여 정식비밀번호를 등록하였다면, 이와 같은 스마트뱅킹 이용 전의 정보처리업무가 전자금융거래법 상 전자금융거래에 해당하는지 여부

회신

■ "전자금융거래"란 금융회사 등의 자금의 융통, 송금 · 자금이체 등 지급거래, 그 밖에 전자적 장치를 통해 이루어지는 '금융상품'의 제공 자체에 한정되는 개념이라기 보다는, 금융상품의 제공 과정에서 수반되거나 밀접한 관련을 가지고 이용자에게 제공되는 '서비스'로서 개인정보 · 신용정보 · 전자금융거래기록 등을 비롯한 일체의 '정보 처리'를 포함하는 법개념으로 해석됩니다.

• 스마트뱅킹 이용 전 정보처리업무도 금융상품의 제공 과정에서 수반되거나 이에 밀접한 관련을 가지고 있으므로, 「전자금융거래법」 상 전자금융거래에 해당한다고 볼 수 있습니다.

이유

■ "전자금융거래"란 금융회사 또는 전자금융업자가 ⁱ⁾전자적 장치를 통하여 ⁱⁱ⁾금융상품 및 서비스를 제공(이하 "전자금융업무")하고, ⁱⁱⁱ⁾이용자가 금융회사 또는 전자금융업자의 종사자와 직접 대면하거나 의사소통을 하지 아니하고 자동화된 방식으로 이를 이용하는 거래를 말합니다(「전자금융거래법」 제2조제1호). 이 경우, 질의하신 해당 스마트뱅킹 시스템이 전자금융거래의 개념 중 ⅰ) · ⅲ)의 개념요소를 포함하고 있음은 명백하지만 그 시스템에서 ⅱ)의 '금융상품 및 서비스의 제공'이 이루어지는지 여부는 추가로 살펴보아야 합니다.

• 「전자금융거래법」에서는 전자적 장치를 통한 '금융상품 및 서비스의 제공', 즉 전자금융업무에 대해서는 별도로 개념을 정하고 있지는 아니합니다. 그런데, '금융상품 및 서비스'에 대해서는 자금의 융통과 관계된 상품 또는 서비스를 제공하는 경우에 국한하지 않고, 금융회사 등이 제공하는 금융 관련상품 및 서비스 일반을 의미한다고 보아인터넷을 통한 신용정보, 자산보유 또는 거래내역 조회 서비스 제공도 전자금융업무에 해당한다고 보는 실무 해석 관행이 확인됩니다(금융감독원, '전자금융감독규정해설', 2017년 참조). 이러한 실무 해석 관행이 일반적 · 보편적인 법해석으로 나아가기 위해서는 "문언의 통상적인 의미에 충실하는 것을 원칙으로 하고, 나아가 법률의 입법취지와 목적, 그 제 · 개정 연혁, 법질서 전체와의 조화, 다른 법령과의 관계 등을 고려하는 체계적 · 논리적 해석 방법을 추가적으로 동원"할 필요가 있습니다.(대법원2009.4.23. 선고, 2006다81035 판결 등 참조)

- 먼저, “금융상품”에 관한 다른 법령과의 관계를 살펴보면, 「금융소비자보호법(2021.9월 시행 예정)」에 따른 “금융상품”이란, 「은행법」에 따른 예금 및 대출, 「자본시장법」에 따른 금융투자상품, 「보험업법」에 따른 보험상품등을 의미하고, 「자본시장법」에 따른 “금융투자상품”이란 이익을 얻거나 손실을 회피할 목적으로 현재 또는 장래 특정시점에 금전, 그밖의 재산적 가치가 있는 것을 지급하기로 약정함으로써 취득하는 ‘계약상의 권리’를 말하며, 「보험업법」도 보험상품을 위험보장을 목적으로 우연한 사건발생에 관하여 금전 및 그밖의 급여를 지급할 것을 약정하고 대가를 수수하는 ’계약’으로 정의하는 점 등에 비추어 볼 때 금융상품의 통상적 의미에는 계약이라는 개념요소를 포함하고 있음을 확인할 수 있습니다.
- 한편, 금융상품의 계약적 요소 등으로 인해 대부분의 전자금융업무 처리 과정에는 그 계약당사자를 확인하는 과정을 거치게 됩니다. 특히, 금융회사 등과 이용자 간에 비대면, 자동화된 방식으로 이루어지는 전자금융거래의 특성 상, 계약당사자의 진실성과 정확성을 확인하는 절차도 전자적으로 이루어 질 수 밖에 없습니다. 이는 「전자금융거래법」에서 전자금융거래에 있어서 거래지시를 하거나 이용자 및 거래내용의 진실성과 정확성을 확보하기 위하여 사용되는 수단 또는 정보로서 “접근매체”에 대해 별도의 규율을 두고 있는 점(법 제2조제10호) 등에서도 확인됩니다. 이와 같이, 전자금융업무에는 계약당사자의 확정 등을 위한 개인정보, 거래내역 등에 관한 신용정보, 거래지시 등에 관한 전자금융거래기록 등 다양한 정보 처리가 필수적으로 수반된다고 할 수 있습니다.
- 따라서, 스마트뱅킹 이용 전 정보처리업무 역시 금융상품의 제공 과정에서 수반되거나 이에 밀접한 관련을 가지고 있으므로, 「전자금융거래법」 상 전자금융거래에 해당한다고 볼 수 있습니다.

전자금융업무 이용 방식 : 자동화된 방식

- 전자금융거래는 이용자가 전자금융업무를 자동화된 방식으로 이용하는 거래임
  - 전자적 장치를 통하여 제공되는 전자금융업무를 금융회사 또는 전자금융업자의 종사자와 대면하거나 의사소통을 하지 아니하고 이용하는 경우, 대체로 자동화된 방식의 이용이 될 것임
  - 이러한 ‘자동성’의 요건도 비대면성 요건과 마찬가지로 전자금융거래의 준비단계에서는 요구되지 아니하며, 거래단계에서는 거래지시단계와 거래처리단계 전반에 걸쳐 요구된다고 할 것임
  - 따라서 단일한 거래의 거래지시는 접근매체를 통하여 자동적으로 이루어지나, 거래의 완결과정에서 인위적인 판단이 개입하는 경우에는 전자금융거래라 할 수 없음[1)]

전자금융거래의 특성: 비대면성

- 금융회사 또는 전자금융업자의 종사자와 직접 대면하거나 의사소통을 하지 아니하는 것
  - 이러한 비대면성은 전자금융거래의 준비단계에서는 요구되지 않지만, 거래단계에서는 거래지시단계 및 거래처리 단계에서 모두 필요함

1) 예컨대 인터넷을 통한 대출 신청의 경우, 전자적 장치를 통하여 약관 등으로 정한 요건 심사가 자동적으로 이루어져 대출이 실행된다면, ‘대출’이라는 독립된 거래로서 전자금융거래에 해당하나, 단순히 신청만을 인터넷으로 접수하고 이에 대한 심사가 별도로 이루어진 후에 자금이체의 방법으로 대출이 실행된다면, 이를 전자금융거래라 할 수 없음

- 따라서 비대면성의 판단은 거래지시의 시점을 기준으로 하여야 하며, 준비단계에서 금융회사 또는 전자금융업자의 종사자와 대면했다는 사실은 전자금융거래의 비대면성 판단에 영향을 미치지 않음

전자금융거래를 위한 수단 : 접근매체

● 접근매체는 자동화기기, 전화기 및 컴퓨터 등의 전자적 장치를 이용하기 위한 수단이며, 전자적 장치를 통하여 전자금융거래에 이용되는 경우 접근매체의 효력이 발생됨

- 예컨대 이용자가 예금통장(뒷면의 Magnetic Stripe)을 이용하여 자동화 기기에서 출금을 한 경우 예금통장은 접근매체로 간주됨

- 하지만 이용자와 금융회사(또는 전자금융업자) 간 전자금융거래계약이 체결되지 않아 전자적 장치를 통해 거래를 할 수 없는 예금통장의 경우 접근매체에 해당하지 않음(대법원 2010.5.27. 선고 2010도2940 판결[2] 참조)

● 이용자 및 거래내용의 진실성과 정확성을 확보하기 위해 사용되는 수단이라면 접근매체에 해당

- 인터넷 홈페이지의 아이디 패스워드, 통장 비밀번호, ARS 사용을 등록하는 과정에서 계좌원장 비밀번호와 별개로 통신용 비밀번호를 설정하여 운영하는 경우 통신용 비밀번호도 접근매체에 해당될 수 있음(법령해석 140189, 200147, 00028)

- 다만, 해약환급금 입금용 통장 등 단순 입출금을 위해 발급되는 통장 및 통장비밀번호는 접근매체에 해당하지 않음(법령해석 200147)

- 공카드 자체로 '재화 또는 용역의 제공과 그 대가의 지급'을 동시에 이행할 수 없다면 이는 직불전자지급수단에 해당하지 않으므로, 공카드를 먼저 송부한 후 이를 전자지급수단으로 전환하는 방식에서 전자지급수단으로 전환하기 전 공카드인 상태에서는 접근매체에 해당하지 않음(법령해석 180258)

---

2) 전자금융거래법(이하 '법'이라 한다) 제2조는 제10호에서 "'접근매체'라 함은 전자금융거래에 있어서 거래지시를 하거나 이용자 및 거래내용의 진실성과 정확성을 확보하기 위하여 사용되는 수단 또는 정보를 말한다."고, 제7호에서 "'이용자'라 함은 전자금융거래를 위하여 금융기관 또는 전자금융업자와 체결한 계약(이하 '전자금융거래계약'이라 한다)에 따라 전자금융거래를 이용하는 자를 말한다."고, 제17호에서 "'거래지시'라 함은 이용자가 전자금융거래계약에 따라 금융기관 또는 전자금융업자에게 전자금융거래의 처리를 지시하는 것을 말한다."고 각 규정하고 있는바, 위 각 규정의 내용과 법이 '전자금융거래의 법률관계를 명확히 하여 전자금융거래의 안전성과 신뢰성을 확보함'을 그 목적으로 하고 있는 점(제1조) 등을 종합하여 보면, 법 제2조 제10호 소정의 '접근매체'라고 하기 위해서는 전자금융거래계약의 체결이 전제되어야 한다고 봄이 상당함

※ 관계 법령

법

제2조(정의) 이 법에서 사용하는 용어의 정의는 다음과 같다.

10. "접근매체"라 함은 전자금융거래에 있어서 거래지시를 하거나 이용자 및 거래내용의 진실성과 정확성을 확보하기 위하여 사용되는 다음 각 목의 어느 하나에 해당하는 수단 또는 정보를 말한다.
    가. 전자식 카드 및 이에 준하는 전자적 정보
    나. 「전자서명법」 제2조제3호에 따른 전자서명생성정보 및 같은 조 제6호에 따른 인증서
    다. 금융회사 또는 전자금융업자에 등록된 이용자번호
    라. 이용자의 생체정보
    마. 가목 또는 나목의 수단이나 정보를 사용하는데 필요한 비밀번호

※ 법령해석('20.7.27.)-200147

질의

- 당행에서는 일정 금액 이하는 통장 비밀번호만으로 이체가 가능한 간편이체 서비스를 구상중입니다. 이에 통장 비밀번호가 거래지시에 필요한 실명확인된 접근매체로 볼 수 있는지 질의 드립니다.

회신

- 귀사가 발급하는 통장 비밀번호는 해당 통장의 전자적 정보를 사용하는 전자금융거래에 있어서 거래지시 (자금이체 등)가 가능하도록 필요한 통장 비밀번호를 이용자에게 발급하는 것이라면, 특별한 사정이 없는 한 「전자금융거래법」 상 '접근매체' 에 해당하는 것으로 판단됩니다.
- 귀사가 「전자금융거래법」 제2조 제10호에 따른 '접근매체' 로서 통장 비밀번호를 이용자에게 발급하는 경우 「전자금융거래법」 제6조제2항 및 「전자금융감독규정」 제34조 제3호에 따라 이용자의 실명확인 후 교부 하여야 합니다.
  - 이 경우, 해당 통장 비밀번호는 특별한 사정이 없는 한 거래지시에 필요한 실명확인된 접근매체에 해당하는 것으로 판단됩니다.

이유

- 귀사가 발급하는 통장 비밀번호는 해당 통장의 전자적 정보를 사용하는 전자금융거래에 있어서 거래지시(자금이체 등)가 가능하도록 필요한 통장 비밀번호를 이용자에게 발급하는 것이라면, 특별한 사정이 없는 한 「전자금융거래법」 상 '접근매체'에 해당하는 것으로 판단됩니다.
  - 한편 , 해약환급금 입금용 통장 등 단순 입출금을 위해 발급되는 통장 및 통장 비밀번호는 「전자금융거래법」 상 '접근매체'에 해당하지 않습니다.
- 귀사가 「전자금융거래법」 제2조 제10호에 따른 '접근매체'로서 통장 비밀번호를 이용자에게 발급하는 경우 「전자금융거래법」 제6조 제2항 및 「전자금융감독규정」 제34조 제3호에 따라 이용자의 실명확인 후 교부 하여야 합니다.
  - 이 경우, 해당 통장 비밀번호는 특별한 사정이 없는 한 거래지시에 필요한 실명확인된 접근매체에 해당하는 것으로 판단됩니다.

※ 법령해석('16.12.27.)-160942

질의

- 암호화된 신용카드 정보가 「전자금융거래법」 상 접근매체에 해당하는지 질의
- 전자금융업자가 암호화된 신용카드번호를 타 전자금융업자에게 전달하는 경우 「전자금융거래법」 제6조에 따른 접근매체의 양도 행위에 해당하는지 질의

회신

- 암호화 여부와 무관하게 신용카드 정보가 거래지시를 하거나 이용자 · 거래내역의 진실성 · 정확성을 확인하는데 사용될 수 있는 경우 전자금융거래법상 접근매체에 해당합니다.
- 암호화된 신용카드 정보를 다른 전자금융업자에게 전달하는 것이 접근매체의 소유권, 처분권 등 배타적 사용 권한을 확정적으로 이전하는 정도인 경우 접근매체의 양도 행위에 해당합니다.

이유

- 신용카드정보가 암호화되었다고 해서 접근매체가 아니라고 단정하기 어려우며, 전자식 카드 뿐만 아니라 이에 준하는 전자적 정보도 접근매체가 될 수 있으므로 실제에 있어서 거래지시를 하거나 이용자 · 거래내역의 진실성 · 정확성을 확인하기 위한 수단으로 사용될 수 있다면 접근매체로 보는 것이 타당할 것입니다.
- 구체적인 상황에서 접근매체의 소유권, 처분권 등 배타적 사용 권한을 확정적으로 이전하는 경우에는 접근매체의 양도 행위에 해당할 수 있으나, 일시적으로 접근매체를 활용(예: 심부름으로 가족명의의 현금카드로 자금을 인출하는 경우)하는 것에 그치는 경우에는 접근매체 양도 행위에 해당하지 않을 수 있으므로 단순히 접근매체를 전달하였다는 사실만으로 전자금융거래법 위반 여부를 판단하기는 어렵습니다.

※ 법령해석('24.3.26.)-240112

질의

- 매 로그인시 블록체인을 활용하여 일회성 키(key)를 생성하는 모바일 앱(App)을 통해 본인인증 서비스를 영위하기 위하여 동 '일회성 키'가 전자금융거래법(제2조제10호)에 따른 '접근매체'에 해당하는지

회신

- 귀사가 제출한 설명자료 및 과기부 유권해석을 참고했을 때, 동 '인증솔루션'은 전자금융거래법 제2조제10호 나목의 전자서명생성정보에 해당합니다. 참고로 전자금융거래법 제2조제10호의 접근매체에 해당하기 위해서는 전자금융거래에 있어 거래지시를 하거나, 이용자 및 거래내용의 진실성과 정확성을 확보할 수 있어야 하며, 이를 위해 키(key) 발급시 법 제6조제2항 등에 따라 실명확인을 거쳐 발급해야 함을 알려드립니다.

이유

- 전자금융거래법 제2조제10호에서는 접근매체를 정의하고 그 대상을 아래와 같이 열거하고 있습니다.
  * 가. 전자식 카드 및 이에 준하는 전자적 정보, 나. 전자서명법 제2조제3호에 따른 전자서명생성정보 및 같은 조 제6호에 따른 인증서, 다. 금융회사 또는 전자금융업자에 등록된 이용자번호, 라. 이용자의 생체정보, 마. 가 또는 나목의 수단이나 정보를 사용하는데 필요한 비밀번호
- 귀사의 인증솔루션은 귀사가 과기부로부터 회신받은 유권해석에 따라 상기 나목의 전자서명생성정보에 해당합니다.
- 전자금융거래법상 접근매체에 해당하기 위해서는 귀사의 '일회성 키'가 전자금융거래 관련 거래지시를 하거나 이용자 및 거래내용의 진실성과 정확성을 확보할 수 있어야 하며, 이를 위해 키 발급시 법 제6조 제2항 등에 따라 실명확인을 거쳐 발급해야 함을 알려드립니다.

※ 법령해석('20.07.28.)-200028

질의

1. 당사가 사용하는 '통신용 비밀번호(ARS 업무비밀번호)'가 「전자금융거래법」 제2조 제10호 및 「전자금융감독규정」 제34조 제3호의 '접근매체'에 해당하는지

회신

■ 귀사의 질의만으로 명확하게 알기 어려우나, 귀사가 고객에게 발급한 통신용 비밀번호가 본인확인을 위한 추가적인 수단으로 사용되고, 귀사가 발급한 통신용 비밀번호를 고객이 지속적으로 입력하도록 하는 방식이라면,

- 특별한 사정이 없는 한, 해당 통신용 비밀번호는 「전자금융거래법」 제2조제10호다목에 따른 '접근매체'에 해당하는 것으로 판단됩니다.

이유

■ 접근매체란 전자금융거래에서 거래지시를 하거나 이용자 및 거래내용의 진실성과 정확성을 확보하기 위하여 사용되는 「전자금융거래법」 제2조 제10호 각 목에 해당하는 수단 또는 정보를 의미합니다.

* 제2조 제10호 "접근매체"라 함은 전자금융거래에 있어서 거래지시를 하거나 이용자 및 거래내용의 진실성과 정확성을 확보하기 위하여 사용되는 다음 각 목의 어느 하나에 해당하는 수단 또는 정보를 말한다.

가. 전자식 카드 및 이에 준하는 전자적 정보
나. 「전자서명법」 제2조제4호의 전자서명생성정보 및 같은 조 제7호의 인증서
다. 금융회사 또는 전자금융업자에 등록된 이용자번호
라. 이용자의 생체정보
마. 가목 또는 나목의 수단이나 정보를 사용하는데 필요한 비밀번호

■ 질의하신 내용으로만은 명확히 알기 어려우나, 귀사가 고객에게 발급한 통신용 비밀번호가 본인확인을 위한 추가적인 수단으로 사용되고, 귀사가 발급한 통신용 비밀번호를 고객이 지속적으로 입력하도록 하는 방식이라면,

- 통신용 비밀번호는 '거래지시를 하는 과정에 있어 하나의 절차'에 해당하거나 또는 '거래내용의 진실성과 정확성을 확보하기 위한 하나의 절차'에 해당하는 것으로 사료됩니다. 따라서 특별한 사정이 없는 한 통신용 비밀번호는 접근매체에 해당하는 것으로 판단됩니다.

※ 법령해석('19.01.28.)-180258

질의

1. 간편결제사업자와 인터넷은행이 제휴하여 '공카드 수령 후 발급신청'의 프로세스로 직불카드(신용카드/체크카드가 아닌 직불카드로 한정)를 발행할 수 있는지

2. (위와 같은 절차로 발행이 가능하다면) 공카드 '발송' 신청 단계에서는 한 가지 방식으로의 실명확인이 가능한지, 아니면 '발급' 신청과 마찬가지로 두 가지 이상의 방식으로 실명확인을 해야 하는지

회신

1. 은행이 전자금융거래법상 직불전자지급수단을 발행하는 경우, 공카드를 송부한 후 이를 직불전자지급수단으로 전환하는 방식으로 발행하는 것도 가능하며, 이때 공카드는 직불전자지급수단이 아닙니다.

2. 공카드는 직불전자지급수단으로 전환되기 전에는 접근매체로 볼 수 없으므로 공카드 발송신청 단계에서는 전자금융거래법 제6조제2항의 본인 확인 의무가 적용되지 않습니다.

이유

1. 전자금융거래법상 직불전자지급수단은 '이용자와 가맹점간에 전자적 방법에 따라 금융회사의 계좌에서 자금을 이체하는 등의 방법으로 재화 또는 용역의 제공과 그 대가의 지급을 동시에 이행할 수 있도록 금융회사 또는 전자금융업자가 발행한 증표(자금을 융통받을 수 있는 증표를 제외한다) 또는 그 증표에 관한 정보'를 말합니다(전자금융거래법 제2조제13호). 그러므로 공카드 자체로 '재화 또는 용역의 제공과 그 대가의 지급'을 동시에 이행할 수 없다면 이는 직불전자지급수단에 해당하지 않습니다.

2. 전자금융거래법상 접근매체는 '전자금융거래에 있어서 거래지시를 하거나 이용자 및 거래내용의 진실성과 정확성을 확보하기 위하여 사용되는 다음 각 목의 어느 하나에 해당하는 수단 또는 정보'를 말합니다(전자금융거래법 제2조제10호). 공카드 자체는 직불전자지급수단이 아니라면, 공카드로 존재하는 한 직불전자지급수단을 이용한 전자금융거래에 있어서 '거래지시를 하거나 이용자 및 거래내용의 진실성과 정확성을 확보하기 위하여 사용' 되는 접근매체라고 볼 수 없다고 판단됩니다.

나. 전자금융거래법 적용 대상

※ 관계 법령

법

제2조(정의) 3. "금융회사"란 다음 각 목의 어느 하나에 해당하는 기관이나 단체 또는 사업자를 말한다.

가. 「금융위원회의 설치 등에 관한 법률」 제38조제1호부터 제5호까지, 제7호 및 제8호에 해당하는 기관
나. 「여신전문금융업법」에 따른 여신전문금융회사
다. 「우체국예금 · 보험에 관한 법률」에 따른 체신관서
라. 「새마을금고법」에 따른 새마을금고 및 새마을금고중앙회
마. 그 밖에 법률의 규정에 따라 금융업 및 금융 관련 업무를 행하는 기관이나 단체 또는 사업자로서 대통령령이 정하는 자

시행령

제2조(금융회사의 범위) 「전자금융거래법」(이하 "법"이라 한다) 제2조제3호마목에서 "대통령령이 정하는 자"라 함은 다음 각 호의 어느 하나에 해당하는 자를 말한다.

1. 「한국산업은행법」에 따른 한국산업은행
2. 「중소기업은행법」에 따른 중소기업은행
3. 「한국수출입은행법」에 따른 한국수출입은행
4. 「산림조합법」에 따른 조합과 그 중앙회의 신용사업부문
5. 「농업협동조합법」에 따른 조합
6. 「수산업협동조합법」에 따른 조합
7. 「자본시장과 금융투자업에 관한 법률」에 따른 거래소
8. 「자본시장과 금융투자업에 관한 법률」에 따른 한국예탁결제원

8의2. 「주식 · 사채 등의 전자등록에 관한 법률」에 따른 전자등록기관
9. 「금융지주회사법」에 따른 금융지주회사와 「금융지주회사법 시행령」 제2조제2항제1호에 해당하는 회사
10. 「보험업법」에 따른 보험협회와 보험요율산출기관
11. 「화재로 인한 재해보상과 보험가입에 관한 법률」에 따른 한국화재보험협회
12. 「자본시장과 금융투자업에 관한 법률」에 따른 한국금융투자협회
14. 「신용정보의 이용 및 보호에 관한 법률」에 따른 신용정보회사, 채권추심회사 및 종합신용정보집중기관
15. 「한국자산관리공사의 설립에 관한 법률」에 따른 한국자산관리공사
16. 「한국주택금융공사법」에 따른 한국주택금융공사
17. 「신용보증기금법」에 따른 신용보증기금
18. 「기술보증기금법」에 따른 기술보증기금
19. 「온라인투자연계금융업 및 이용자 보호에 관한 법률」 제2조제3호에 따른 온라인투자연계금융업자

제2장 총 칙

FSS
FINANCIAL SUPERVISORY
SERVICE

제2장 총 칙

1. 규정 목적

감독규정

제1조(목적) 이 규정은 「전자금융거래법」(이하 "법"이라 한다) 및 동법 시행령(이하 "시행령"이라 한다)에서 금융위원회에 위임한 사항과 그 시행에 필요한 사항 및 다른 법령에 따라 금융감독원의 검사를 받는 기관의 정보기술부문 안전성 확보 등을 위하여 필요한 사항을 규정함을 목적으로 한다.

시행세칙

제1조(목적) 이 세칙은 「전자금융거래법」(이하 "법"이라 한다) 및 동법 시행령(이하 "시행령"이라 한다)과 「전자금융감독규정」(이하 "규정"이라 한다)에서 금융감독원장(이하 "감독원장"이라 한다)에게 위임한 사항과 그 시행에 필요한 사항을 규정함을 목적으로 한다.

- 전자금융거래법(이하 '법') 및 동법 시행령(이하 '시행령') 제정에 따라 동 법령에서 위임되거나 시행에 필요한 사항 등을 전자금융감독규정(이하 '감독규정') 및 전자금융감독규정시행세칙(이하 '시행세칙') 등으로 정함
  - 전자금융업자의 전자금융업 진입 요건 및 안전한 전자금융거래를 위해 필요한 정보기술부문의 안전성 기준 등을 중심으로 규정

- 전자금융감독규정은 전자금융거래법 및 동법 시행령에 근거하였고,
  - 금융위 규정사항 중 중요한 의사결정이 요하지 않는 사항에 대하여 범위를 설정하여 금감원장에게 위탁하였으며(법 제48조 및 시행령 제30조), 동 사항에 대해 전자금융감독규정시행세칙으로 규정

※ 관계 법령

시행령

제30조(권한의 위탁) ① 금융위원회는 법 제48조에 따라 다음 각 호의 업무를 「금융위원회의 설치 등에 관한 법률」에 따른 금융감독원의 장(이하 "금융감독원장"이라 한다)에게 위탁한다.

1. 법 제21조제2항에 따른 인증방법에 관한 기준의 설정

1의2. 법 제21조제4항에 따른 정보기술부문에 대한 계획의 접수

1의3. 법 제21조의3제1항에 따른 취약점 분석 · 평가 결과의 접수

1의4. 법 제25조에 따른 약관의 제정 및 변경 보고의 접수, 약관 변경의 권고

(이하 생략)

2. 용어의 정의

감독규정

제2조(정의) 이 규정에서 사용하는 용어의 정의는 다음과 같다.

1. "전산실"이라 함은 전산장비, 통신 및 보안장비, 전산자료 보관 및 출력장비가 설치된 장소를 말한다.
2. "전산자료"라 함은 전산장비에 의해 입력 · 보관 · 출력되어 있는 자료를 말하며 그 자료가 입력 · 출력되어 있는 자기테이프, 디스크, 디스켓, 콤팩트디스크(CD) 등 보조기억매체를 포함한다.
3. "정보처리시스템"이라 함은 전자금융업무를 포함하여 정보기술부문에 사용되는 하드웨어(hardware)와 소프트웨어(software)를 말하며 관련 장비를 포함한다.
4. "정보기술부문"이라 함은 컴퓨터 등 정보처리능력을 가진 장치를 이용하여 정보를 수집 · 가공 · 저장 · 검색 · 송신 또는 수신을 행하는 금융회사 또는 전자금융업자의 업무, 인력, 시설 및 조직을 말한다.
5. "정보보호" 또는 "정보보안"이라 함은 컴퓨터 등 정보처리능력을 가진 장치를 이용하여 수집 · 가공 · 저장 · 검색 · 송신 또는 수신되는 정보의 유출 · 위변조 · 훼손 등을 방지하기 위하여 기술적 · 물리적 · 관리적 수단을 강구하는 일체의 행위를 말하며 사이버안전을 포함한다.
6. "정보보호시스템"이라 함은 정보처리시스템내 정보를 유출 · 위변조 · 훼손하거나 정보처리시스템의 정상적인 서비스를 방해하는 행위로부터 정보 등을 보호하기 위한 장비 및 프로그램을 말한다.
7. "해킹"이라 함은 접근을 허가받지 아니하고 전자금융기반시설에 불법적으로 침투하거나 허가받지 아니한 권한을 불법적으로 갖는 행위 또는 전자금융기반시설을 공격하거나 해를 끼치는 행위를 말한다.
8. "컴퓨터악성코드"(이하 "악성코드"라 한다)라 함은 컴퓨터에서 이용자의 허락 없이 스스로를 복사하거나 변형한 뒤 정보유출, 시스템 파괴 등의 작업을 수행하여 이용자에게 피해를 주는 프로그램을 말한다.
9. "공개용 웹서버"라 함은 인터넷 이용자들이 웹페이지를 자유롭게 보고 웹서비스(월드 와이드 웹을 이용한 서비스를 말한다)를 이용할 수 있게 해주는 프로그램이 실행되는 장치를 말한다.
10. "정보통신망"(이하 "통신망"이라 한다)이라 함은 유 · 무선, 광선 등 정보통신 수단에 의하여 부호 · 문자 · 음향 · 영상 등을 처리 · 저장 및 송 · 수신할 수 있는 정보통신 조직형태를 말한다.

시행세칙

제2조(정의) 이 세칙에서 별도로 정하지 아니한 용어는 법 · 시행령 · 규정에서 정하는 바에 따른다.

■ 전자금융거래법 및 시행령에서 별도로 정의하지 않은 용어에 대해 정의를 규정

■ 용어별 해설

● **전산실** : 전산장비를 비롯한 관련 시설 및 전산자료가 보관된 장소 (예시 : 서버, 데이터베이스, 스토리지, 라우터, 스위치, 방화벽, 백업 미디어 등 전산장비, 통신 및 보안장비 등이 설치되고 전산자료가 존재하는 장소 등)

- 금융회사(또는 전자금융업자)가 클라우드컴퓨팅서비스를 정보처리 업무의 위탁의 형태로 이용하는 경우, 금융회사의 전산실 범위에는 CSP(Cloud Service Provider)의 전산센터도 포함됨(법령해석 200036)

● **정보보호시스템** : 정보처리시스템 내 정보를 유출·위변조·훼손하거나 정보처리시스템의 정상적인 서비스를 방해하는 행위로부터 정보 등을 보호하기 위한 장비 및 프로그램으로, 컨텐츠 정보보호, 시스템 정보보호, 네트워크 정보보호, 정보보호관리로 분류할 수 있음

- 침입차단시스템(Firewall), 가상사설망(VPN: Virtual Private Network), 침입탐지시스템(IDS: Intrusion Detection System), 침입방지시스템(IPS: Intrusion Prevention System) 등이 있으며, 각 세부 항목은 전자금융감독규정 [별표2] "2. 정보보호 예산 기준"의 "다. 정보보호시스템 분류표" 참고

● **컴퓨터악성코드** : 컴퓨터에서 이용자의 허락 없이 스스로를 복사하거나 변형한 뒤 정보유출, 시스템 파괴 등의 작업을 수행하여 이용자에게 피해를 주도록 설계된 프로그램

● **공개용 웹서버** : 인터넷 이용자들이 웹페이지를 자유롭게 보고 웹서비스(월드 와이드 웹을 이용한 서비스를 말한다)를 이용할 수 있게 해주는 프로그램이 실행되는 장치로 정의되며, 인터넷 등 외부에서 불특정 다수가 자유롭게 접근할 수 있는 정보처리시스템으로서, 일반적으로 웹사이트나 웹 애플리케이션을 호스팅하며, 이용자들이 브라우저를 통해 해당 서버에 요청을 보내는 방식으로 이용됨

● **내부통신망(내부망)** : 방화벽 등으로 외부망과 구분되어 회사 외부에서는 접근할 수 없고 회사가 통제할 수 있는 범위의 사설 네트웍으로 전산센터, 본사, 백업센터, 재해복구센터, 지점 등 전용선이나 전용 사설망으로 연결된 구간

※ 관계 법령

법

제2조(정의) 이 법에서 사용하는 용어의 정의는 다음과 같다.

1. "전자금융거래"라 함은 금융회사 또는 전자금융업자가 전자적 장치를 통하여 금융상품 및 서비스를 제공(이하 "전자금융업무"라 한다)하고, 이용자가 금융회사 또는 전자금융업자의 종사자와 직접 대면하거나 의사소통을 하지 아니하고 자동화된 방식으로 이를 이용하는 거래를 말한다.

2. "전자지급거래"라 함은 자금을 주는 자(이하 "지급인"이라 한다)가 금융회사 또는 전자금융업자로 하여금 전자지급수단을 이용하여 자금을 받는 자(이하 "수취인"이라 한다)에게 자금을 이동하게 하는 전자금융거래를 말한다.

3. "금융회사"란 다음 각 목의 어느 하나에 해당하는 기관이나 단체 또는 사업자를 말한다.
   가. 「금융위원회의 설치 등에 관한 법률」 제38조제1호부터 제5호까지, 제7호 및 제8호에 해당하는 기관
   나. 「여신전문금융업법」에 따른 여신전문금융회사
   다. 「우체국예금·보험에 관한 법률」에 따른 체신관서
   라. 「새마을금고법」에 따른 새마을금고 및 새마을금고중앙회
   마. 그 밖에 법률의 규정에 따라 금융업 및 금융 관련 업무를 행하는 기관이나 단체 또는 사업자로서 대통령령이 정하는 자

4. "전자금융업자"라 함은 제28조의 규정에 따라 허가를 받거나 등록을 한 자(금융회사는 제외한다)를 말한다.

5. "전자금융보조업자"라 함은 금융회사 또는 전자금융업자를 위하여 전자금융거래를 보조하거나 그 일부를 대행하는 업무를 행하는 자 또는 결제중계시스템의 운영자로서 「금융위원회의 설치 등에 관한 법률」 제3조에 따른 금융위원회(이하 "금융위원회"라 한다)가 정하는 자를 말한다.

6. "결제중계시스템"이라 함은 금융회사와 전자금융업자 사이에 전자금융거래정보를 전달하여 자금정산 및 결제에 관한 업무를 수행하는 금융정보처리운영체계를 말한다.

7. "이용자"라 함은 전자금융거래를 위하여 금융회사 또는 전자금융업자와 체결한 계약(이하 "전자금융거래계약"이라 한다)에 따라 전자금융거래를 이용하는 자를 말한다.

8. "전자적 장치"라 함은 전자금융거래정보를 전자적 방법으로 전송하거나 처리하는데 이용되는 장치로서 현금자동지급기, 자동입출금기, 지급용단말기, 컴퓨터, 전화기 그 밖에 전자적 방법으로 정보를 전송하거나 처리하는 장치를 말한다.

9. "전자문서"라 함은 「전자문서 및 전자거래 기본법」 제2조제1호에 따른 작성, 송신·수신 또는 저장된 정보를 말한다.

10. "접근매체"라 함은 전자금융거래에 있어서 거래지시를 하거나 이용자 및 거래내용의 진실성과 정확성을 확보하기 위하여 사용되는 다음 각 목의 어느 하나에 해당하는 수단 또는 정보를 말한다.
    가. 전자식 카드 및 이에 준하는 전자적 정보
    나. 「전자서명법」 제2조제3호에 따른 전자서명생성정보 및 같은 조 제6호에 따른 인증서
    다. 금융회사 또는 전자금융업자에 등록된 이용자번호
    라. 이용자의 생체정보
    마. 가목 또는 나목의 수단이나 정보를 사용하는데 필요한 비밀번호

11. "전자지급수단"이라 함은 전자자금이체, 직불전자지급수단, 선불전자지급수단, 전자화폐, 신용카드, 전자채권 그 밖에 전자적 방법에 따른 지급수단을 말한다.

12. "전자자금이체"라 함은 지급인과 수취인 사이에 자금을 지급할 목적으로 금융회사 또는 전자금융업자에 개설된 계좌(금융회사에 연결된 계좌에 한한다. 이하 같다)에서 다른 계좌로 전자적 장치에 의하여 다음 각 목의 어느 하나에 해당하는 방법으로 자금을 이체하는 것을 말한다.
   가. 금융회사 또는 전자금융업자에 대한 지급인의 지급지시
   나. 금융회사 또는 전자금융업자에 대한 수취인의 추심지시(이하 "추심이체"라 한다)

13. "직불전자지급수단"이라 함은 이용자와 가맹점간에 전자적 방법에 따라 금융회사의 계좌에서 자금을 이체하는 등의 방법으로 재화 또는 용역의 제공과 그 대가의 지급을 동시에 이행할 수 있도록 금융회사 또는 전자금융업자가 발행한 증표(자금을 융통받을 수 있는 증표를 제외한다) 또는 그 증표에 관한 정보를 말한다.

14. "선불전자지급수단"이라 함은 이전 가능한 금전적 가치가 전자적 방법으로 저장되어 발행된 증표(전자적 방법으로 변환되어 저장된 증표를 포함한다) 또는 그 증표에 관한 정보로서 발행인(대통령령으로 정하는 특수관계인을 포함한다) 외의 제3자로부터 재화 또는 용역을 구입하고 그 대가를 지급하는데 사용되는 것을 말한다. 다만, 전자화폐를 제외한다.

15. "전자화폐"라 함은 이전 가능한 금전적 가치가 전자적 방법으로 저장되어 발행된 증표 또는 그 증표에 관한 정보로서 다음 각 목의 요건을 모두 갖춘 것을 말한다.
   가. 대통령령이 정하는 기준 이상의 지역 및 가맹점에서 이용될 것
   나. 제14호 가목의 요건을 충족할 것
   다. 구입할 수 있는 재화 또는 용역의 범위가 5개 이상으로서 대통령령이 정하는 업종 수 이상일 것
   라. 현금 또는 예금과 동일한 가치로 교환되어 발행될 것
   마. 발행자에 의하여 현금 또는 예금으로 교환이 보장될 것

16. "전자채권"이라 함은 다음 각 목의 요건을 갖춘 전자문서에 기재된 채권자의 금전채권을 말한다.
   가. 채무자가 채권자를 지정할 것
   나. 전자채권에 채무의 내용이 기재되어 있을 것
   다. 「전자서명법」 제2조제2호에 따른 전자서명(서명자의 실지명의를 확인할 수 있는 것을 말한다)이 있을 것
   라. 금융회사를 거쳐 제29조제1항의 규정에 따른 전자채권관리기관(이하 "전자채권관리기관"이라 한다)에 등록될 것
   마. 채무자가 채권자에게 가목 내지 다목의 요건을 모두 갖춘 전자문서를 「전자문서 및 전자거래 기본법」 제6조제1항에 따라 송신하고 채권자가 이를 같은 법 제6조제2항의 규정에 따라 수신할 것

17. "거래지시"라 함은 이용자가 전자금융거래계약에 따라 금융회사 또는 전자금융업자에게 전자금융거래의 처리를 지시하는 것을 말한다.

18. "오류"라 함은 이용자의 고의 또는 과실 없이 전자금융거래가 전자금융거래계약 또는 이용자의 거래지시에 따라 이행되지 아니한 경우를 말한다.

19. "전자지급결제대행"이라 함은 전자적 방법으로 재화의 구입 또는 용역의 이용에 있어서 지급결제정보를 송신하거나 수신하는 것 또는 그 대가의 정산을 대행하거나 매개하는 것을 말한다.

20. "가맹점"이란 다음 각 목의 자를 말한다.
   가. 금융회사 또는 전자금융업자와의 계약에 따라 직불전자지급수단이나 선불전자지급수단 또는 전자화폐에 의한 거래에 있어서 이용자에게 재화 또는 용역을 제공하는 자
   나. 금융회사 또는 전자금융업자와의 계약에 따라 이용자에게 재화 또는 용역을 제공하는 자를 위하여 직불전자지급수단이나 선불전자지급수단 또는 전자화폐에 의한 거래를 대행하는 자로서 대통령령으로 정하는 자

21. "전자금융기반시설"이란 전자금융거래에 이용되는 정보처리시스템 및 「정보통신망 이용촉진 및 정보보호 등에 관한 법률」 제2조제1항제1호에 따른 정보통신망을 말한다.

22. "전자적 침해행위"란 해킹, 컴퓨터 바이러스, 논리폭탄, 메일폭탄, 서비스 거부 또는 고출력 전자기파 등의 방법으로 전자금융기반시설을 공격하는 행위를 말한다.

3. 전자금융보조업자

감독규정

제3조(전자금융보조업자의 범위) 법 제2조제5호에서 "금융위원회가 정하는 자"라 함은 다음 각 호의 어느 하나에 해당하는 자를 말한다.

1. 정보처리시스템을 통하여 「여신전문금융업법」 상 신용카드업자의 신용카드 승인 및 결제 그 밖의 자금정산에 관한 업무를 지원하는 사업자
2. 정보처리시스템을 통하여 은행업을 영위하는 자의 자금인출업무, 환업무 및 그 밖의 업무를 지원하는 사업자
3. 전자금융업무와 관련된 정보처리시스템을 해당 금융회사 또는 전자금융업자를 위하여 운영하는 사업자
4. 제1호 부터 제3호의 사업자와 제휴, 위탁 또는 외부주문(이하 "외부주문등"이라 한다)에 관한 계약을 체결하고 정보처리시스템을 운영하는 사업자

■ 전자금융보조업자란 금융회사 또는 전자금융업자의 전자금융업무와 관련된 정보처리시스템을 해당 금융회사 또는 전자금융업자를 위하여 운영하는 사업자로서, 해당 금융회사 또는 전자금융업자의 전자금융업무 수행에 밀접한 역할을 수행하는 자를 의미(제3호)

- 국외 사업자가 「전자금융거래법」 제28조에 따라 허가·등록을 받은 전자금융업자를 위하여 해당 전자금융업무와 관련한 정보처리시스템을 운영하는 경우 전자금융보조업자에 해당 (법령해석 240012)
- 다만, 자신의 고유 업무로서 금융회사의 전자금융업무를 수행하는 경우는 전자금융업무 관련성이 있다 하더라도 해당 금융회사의 전자금융보조업자에 해당하지 않음(예 : 보험료 납부 중계 등을 수행하는 PG사는 보험사의 전자금융보조업자에 해당하지 않음. 법령해석 160658)

- 데이터센터 운영 업무와 관련하여 단순 공간만을 임대하는 경우 전자금융보조업자 범위에 해당되지 않음(법령해석 170315)
- 금융회사등의 통합보안관제 및 보안 운영/ITO 업무의 경우 인프라 및 보안 장비가 전자금융업무와 관련된 시스템인 경우 전자금융보조업자에 해당(법령해석 170315)

■ 금융회사 및 전자금융업자와 직접 계약을 체결하고 전자금융업무와 관련된 업무를 수행하는 사업자는 전자금융보조업자로 분류하여야 하나

- 이들 사업자와 재위탁 계약을 체결한 사업자들 중 전자금융거래와 직접적인 관련이 없는 단순 콜센터, DM 발송 업체 등은 제외
- 내부에 상주하지 않는 콜센터, 쇼핑몰, 외부통신회선 관리, IDC 장소임치 등도 전자금융보조업자의 범위에 포함되지 않음
- 그러나 전자금융보조업자로부터 일부 업무를 위탁받아 외부주문에 관한 계약을 체결하고, 전자금융거래의 안전성을 확보하기 위한 정보보안관제업무를 수행하는 사업자의 경우 전자금융보조업자에 해당 (법령해석 190029)

※ **전자금융보조업자 예시** : 카드 결제 승인, 카드사와 가맹점 간의 데이터를 송수신하는 카드VAN사, 은행의 ATM기기 운영 업체, 전자금융업무를 포함한 토탈 IT아웃소싱 업체, 전자금융업무와 관련된 정보처리를 담당하는 클라우드컴퓨팅 업체

■ 전자금융거래와 관련하여 전자금융보조업자의 고의나 과실로 인한 손해에 대해서는 금융회사 또는 전자금융업자가 배상책임을 가짐(금융회사 또는 전자금융업자는 전자금융보조업자에 대해 구상 가능)

※ 관계 법령

법

제2조(정의) 이 법에서 사용하는 용어의 정의는 다음과 같다.

5. "전자금융보조업자"라 함은 금융회사 또는 전자금융업자를 위하여 전자금융거래를 보조하거나 그 일부를 대행하는 업무를 행하는 자 또는 결제중계시스템의 운영자로서 「금융위원회의 설치 등에 관한 법률」 제3조에 따른 금융위원회(이하 "금융위원회"라 한다)가 정하는 자를 말한다.

제11조(전자금융보조업자의 지위) ① 전자금융거래와 관련하여 전자금융보조업자(전자채권관리기관을 포함한다. 이하 이 장에서 같다)의 고의나 과실은 금융회사 또는 전자금융업자의 고의나 과실로 본다.

② 금융회사 또는 전자금융업자는 전자금융보조업자의 고의나 과실로 인하여 발생한 손해에 대하여 이용자에게 그 손해를 배상한 경우에는 그 전자금융보조업자에게 구상할 수 있다.

③ 이용자는 금융회사 또는 전자금융업자와의 약정에 따라 금융회사 또는 전자금융업자에게 행하는 각종 통지를 전자금융보조업자에게 할 수 있다. 이 경우 전자금융보조업자에게 한 통지는 금융회사 또는 전자금융업자에게 한 것으로 본다.

※ 법령해석('25.01.22.)-240012

질의

1 외국(대만)에서 취득한 전자금융업 관련 자격으로 국내에서 「전자금융거래법」상 전자금융업자로 인정될 수 있는지 여부

2 외국인이 한국 내 제로페이 가맹점에서 전자금융거래를 이용할 수 있도록 플랫폼을 제공하는 국외 사업자를 전자금융보조업자로 볼 수 있는지 여부 및 해당 서비스 제공 가능여부

3 전자금융업자가 제로페이 운영기관인 한국간편결제진흥원과 제휴 서비스 계약을 체결할 수 있는지 여부 및 해당 계약을 통해 전자금융업을 수행할 수 있는지 여부

회신

■ 국외 사업자가 외국에서 취득한 전자금융업 자격만으로 국내에서 전자금융업을 수행할 수 없는 것으로 판단되며, 국외 사업자가 「전자금융거래법」 제28조에 따라 허가 · 등록을 받은 전자금융업자를 위하여 해당 전자금융업무와 관련한 정보처리시스템을 운영하는 경우 "전자금융보조업자"에 해당할 것으로 판단됩니다.

- 「전자금융거래법」 제28조에 따라 허가 · 등록을 받은 전자금융업자는 해당 전자금융업무를 수행할 수 있으며 「전자금융거래법」 및 하위법령을 준수하여 다른 사업자와 제휴계약도 체결할 수 있을 것으로 판단됩니다.

이유

1 「전자금융거래법」 제28조에 따라 전자금융업을 수행하고자 하는 자는 금융위원회의 허가를 받거나 등록하여야 하며,

- 제4조에서 외국인 또는 외국법인에 대하여도 이 법을 적용하도록 명시적으로 규정하고 있으므로 외국에서 취득한 전자금융업 자격만으로 국내에서 전자금융업을 수행할 수 없는 것으로 판단됩니다.

2 "전자금융보조업자"라 함은 금융회사 또는 전자금융업자를 위하여 전자금융거래를 보조하거나 그 일부를 대행하는 업무를 행하는 자 또는 결제중계시스템의 운영자로서 금융위원회가 정하는 자를 말하며,

- 전자금융업감독규정 제3조에서는 구체적으로 ① 정보처리시스템을 통하여 「여신전문금융업법」상 신용카드업자의 신용카드 승인 및 결제 그 밖의 자금정산에 관한 업무를 지원하는 사업자, ② 정보처리시스템을 통하여 은행업을 영위하는 자의 자금인출업무, 환업무 및 그 밖의 업무를 지원하는 사업자, ③ 전자금융업무와 관련된 정보처리시스템을 해당 금융회사 또는 전자금융업자를 위하여 운영하는 사업자, ④ ①~③의 사업자와 제휴, 위탁 또는 외부주문에 관한 계약을 체결하고 정보처리시스템을 운영하는 사업자로 규정하고 있습니다.
- 따라서, 국외 사업자가 「전자금융거래법」 제28조에 따라 허가 · 등록을 받은 전자금융업자를 위하여 해당 전자금융업무와 관련한 정보처리시스템을 운영하는 경우 "전자금융보조업자"에 해당할 것으로 판단됩니다.

3 「전자금융거래법」 제28조에 따라 허가 · 등록을 받은 전자금융업자는 해당 전자금융업무를 수행할 수 있으며 「전자금융거래법」 및 하위법령을 준수하여 다른 사업자와 제휴계약도 체결할 수 있을 것으로 판단됩니다.

※ 법령해석('16.06.03.)-160658

질의

- 금융회사(보험사)에서 이용자가 보험료 납부를 위하여 전자금융업자(PG사)의 전자지급결제대행서비스를 이용하게 될 경우 보험사와 PG사간의 서비스 연계는 전용회선을 사용하여야 하는지 여부

회신

- 이용자의 보험료 납부 중계 등 PG업 고유의 업무를 수행하기 위해 금융회사를 가맹점으로 연결하는 PG업자는 해당 금융회사의 전자금융보조업자에 해당되지 않아 전용선 사용의무는 없습니다.

이유

- 「전자금융감독규정」 제60조제1항제5호에서는 금융회사와 전자금융보조업자와의 연결시 전용회선을 사용토록 하고 있습니다.
  - 이때 전자금융보조업자란 금융회사의 전자금융업무와 관련된 정보처리시스템을 해당 금융회사를 위하여 운영하는 사업자입니다.
- 질의하신 거래 프로세스에서 전자금융업무 수행주체는 PG업자이고, 이때의 금융회사는 가맹점으로서 기능하는 것으로 해당 금융회사의 전자금융업무를 PG업자가 대신 운영하는 것이 아닙니다.

※ 법령해석('17.08.23)-170315

질의

- 다음의 각 사업을 수행하는 경우, 사업별로 「전자금융거래법」상 '금융회사', '전자금융업자', '전자금융보조업자' 중 어느 지위에 해당하는지에 대해 질의
  - 데이터센터 운영 : 입주사 인프라 장비에 대한 상면 공간 임대 서비스
  - 통합보안관제 : 입주사 인프라 장비에 대한 보안관제 서비스
  - 관계사 보안 운영/ITO : 관계사 보안 장비 운영(관리 주체 : 관계사)

회신

- 데이터센터 운영(단순 상면 공간 임대) → 「전자금융거래법」상 지위 없음
- 입주사(관계사) 통합보안관제 및 보안 운영/ITO → 입주사(관계사)가 금융회사 또는 전자금융업자(이하 '금융회사등')이고, 관련 인프라 및 보안 장비가 전자금융업무와 관련 있을 경우 '전자금융보조업자'에 해당된다고 판단됨

이유

- 귀 사가 질의한 사업은 상면 공간 임대 및 입주사 등의 인프라 장비 또는 보안 장비를 대신 운영하는 것으로서, '금융회사'나 '전자금융업자'에는 해당되지 않으며, 귀 사의 각 사업별 구체적인 운영방침에 따라 일부 사업 영위시 전자금융보조업자에 해당될 수 있습니다.
  - '전자금융보조업자'(이하 '보조업자')란 금융회사등을 위하여 전자금융거래를 보조하거나 그 일부를 대행하는 업무를 행하는 자 또는 결제중계시스템의 운영자로서, 다음 각 업무를 수행하는 자를 말합니다(「전자금융거래법」 제2조제5호 및 「전자금융감독규정」 제3조)

〈참고 : 보조업자 범위 (「전자금융감독규정」 제3조)〉

① 정보처리시스템을 통하여 「여신전문금융업법」 상 신용카드업자의 신용카드 승인 및 결제 그 밖의 자금정산에 관한 업무를 지원하는 사업자
② 정보처리시스템을 통하여 은행업을 영위하는 자의 자금인출업무, 환업무 및 그 밖의 업무를 지원하는 사업자
③ 전자금융업무와 관련된 정보처리시스템을 해당 금융회사 또는 전자금융업자를 위해 운영하는 사업자
④ ①~③의 사업자와 제휴, 위탁 또는 외부주문에 관한 계약을 체결하고 정보처리시스템을 운영하는 사업자

■ 데이터센터 운영업무는 단순 공간만을 임대하는 사업으로서, 보조업자 범위에 해당되지 않습니다.
- 다만, 입주사(관계사) 통합보안관제 및 보안 운영/ITO 업무의 경우 입주사(관계사)가 금융회사 등이면서 관련 인프라 및 보안 장비가 전자금융업무와 관련된 시스템인 경우 귀사는 보조업자(③에 해당)에 해당된다고 판단됩니다.

※ 법령해석('19.03.11.)-190029

질의

■ 전자금융보조업자로부터 일부 업무를 위탁받아 다음의 정보보안관제 업무를 수행하는 사업자가 전자금융보조업자에 해당하는지 여부
- 보안시스템 탐지 이벤트 모니터링
- 보안시스템 로그 수집 분석
- 침해사고, 취약점진단(보안 장비를 운영하는 업무는 없음)

회신

■ 전자금융보조업자와 외부주문에 관한 계약을 체결하고, 전자금융거래의 안전성을 확보하기 위한 정보보안관제업무를 수행하는 사업자의 경우 전자금융보조업자에 해당한다고 볼 수 있습니다(전자금융감독규정 제3조제4호).

이유

■ "전자금융보조업자"라 함은 금융회사 또는 전자금융업자를 위해 전자금융거래를 보조하거나 그 일부를 대행하는 업무를 행하는 자를 의미합니다(전자금융거래법 제2조 제5호).
- 또한, 전자금융보조업자와 제휴, 외부주문에 관한 계약을 체결하고 정보처리시스템을 운영하는 사업자도 기본적으로 전자금융보조업자에 해당합니다.

■ 전자금융거래와 직접적 관련이 없는 콜센터, DM 발송업체 등의 경우에는 그 업무의 성격이 전자금융거래를 보조하기 위한 것은 아니므로 전자금융보조업자가 아니라 할 것이나,
- 금융회사 및 전자금융업자와 관련된 보안시스템 로그를 탐지 · 분석하는 업무는 전자금융거래의 안전성을 확보하기 위한 조치에 해당합니다.
- 따라서, 전자금융보조업자와 외부주문에 관한 계약을 체결하고 동 업무를 수행하는 사업자도 전자금융보조업자에 해당한다고 볼 수 있습니다(전자금융감독규정 제3조제4호).

※ 비조치의견서('23.12.22.)-230018

비조치의견서는 행정해석의 일종으로 최종 법적구속력은 없으며, 유권해석과는 달리 특정행위에 대해 해당 회사의 상황을 고려한 검토결과로써 일반적 효력을 가지지 아니하므로 참고자료로만 활용하시기 바랍니다.

요청대상 행위

- 금융회사의 모든 상품 가입자를 대상으로 무료 부가서비스*를 제공하는 수탁사가 '전자금융보조업자'에 해당하는지 여부

  * 병원 동행, 간병인 지원, 진료 예약 대행, 건강상담, 병원 이송 서비스 등

판단

- 아래 내용을 참고하시기 바랍니다.

판단이유

- 전자금융보조업자는 금융회사를 위하여 전자금융거래를 보조하거나 그 일부를 대행하는 업무를 행하는 자로서(전자금융거래법 제2조제5호).
  - 전자금융업무와 관련된 정보처리시스템을 해당 금융회사를 위하여 운영하는 사업자를 말합니다(전자금융감독규정 제3조제3호).

- 귀 사가 제공한 정보에 한하여, 제공 예정인 서비스는 병원 동행, 간병인 지원 등으로 전자금융거래를 보조하거나 그 일부를 대행하는 것으로 보기 어려우며
  - 부가서비스를 제공하는 수탁사가 금융회사를 위하여 전자금융업무와 관련된 정보처리시스템을 운영하지 않으므로 전자금융거래법 제2조제5항의 '전자금융보조업자'로 보기 어렵습니다.
  - IT검사매뉴얼 중 '전자금융 신청단계의 적정성' 점검항목은 동 규정의 내용과 상충하지 않도록 개정('15.11.9.) 되었으니 이 점 참고하시기 바랍니다.

제3장 전자금융거래 당사자의 권리와 의무

FSS
FINANCIAL SUPERVISORY SERVICE

제3장 전자금융거래 당사자의 권리와 의무

1. 확인에 필요한 구체적인 거래 내용

감독규정

제4조(확인에 필요한 구체적인 거래내용) 시행령 제7조제4항제6호에서 "금융위원회가 정하여 고시하는 사항"이란 다음 각 호를 말한다.

1. 법 제8조에 따른 오류정정 요구사실 및 처리결과에 관한 사항
2. 전자금융거래 신청, 조건변경에 관한 내용

■ 금융회사 또는 전자금융업자는 이용자가 자신의 전자금융거래 서비스에 대한 거래내용을 전자적 장치 등을 통해서 확인할 수 있도록 하여야 함

● 전자금융 거래내용에 대한 범위

- 전자금융거래의 종류, 금액 및 전자금융거래의 상대방에 관한 정보
- 전자금융거래의 거래일시, 전자적 장치의 종류 및 전자적 장치를 식별할 수 있는 정보 등
- 이용자의 오류정정 요구사실 및 처리결과와 전자금융거래신청 및 조건변경에 관한 내용도 기록보관하여야 함

■ 해설

● 전자금융 거래확인에 필요한 시스템은 법에서 정해진 요건대로 반드시 갖추어야 함

● 많은 경우 장애나 오류가 발생하였음에도 이를 고객들에게 알리지 않거나, 법에서 정해진 내용이 제공되지 않을 경우 법적 책임을 지게 되는 경우가 있으므로 주의가 요구됨

※ 관계 법령

법

제7조(거래내용의 확인) ① 금융회사 또는 전자금융업자는 이용자가 전자금융거래에 사용하는 전자적 장치(금융회사 또는 전자금융업자와 이용자 사이에 미리 약정한 전자적 장치가 있는 경우에는 그 전자적 장치를 포함한다)를 통하여 거래내용을 확인할 수 있도록 하여야 한다.

② 금융회사 또는 전자금융업자는 이용자가 거래내용을 서면(전자문서를 제외한다. 이하 같다)으로 제공할 것을 요청하는 경우에는 그 요청을 받은 날부터 2주 이내에 거래내용에 관한 서면을 교부하여야 한다.

③ 제1항 및 제2항의 규정에 따라 제공하는 거래내용의 대상기간, 종류 및 범위 등에 관한 사항은 대통령령으로 정한다.

시행령

제7조(거래내용의 확인 등) ① 금융회사 또는 전자금융업자는 법 제7조제1항에 따라 이용자가 전자적 장치를 통하여 거래내용을 확인할 수 있도록 하는 경우에 전자적 장치의 운영장애, 그 밖의 사유로 거래내용을 확인하게 할 수 없는 때에는 인터넷 등을 이용하여 즉시 그 사유를 알리고, 그 사유가 종료된 때부터 이용자가 거래내용을 확인할 수 있도록 하여야 한다.

② 금융회사 또는 전자금융업자는 법 제7조제2항에 따라 이용자로부터 거래내용을 서면(전자문서를 제외한다. 이하 같다)으로 제공할 것을 요청받은 경우 전자적 장치의 운영장애, 그 밖의 사유로 거래내용을 제공할 수 없는 때에는 그 이용자에게 즉시 이를 알려야 한다. 이 경우 법 제7조제2항의 거래내용에 관한 서면의 교부기간을 산정함에 있어서 전자적 장치의 운영장애, 그 밖의 사유로 거래내용을 제공할 수 없는 기간은 산입하지 아니한다.

③ 법 제7조제3항에 따른 거래내용의 대상기간은 제12조제1항 각 호에 따른 전자금융거래기록의 보존기간으로 한다.

④ 법 제7조제3항에 따른 거래내용의 종류(조회거래를 제외한다. 이하 이 조에서 같다) 및 범위는 다음 각 호와 같다.

1. 전자금융거래의 종류(보험계약의 경우에는 보험계약의 종류를 말한다) 및 금액, 전자금융거래의 상대방에 관한 정보
2. 전자금융거래의 거래일시, 전자적 장치의 종류 및 전자적 장치를 식별할 수 있는 정보
3. 전자금융거래가 계좌를 통하여 이루어지는 경우 거래계좌의 명칭 또는 번호(보험계약의 경우에는 보험증권 번호를 말한다)
4. 금융회사 또는 전자금융업자가 전자금융거래의 대가로 받은 수수료5. 법 제15조제1항에 따른 지급인의 출금 동의에 관한 사항
6. 그 밖에 이용자의 전자금융거래내용 확인에 필요한 사항으로서 금융위원회가 정하여 고시하는 사항

⑤ 금융회사 또는 전자금융업자는 법 제7조제2항에 따른 거래내용의 서면 제공과 관련하여 그 요청의 방법 · 절차, 접수창구의 주소(전자우편주소를 포함한다) 및 전화번호 등을 전자금융거래와 관련한 약관(이하 "약관"이라 한다)에 규정하여야 한다.

2. 전자금융사고 책임이행을 위한 보험 등의 가입에 관한 기준

감독규정

제5조(전자금융사고 책임이행을 위한 보험 등의 가입에 관한 기준) ① 금융회사 또는 전자금융업자가 법 제9조제4항에 따라 전자금융사고 책임이행을 위한 보험 또는 공제에 가입하는 경우 보상한도는 전자금융거래 규모, 전자금융사고 발생 건수 등을 고려하여 다음 각 호에서 정하는 금액 이상으로 설정해야 한다.

1. 「금융위원회의 설치 등에 관한 법률」 제38조제1호(다만, 「은행법」에 의한 지방금융회사 및 같은 법 제58조에 의해 인가를 받은 외국금융회사의 국내지점은 제외한다) 및 제7호의 회사, 「전자금융거래법 시행령」 제2조 제2호의 회사 : 20억원
2. 「금융위원회의 설치 등에 관한 법률」 제38조제2호의 회사(명의개서대행회사는 제외한다. 이하 이 조에서 같다) 중 자산이 2조원 이상인 회사, 같은 법 제38조제8호의 회사, 「전자금융거래법」 제2조제3호나목(신용카드업자에 한한다) 및 다목의 회사, 「전자금융거래법 시행령」 제2조제1호의 회사, 「은행법」에 따른 지방금융회사 및 같은 법 제58조에 의해 인가를 받은 외국금융회사의 국내지점 : 10억원
3. 「금융위원회의 설치 등에 관한 법률」 제38조제2호의 회사 중 자산이 2조원 미만인 회사 : 5억원
4. 제1호 부터 제3호 이외의 금융회사 : 2억원. 다만, 제1호 부터 제3호 이외의 금융회사들이 관련 법령에 의해 당해 금융회사를 구성원으로 하는 금융회사를 통해 전자금융거래 관련 정보기술부문의 주요부분을 공동으로 이용하는 경우, 정보기술부문의 주요부문을 제공하는 금융회사가 공동 이용 금융회사 전체의 사고를 보장하는 내용으로 제2호의 금액(시행령 제2조제5호의 금융회사는 제1호의 금액) 이상의 보험 또는 공제에 가입하면 공동 이용 금융회사는 본호의 보험 또는 공제에 가입한 것으로 본다.
5. 법 제28조제2항제1호의 전자금융업자 : 2억원
6. 법 제28조제2항제2호의 전자금융업자 : 2억원
7. 법 제28조제2항제3호의 전자금융업자 : 2억원
8. 법 제28조제2항제4호의 전자금융업자 중 제1호 또는 제2호에 속하는 금융회사가 발급한 신용카드, 직불카드 등 거래지시에 사용되는 접근매체의 정보를 저장하는 전자금융업자 : 10억원
9. 법 제28조제2항제4호의 전자금융업자 : 2억원(제1호 또는 제2호에 속하는 금융회사가 발급한 신용카드, 직불카드 등 거래지시에 사용되는 접근매체의 정보를 저장하는 전자금융업자는 제외한다)
10. 시행령 제15조제3항제1호의 전자금융업자 : 2억원
11. 시행령 제15조제3항제2호의 전자금융업자 : 2억원
12. 법 제28조제1항의 전자금융업자 : 2억원
13. 제1호부터 제12호에 2개 이상 해당하는 회사는 각 호의 금액의 합계액으로 한다. 다만 제5호부터 제12호의 합계액이 15억원을 초과하는 경우에는 제5호부터 제12호의 합계액을 15억원으로 한다.

② 금융회사 또는 전자금융업자가 전자금융사고 책임이행을 위한 준비금을 적립하는 경우에는 전자금융거래 규모, 전자금융사고 발생 건수 등을 고려하여 제1항 각 호에서 정한 금액 이상의 금액을 보유하고 책임이행이 신속히 이루어질 수 있도록 준비금 관리 및 지급에 관한 내부 절차를 수립하여 운영하여야 한다.

③ 금융회사 또는 전자금융업자가 보험 또는 공제 가입과 준비금 적립을 병행하는 경우 보험 또는 공제의 보상한도는 제1항에서 정한 금액에서 준비금 적립액을 차감한 금액 이상으로 한다.

④ 제1항부터 제3항의 규정은 전자금융업무를 취급하지 않는 금융회사에 대하여는 적용하지 아니한다.

■ 전자금융거래 서비스를 제공하는 금융회사 및 전자금융업자는 보험(공제) 또는 준비금을 적립해야 함

- 금융회사 및 전자금융업자에 대한 보험금액은 자산규모, 전자금융거래 규모 및 과거 전자금융사고 등을 참고하여 권역별로 최저 금액 한도를 결정

■ 해설

- 전자금융업무를 취급하지 않는 금융회사는 보험 등에 가입할 의무 없음
- 복수 업종의 전자금융업무를 하는 경우 각 해당 보험금액을 합산하여 준비금 적립 또는 보험가입 (제5호~제12호 합계액 최대 15억원)
- 금융회사 및 전자금융업자가 보험(또는 공제) 가입 대신 준비금을 적립할 경우 동사가 적립해야 할 적립금액은 보험금액과 일치함
- 보험(공제)과 준비금을 병행하는 경우에는 각각의 합이 기준금액을 충족하면 가능
- 단위조합 등이 전자금융거래 관련 정보기술부문의 주요 부분을 공동으로 이용하여, 현행 보험제도 하에서 공동 이용 금융회사 전체의 사고를 보장하는 내용으로 책임보험에 가입하는 것은 가능토록 함
- '25.2.5. 전자금융감독규정 개정으로 전자금융업자, 보험사, 자산 2조원 이상의 금융투자업자 등이 가입하여야 할 보상한도 기준금액이 상향되었으므로 이를 준수할 필요
- 전자금융사고 책임이행을 위해 준비금을 적립하는 경우 준비금 관리 및 지급에 대한 절차를 수립하여야 함

【금융업종 및 전자금융업별 의무적 보험(공제) 가입 기준】

구 분		보상한도	대상 기관
금융 업종별	은 행	20억원	▪ 시중은행(농협은행 포함), 인터넷전문은행, 중소기업은행
		10억원	▪ 지방은행, 외은지점, 수협은행, 산업은행, 체신관서
	금 투	10억원	▪ 자산 2조원 이상의 금융투자업자, 증권금융회사, 종합금융회사
		5억원	▪ 그 외 자산 2조원 미만의 금융투자업자, 증권금융회사, 종합금융회사
	보 험	2억원	▪ 보험회사
	신용카드	10억원	▪ 신용카드업자
	기 타	20억원	▪ 농협중앙회 (관련 법령에 의해 당해 금융회사를 구성원으로 하는 금융회사를 통해 전자금융거래 관련 정보기술부문의 주요부분을 공동으로 이용하는 경우로서 공동 이용 금융회사 전체의 사고를 보장하는 경우)

구 분		보상한도	대상 기관
금융 업종별	기 타	10억원	▪ 저축은행중앙회, 상호금융중앙회(신협/수협/산림조합)(관련 법령에 의해 당해 금융회사를 구성원으로 하는 금융회사를 통해 전자금융거래 관련 정보기술부문의 주요부분을 공동으로 이용하는 경우로서 공동 이용 금융회사 전체의 사고를 보장하는 경우)
		2억원	▪ 상호저축은행, 농 · 수협 단위조합, 새마을금고(연합회), 신협, 여신전문금융회사(신용카드업자 제외) 등
전자금융업자		10억원	▪ 전자자금이체업자, 직불전자지급수단 발행 및 관리업자가 발급한 신용카드, 직불카드 등 거래지시에 사용되는 접근매체의 정보를 저장하는 전자지급결제대행업자
		2억원	▪ 전자화폐발행, 전자자금이체, 직불전자지급수단발행, 선불전자지급수단발행, 전자지급결제대행업자(접근매체 저장을 하지 않는 경우), 에스크로, 전자고지결제 등 전자금융업자

※ 복수 업종의 전자금융업무를 하는 경우 각 해당 보험금액을 합산하여 보상 한도를 정하여야 하므로, 자산 2조원 미만의 금융투자업자이면서 전자금융거래법 제28조제2항제2호에 따라 등록한 전자금융업자는 보상한도를 7억원(5억원+2억원) 이상으로 설정해야 함

3. 추심이체 출금동의의 방법

감독규정

제6조(추심이체 출금 동의의 방법 등) ① 시행령 제10조제1호에서 "금융위원회가 정하여 고시하는 전자문서"라 함은 다음 각 전자문서을 말한다.

1. 「전자서명법」 제2조제2호에 따른 전자서명으로 다음 각 목의 요건을 구비된 전자서명을 한 전자문서
   가. 전자서명을 생성하기 위하여 이용하는 전자적 정보(이하 "전자서명생성정보"라함)가 본인에게 유일하게 속할 것
   나. 전자서명 당시 본인이 전자서명생성정보를 지배 · 관리하고 있을 것
   다. 전자서명이 있은 후에 당해 전자서명에 대한 변경여부를 확인할 수 있을 것
   라. 전자서명이 있은 후에 당해 전자문서의 변경여부를 확인할 수 있을 것
2. 「전자서명법」 제2조제2호에 따른 전자서명으로 다음 각 목의 요건을 구비된 전자서명을 한 전자문서
   가. 서명 전 실명증표를 통해 본인확인
   나. 전자문서가 생성된 이후 서명자가 지급인 본인임을 확인 가능
   다. 전자서명 및 전자문서에 대한 위변조 여부 확인이 가능
   라. 전자문서를 고객에게 전송한 이후 고객이 취소할 수 있는 충분한 기간 부여
3. 삭제

② 시행령 제10조제1호 및 제2호에서 "금융위원회가 정하는 방법"이라 함은 다음 각 호의 방법을 말한다.

1. 전화 녹취
2. 음성응답 시스템(Audio Response System : ARS)

③ 지급인(출금계좌의 실지명의인을 포함한다)이 출금의 동의를 해지하는 경우에도 제1항 및 제2항의 규정을 준용한다.

④ 금융회사 · 전자금융업자 또는 수취인은 제1항 각 호의 출금 동의의 방법을 운용함에 있어 다음 각 호의 어느 하나에 해당하는 사실을 확인하여야 한다.

1. 지급인과 추심이체 출금계좌 실지명의인이 동일인인 사실
2. 지급인과 추심이체 출금계좌 실지명의인이 동일인이 아닐 경우에는 지급인이 당해 계좌에서 출금할 수 있는 권한을 보유하고 있는 사실

- 추심이체 출금 동의는금융회사 또는 전자금융업자가 지급인으로부터 직접 동의를 받을 수도 있으나, 수취인이 지급인으로부터 동의를 받아 금융회사 또는 전자금융업자에게 전달할 수도 있음 (법령해석 240273)
  - 추심이체 출금 동의는 비대면 방법도 인정 (비조치의견서 150151)

- 사설전자서명 방식으로 전자서명을 한 전자문서도 추심이체 출금동의의 방법으로 활용할 수 있으므로 해당기관에서 발급하는 사설인증서도 일정 요건을 갖춘 경우 추심이체 출금동의의 방법으로 인정

- 다만, 전자금융거래법 및 관련 법령에서는 추심이체 출금동의에 필요한 전자서명의 구체적인 기술 방식을 규정하고 있지 않으므로 각 전자서명이 요건을 충족하는지 여부는 개별 금융회사 등이 자율적으로 판단할 필요(법령해석 190378, 190371)

■ 음성응답시스템(ARS)로 추심이체 출금동의를 받는 경우 녹취하여 관련 자료를 금융회사 등에게 전달하여야 하는 것이 기존 해석이었으나, 지급인의 육성이 포함되지 않은 경우 본인확인이 가능한 ARS 로그기록 등을 통해 대체 가능

■ 금융회사 · 전자금융업자 또는 수취인은 출금동의와 관련하여 지급인과 추심이체 출금계좌 실지명의가 동일인인 사실을 확인할 필요(전자금융감독규정 제4항)

- 추심이체 출금 동의는 수취인, 예금주, 출금계좌를 출금동의 효력 판단의 기준으로 보고 있으며, 해당 기준이 변경될 경우 별도 동의가 필요(법령해석 230291)

※ 관계 법령

법

제15조(추심이체의 출금 동의) ①금융회사 또는 전자금융업자는 추심이체를 실행하기 위하여 대통령령이 정하는 바에 따라 미리 지급인으로부터 출금에 대한 동의를 얻어야 한다.

시행령

제10조(출금 동의의 방법) 법 제15조제1항에 따라 지급인으로부터 출금에 대한 동의를 얻는 방법은 다음 각 호와 같다.

1. 금융회사 또는 전자금융업자가 지급인으로부터 서면(금융위원회가 정하여 고시하는 전자문서를 포함한다. 이하 이 조에서 같다) 또는 녹취 등 금융위원회가 정하는 방법으로 출금 동의를 받는 방법
2. 수취인이 지급인으로부터 서면 또는 녹취 등 금융위원회가 정하는 방법으로 출금 동의를 받아 금융회사 또는 전자금융업자에게 전달(전자적 방법으로 출금의 동의내역을 전송하는 것을 포함한다)하는 방법

※ 비조치의견서('15.11.24.)-150151

비조치의견서는 행정해석의 일종으로 최종 법적구속력은 없으며, 유권해석과는 달리 특정행위에 대해 해당 회사의 상황을 고려한 검토결과로써 일반적 효력을 가지지 아니하므로 참고자료로만 활용하시기 바랍니다.

요청대상 행위

- 대출고객이 홈페이지나 앱을 통해 원리금을 선결제하는 서비스*를 운영할 경우, 서비스 신청 단계에서 고객 대면확인이 필요한지 여부

  * 대출고객이 ○○저축은행 홈페이지 또는 앱에 접속하여(로그인 필요) 대출 원리금 선결제 신청서(추심이체에 대한 동의 내용 포함) 작성 및 공인인증서 인증을 완료하면 고객계좌에서 신청금액만큼 추심 이체됨

판단

■ 선결제 서비스 신청서에 추심이체 동의 내용이 포함되어 있고, 신청서 제출시 공인인증서를 통한 인증(전자서명)을 하였다면 별도의 대면확인 절차는 필요하지 않습니다.

판단이유

■ 전자금융 관련 법규에서는 추심이체 동의 방법으로 공인전자서명*한 전자문서, 녹취, ARS와 같은 비대면 방법을 인정하고 있는바(전자금융거래법 시행령 제10조 및 감독규정 제6조)
* 공인인증서에 기초한 전자서명(전자서명법 제2조 제2호)

- 홈페이지 또는 앱을 통한 선결제 서비스 신청 시에 공인인증서 인증절차를 통해 추심이체 출금 동의를 받은 경우 별도의 대면확인 절차는 필요하지 않습니다.
- IT검사매뉴얼 중 '전자금융 신청단계의 적정성' 점검항목은 동 규정의 내용과 상충하지 않도록 개정('15.11.9.) 되었으니 이 점 참고하시기 바랍니다.

※ 법령해석('25.01.22.)-240273

질의

■ 추심이체 출금동의의 방법으로 A사가 지급인으로부터 출금동의를 받아 금융회사에 제출한 후, A사가 해당 금융회사에 지급 요청을 하는 경우 금융회사는 지급인의 계좌에서 출금하여 A사의 계좌로 입금하게 됨

■ 위 과정에서, A사가 지급인으로부터 출금 동의를 접수하고 해당 동의내역을 금융회사에 제출하는 업무가 금융기관의 업무위탁 등에 관한 규정에 따른 금융업의 본질적 요소인 지급 업무에 해당한다고 볼 수 있는지

회신

■ 금융회사는 미리 지급인으로부터 출금에 대한 동의를 받은 경우, 수취인의 추심지시에 따라 전자자금이체를 실행할 수 있습니다.

- 이 경우, 추심이체를 실행하는 주체는 금융회사로서, 금융회사가 지급인의 출금 동의를 받는 것과 관련하여, 수취인이 지급인의 출금 동의를 금융회사에게 단순 전달하는 것은 금융회사의 추심이체 업무를 위탁받은 것으로 보기 어렵습니다.

이유

■ 금융회사 또는 전자금융업자는 수취인의 추심지시에 따라 전자자금이체(추심이체)를 실행할 수 있으며, 이 경우 미리 지급인으로부터 출금에 대한 동의를 얻어야 합니다.

■ 미리 지급인으로부터 출금 동의를 얻은 경우, 금융회사 또는 전자금융업자는 전자자금이체(추심이체)를 실행하여 지급인의 계좌에서 수취인의 계좌로 자금을 이체할 수 있게 됩니다.

- 출금 동의를 받는 주체와 관련해, 금융회사 또는 전자금융업자가 지급인으로부터 직접 동의를 받을 수도 있으나, 수취인이 지급인으로부터 동의를 받아 금융회사 또는 전자금융업자에게 전달할 수도 있습니다.
- 질의해주신 사안의 경우 후자에 해당하는 것으로 보이며, 수취인인 회사가 본인과 지급인을 위하여 지급인의 출금 동의를 단순 전달하는 경우라면 금융회사 또는 전자금융업자가 수행하는 전자자금이체(추심이체) 업무의 일부를 위탁받은 것으로 보기 어렵습니다.

※ 법령해석('23.10.10.)-230291

질의

■ 전자금융거래법 제15조에 따라 복수의 서비스에 대해 고객동의 후 자동이체를 진행 중에 있는데, 서비스가 분리되어 출금을 별도*로 진행하는 경우 고객동의를 다시 획득해야 하는지 여부

* 출금계좌는 동일하며, 출금 날짜만 별도로 지정

회신

■ 전자금융거래법령은 추심이체 출금동의는 수취인, 예금주, 출금계좌를 출금동의 효력 판단의 기준으로 보고 있습니다.

- 본 건은 서비스가 분리되더라도 수취인, 예금주, 출금계좌 등 출금에 필요한 정보가 변경되지 않으므로 별도 동의는 필요하지 않습니다.

이유

■ 전자금융거래법 제15조는 금융회사 또는 전자금융업자가 추심이체를 실행하기 위해서는 지급인(고객)으로부터 출금에 대한 동의를 얻어야 하며, 전자금융감독규정 제6조는 출금 동의시 지급인과 추심이체 출금계좌 실지명의가 동일인인 사실을 확인하도록 하고 있습니다.

- 이에 추심이체 출금 동의는 수취인, 예금주, 출금계좌를 출금동의 효력 판단의 기준으로 보고 있으며, 해당 기준이 변경될 경우 별도 동의가 필요합니다.

■ 본 건의 경우 지급인의 출금계좌는 동일하며 수취인도 변경되지 않는 등 추심이체 출금동의에 필요한 정보가 변경되지 않으므로 별도 동의는 필요하지 않습니다.

- 다만, 복수의 서비스에 대한 출금 날짜를 수취인이 별도로 지정할 경우 지급인과 수취인간 계약 관계에 문제가 발생될 소지가 있으므로 날짜의 별도 지정에 대한 지급인 동의나 통지 절차 등을 마련할 필요가 있습니다.

※ 법령해석('15.11.6.)-150334

질의

■ 「국세징수법」 등에 따른 과세관청의 강제징수 절차 진행과 관련하여 금융회사가 「전자금융거래법」 제15조상 추심이체에 대한 지급인의 동의 획득 의무를 지는지 여부

회신

■ 「국세징수법」 등에 따른 과세관청의 강제징수 절차 진행에 따라 금융회사가 채무자의 압류자산을 추심하는 경우 금융회사는 「전자금융거래법」 제15조상 추심이체에 대한 지급인의 동의를 획득하지 않아도 됩니다.

이유

■ 과세관청의 강제징수는 「국세징수법」 등에 따른 권한 및 절차에 따른 것으로 「전자금융거래법」 제3조상 다른 법률에 특별한 규정이 있는 경우에 해당하여 추심이체에 대한 지급인의 동의 없이 과세관청의 강제징수 절차 진행이 가능합니다.

※ 법령해석('16.1.19.)-160457

질의

■ 납입기일이 속한 해당 월에 잔고가 부족한 경우 납입기일이 속한 해당 월의 불특정일자에 해당 이체계좌(지급인이 기동의한 계좌)에서 출금을 하도록 지급인으로부터 서면으로 동의를 받는 경우에 이체일 이후에 지속적으로 인출하는 방식이 가능한지 여부

회신

■ 약관, 청약서 등을 통해 지급인으로부터 보험료 납입기일 이후 매영업일 또는 보험사가 특정하는 출금일에 미납된 금액을 인출할 수 있다는 내용의 사전 동의를 받은 경우에는 최초 납입기일 이후 출금이 가능합니다.

이유

■ 「전자금융거래법」 제15조에서는 지정된 방법에 따라 지급인의 동의를 받는 경우 추심이체를 허용하고 있으며, 잔고 부족 등의 이유로 추심이체가 안된 경우의 재시도 방법 등에 대해서는 정의하고 있지 않습니다.
따라서 약관 또는 청약서 등에 관련 내용을 기재하여 지급인의 동의를 받은 경우에는 납입기일 이후에 출금이 가능할 것입니다. 또한, 신용카드사의 경우에도 지급인의 동의를 받아 이용대금결제일 이후에 미결제된 금액을 인출하고 있는바, 보험사와 카드사를 달리 규정할 특별한 이유가 없습니다.

※ 법령해석('19.12.27.)-190371

질의

■ 오픈뱅킹 출금서비스 이용 시, 사설전자서명 방식의 추심이체 출금동의가 가능한지

회신

■ 현행 「전자금융거래법 시행령」 제10조 제1호와 「전자금융감독규정」 제6조 제1항 제1호는 "일정 요건을 갖춘 전자서명을 한 전자문서"를 통해 지급인으로부터 추심이체의 출금 동의를 받을 수 있다고 규정하고 있음
- 따라서, 「전자금융감독규정」 제6조 제1항 제1호의 요건을 충족하는 경우, 사설전자서명 방식으로 전자서명을 한 전자문서도 추심이체 출금 동의의 방법으로 활용할 수 있는 것으로 판단됨
- 다만, 전자금융거래법령 및 감독규정은 전자서명의 구체적인 기술을 규정하고 있지 않으므로 각 전자서명이 요건을 충족하는지 여부는 개별적으로 판단해야 하는 것으로 사료됨

이유

■ 현행 「전자금융거래법 시행령」 제10조제1호에 따라, 금융회사 또는 전자금융업자는 서면(금융위가 정하여 고시하는 전자문서를 포함) 또는 녹취 등의 방법으로 지급인으로부터 추심이체 출금 동의를 받을 수 있으며,
- 「전자금융감독규정」 제6조제1항제1호에서는 전자서명을 한 전자문서의 요건을, ① 전자서명을 생성하기 위하여 이용하는 전자적 정보가 본인에게 유일하게 속할 것, ② 전자서명 당시 본인이 전자서명생성정보를 지배 · 관리하고 있을 것, ③ 전자서명이 있은 후에 당해 전자서명에 대한 변경여부를 확인할 수 있을 것, ④ 전자서명이 있은 후에 당해 전자문서의 변경여부를 확인할 수 있을 것 등으로 규정하고 있습니다.

※ 법령해석('20.04.01.)-190378

질의

■ 휴대폰 본인확인을 통해 통신사로부터 카드사가 수신하는 CI/DI/Timestamp 등의 값과 고객이 본인확인 기관으로부터 수신(SMS)하는 '일회용 인증번호 값(6자리 숫자)'을 이용한 '일회용 전자서명생성정보(서명 Key)'로 전자서명을 구현하는 방식이

- 전자금융감독규정 내용 중 제6조(추심이체 출금 동의의 방법 등) ① 항 1호 가목(전자서명을 생성하기 위하여 이용하는 전자적 정보(이하 "전자서명생성정보"라 함)가 본인에게 유일하게 속할 것) 및 나목(전자서명 당시 본인이 전자서명생성정보를 지배 · 관리하고 있을 것)의 내용에 부합하는지 여부를 문의합니다.

회신

■ 현행 「전자금융거래법 시행령」 제10조 제1호와 「전자금융감독규정」 제6조 제1항 제1호에 따를 때,

- 「전자금융감독규정」 제6조 제1항 제1호의 요건을 충족하는 경우, 사설전자서명 방식으로 전자서명을 한 전자문서도 추심이체 출금 동의의 방법으로 활용할 수 있습니다.
- 다만, 전자금융거래법령 및 감독규정은 전자서명의 구체적인 기술을 규정하고 있지 않으므로 각 전자서명이 요건을 충족하는지 여부(문의하신 가목, 나목에의 부합여부를 포함하여)는 개별 금융회사 등이 자율적으로 판단해야 할 것입니다.

이유

■ 현행 「전자금융거래법 시행령」 제10조 제1호에 따라, 금융회사 또는 전자금융업자는 서면(금융위가 정하여 고시하는 전자문서를 포함) 또는 녹취 등의 방법으로 지급인으로부터 추심이체 출금 동의를 받을 수 있으며,

- 「전자금융감독규정」 제6조 제1항 제1호에서는 전자서명을 한 전자문서의 요건을, ① 전자서명을 생성하기 위하여 이용하는 전자적 정보가 본인에게 유일하게 속할 것, ② 전자서명 당시 본인이 전자서명생성정보를 지배 · 관리하고 있을 것, ③ 전자서명이 있은 후에 당해 전자서명에 대한 변경여부를 확인할 수 있을 것, ④ 전자서명이 있은 후에 당해 전자문서의 변경여부를 확인할 수 있을 것 등으로 규정하고 있습니다.

■ 전자금융감독규정」 제6조 제1항 제1호의 요건을 충족하는 경우, 사설전자서명 방식으로 전자서명을 한 전자문서도 추심이체 출금 동의의 방법으로 활용할 수 있습니다.

- 즉,「전자금융감독규정」 제6조 제1항 제1호의 요건을 충족하는 경우, 사설전자서명 방식으로 전자서명을 한 전자문서도 추심이체 출금 동의의 방법으로 활용할 수 있습니다.
- 다만, 전자금융거래법령 및 감독규정은 전자서명의 구체적인 기술을 규정하고 있지 않으므로 각 전자서명이 요건을 충족하는지 여부(문의하신 가목, 나목에의 부합여부를 포함하여)는 개별 금융회사 등이 자율적으로 판단해야 할 것입니다.

4. 정보보호최고책임자(CISO)의 지정대상

감독규정

제6조의2(정보보호최고책임자의 지정대상) ① 시행령 제11조의3제1항 후단에서 "금융위원회가 정하여 고시하는 상시 종업원 수의 산정방식"이란 「소득세법」에 따른 원천징수의무자가 근로소득세를 원천징수한 자를 말한다.
② 시행령 〈별표 1〉의제3호나목 단서에서 "금융위원회가 정하여 고시하는 산정방식"이란 「소득세법」에 따른 원천징수의무자가 근로소득세를 원천징수한 자를 말한다.

- 금융회사 또는 전자금융업자는 전자금융업무 및 그 기반이 되는 정보기술부문 보안을 총괄하여 책임질 정보보호최고책임자(CISO)를 지정하여야 함(법 제21조의2 제1항)
  - 전자금융업무를 하지 않는 은행, 증권사, 보험회사, 신용카드사, 신용정보회사 등은 예외(법 제3조 제3항, 시행령 제5조 제2항)

※ 관계 법령

법

제21조의2(정보보호최고책임자 지정) ① 금융회사 또는 전자금융업자는 전자금융업무 및 그 기반이 되는 정보기술부문 보안을 총괄하여 책임질 정보보호최고책임자를 지정하여야 한다.
② 총자산, 종업원 수 등을 감안하여 대통령령으로 정하는 금융회사 또는 전자금융업자는 정보보호최고책임자를 임원(「상법」 제401조의2제1항제3호에 따른 자를 포함한다)으로 지정하여야 한다.
③ 총자산, 종업원 수 등을 감안하여 대통령령으로 정하는 금융회사 또는 전자금융업자의 정보보호최고책임자는 제4항의 업무 외의 다른 정보기술부문 업무를 겸직할 수 없다.
④ 제1항에 따른 정보보호최고책임자는 다음 각 호의 업무를 수행한다.
1. 제21조제2항에 따른 전자금융거래의 안정성 확보 및 이용자 보호를 위한 전략 및 계획의 수립
2. 정보기술부문의 보호
3. 정보기술부문의 보안에 필요한 인력관리 및 예산편성
4. 전자금융거래의 사고 예방 및 조치
5. 그 밖에 전자금융거래의 안정성 확보를 위하여 대통령령으로 정하는 사항
⑤ 정보보호최고책임자의 자격요건 등에 필요한 사항은 대통령령으로 정한다.

시행령

제11조의4(정보보호최고책임자 지정대상 금융회사 등) ① 법 제21조의2제2항에서 "대통령령으로 정하는 금융회사 또는 전자금융업자"란 직전 사업연도 말을 기준으로 총자산이 2조원 이상이고, 상시 종업원 수가 300명 이상인 금융회사 또는 전자금융업자를 말한다. 이 경우 상시 종업원 수의 산정방식은 금융위원회가 정하여 고시한다.
② 법 제21조의2제3항에서 "대통령령으로 정하는 금융회사 또는 전자금융업자"란 직전 사업연도 말을 기준으로 총자산이 10조원 이상이고, 상시 종업원 수가 1,000명 이상인 금융회사를 말한다. 이 경우 상시 종업원 수의

산정방식은 제1항 후단을 준용한다.
③ 법 제21조의2제4항제5호에서 "대통령령으로 정하는 사항"이란 다음 각 호의 사항을 말한다.
1. 전자금융업무 및 그 기반이 되는 정보기술부문 보안을 위한 자체심의에 관한 사항
2. 정보기술부문 보안에 관한 임직원 교육에 관한 사항
④ 법 제21조의2제5항에 따른 정보보호최고책임자의 자격요건은 별표 1과 같다.

■ 금융회사 또는 전자금융업자의 총자산, 상시 종업원 수에 따라 정보보호최고책임자(CISO)의 자격 요건 및 겸직 가능 여부가 달리 적용됨(법 제21조의2 제2항 및 제3항, 시행령 제11조의4 제1항 및 제2항)

- 시행령 〈별표 1〉에 따른 정보보호최고책임자(CISO)의 자격 기준은 총자산, 상시 종업원 수에 따른 차등 적용은 없음(법 제21조의2 제5항)
- 상시 종업원 수는 「소득세법」에 따른 원천징수의무자가 근로소득세를 원천징수한 자를 기준으로 함(감독규정 제6조의2 제2항)

직전 사업연도 말 기준 총자산이 2조원 이상이고, 상시 종업원 수가 300명 이상	금융회사 전자금융업자	▪ 정보보호최고책임자(CISO)를 임원(「상법」 제401조의2제1항제3호에 따른 자[3])를 포함)으로 지정
직전 사업연도 말 기준 총자산이 10조원 이상이고, 상시 종업원 수가 1,000명 이상	금융회사	▪ 법 제21조의2 제4항의 업무 외의 다른 정보기술부문 업무를 겸직할 수 없음

■ 전자금융거래법 적용 대상인 금융회사 또는 전자금융업자는 정보보호최고책임자(CISO)의 지정과 관련하여 「정보통신망 이용촉진 및 정보보호 등에 관한 법률」보다 전자금융거래법이 우선 적용 (비조치의견서 240074)

- 금융회사 또는 전자금융업자의 사업 영역 중 전자금융거래법이 적용되지 않는 사업 부문이 존재하는 경우는 「정보통신망 이용촉진 및 정보보호 등에 관한 법률」에서 규율하는 바에 따름 (법령해석 230303).

3) 이사가 아니면서 명예회장 · 회장 · 사장 · 부사장 · 전무 · 상무 · 이사 기타 회사의 업무를 집행할 권한이 있는 것으로 인정될 만한 명칭을 사용하여 회사의 업무를 집행한 자

※ 비조치의견서('24.09.24.)-240074

비조치의견서는 행정해석의 일종으로 최종 법적구속력은 없으며, 유권해석과는 달리 특정행위에 대해 해당 회사의 상황을 고려한 검토결과로써 일반적 효력을 가지지 아니하므로 참고자료로만 활용하시기 바랍니다.

요청대상 행위

■ 전자금융업자 등록 예정인 회사의 부서장이 「정보통신망 이용촉진 및 정보보호 등에 관한 법률」 제45조의3에 따른 정보보호 최고책임자 및 「개인정보 보호법」 제31조에 따른 개인정보 보호책임자로 지정되어 있는 경우에도
- 「전자금융거래법」 제21조의2 제2항 및 동법 시행령 제11조의4(개정 전 제11조의3) 제1항에 따라 정보보호 최고책임자를 임원(「상법」 제401조의2제1항제3호에 따른 자를 포함한다)으로 지정하여야 하는지 여부

판단

■ 아래 내용을 확인하시기 바랍니다.

판단이유

■ 「전자금융거래법」 제28조 제2항 제3호에 따라 선불전자지급수단의 발행 및 관리 업무를 행하고자 하는 자는 금융위원회에 등록하여야 하며, 이에 따라 동법 시행령 제11조의4(개정 전 제11조의3) 제1항에 해당하는 경우에는 동법 제21조의2 제2항에 따라 정보보호최고책임자를 임원으로 지정하여야 합니다.
- 위 법령은 총자산, 종업원 수 등 고려 요소를 감안하여 정보보호최고책임자를 임원으로 지정할 의무를 규정한 것으로, 선불전자지급수단의 발행 및 관리 업무가 부수 업무라는 사유만으로는 해당 법령에 대한 예외를 인정하기 어렵습니다.

■ 제시하여 주신 현장건의 과제 "금융지주회사에 대한 전자금융거래 일부적용 배제"(회신일 2015.5.20.)의 경우 전자금융거래법의 일반적인 적용 대상인 금융회사의 범위에 금융지주회사를 포함할 것인지에 대한 건의 내용입니다.
- 따라서 전자금융업 업무 수행을 위하여 전자금융업자로 등록하는 경우에까지 위 회 회신사례의 취지를 그대로 적용하기는 어렵습니다.

■ 「개인정보 보호법」 제31조에 따른 개인정보 보호책임자의 경우,
- 개인정보의 처리 및 보호에 관한 책임자를 규정한 것으로, 「전자금융거래법」 및 「정보통신망 이용촉진 및 정보보호 등에 관한 법률」에서 정하는 '정보보호최고책임자'와 동일하게 보기는 어렵습니다.

■ 「정보통신망 이용촉진 및 정보보호 등에 관한 법률」(이하 '정보통신망법') 제45조의3에 따른 정보보호 최고책임자의 경우,
- 정보보호 최고책임자(CISO)에 관하여 「정보통신망법」은 일반법, 「전자금융거래법」은 특별법의 관계에 있으므로 「전자금융거래법」을 적용해야 한다는 과학기술정보통신부 답변 사례 및 「정보통신망법」 제5조의 반대해석을 참조할 때, 「전자금융거래법」 제21조의2 제1항, 제2항 및 동법 시행령 제11조의4(개정 전 제11조의3) 제1항의 적용을 받는 경우에는 전자금융거래법을 우선 적용하여 정보보호최고책임자를 임원으로 지정하여야 합니다.
- 이와 관련하여서는 정보보호 최고책임자(CISO) 관련 정보통신망법령 Q&A(2019.6.4.자 과학기술정보통신부 보도자료 "정보보호 최고책임자(CISO) 제도개선 6월 13일 시행" 붙임 1)에서 「전자금융거래법」의 적용대상인 금융회사, 전자금융업자의 「정보통신망법」 적용 여부에 대한 질의 및 답변 내용을 참고하여 주시기 바랍니다.

※ 법령해석('23.11.01.)-230303

질의

- 당사는 할부금융 및 신기술사업금융업 등을 영위하는 여신전문금융회사로서 온라인 중고차 매물 광고 서비스 제공 웹사이트*를 운영하고 있는데, 해당 정보통신 서비스에 대해서도 전자금융거래법이 적용되어 전자금융거래법 상의 CISO 선임 규정만 준수하면 되는지 여부
  * ○○○ 서비스 (웹 : 생략, 앱 : 앱스토어, 구글플레이 다운로드)는 중고차 거래 플랫폼으로서 내차 시세, 사고 이력, 리콜 정보 등 차량관리 서비스와 KB인증/진단 중고차 매물 소개, 차량 거래 지원, 차테크(마이데이터서비스를 활용한 구매 컨설팅) 서비스 등을 제공

회신

- 귀사의 ○○○ 서비스의 경우 전자금융업무에 해당되지 않아 전자금융거래법 제21조의2에 따른 정보보호최고책임자 지정 의무가 부과되지 않습니다.

이유

- 전자금융업무란 전자금융거래법 제2조 제1호에 따라 전자적 장치를 통하여 이용자에게 금융상품 및 서비스를 제공하는 것을 의미합니다.
  - ○○○ 서비스의 경우 금융상품 및 서비스를 제공하지 않으므로 전자금융업무에 해당되지 않으며, 해당 서비스에 관해서는 전자금융거래법 제21조의2에 따른 정보보호최고책임자 지정 의무가 부과되지 않습니다.
- 다만, ○○○ 서비스 외에 전자금융업무를 수행하는 부분에 대해서는 정보보호최고책임자 지정 의무가 부여되는 점을 참고해주시고, ○○○ 서비스와 관련하여 정보통신망법에 따른 정보보호최고책임자 지정 의무가 부과되는지 여부 등은 정보통신망법을 소관하는 과학기술정보통신부에 문의하여 주시기 바랍니다.

제4장 전자금융거래의 안전성 확보 및 이용자 보호

FSS
FINANCIAL SUPERVISORY SERVICE

제4장 전자금융거래의 안전성 확보 및 이용자 보호

제1절 통 칙

1. 전자금융거래 종류별 안전성 기준

감독규정

제7조(전자금융거래 종류별 안전성 기준) 법 제21조제2항의 "금융위원회가 정하는 기준"이라 함은 다음 각 호의 내용에 관하여 제8조부터 제36조에서 정하는 기준을 말한다.

1. 인력, 조직, 교육 및 예산 부문
2. 건물, 설비, 전산실 등 시설 부문
3. 단말기, 전산자료 및 정보처리시스템 등 정보기술부문
4. 해킹, 악성코드 감염 등 정보보호부문
5. 정보처리시스템 및 전자금융거래 관련 사업 부문
6. 비상대책 등 업무지속성부문
7. 전산원장통제, 프로그램 통제 등 정보기술부문 내부통제
8. 그 밖에 전자금융업무의 안전성 확보를 위하여 필요한 사항

- 전자금융거래법 제21조 제2항에서 규정한 "금융위원회가 정하는 기준"은 전자금융감독규정 제8조~제36조가 해당

※ 관계 법령

법

제21조(안전성의 확보의무) ① 금융회사 · 전자금융업자 및 전자금융보조업자(이하 "금융회사등"이라 한다)는 전자금융거래가 안전하게 처리될 수 있도록 선량한 관리자로서의 주의를 다하여야 한다.

② 금융회사등은 전자금융거래의 안전성과 신뢰성을 확보할 수 있도록 전자적 전송이나 처리를 위한 인력, 시설, 전자적 장치, 소요경비 등의 정보기술부문, 전자금융업무 및 「전자서명법」에 의한 인증서의 사용 등 인증방법에 관하여 금융위원회가 정하는 기준을 준수하여야 한다.

③ 금융위원회는 제2항의 기준을 정할 때 특정 기술 또는 서비스의 사용을 강제하여서는 아니 되며, 보안기술과 인증기술의 공정한 경쟁이 촉진되도록 노력하여야 한다.

④ 대통령령으로 정하는 금융회사 및 전자금융업자는 안전한 전자금융거래를 위하여 대통령령으로 정하는 바에 따라 정보기술부문에 대한 계획을 매년 수립하여 대표자의 확인 · 서명을 받아 금융위원회에 제출하여야 한다.

제2절 인력, 조직, 교육 및 예산 부문

1. 인력, 조직 및 예산

감독규정

제8조(인력, 조직, 교육 및 예산) ① 금융회사 또는 전자금융업자는 인력 및 조직의 운용에 관하여 다음 각 호의 사항을 준수하여야 한다.

1. 정보처리시스템 및 전자금융업무 관련 전담 조직을 확보할 것
2. 외부주문 등에 관한 계약을 체결하는 때에는 계약내용의 적정성을 검토하고 자체적으로 통제가 가능하도록 회사내부에 조직과 인력을 갖출 것
3. 정보보호최고책임자는 임직원의 정보보호역량 강화를 위하여 매년 교육계획을 수립·시행할 것
4. 최고경영자는 전년도 교육계획 시행 결과를 평가하고, 정보보호최고책임자는 그 결과를 금년도 교육계획에 반영할 것
5. 정보보호최고책임자는 임직원의 정보보안 관련법규를 준수하고 있는지 정기적으로 점검하고 그 점검결과 및 보완계획을 최고경영자에게 보고할 것
6. 최고경영자는 임직원이 정보보안 관련법규를 위반할 경우 그 제재에 관한 세부기준 및 절차를 마련하여 운영할 것

② 금융회사 또는 전자금융업자는 정보기술 및 정보보호 분야별 전문성을 갖춘 인력과 충분한 예산을 확보해야 한다.

■ 금융회사 및 전자금융업자는 정보처리시스템 및 전자금융거래의 안전성을 확보하기 위해 충분한 예산과 정보기술 및 정보보호 전문성을 갖춘 인력 및 조직을 확보하고 이를 효율적으로 운영할 수 있는 체계를 마련하여야 함

■ 해설

- 전자금융거래 규모, 이용자 수를 고려하여 정보처리시스템 및 전자금융업무의 안정적 운영에 필요한 적정인력으로 구성된 전담조직을 확보하여야 함 (제1항 제1호)
  - 전담조직의 규모 및 조직 운영방식은 회사의 사정에 따라 자율적으로 정할 수 있음
- 전자금융거래 관련 제휴, 위탁 또는 외주주문 등(이하 '외주주문')에 관한 계약시 계약내용의 적정성을 검토할 수 있고 외부주문업무에 관한 리스크 관리체계와 이를 위한 조직 및 인력을 갖춰야 함(제1항 제2호)

- 정보보호최고책임자는 조직의 정보보호 전략, 리스크 관리 계획 및 규제요건을 고려하여 임직원의 정보보호역량을 강화하기 위한 연간 교육계획을 수립하고 교육 및 연수 프로그램을 마련하여 시행하여야 함(제1항 제3호)

  - 온·오프라인 강의, 모의훈련, 실습 및 체험형 교육 등 효과적인 방식으로 교육을 구성하고, 경영진의 참여, 보상 및 인센티브 제공, 지속적인 홍보 등을 통해 단순히 형식적인 교육이 아니라 실제 조직 내 보안 수준을 향상시키는 방향으로 운영

  - 임직원 업무별 차별화된 교육계획을 수립하는 것도 효과적

    (예) 일반 직원 : 기본 보안 수칙, 정보보안 관련 규제
    경영진 : 정보보호 거버넌스 및 보안 투자 전략
    정보보호업무 및 정보기술업무 담당 직원 : 사이버 공격 대응, 침해사고 분석
    외주업체 직원 : 기업 보안 정책, 데이터 보호 방안 등

- 최고경영자는 전년도 교육계획 시행결과의 효과성을 평가하고, 정보보호최고책임자는 그 결과를 제1항제3호에 따른 당해연도 교육계획에 반영해야 함(제1항 제4호)

  - 교육의 효과성 평가는 임직원 대상의 보안인식 설문조사, 정보보호 지식 테스트, 모의 피싱 공격, 보안사고 대응 훈련 등의 방식을 활용할 수 있음

- 정보보호최고책임자는 임직원이 전자금융거래법 등 정보보안 관련 법규 및 회사의 보안정책을 준수하고 있는지 정기적으로 점검하고, 그 점검결과, 주요 리스크, 보완계획 및 경영진의 협력 및 의사결정이 필요한 사항 등을 최고경영자에게 보고하여 최고경영자가 보안의 중요성을 인식하고 필요한 투자와 정책을 실행할 수 있도록 지원(제1항 제5호)

- 최고경영자는 임직원이 정보보안 관련 법규를 위반할 경우 그 제재에 관한 세부 기준 및 절차를 마련하여 운영해야 함(제1항 제6호)

2. 정보보호위원회의 운영

감독규정

제8조의2(정보보호위원회 운영) ① 금융회사 또는 전자금융업자는 중요 정보보호에 관한 사항을 심의 · 의결하는 정보보호위원회를 설치 운영하여야 한다.

② 정보보호위원회의 장은 정보보호최고책임자로 하며, 위원은 정보보호업무 관련 부서장, 전산운영 및 개발 관련 부서장, 준법업무 관련 부서의 장 등으로 구성한다.

③ 정보보호위원회는 다음 각 호의 사항을 심의 · 의결한다.

1. 법 제21조제4항에 따른 정보기술부문 계획서에 관한 사항
2. 법 제21조의2제4항제1호에 관한 사항
3. 법 제21조의3에서 정한 취약점 분석 · 평가 결과 및 보완조치의 이행계획에 관한 사항
4. 전산보안사고 및 전산보안관련 규정 위반자의 처리에 관한 사항
5. 제14조의2제1항의 클라우드컴퓨팅서비스의 이용에 관한 사항
6. 기타 정보보호위원회의 장이 정보보안업무 수행에 필요하다고 정한 사항

④ 정보보호최고책임자는 정보보호위원회 심의 · 의결사항을 최고경영자에게 보고하여야 하며, 정보보호최고책임자가 전자금융거래의 안전성 및 신뢰성에 중대한 영향을 미친다고 판단하는 심의 · 의결사항에 대해서는 이사회에 보고하여야 한다.

⑤ 최고경영자는 특별한 사정이 없는 한 정보보호위원회의 심의 · 의결사항을 준수하여야 한다.

정보보호와 관련된 정책, 사업, 징계 등 회사의 정보보호와 관련된 주요사항을 검토 및 의결할 수 있도록 정보보호최고책임자(CISO)를 장으로 하는 정보보호위원회를 구성 · 운영

해설

- 정보보호위원회는 아래의 사항을 심의 · 의결 또는 승인
  - 정보기술부문에 대한 계획은 정보보호위원회 심의 · 의결을 거친 후 대표자의 확인 · 서명을 받아 금융감독원에 제출(제3항 제1호, 법 제21조 제4항, 시행령 제30조 제1항 제1호의2)
  - 정보보호최고책임자가 전자금융거래의 안정성 확보 및 이용자 보호를 위한 전략 및 계획을 수립한 사항에 대해 정보보호위원회 심의 · 의결(제3항 제2호)
  - 취약점 분석 · 평가 결과 및 보완조치의 이행계획에 관한 사항에 대하여서는 정보보호위원회 심의 · 의결을 거치고, 금융감독원에 보고하며(제3항 제3호, 법 제21조의3, 시행령 제30조 제1항 제1호의3), 이행계획의 시행 결과는 최고경영자에게 보고(감독규정 제37조의2 제5항 제3호)
  - 전산보안사고 및 전산보안관련 규정 위반자의 처리(제3항 제4호)
  - 클라우드컴퓨팅서비스 이용시 이용업무의 중요도 평가 결과, 클라우드컴퓨팅서비스 제공자의 건전성 및 안전성 등에 대한 평가 업무연속성 계획 및 안전성 확보조치가 심의 · 의결 사항에 포함되어야 함(제3항 제5호, 감독규정 제14조의2)

- 망분리 예외처리 관련 정보보호위원회 승인(감독규정 제15조 제1항 제3호, 제5호, 시행세칙 제2조의3)
- 그 외 정보보호위원회의 장이 정보보안업무 수행에 필요하다고 정한 사항에 대해서 심의 · 의결 사항으로 정할 수 있음(제3항 제6호)

● 정보보호최고책임자는 정보보호위원회의 심의 · 의결 결과를 최고경영자에게 보고하여야 하며, 전자금융거래 안전성과 신뢰성에 중대한 영향을 미치는 사안에 대해서는 이사회에 보고하여야 함(예시 참조)

※ (참고) 정보보호위원회 심의 · 의결사항 이사회 보고 예시

■ 전자금융거래의 안전성 및 신뢰성을 확보하기 위해 주요 보안리스크에 대해서는 이사회에 보고하고, 최고경영진의 역할 · 관심을 제고하여 전사적 차원에서 보안 역량을 강화할 필요

● **(보고 대상)** CISO는 아래의 기본원칙에 해당한다고 판단하는 정보보호위원회 심의 · 의결 주요사항에 대해 이사회에 보고 필요

〈정보보안 관련 이사회 보고 주요 원칙〉

❶ 정보보안에 관한 목표 · 전략 및 계획 수립에 관한 사항
❷ 정보보안 리스크 평가 및 대응 조치에 관한 사항
❸ 침해사고 및 개인정보 유출 등 정보보안 사고에 관한 사항
❹ 클라우드 등 제3자 리스크 관리에 관한 사항

- 제시된 이사회 보고 대상 예시는 참고용으로, 정보보호 수준에 큰 영향을 미치는 사항이 누락되지 않도록 회사별로 적의 조정
- CISO의 판단 하에 사안별로 개별보고 또는 종합적으로 보고
- 특히, 취약점 분석 · 평가와 같이 ❷정보보안 리스크 평가 및 대응 조치에 관한 사항 등을 종합적으로 보고 시에는 이사회가 회사의 정보보안수준을 인식하고 적절한 의사결정을 할 수 있도록 충분한 정보를 제공하여야 하며,
- 이를 위해 IT 인프라 · 서비스 등 전사적 정보보안 수준, 주요 리스크 및 영향도(미조치시 손실*), 투자 필요 사항 등이 포함될 필요

  * 법 위반에 따른 과태료 · 과징금, 정량적 또는 정성적 손실 가능성

〈이사회의 효율적인 의사결정을 위해 보고 시 포함 필요사항(참고예시)〉

❶ 조직의 정보보안 수준(예 전자금융기반시설 취약점 분석 · 평가 종합등급 등)
❷ 동종업계 또는 타사 대비 정보보안 수준 비교(예산 및 인력 등 공시된 자료 등을 활용)
❸ 주요 보안 리스크 내역 및 조치계획
❹ 보안 리스크 미조치에 따른 예상 손실 및 리스크 경감방안
❺ 보안 리스크 경감을 위한 필요 사항

● **(보고시기 및 빈도)** 보고 사유가 발생한 날 이후 최초에 개최되는 이사회에 보고하는 것을 원칙으로 하되, 안건의 중요도 등을 고려하여 일괄·통합보고 등 보고시기를 조정하는 것도 가능

- 이사회 보고는 최소 연 1회 이상 보고하는 것이 바람직
- 다만, 대규모 침해사고 등으로 인한 신속 대응이 필요한 사안에 대해서는 지체없이 이사회를 개최하여 보고하고, 아울러 이사회 의사결정이 필요한 사안*에 대해서는 사전 보고를 권장
  * 예 : 대규모 예산이 수반되는 IT보안 사업의 추진 등

● **(보고 방법)** 이사회에 정확하고 상세한 정보를 제공하고 관심을 제고하기 위해 CISO가 직접 대면 보고하는 것을 원칙으로 하되,
- 안건의 중요도 등을 고려하여 필요시 서면보고도 무방

● **(내규 반영)** 이사회 보고 내용의 범위·시기 등을 내규*에 반영하여 명확히 하는 것이 필요
  * 이사회 운영 내규 또는 정보보호위원회 내규에 반영

■ 정보보호위원회 심의·의결사항 중에서 CISO가 이사회에 보고해야 하는 사항의 예시는 다음과 같음

❖ [보고대상 ①] 정보보안에 관한 목표·전략 및 계획 수립에 관한 사항

• [예시] ① 정보기술부문 계획서(정보보호 예산·조직, 주요 보안 사업 계획 등)
② 중장기 정보보안 전략 및 계획
③ 정보보안관련 중요 내규에 관한 사항
④ 조직의 정보보안 강화를 위한 기준 및 정책 수립에 관한 사항

❖ [보고대상 ②] 정보보안 리스크 평가 및 대응 조치에 관한 사항

• [예시] ① 전자금융기반 시설 취약점 분석·평가 및 이행 계획
② 망분리 예외 승인 현황 및 이에 따른 보안 조치 현황(전체 현황 및 주요 사항에 한정)
③ 감독 당국의 정보보안법규 관련 제재 등 조치에 관한 사항
④ 전사 정보보안 리스크 평가 결과 및 위험 항목에 대한 조치방안

❖ [보고대상 ③] 침해사고 및 개인정보 유출 등 정보보안 사고에 관한 사항

• [예시] ① 침해사고 및 정보 유출사고 현황·원인 및 대응방안
② 침해사고 및 정보 유출사고 관련 소비자 구제 및 대응방안

❖ [보고대상 ④] 클라우드 등 제3자 리스크 관리에 관한 사항

• [예시] ① 클라우드 이용(생성형 AI SaaS 포함)에 관한 보안대책, 업무 연속성 확보, 위험관리, 종료전략 등 제3자 리스크 관리 방안 수립· 이행 현황
② 주요 정보처리 업무 수탁자에 대한 보안 평가 결과 및 개선방안

3. 직무의 분리

감독규정

제8조의3(직무의 분리) 금융회사 또는 전자금융업자는 정보기술부문의 내부통제를 위한 직무분리 기준을 수립 · 운용하여야 한다.

■ 금융회사 등은 정보처리시스템 개발, 운영, 보안관리에 있어 권한 오 · 남용 등으로 인한 내부 부정행위, 보안사고, 데이터 조작 등 잠재적인 피해 예방을 위하여 직무 분리 기준을 수립 · 운용하여야 함

■ 해설

● 한 사람이 IT시스템을 개발하면서 동시에 운영 및 모니터링 권한을 보유한 경우, 개발자가 직접 운영시스템을 변경하여 고객 계좌 잔고를 변경, 부정 송금, 보안로그를 조작하여 데이터 조회 흔적을 삭제하는 등의 사고가 발생할 수 있음

- 또한 한 사람이 시스템을 변경하고 직접 테스트 및 검증을 하는 경우 오류를 놓칠 가능성이 높아 실수로 인한 금융사고나 서비스 장애 발생 가능

● 시스템 무단조작, 민감정보 무단조회 등의 사고를 방지하기 위해 담당업무별로 업무를 분리하고 최대한 상호견제가 이루어질 수 있도록 통제체계를 마련하여 운영

- 소규모 조직 등의 사유로 불가피하게 직무 분리가 어려운 경우 직무자 간의 상호검토, 책임 추적성(Audit Trail) 확보 등 보완통제 방안을 수립

● 직무분리는 시스템 개발, 운영, 보안, 감사 등의 역할을 명확히 구분하여 한 사람이 중요한 업무를 동시에 수행하지 않도록 하는 것을 원칙으로 하며,

- 소프트웨어 개발과 IT운영을 통합하여 빠르게 애플리케이션을 배포하기 위한 개발방식(예시 : DevOps)을 채택한 경우에도 직무분리 원칙은 준수되어야 함

직무 분리 예시

- 입력 · 승인 · 확인 등 모든 거래과정이 동일 직원에 의해 처리되지 않도록 분리
- 프로그램 개발자와 시스템 운영자(서버 관리자) 분리
- 데이터베이스 관리자와 시스템 및 응용 프로그래머 분리
- 시스템 프로그래머의 작업에 대한 자체 감사자의 통제
- 전산기기 운영자(Operator)에 대한 자체 감사자 또는 시스템 프로그래머의 통제
- Batch 프로그램에 의한 온라인 데이터베이스 접근 통제
- 업무개발자와 관리자의 분리
- 내부감사자 및 보안 관리자의 타 업무 겸임 금지

■ 개선 요구 등 사례('24.4.26)

- 인프라보안 팀장이 정보보호업무 담당 부서장을 겸임하고 있어 전반적인 정보보호 업무 준수여부를 감독하여야 하는 정보보호 조직의 독립적인 운영이 어렵고, 인프라 및 보안간 이해상충 문제로 인해 상호견제가 제대로 이루어지지 않을 우려가 있으므로 개선 필요

제3절 시설 부문

1. 건물에 관한 사항

감독규정

제9조(건물에 관한 사항) 금융회사 또는 전자금융업자는 전산실이 위치한 건물에 관하여 안전대책 및 출입통제 보안대책을 수립 · 운용해야 한다.

■ 자연재해, 인적재해 등 물리적 · 환경적 위협으로부터 전산센터를 포함한 전산실을 물리적으로 보호하기 위한 대책을 마련하고 운용

■ 해설

- 전산실 건물에 대해서는 지진, 수해 및 화재 등의 재난으로부터 업무연속성을 확보하기 위해 보호대책을 마련하여야 하며, 외부 시설을 이용하는 경우에는 보호대책이 적절히 적용되어 있는지 확인
- 전산실 건물에 대한 출입은 인가된 직원만 가능하도록 출입통제체계를 마련하여 운영

전산실 건물 안전대책 및 출입통제 예시

- 건물 내 화재감지기 및 자동소화장치 설치
- 침수, 정전 등에 대비한 환경 감시장비 설치
- 재난, 화재, 정전 등 비상시 안전한 대피를 위한 경로, 비상조명 설치
- 번개, 과전류 등에 의한 전산장비 보호를 위한 피뢰설비, 접지시설 설치
- 방범 설비, 경보 장치 등 침입 대응체계 마련
- 건물 출입구 및 주요 동선에 출입통제 장비(출입카드, 생체인식 등) 설치
- 출입기록의 전자적 저장 및 이상징후 탐지체계 마련
- CCTV 및 침입탐지시스템 구축
- 경비 인력 운영 등 감시체계 확보
- 출입 권한에 따른 구역별 제한 설정 및 방문객 관리 절차 운영

2. 전원, 공조 등 설비에 관한 사항

감독규정

제10조(전원, 공조 등 설비에 관한 사항) 금융회사 또는 전자금융업자는 전산실이 위치한 건물의 전원, 공조 등 설비의 안전성을 위한 기준을 수립 · 운용해야 한다.

■ 전산실이 위치한 건물 내 전원, 공조 등 물리적 · 기술적 인프라에 대한 운영 연속성과 복원력 확보를 위한 기준을 마련하고 운용

■ 해설

● 서버 등 주요 정보처리시스템이 위치한 전산실의 안전성 확보를 위해 전원 및 공조설비에 대한 운영기준을 마련하여 운용

※ 세부기준은 집적정보통신시설 보호지침(과학기술정보통신부고시 제2024-19호) 제8조 및 [별표] 집적정보통신시설 보호조치 세부기준참고 가능

전원, 공조 등 설비의 안전성 기준 예시

- 전원실, 공조실 등 주요 설비시설에 출입통제장치를 설치
- 무정전 전원공급장치(UPS) 및 비상발전기 설치
- 항온항습기, 공조기 등 환경 유지 설비의 이중화 및 병렬 운용
- 설비 이상 탐지센서 및 경보 시스템 구축
- 설비의 정기 점검 및 유지보수 계획 수립

3. 전산실 등에 관한 사항

감독규정

제11조(전산실 등에 관한 사항) 금융회사 또는 전자금융업자는 전산실에 관하여 다음 각 호의 사항을 포함한 대책을 수립 · 운용하여야 한다.

1. 국내에 본점을 둔 금융회사 또는 전자금융업자의 전산실 및 재해복구센터는 국내에 설치할 것(단, 제50조제2항에 따라 등록한 국외 사이버몰을 위한 전자지급 결제대행업자는 제외)
2. 무선통신망을 설치하지 아니할 것
3. 그 밖에 재해 및 위해방지, 출입 · 접근통제 등 전산실의 안전 및 보안에 관한 사항

■ 전산실 등 설치요건, 보안 금지사항 및 물리적 안전 · 보안 대책 수립 · 운용의무를 규정

해설

- 전산실의 안전성과 통제체계 마련을 위해 국내에 본점을 둔 금융회사 또는 전자금융업자의 전산실 및 재해복구센터는 국내에 설치하여 국내 법규 및 규정 준수(제1호)
- 무선통신망은 외부 전파로 인한 정보 유출, 해킹 등 보안 취약성이 높으므로, 전산센터 및 재해복구센터의 서버룸, 운영자 사무실, 통신장비실 등 전산실 내 무선통신망 설치 금지(제2호)
- 화재 · 수해 · 지진 등의 자연재해, H/W · S/W의 장애, 운용요원의 고의 또는 실수, 테러 등으로 인하여 전산실의 기능이 마비되는 것을 방지하기 위한 대책을 마련하여 운영(제3호)

전산실의 안전 및 보안에 관한 대책 예시

1. 출입 · 접근 통제 관련 조치
   - 전산실 출입 시 다중 인증방식 적용 (예: 카드키 + 생체인식)
   - 권한별 출입구역 분리
   - 출입기록 자동 기록 및 주기적 모니터링
   - 퇴직자 · 이직자 출입권한 즉시 회수 절차 마련

2. 재해 및 위해 방지 조치
   - 화재 감지기 및 자동소화 시스템 설치
   - 수분 감지기, 침수 경보 장치 등 설치
   - 지진 · 화재 · 정전 등 재해 대비훈련 및 시나리오 기반 모의훈련 실시
   - 고온 · 저온 · 습도 이상 감지를 위한 환경 모니터링 센서 구축

3. 내부 장비 보호 및 보안관리
   - 서버, 스토리지, 통신장비 등에 대한 장비 고정 및 잠금장치 설치
   - 보안 스티커, 봉인 라벨 등 훼손 탐지 장치 부착
   - 전산장비 교체 · 이동 시 이력 관리 체계 및 승인 절차 마련
   - 정보 저장매체 폐기 시 파쇄 또는 완전 삭제 조치 시행

4. 감시 · 경보 체계
   - 전산실 내부 및 주변에 CCTV 설치 및 실시간 모니터링
   - 이상 출입 · 환경 변화 감지 시 즉시 경보 및 보고 체계 운영
   - 보안 관제 시스템과 연계된 물리 보안 이벤트 로그 분석

제4절 정보기술부문

1. 단말기 보호대책

감독규정

제12조(단말기 보호대책) 금융회사 또는 전자금융업자는 단말기 보호를 위하여 다음 각 호의 사항을 준수하여야 한다.

1. 단말기는 인가된 사용자만 사용할 수 있도록 관리할 것
2. 정보처리시스템에 접속하는 단말기에 대해 정당한 사용자인가의 여부를 확인할 수 있는 기록을 유지할 것
3. 외부 반출, 인터넷 접속, 그룹웨어 접속의 금지, 정기적인 악성코드 감염여부 확인 등 강화된 보호대책이 적용되는 중요단말기를 지정할 것
4. 정보유출 및 악성코드 감염 등을 방지할 수 있도록 단말기에서 보조기억매체 등에 접근하는 것을 통제할 것

■ 금융회사 내부통신망에 연결된 단말기(이하 개인용 컴퓨터 포함)가 비인가자에 의한 무단 사용, 분실, 악성코드 감염, 정보유출에 이용되지 않도록 단말기 보호 대책을 마련·운영하여야 함

● 본 조에서 "단말기"란 내부통신망에 접속하거나, 접속이 가능한 전자적 장치(개인용, 업무용 컴퓨터 포함) 등을 의미하고, 내부통신망에 접속하지 못하도록 통제된 컴퓨터 등은 적용대상이 아님(법령해석 200113)

■ 해설

● 인가된 사용자 이외의 자가 내부 정보통신망과 연결된 단말기를 무단으로 조작하여 전산자료를 수정, 삭제, 조회하지 못하도록 조치(제1호)

- IP 및 MAC 통제, 로그인 비밀번호, 일정시간 단말기 사용중지 시 화면보호기능 설정 및 비밀번호 재입력, 취급자 지정, 공유폴더 관리 등 단말기 접근통제

● 정보처리시스템에 접속하는 단말기의 사용자인가 정보를 기록·유지함으로써 필요시 정보처리시스템 사용자의 정당성 확인 등을 위한 책임추적성을 확보(제2호)

● 중요단말기가 외부에 반출되거나 인터넷 및 그룹웨어에 접속되는 경우 해커가 침입하거나 해킹프로그램 또는 악성코드에 감염되어 내부 정보유출 및 자료파괴 등 피해가 발생할 수 있으므로 이를 방지하기 위하여 중요단말기는 외부 반출, 인터넷 접속, 그룹웨어 접속 금지, 정기적인 악성코드 감염여부 확인 등 강화된 보호대책을 적용(제3호)

- 중요단말기의 범위는 업무 및 데이터의 종류에 따라 자율적으로 지정 가능(비조치의견서 210034 등)

✔ 중요단말기 선정 예시

- 접속 가능 시스템, 처리하는 업무의 내용 및 위험수준을 고려하여 자체적으로 중요단말기 지정 기준을 수립 · 운영
- **(예시 1)** 서버, 네트워크, DB, 보안시스템을 직접 접속하는 단말기
- **(예시 2)** 개인신용정보 등 이용자 주요 정보 및 주요 자산에 접근(조회, 변경 등)하는 단말기

● 보조기억매체 등이 내부통신망에 연결된 단말기에 접속되는 경우 동 매체나 장비를 이용한 정보유출 및 악성코드 유입이 발생할 수 있으므로 사고방지를 위하여 내부통신망에 접속하는 단말기는 보조기억매체 등 접근을 통제(제4호)

※ 법령해석(('20.07.28.)-200113

질의

■ 「전자금융감독규정」 제12조 단말기 보호대책에서 말하고 있는 단말기란, 정보처리 시스템에 접속이 가능한 단말기(컴퓨터 등)을 의미한 것인지 아니면 정보처리시스템에 접속하지 않더라도 업무 목적으로 사용하는 컴퓨터는 모두 단말기에 해당되는지 여부

회신

■ 「전자금융감독규정」은 제12조에서 금융회사 등으로 하여금 정보처리시스템에 접근할 수 있는 단말기를 제한함으로써,
- 비인가자에 의한 정보 유출 및 악성코드 감염, 프로그램 변경, 불법 거래 등을 방지할 목적으로 단말기 보호 대책을 수립 · 운영하도록 하고 있습니다.

■ 이에 「전자금융감독규정」 상 "단말기"란 원칙적으로 내부통신망에 접속하거나, 접속이 가능한 전자적 장치(개인용, 업무용 컴퓨터 포함) 등을 의미한다고 보아야 할 것이며,
- 내부통신망에 접속하지 못하도록 통제된 컴퓨터 등은 특별한 사정이 없는 한 「전자금융감독규정」 제12조의 적용대상이 아니라고 할 수 있습니다.

■ 다만, 일시적으로라도 내부통신망, 정보처리시스템에 접속 가능성이 있는 컴퓨터 등은 해당 컴퓨터 등을 통한 정보유출, 악성코드 감염 등이 발생할 수도 있으므로 단말기에 해당하며, 동 규정이 적용됩니다.

이유

■ 현재 「전자금융감독규정」에서는 "단말기"의 개념에 대해서 따로 정의하고 있지는 않습니다.

■ 다만, "단말기"의 사전적 의미는 중앙컴퓨터와 통신망으로 연결되어 자료를 입력하거나, 출력하는 장치를 의미하며,
- 동 규정은 제12조에서 금융회사 등으로 하여금 정보처리시스템에 접근할 수 있는 단말기를 제한함으로써,
  - 비인가자에 의한 정보 유출 및 악성코드 감염, 프로그램 변경, 불법 거래 등을 방지할 목적으로 단말기 보호 대책을 수립 · 운영하도록 하고 있습니다.
- 따라서, 「전자금융감독규정」 상 "단말기"란 원칙적으로 내부통신망에 접속하거나, 접속 가능한 전자적 장치(개인용, 업무용 컴퓨터 포함) 등을 의미한다고 볼 수 있습니다.

■ 결론적으로 내부통신망, 정보처리시스템에 접속하지 못하도록 통제된 컴퓨터 등은 특별한 사정이 없는 한 「전자금융감독규정」 제12조의 적용대상이 아니라고 할 수 있습니다.
- 다만, 일시적으로라도 내부통신망, 정보처리시스템에 접속 가능성이 있는 컴퓨터 등에 대해서는 해당 컴퓨터 등을 통한 정보유출, 악성코드 감염 등이 발생할 수도 있으므로 단말기에 해당하며, 동 규정이 적용되어야 할 것입니다.
- 또한, 외주개발을 위해 투입된 외주직원이 사용하는 단말기에도 동 규정이 적용됨을 알려드립니다.

※ 비조치의견서('15.06.08.)-150605

비조치의견서는 행정해석의 일종으로 최종 법적구속력은 없으며, 유권해석과는 달리 특정행위에 대해 해당 회사의 상황을 고려한 검토결과로써 일반적 효력을 가지지 아니하므로 참고자료로만 활용하시기 바랍니다.

요청대상 행위

■ 단말기별 취급자를 지정하고, 단말기를 켤 때 및 운영체제(O/S)에 접속할 때 각각 비밀번호를 설정 · 입력하며, 화면보호기능을 설정한 것이

- 업무당당자 이외의 사람이 단말기를 무단으로 조작하지 못하도록 조치*한 것인지 여부
  * 전자금융감독규정 제12조제1호

판단

■ 요청대상 행위는 적절한 조치에 해당하는 것으로 판단되는바, 특별한 사정이 없는 한 제재대상에 해당하지 않습니다.

판단이유

■ 전자금융감독규정 제12조(단말기 보호대책) 제1호에 의해 금융회사 또는 전자금융업자는 '업무담당자 이외의 사람이 단말기를 무단으로 조작하지 못하도록 조치'하여야 하는데, 구체적인 조치 방법은 금융회사 등이 자율적으로 결정하여 운영할 수 있는바,

- 단말기별로 취급자를 지정하며 비밀번호를 2중으로 설정하게 하고 화면보호기 등을 설정할 경우 단말기가 무단으로 부팅 · 사용되거나 작업 중 권한 없는 자가 임의로 사용하는 것을 예방할 수 있다고 판단됩니다.*
  * 구 전자금융감독규정 제12조 제1호(2015.2.3. 개정 전)는 '업무담당자 이외의 사람이 단말기를 무단으로 조작하지 못하도록 단말기별 취급자 및 비밀번호를 지정하고 화면보호기능을 부여'하도록 명시하고 있었음

■ 다만, 비밀번호 설정 · 입력과 관련하여 전자금융감독규정 제32조(내부사용자 비밀번호 관리)를 준수해야 합니다.

※ 비조치의견서('21.06.28.)-210034

비조치의견서는 행정해석의 일종으로 최종 법적구속력은 없으며, 유권해석과는 달리 특정행위에 대해 해당 회사의 상황을 고려한 검토결과로써 일반적 효력을 가지지 아니하므로 참고자료로만 활용하시기 바랍니다.

요청대상 행위

■ 중요단말기의 범위와 보호조치에 대하여 구성이 적법한지

판단

■ 아래 내용을 참고하시기 바랍니다.

판단이유

1 금융회사는 단말기 보호를 위해 외부반출, 인터넷 접속, 그룹웨어 접속의 금지 등 강화된 보호대책이 적용되는 중요 단말기를 지정하여야 합니다. (「전자금융감독규정」(이하 '감독규정') 제12조 제3호)

- 「감독규정」에서 중요단말기의 범위를 별도로 정하고 있지 않아 업무 및 데이터의 종류에 따라 회사가 자율적으로 중요단말기를 지정하실 수 있으며, 동 규정 제12조 제3호에 따라 중요 단말기는 외부 반출, 인터넷 접속, 그룹웨어 접속을 금지하여야 합니다.

2 금융회사는 전산실에 위치한 정보처리시스템의 운영, 개발, 보안 목적으로 직접 접속하는 단말기를 인터넷 등 외부통신망으로부터 물리적으로 분리하여야 합니다. (「감독규정」 제15조 제1항 제5호)

- 귀 사가 문의하신 사실관계 하에서 판단하건데, 개발 및 테스트 시스템에 접속하여 개발업무를 수행하고 있는 업무단말기는 「감독규정」 제15조의 제1항 제5호의 단말기에 해당하므로 물리적 망분리의 대상입니다.
- 또한, 동 단말기가 중요단말기로 지정되어 있다면 「감독규정」 제12조 제3호에 따라 그룹웨어 접속 등도 금지하여야 합니다.

2. 전산자료 보호대책

감독규정

제13조(전산자료 보호대책) ① 금융회사 또는 전자금융업자는 전산자료의 유출, 파괴 등을 방지하기 위하여 다음 각 호를 포함한 전산자료 보호대책을 수립·운용하여야 한다.

1. 사용자 인증 수단을 개인별로 부여하고 접근권한은 최소한으로 부여하는 등 적절한 접근권한 관리 및 통제 절차를 수립·운용할 것
2. 전산자료의 보유현황을 관리하고 책임자를 지정·운용할 것
3. 전산자료 및 전산장비의 반출·반입을 통제할 것
4. 비상시에 대비하여 전산자료에 대한 안전지출 및 긴급파기 계획을 수립·운용할 것
5. 정기적으로 보조기억매체의 보유 현황 및 관리실태를 점검하고 책임자의 확인을 받을 것
6. 중요도에 따라 전산자료를 정기적으로 백업하여 원격 안전지역에 소산하고 백업내역을 기록·관리할 것
7. 주요 백업 전산자료에 대하여 정기적으로 검증할 것
8. 이용자 정보의 조회·출력에 대한 통제를 하고 테스트 시 이용자 정보 사용 금지(다만, 법인인 이용자 정보는 금융감독원장이 정하는 바에 따라 이용자의 동의를 얻은 경우 테스트 시 사용 가능하며, 그 외 부하 테스트 등 이용자 정보의 사용이 불가피한 경우 이용자 정보를 변환하여 사용하고 테스트 종료 즉시 삭제하여야 한다)
9. 정보처리시스템의 가동기록은 금융감독원장이 정하는 사항을 접속의 성공여부와 상관없이 자동적으로 기록·유지하고 1년 이상 보존할 것
10. 단말기에 이용자 정보 등 주요정보를 보관하지 아니하고, 단말기를 공유하지 아니할 것(다만, 불가피하게 단말기에 보관할 필요가 있는 경우 보관사유, 보관기간 및 관리 비밀번호 등을 정하여 책임자의 승인을 받아야 한다)
11. 사용자가 전출·퇴직 등 인사조치가 있을 때에는 지체 없이 해당 사용자계정 삭제, 계정 사용 중지, 공동 사용 계정 변경 등 정보처리시스템에 대한 접근을 통제할 것

② 사용자계정의 공동 사용이 불가피한 경우에는 개인별 사용내역을 기록·관리하여야 한다.

③ 금융회사 또는 전자금융업자는 단말기와 전산자료의 접근권한이 부여되는 정보처리시스템 관리자에 대하여 적절한 통제장치를 마련·운용하여야 한다. 다만, 정보처리시스템 관리자의 주요 업무 관련 행위는 책임자가 제28조제2항에 따라 이중확인 및 모니터링을 하여야 한다.

시행세칙

제2조의2(정보처리시스템 가동기록) 규정 제13조제1항제9호에 따라 감독원장이 정하는 사항은 다음 각 호와 같다.

1. 정보처리시스템에 접속한 일시, 접속자 및 접근을 확인할 수 있는 접근기록
2. 전산자료를 사용한 일시, 사용자 및 자료의 내용을 확인할 수 있는 접근기록
3. 정보처리시스템내 전산자료의 처리 내용을 확인할 수 있는 사용자 로그인·액세스 로그 등 접근기록

제2조의5(법인 이용자 정보의 사용에 대한 동의) 규정 제13조제1항제8호에 따라 동의를 얻는 경우 다음 각 호의 사항을 정보주체에게 사전에 알려야 한다.

1. 테스트의 목적 및 기간
2. 사용되는 이용자 정보의 항목
3. 테스트 기간 중 정보유출 방지를 위한 통제 계획
4. 테스트 종료 후 테스트에 사용된 이용자 정보의 파기 계획

■ 금융회사 또는 전자금융업자가 보유하고 있는 고객정보 등 중요정보의 외부유출 및 불법사용을 방지하고, 정보 파괴 시 신속한 복구가 가능하도록 대책을 수립하며, 사고발생시 추적이 용이하도록 정보처리시스템 접속 및 이용자정보 조회 로그 등 정보처리시스템 가동기록 유지

■ 해설

- 정보처리시스템 및 전산자료에 접근하는 사용자 인증수단(계정과 비밀번호 등)은 개인별 부여를 원칙으로 하며, 사용자 계정에 관한 등록 · 변경 · 폐기 등 절차를 마련하여 체계적으로 관리하여야 함. 다만, 시스템의 특성상 공동 사용이 불가피한 사용자 계정(예: UNIX의 "root" 등)은 사용자 개인별 사용 내역이 파악될 수 있도록 사용자 IP, 접근시간 등 개인별 세부 사용내역을 기록 · 유지함으로써 추후에 추적 및 확인이 가능하도록 관리(제1항 제1호, 제2항)
- 사용자의 접근권한은 업무수행에 필요한 최소 권한만 부여하고, 접근권한의 부여 · 변경 · 삭제 이력을 남기며, 부여된 접근 권한 및 변경내역을 주기적으로 검토하여 적정성을 점검하는 등 사용자 접근권한 통제 절차를 수립 · 운용해야 함(제1항 제1호)
- 전산자료의 적절한 관리와 통제를 위하여 전산자료 보유현황을 관리하고 책임자를 지정하여 운영(제1항 제2호)
- 전산자료 및 장비를 반출하거나 반입할 경우에는 반 · 출입 사항을 기록 관리하여야 하며, 반출된 전산자료는 목적 외 사용이 되지 않도록 하여야 하고, 사용 용도가 완료된 후에는 즉시 회수 또는 파기토록 조치(제1항 제3호)

✔ 반출입 통제 대상 및 절차(예시)

- **반출입 통제 대상:** 정보처리시스템(서버, 네트워크. 장비 등), 모바일 기기 (노트북 등), 저장매체(HDD, SDD, USB 메모리, 외장 하드디스크 등)
- **반출입 통제 절차:** 반출입 관리대장 기록 및 책임자 승인, 반출입 통제대상 기기 및 자료에 대한 보안 점검수행 (백신설치, 악성코드 검사, 보안업데이트, 매체봉인 등)

- 비상시(분실 등) 대비 전산자료에 대한 안전지출(이용시 비밀번호 인증 등) 및 긴급파기(원격파기, 불용처리 등)를 위한 계획을 수립하여 운용하여야 함(제1항 제4호)

  ※ **(예시)** 전산자료 지출 및 파기시 책임자가 승인, 전산자료 파기시 디가우징, 파쇄, 소각 등의 방법으로 복구가 불가능하게 파기, 파기대상 및 파기방식 등 파기 현황을 기록

- 보조기억매체는 보유현황, 사용자, 사용용도 등이 파악될 수 있도록 관리대장을 통해 관리되어야 함(제1항 제5호)

- 재해, 장애, 침해사고 등으로 인해 정보시스템에 저장된 데이터 및 프로그램 등이 손상된 경우에도 적시에 복구가 가능하도록 정기적인 백업 및 소산을 실시하여야 하며, 백업현황을 기록·관리해야 함(제1항 제6호)
- 백업자료의 소산은 전산센터의 화재, 수해 등 재해에 대처할 수 있도록 전산센터로부터 물리적으로 떨어진 장소에 소산하고 이력을 관리하여야 하며, 관련법에서 정한 보존기간 및 업무중요도를 고려하여 소산 대상 및 보존기간을 정함(제1항 제6호)
  - 소산장소의 이격거리는 데이터 전송 속도 및 운영 비용을 고려하여 금융회사 자율로 정하되, 동일한 재해 영향권에서 벗어나기 위한 충분한 물리적 거리를 확보
- 소산장소는 백업자료가 손상되지 않도록 내화금고, 방염처리 등 화재, 홍수와 같은 자연재해에 대한 대책을 마련하여야 하며, 소산장소의 접근통제 필요(제1항 제6호)
- 주요 백업 전산자료는 정보의 완전성과 정확성, 복구절차의 적절성을 확인하기 위해 정기적으로 복구 테스트를 실시하여 검증(제1항 제7호)
- 전산업무 개발 또는 프로그램을 변경하는 경우 테스트 목적으로 실이용자 정보의 사용을 금지, 필요시 이용자 식별이 불가능하도록 하여 사용하고, 테스트 종료 즉시 테스트 데이터 삭제 조치(제1항 제8호)
  - 고객 인적사항, 금융거래 정보 등 이용자 정보가 포함된 조회나 출력시 이용자가 노출되지 않도록 이용자 식별정보를 통제(마스킹 등)
  - 다만, 법인인 이용자 정보는 테스트의 목적 및 기간, 사용되는 이용자 정보의 항목 등을 사전에 고지한 후 동의를 얻어 사용 가능
- 서버, 데이터베이스, 네트워크 장비, 백업 장비, 스토리지, 어플리케이션 등 정보처리시스템의 가동기록은 정보처리시스템 접속일시, 접속자 및 접근을 확인할 수 있는 접근기록, 전산자료를 사용한 일시, 사용자 및 자료의 내용을 확인할 수 있는 접근기록, 정보처리시스템 내 전산자료의 처리내용을 확인할 수 있는 사용자 접근기록 등을 자동 기록·유지하고 1년 이상 보존(제1항 제9호 및 시행세칙 제2조의2)

✔ 정보처리시스템 주요 가동기록 유형(예시)

- 시스템 이벤트 로그 : 운영체제 구성요소에 의하여 발생하는 로그
- 네트워크 이벤트 로그 : IP 주소 할당, 주요구간 트래픽 로그
- 시스템 감사 로그 : 사용자 접속기록, 인증 성공/실패 로그, 파일 접근, 계정 생성 및 변경 등
- 주요 어플리케이션 접속 기록 : 개인신용정보 등 중요 시스템에 대한 접속 계정, 일시, 접속자 정보, 처리내용 등
- 보안시스템 로그 : 관리자 접속, 보안 정책 등록 및 변경 기록, 전산 자료 통제(반/출입 등) 로그 및 암/복호화 기록 등

- 단말기에는 이용자 정보(고객의 개인정보, 개인신용정보, 금융거래정보 등)등 주요정보를 보관하지 아니하고 단말기를 타인과 공유하지 않도록 조치하며, 불가피하게 단말기에 이용자 정보 등 주요정보를 보관할 필요가 있는 경우에는 보관사유·보관기간 및 관리 비밀번호 등을 정하여 책임자 승인을 받을 것(제1항 제10호)

  - 단말기에 이용자 정보를 저장하지 않았더라도 이용자 정보보다 넓은 개념인 전산자료의 보호를 위해 단말기 공유 금지

- 사용자가 전출·퇴직 등 인사조치가 있을 때에는 지체 없이 해당 사용자 계정 삭제, 계정 사용중지, 공동 사용 계정변경 등 조치하고 접근권한을 회수하여 이전 계정 및 권한으로 정보처리시스템에 접속할 수 없도록 통제(제1항 제11호)

- 단말기와 전산자료의 접근권한이 부여되는 정보처리시스템 관리자에 의한 사고예방을 위해 관리자의 업무행위에 대해 명령어 권한통제 등과 같은 적절한 통제장치를 마련하여 운영하고, 정보처리시스템 관리자가 전산원장, 이용자 정보 등 주요정보가 저장된 정보처리시스템에 대한 변경 등 중요작업 수행 시 책임자가 이중 확인하고 작업수행 내역에 대해 정기적으로 모니터링 실시(제3항, 제28조 제2항)

※ 법령해석('15.10.12.) -150265

질의

■ 「전자금융감독규정」 제13조제1항제13호에서 "단말기에 이용자 정보 등 주요정보를 보관하지 아니하고, 단말기를 공유하지 아니할 것(다만, 불가피하게 단말기에 보관할 필요가 있는 경우 보관사유, 보관기간 및 관리 비밀번호 등을 정하여 책임자의 승인을 받아야 한다)"이라고 정하고 있는바, 단말기에 이용자 정보 등 주요 정보를 보관하고 있지 않은 경우 단말기 공유가 가능한지 여부

회신

■ 「전자금융감독규정」 제13조제1항제13호에 따라 금융회사 및 전자금융업자는 단말기에 이용자 정보 등 주요정보를 보관하고 있지 않더라도 단말기를 공유하는 것이 금지됩니다.

이유

■ '전산자료'는 전산장비에 의해 입력·보관·출력되어 있는 자료를 말하며 그 자료가 입력·출력되어 있는 보조기억매체를 포함합니다(「전자금융감독규정」 제2조제2호).

- 「전자금융감독규정」 제13조제1항은 이 같은 '전산자료'의 유출·파괴 등을 방지하기 위해 보유현황의 관리, 책임자 지정·운영, 업무별 접근권한 통제, 비상시 안전지출 및 긴급파기, 정기적 백업, 정보처리시스템의 접근 통제 등을 요구하고 있습니다.
- 동항 제13호 또한 이용자 정보보다 넓은 개념인 '전산자료'의 유출·파괴 등을 방지하기 위한 취지로, 결과적으로 이용자 정보가 포함되어 있지 않더라도 단말기의 공유를 금지하는 것으로 해석해야 할 것입니다.

※ 비조치의견서('16.09.08.)-160648

비조치의견서는 행정해석의 일종으로 최종 법적구속력은 없으며, 유권해석과는 달리 특정행위에 대해 해당 회사의 상황을 고려한 검토결과로써 일반적 효력을 가지지 아니하므로 참고자료로만 활용하시기 바랍니다.

질의

■ OO은행은 사업구조개편에 따라 은행과 상호금융 계정계 시스템을 분리 · 구축하는 사업을 추진 중(예정일: '17.1.31)

- 전환시스템 운영 전 이용자 정보를 사용하여 전 영업점을 대상으로 사전 정합성 검증*을 실시하는 것이 전자금융감독규정 제13조제1항제10호 위반에 따른 조치대상에 해당하는지 여부

  * 특정 거래일에 발생한 금융거래를 구축 중인 전환시스템을 이용하여 재수행하고 그 결과를 상호 비교

회신

■ 이용자 정보를 테스트 용도로만 제한하여 사용한 후 즉시 삭제하는 한편, 정보 유출을 방지하기 위한 내부통제기준을 마련하는 등 안전성을 확보하여 정합성 검증을 실시하는 경우 감독규정 제13조제1항제10호 위반으로 조치하지 않을 예정입니다.

이유

■ 동 규정의 취지가 전산자료 유출 방지 및 전자금융거래의 안전성 확보라는 점을 고려하여

- 시스템의 안전성 확보를 위해 부득이하게* 이용자 정보를 테스트 용도로만 제한하여 사용한 후 즉시 삭제하는 한편,
- 외부주문에 대한 보안관리방안** 및 실제 운영시스템과 동일한 수준의 보안 대책***을 적용하는 등 검증 작업시 정보 유출을 방지하기 위한 내부통제기준을 마련한 경우에 한하여 이용자 정보를 사용한 정합성 검증을 허용

  * 정합성 검증은 실제 발생한 거래지시를 전환시스템으로 재처리하고 그 결과를 실거래 데이터와 비교하는 절차로 이용자 정보 · 실거래 데이터 없이 효율적인 검증 곤란

  ** 전자금융감독규정 제60조①항7호 및 동 시행세칙 제9조의2①항

  *** 비인가 전산장비 · 무선통신 접속 통제, 해킹 방지대책, 악성코드 감염 방지 대책, 사용자 권한 및 비밀번호 설정 · 운영, 이용자 비밀번호 암호화 등

※ 비조치의견서('22.9.26.)-220054

비조치의견서는 행정해석의 일종으로 최종 법적구속력은 없으며, 유권해석과는 달리 특정행위에 대해 해당 회사의 상황을 고려한 검토결과로써 일반적 효력을 가지지 아니하므로 참고자료로만 활용하시기 바랍니다.

질의

■ 전자금융감독규정 제13조제1항제8호에 따라 전산자료를 원격 안전지역에 소산시 네트워크를 통해 디스크 기반 복제 방식으로 진행하는 것이 관련 규정에 위배되는지 여부

회신

■ 아래 내용을 참고하시기 바랍니다.

이유

■ 금융회사 또는 전자금융업자는 중요도에 따라 전산자료를 정기적으로 백업하여 원격 안전지역에 소산하고 백업내역을 기록 · 관리해야 합니다(「전자금융감독규정」 제13조제1항제8호.

「전자금융감독규정」 제13조제1항제8호는 전산자료 소산방식을 특정하고 있지는 않습니다. 다만, 네트워크를 통해 전산자료를 소산하는 과정에서 전용회선을 통해 자료를 전송하는 등 전산자료의 안전성을 확보하고 관련 규정*을 준수하며 운영하시기 바랍니다.

* 「전자금융감독규정」 제15조제1항제3호 및 제5호 등

• 아울러, 소산장소는 백업자료가 손상되지 않도록 환경을 유지하여야 하며, 정기적으로 자료를 점검하여 항시 사용이 가능토록 유지해주시기 바랍니다.

조치 사례('23.12.21.)

- 금융회사는 전산자료의 유출, 파괴 등을 방지하기 위하여 정보처리시스템의 가동기록을 1년 이상 보존하여야 하는데도(제1항 제9호)
- ○○회사는 공모주 상장을 대비하여 시세처리 서버 6대를 임대하여 운영하면서도 전체 사용 기간에 대한 정보처리시스템 가동기록을 보존하지 않아 지적받은 사례

조치 사례('20.6.30.)

- 금융회사는 전산자료의 유출, 파괴 등을 방지하기 위해 테스트 시 이용자 정보 사용이 금지됨에도
- ○○회사는 ○○○○업무 개발 및 테스트를 위하여 업무계 운영 데이터베이스에 저장 중인 이용자 정보 000건을 사용한 사실로 지적

3. 정보처리시스템 보호대책

감독규정

제14조(정보처리시스템 보호대책) 금융회사 또는 전자금융업자는 정보처리시스템의 안전한 운영을 위하여 운영매뉴얼, 유지보수관리대장, 책임자명부 및 장애상황기록부 등 다음 각 호를 포함한 보호대책을 수립 · 운용하여야 한다.

1. 다음 각 목을 작성 · 보관 할 것
   가. 주요 정보처리시스템에 대한 운영매뉴얼
   나. 주요 정보처리시스템에 대한 정기적인 유지보수 실시 내용을 기록한 유지보수관리대장
   다. 정보처리시스템에 대한 책임자명부 및 장애상황기록부

2. 정보처리시스템의 정상작동여부 확인을 위하여 시스템 자원 상태의 감시, 경고 및 제어가 가능하도록 모니터링 시스템을 갖출 것
3. 시스템 통합, 전환 및 재개발 시 장애 등으로 인하여 정보처리시스템의 운영에 지장이 초래되지 않도록 통제 절차를 마련하여 준수할 것
4. 정보처리시스템의 긴급하고 중요한 보정(patch)사항에 대하여는 즉시 보정 작업을 할 것
5. 중요도에 따라 정보처리시스템의 운영체제 및 설정내용 등을 정기 백업 및 원격 안전지역에 소산하고 백업자료는 1년 이상 기록 · 관리할 것
6. 정보처리시스템의 운영체제(Operating System) 계정으로 로그인(Log in)할 경우 이중인증 절차를 시행하고, 계정에 대한 사용권한, 접근 기록, 작업 내역 등에 대한 상시 모니터링체계를 수립하며, 이상 징후 발생 시 필요한 통제 조치를 즉시 시행할 것

정보처리시스템이 정상적으로 안전하게 운영되고 장애 발생시 신속하게 복구 및 정상 가동되는데 필요한 대책(운영매뉴얼, 유지보수관리대장, 책임자명부 및 장애상황기록부 등 포함)을 수립 · 운용

- "정보처리시스템"은 전자금융업무를 포함하여 정보기술부문에 사용되는 하드웨어(hardware)와 소프트웨어(software) 및 관련 장비를 포함하는 개념으로(제2조 제3호) 서버, 데이터베이스, 네트워크 장비, 백업 장비, 스토리지, 어플리케이션 등을 의미

해설

- 비상시 정보처리시스템의 신속한 구동 및 조작, 업무 담당자 유고시 대체인력에 의한 원활한 시스템 운영을 위하여 주요 정보처리시스템 및 주요 프로그램에 대한 운영매뉴얼을 작성하여 지정된 장소(전산실 및 재해복구센터)에 보관 및 관리(제1호 가목)
  - 운영매뉴얼은 정보처리시스템 및 프로그램 등 주요프로그램의 변경사항이 발생하는 경우 현재 상태를 반영하여 최신상태 유지
- 정보처리시스템 및 주요 프로그램(DBMS, 운영체제, Web 및 WAS 등)은 장애예방을 위해 정기적으로 유지보수되어야 하며, 외부업체로부터 유지보수를 받는 경우 고객정보 등의 중요정보가 유출되지 않도록 주의하고 유지보수 내용을 기록한 유지보수관리대장을 작성 · 보관(제1호 나목)
- 정보처리시스템의 장애예방을 위해 정보처리시스템의 운영책임자를 지정하고 시스템의 장애는 장애등급, 장애 원인, 조치사항 등을 포함한 장애상황기록부에 기록하여 관리(제1호 다목)
- 시스템의 정상작동여부 확인이 가능하도록 시스템의 자원 상태를 감시하고, 장애 등 이상 징후 발생 시 경고 및 제어가 가능하도록 모니터링 시스템을 구축(제2호)
- 정보처리시스템의 통합, 전환 및 재개발 시 기 운영시스템 및 신규 도입 시스템의 장애, 업무 지연 등의 사고 발생으로 정보처리시스템 운영에 지장을 초래하지 않도록 데이터 정합성 · 일치성, IT인프라 가용성 등을 사전에 철저히 검증하는 등 통제절차를 마련하여 운영(제3호)

- 정보처리시스템 관리책임자는 정보처리시스템의 안전한 운영을 위하여 시스템 운영체제 및 유틸리티 등 주요 소프트웨어에 대해 주기적으로 보정(patch)사항이 발표되는지 확인하고 필수적인 보정사항이 발표되는 경우에는 테스트 시스템에 우선 적용하여 테스트를 실시하고 시스템 운영에 지장을 초래하지 않을 경우 즉시 실 운영시스템에 적용(제4호)

- 정보처리시스템의 운영체제 삭제 등 비상상황 발생시 신속하게 정상복구가 가능하도록 정보처리시스템의 운영체제 및 설정내용 등을 정기적으로 백업하여 원격 안전지역에 소산하고, 백업자료는 정기적 검증을 실시하며 1년 이상 보관(제5호)

- 정보처리시스템의 운영체제 계정에 대한 보안강화를 위하여 로그인시 계정 및 비밀번호 이외의 인증서, OTP 등의 별도의 안전한 추가인증(이중인증) 절차를 시행하고, 운영체제 계정의 작업수행에 대한 이상 징후 발생 시 필요한 통제 조치가 즉시 시행될 수 있도록 모니터링 체계 수립(제6호)

개선요구 등 사례('24.11.26.)

- ○○회사는 엑셀파일로 관리하고 있는 장애관리대장에 장애시간, 장애내용, 조치사항, 향후대책, 작성자, 작성일시, 확인자 및 확인일시 등의 내용이 누락되어 있으므로, 장애별로 누락되는 정보가 없도록 철저히 기록·관리할 필요

개선요구 등 사례('25.1.23.)

- ○○회사는 서버 등 운용 중인 정보처리시스템 000대를 제조사의 기술지원이 종료된 노후 장비를 운용하고 있어 시스템 장애에 대한 신속한 대응이 어렵고 신규 취약점을 이용한 해킹 및 악성코드 등에 의한 침해사고가 발생할 우려가 있으므로,

- 기술지원이 종료된 운영체제 등의 구체적인 전환계획을 수립하고 전환이 이루어지기 전까지 유지보수를 받는 등 보안대책을 마련하여 개선할 필요

조치 사례('23.12.21.)

- 금융회사는 정보처리시스템의 정상작동 여부를 확인하기 위하여 시스템 자원 상태의 감시, 경고 및 제어가 가능한 모니터링 시스템을 갖춰야 하는데도

- ○○회사는 트레이딩 시스템(HTS·MTS) 등 주요 운영서버에서 사용하는 스토리지 장비에 대한 장애발생 여부를 모니터링할 수 있는 시스템을 구축하지 아니하여 스토리지 장비 전원공급장치의 고장을 적시에 인지하지 못하였음

4. 클라우드컴퓨팅서비스 이용절차

감독규정

제14조의2(클라우드컴퓨팅서비스 이용절차) ① 금융회사 또는 전자금융업자는 「클라우드컴퓨팅 발전 및 이용자 보호에 관한 법률」 제2조제3호에 따른 클라우드컴퓨팅서비스를 이용하고자 하는 경우 다음 각 호의 절차를 수행하여야 한다.

1. 다음 각 목의 기준에 따른 이용업무의 중요도 평가
   가. 규모, 복잡성 등 클라우드컴퓨팅서비스를 통해 처리되는 업무의 특성
   나. 클라우드컴퓨팅서비스 제공자로부터 제공받는 서비스가 중단될 경우 미치는 영향
   다. 전자적 침해행위 발생 시 고객에게 미치는 영향
   라. 여러 업무를 같은 클라우드컴퓨팅서비스 제공자에게 위탁하는 경우 해당 클라우드컴퓨팅서비스 제공자에 대한 종속 위험
   마. 클라우드컴퓨팅서비스 이용에 대한 금융회사 또는 전자금융업자의 내부통제 및 법규 준수 역량
   바. 그 밖에 금융감독원장이 정하여 고시하는 사항
2. 클라우드컴퓨팅서비스 제공자의 건전성 및 안전성 등에 대한 평가(단, 제1호의 평가를 통해 비중요업무로 분류된 업무에 대해서는 〈별표 2의2〉의 평가항목 중 필수항목만 평가할 수 있다.)
3. 클라우드컴퓨팅서비스 이용과 관련한 업무 연속성 계획 및 안전성 확보조치의 수립 · 시행(단, 제1호의 평가를 통해 비중요업무로 분류된 업무에 대해서는 〈별표 2의3〉 및 〈별표 2의4〉의 필수 사항만 수립 · 시행할 수 있다.)

② 금융회사 또는 전자금융업자는 제1항 각 호에 따른 평가결과, 업무연속성 계획 및 안전성 확보조치에 대하여 제8조의2에 따른 정보보호위원회의 심의 · 의결을 거쳐야 한다.

③ 금융회사 또는 전자금융업자는 제1항제2호의 평가를 직접 수행하거나 제37조의6제1항의 침해사고대응기관이 수행한 평가 결과를 활용할 수 있다.

④ 금융회사 또는 전자금융업자는 다음 각 호의 어느 하나에 해당하는 사유가 발생한 날로부터 3개월 이내에 금융감독원장에게 보고하여야 하고, 관련 서류를 최신상태로 유지하여야 한다.

1. 클라우드컴퓨팅서비스 이용계약을 신규로 체결하거나, 기존 클라우드컴퓨팅서비스 이용계약을 통해 신규 업무를 처리하는 경우
2. 클라우드컴퓨팅서비스 제공자의 합병, 분할, 계약상 지위의 양도, 재위탁 등 중대한 변경사항이 발생한 경우
3. 클라우드컴퓨팅서비스 제공자가 서비스품질의 유지, 안전성 확보 등과 관련한 중요 계약사항을 이행하지 아니한 경우
4. 제1항제2호 또는 제3호에 관한 중대한 변경사항이 발생한 경우

⑤ 제4항의 보고에 관한 양식, 첨부서류 등에 관해서는 금융감독원장이 정하는 바에 따른다.

⑥ 금융감독원장은 제4항에 따라 제출한 보고 서류가 누락되거나, 중요도 평가 또는 업무연속성계획 · 안전성 확보조치 등이 충분하지 않다고 판단하는 경우에는 금융회사 또는 전자금융업자에 대하여 개선 · 보완을 요구할 수 있다.

⑦ 제1항의 절차를 거친 클라우드컴퓨팅서비스 제공자의 정보처리시스템이 위치한 전산실에 대해서는 제11조제1호 및 제2호, 제15조제1항제5호를 적용하지 아니한다. 다만, 금융회사 또는 전자금융업자(전자금융거래의 안전성 및 신뢰성에 중대한 영향을 미치지 않는 외국금융회사의 국내지점, 제50조의2에 따른 국외 사이버몰을 위한 전자지급결제대행업자는 제외한다)가 고유식별정보 또는 개인신용정보를 클라우드컴퓨팅서비스를 통하여 처리하는 경우에는 제11조제2호를 적용하고, 해당 정보처리시스템을 국내에 설치하여야 한다.

⑧ 그 밖에 금융회사 또는 전자금융업자의 클라우드컴퓨팅서비스 이용에 대해서는 「금융회사의 정보처리 업무 위탁에 관한 규정」에 따른다.

시행세칙

제2조의4(클라우드컴퓨팅서비스의 보고) ① 규정 제14조의2제4항에 따라 감독원장에게 보고하는 양식은 별지 제6호 서식에 따른다.

② 규정 제14조의2제4항 및 제5항에 따라 감독원장에게 보고할 경우 첨부해야 하는 서류는 다음 각 호와 같다.

1. 「금융회사의 정보처리 업무 위탁에 관한 규정」 제7조제1항 각 호에 관한 서류
2. 규정 제14조의2제1항제1호에 따른 업무의 중요도 평가 기준 및 결과
3. 규정 제14조의2제1항제2호에 따른 클라우드컴퓨팅서비스 제공자의 건전성 및 안전성 등에 대한 평가 결과
4. 규정 제14조의2제1항제3호에 따른 업무 연속성 계획 및 안전성 확보조치에 관한 사항
5. 규정 제14조의2제2항에 따른 정보보호위원회 심의 · 의결 결과
6. 규정 별표 2의5의 계약서 주요 기재사항을 포함한 클라우드컴퓨팅서비스 이용계약서

금융회사 또는 전자금융업자는 클라우드컴퓨팅서비스를 이용하고자 하는 경우, 중요도 평가 등 클라우드컴퓨팅서비스 이용 절차를 거쳐야 함

적용범위

- 무상 · 유상에 구애받지 않고 상용(商用)으로 타인에게 정보통신자원을 제공하는 서비스(클라우드컴퓨팅서비스)를 이용시 적용되고,
  - 금융회사가 전용으로 이용하며 상용으로 제공되지 않는 경우에는 적용되지 않음(비조치의견서 230024 등)
- 클라우드컴퓨팅서비스 이용은 정보처리업무 위탁의 한 유형에 해당되고 정보처리업무 위탁은 자신의 정보처리 업무를 제3자로 하여금 계속적으로 처리하는 것이므로(「금융회사의 정보처리 업무 위탁에 관한 규정」 제2조 제6항), 금융회사 또는 전자금융업자가 클라우드컴퓨팅서비스를 자신의 정보처리 업무에 이용하지 않는 경우 본 조의 적용대상에 해당하지 아니함
  - **(예시)** 금융회사 고객이 금융회사의 제휴사에서 제공하는 클라우드서비스(OCR 텍스트 변환 기능)를 선택적으로 이용하고 은행과 제휴사는 통신/정보 교환 없이 고객 스마트폰만이 제휴사 서버와 API 통신으로 고지서 등 이미지의 텍스트 변환이 이루어지는 경우 제휴사의 OCR 서비스는 금융회사의 정보처리 업무에 해당하지 않고, 제휴사가 자신의 서비스 업무를 처리하는 것에 해당하여 제휴사의 OCR서비스는 금융회사의 클라우드이용절차 준수 대상에 해당하지 아니함(법령해석 190152)
  - **(예시)** 금융회사의 애플리케이션 내에서 외부 제휴사의 클라우드서비스(검색어 키워드 정제)를 이용 과정에서 금융회사의 정보처리시스템과 제휴사 클라우드 서버 간 통신 및 정보 교환이 발생하지 않고, 금융회사 고객이 검색어 키워드 서비스 제공 주체가 제휴사임을 인지하고 선택적으로 이용한다면, 제휴사의 클라우드 서비스는 금융회사의 클라우드이용절차 준수 대상에 해당하지 아니함(비조치의견서 240075)

- (예시) 금융회사가 정보주체의 동의를 받아 개인신용정보 등을 제3자에게 제공하고, 제3자가 제공받은 자신의 업무 목적을 위하여 클라우드컴퓨팅서비스를 이용하여 처리하는 경우 제3자가 제공하는 클라우드컴퓨팅서비스는 금융회사의 클라우드이용절차 준수 대상에 해당하지 아니함 (비조치의견서 240011)

● 금융회사가 전자금융거래와 관련이 없는 업무에 대해 클라우드컴퓨팅 서비스를 이용하는 경우에도 클라우드이용절차 준수 대상에 해당함(법령해석 200337, 비조치의견 240054)

- 단, 전자금융업자는 「정보처리업무위탁규정」 제7조제4항제2호 단서에 따라 금융거래정보 이외의 정보를 클라우드로 처리하는 경우에는 별도 보고 의무가 없음

■ 클라우드컴퓨팅서비스 규정 적용 예외 등

● 클라우드컴퓨팅서비스 이용절차를 거친 클라우드컴퓨팅서비스 제공자의 정보처리시스템이 위치한 전산실에 대해서는 제11조제1호 및 제2호, 제15조제1항제5호가 적용되지 아니함 (제7항 본문)

- 다만, 고유식별정보 또는 개인신용정보를 클라우드컴퓨팅서비스를 통해 처리하는 경우에는 (i) 전산실에 무선통신망을 설치하여서는 아니되며 (ii) 해당 정보처리시스템을 국내에 설치하여야 함(제7항 단서)

- 따라서 금융회사등이 클라우드서비스를 이용하여 개인신용정보처리를 하는 경우 해외 소재 클라우드는 이용할 수 없고 국내에 전산센터를 갖춘 해외 클라우드 사업자의 서비스는 이용 가능함(법령해석 190042)

- 금융회사등이 클라우드서비스를 이용하여 임직원의 고유식별정보를 처리하는 경우는 해외 소재 클라우드를 이용할 수 있으나, 「개인정보 보호법」 등 다른 법령에서 정보 주체의 사전동의 요구 등 정보의 이전을 제한하거나 별도의 규제가 있는 경우, 해당 법령을 준수해야 함(법령해석 200449)

□ 해설

※ 금융회사 정보처리시스템과 클라우드컴퓨팅서비스 연결시 망분리 등에 대해서는"제5절 정보보호부문 – 1. 해킹 등 방지대책" 부분도 함께 참조

● 금융회사등은 클라우드컴퓨팅서비스를 이용하고자 하는 경우, ① 클라우드컴퓨팅서비스를 이용할 업무에 대하여 중요도를 평가하고(제1항 제1호) ② 클라우드컴퓨팅서비스 제공자의 건전성 및 안전성에 대한 평가를 진행하여야 하며(제2호), ③ 데이터 백업, 재해복구 및 침해 사고대응 훈련계획, 출구전략을 포함한 업무 연속성 계획을 수립하고 ④ 보안사고 예방을 위해 계정관리, 접근통제 등 필수 보안 통제가 구현되도록 안전성 확보조치를 수립·시행하여야 함(제3호)

- 업무 중요도 평가방법은 제1항 제1호 각목 기준에 따라 금융회사가 자체적으로 평가기준을 마련하고 클라우드컴퓨팅서비스를 이용할 업무에 대한 중요도를 최종 판단

- 건전성 및 안전성 평가는 금융회사가 자체적으로 평가를 진행하거나 금융보안원 등 제37조의6 제1항의 침해사고대응기관이 수행한 평가(대표평가) 결과를 활용할 수 있음(제3항)

● 클라우드 유형 및 중요도에 따른 차등 적용

- 자체 중요도 평가 결과에 따라 "비중요업무"로 분류된 업무에 대해서는 일부 사항만을 적용 가능

  (i) 〈별표 2의2〉의 건전성 및 안전성 평가항목 중 필수항목만 평가

  (ii) 〈별표 2의3〉의 업무 연속성 계획 및 〈별표 2의4〉의 안전성 확보조치를 필수 사항만 수립·시행

  (iii) 위수탁 계약 체결시 〈별표 2의5〉에 따른 기본 사항만 포함

- IaaS, PaaS, SaaS 등 클라우드컴퓨팅서비스 유형에 따라 평가기준 등이 달리 적용될 수 있으므로 개별 클라우드컴퓨팅서비스 이용시 유의

● 업무 중요도 평가 결과, 클라우드서비스 제공자 평가 결과, 업무 연속성계획 및 안전성 확보조치 방안에 대하여 정보보호위원회 심의·의결을 거쳐야 함(제2항)

● 클라우드컴퓨팅서비스 이용계약을 신규로 체결하는 경우 뿐만 아니라, 기존 클라우드컴퓨팅서비스 이용계약을 통해 신규 업무를 처리하는 경우에도 보고의무 이행 필요

- 예를 들어 금융회사가 a업무를 클라우드컴퓨팅서비스를 이용하기 위해 CSP A사와 '23.5.6에 신규로 계약을 체결하고 '23.7.5에 금융감독원에 클라우드이용보고를 한 후, '24.1.3.에 CSP A사와의 기존 계약을 이용하여 별도 계약 체결 없이 b업무를 클라우드컴퓨팅서비스에서 처리하기 시작했다면. 금융회사는 '24.4.2.까지 금융감독원에 b업무에 대한 클라우드이용보고를 하여야 함

● 보고 관련 서류의 세부내용은 시행세칙에 위임(시행세칙 제2조의4)

- 「전자금융감독규정」 적용대상에는 해당하지만 「정보처리 업무 위탁에 관한 규정」 적용대상은 아닌 경우에도, 클라우드컴퓨팅서비스 이용과 관련하여 금융감독원장에게 보고시 「금융회사의 정보처리 업무 위탁에 관한 규정」 제7조제1항를 포함한 전자금융감독규정 시행세칙 제2조의4에서 제시된 모든 서류를 빠짐없이 제출하여야 함(비조치의견서 240004)

  * 서류 중 금융기관의 업무위탁 등에 관한 규정 제3조의2에 따라 금융기관이 마련하고 준수하여야 할 '업무위수탁 운영기준' 이 구비되어 있지 않은 경우 클라우드컴퓨팅서비스 관련 업무절차 등 그에 준하는 서류로 대체하여 제출(비조치의견서 240004)

ㅇ 감독규정 제14조의2제4항에 따른 사후보고를 한 경우 「정보처리위탁규정」 제7조제1항 내지 제3항 및 제4항제2호 본문에 따라 보고한 것으로 봄

※ 비조치의견서('24.7.8.)-240054

비조치의견서는 행정해석의 일종으로 최종 법적구속력은 없으며, 유권해석과는 달리 특정행위에 대해 해당 회사의 상황을 고려한 검토결과로써 일반적 효력을 가지지 아니하므로 참고자료로만 활용하시기 바랍니다.

요청대상 행위

■ 금융회사가 전자금융거래와 관련이 없는 대고객 서비스*를 제공하기 위하여 외부통신망에 위치한 SaaS를 API 형태로 이용하는 경우 전자금융감독규정 제14조2에 따른 클라우드컴퓨팅서비스 이용절차를 준수하여야 하는지 여부

* 외부에 공개된 뉴스, 재무 정보 등을 AI서비스를 통해 요약하여 고객에게 제공하거나 AI서비스를 활용한 챗봇으로 고객 문의에 대응하는 등의 서비스

판단

■ 아래 내용을 참고하시기 바랍니다.

판단이유

■ 전자금융감독규정 제14조의2는 금융회사가 클라우드컴퓨팅 발전 및 이용자 보호에 관한 법률 제2조제3호에 따른 클라우드컴퓨팅서비스*를 이용하고자 하는 경우에 적용됩니다.

* 클라우드컴퓨팅을 활용하여 상용(商用)으로 타인에게 정보통신자원을 제공하는 서비스 (클라우드컴퓨팅 발전 및 이용자 보호에 관한 법률 제2조제3호)

- 귀사가 이용하고자 하는 SaaS는 클라우드컴퓨팅을 활용하여 상용으로 타인에게 응용프로그램 등 소프트웨어를 제공하는 서비스로써 동 법이 정하는 클라우드컴퓨팅서비스에 해당하고,
- 금융위원회는 전자금융거래와 직접적으로 관련이 없는 업무라 할지라도 금융회사가 클라우드컴퓨팅서비스를 이용하는 경우에는 동 규정을 준수하여야 한다고 해석한 바 있습니다(법령해석 200337).

■ 또한, 「금융회사의 정보처리 업무 위탁에 관한 규정」 제2조제6항은 금융회사가 자신의 정보처리* 업무를 제3자로 하여금 계속적으로 처리하게 하도록 하는 행위를 "정보처리의 위탁"으로 규정하고 있고,

* 금융회사가 전산설비를 활용하여 정보의 수집, 생성, 기록, 저장, 보유, 가공, 편집, 검색, 출력, 정정, 복구, 이용, 제공, 공개, 파기 및 기타 이와 유사한 행위를 하는 것을 말한다. (「금융회사의 정보처리 업무 위탁에 관한 규정」 제2조제5항)

- 문의하신 사실관계 하에서 귀사가 제공하는 서비스의 이용주체가 귀사 고객인 점, 귀사가 서비스 내 정보처리 일부를 계속적으로 대신하는 SaaS사업자에게 대가(API 사용료 등)를 지급하는 점 등을 고려하면 귀사의 정보처리 업무를 SaaS사업자에게 위탁하는 것으로 보입니다.

■ 따라서 귀사의 행위는 클라우드컴퓨팅서비스 이용 및 정보처리 업무 위탁에 해당하므로 「전자금융감독규정」 제14조의2에 따른 클라우드컴퓨팅서비스 이용절차 및 「금융회사의 정보처리 업무 위탁에 관한 규정」을 준수하여야 합니다.

- 또한, SaaS 이용에 따른 귀사의 통신망 구성이 「전자금융감독규정」 제15조제1항제3호가 규정하는 망 분리 의무를 위반하지 않도록 유의하시기 바랍니다. (비조치의견서 240051, 240037 등 참조)

※ 법령해석('19.7.3.)-190152

질의

■ 고객이 스마트폰으로 촬영하는 공과금 고지서 이미지에 대해 고객이 선택적으로 제휴사 에서 제공하는 OCR 텍스트 변환 기능을 이용하고, 은행 서버와 제휴사 서버 간에는 통신/정보 교환 없이 고객 스마트폰만이 제휴사 서버와 API 통신으로 고지서 이미지의 텍스트 변환이 이루어질 경우, 은행의 정보처리업무 위탁 및 클라우드 컴퓨팅 서비스 이용 해당여부

회신

■ "정보처리의 위탁"이라 함은 금융회사가 자신의 정보처리 업무를 제3자로 하여금 계속적으로 처리하도록 하는 행위를 의미합니다(「금융회사의 정보처리 업무 위탁에 관한 규정」 제2조 제6항).

- 따라서 OCR 서비스가 금융회사 자신의 정보처리 업무가 아니라면 동 규정이 적용 되지 않으며, 이 경우 정보처리 업무 위탁의 한 유형인 전자금융감독규정상의 클라우드 서비스 이용 관련 규정도 적용된다고 보기 어렵습니다.

이유

■ 질의하신 사항은 금융회사가 고객정보를 위탁 · 전송하지 않으며(은행 서버와 해당 업체 서버 간 통신/정보 교환도 없음),

- 고객이 OCR 서비스를 제공하는 업체와 직접 정보 제공 동의, 이용 계약을 체결하는 경우에 정보처리 업무 위탁의 해당 여부 등입니다.

■ "정보처리의 위탁"이라 함은 금융회사가 자신의 정보처리 업무를 제 3 자로 하여금 계속적으로 처리하도록 하는 행위를 의미합니다.(「금융회사의 정보처리 업무 위탁에 관한 규정」 제2조 제6항)

- 따라서 금융회사 자신의 정보처리 업무가 아니라면 동 규정이 적용되지 않으며, 이 경우 정보처리 업무 위탁의 한 유형인 전자금융감독규정상의 클라우드 서비스 이용 관련 규정도 적용된다고 보기 어렵습니다.
- 질의사항은 OCR 서비스 제공 업체가 자신의 서비스 업무를 처리할 목적으로 고객 정보를 직접 수집 · 처리하고, 금융회사-OCR 서비스 제공자간 고객정보의 전송 행위도 이루어지지 않으므로 (이미지의 텍스트 변환 결과는 고객 스마트폰에 저장) 정보처리 업무위탁, 금융회사의 클라우드 서비스 이용 행위 (클라우드 서비스는 OCR 서비스 제공자가 이용)라고 보기는 어렵습니다.

※ 법령해석('20.11.19.)-200337

질의

■ 전자금융업무를 수행하는 금융회사가 전자금융거래와 관련이 없는 업무와 관련하여 클라우드 시스템을 사용하려고 하는 경우도 전자금융감독규정(특히, 그 중 에서도 클라우드컴퓨팅서비스 이용절차 등에 관한 제14조의2 규정)이 적용되는지? 만약 적용되지 않는다면 클라우드 시스템의 전자금융거래와 관련성(즉, 전자금융감독규정 적용 여부)을 판단하는 구체적인 기준은 무엇인지?

회신

■ 금융회사 등은 전자금융거래와 관련이 없는 업무라 할지라도 클라우드컴퓨팅서비스를 이용하여 업무를 처리하고자 하는 경우에는 「전자금융감독규정」 제14조의2에 따른 클라우드컴퓨팅서비스 이용절차 등을 준수하여야 합니다.

이유

- 지난 '18.7월「전자금융감독규정」개정을 통해 금융분야 클라우드 이용을 확대한 바, 금융권의 인공지능(AI)·클라우드 등 디지털 신기술을 활용하는 사례가 증가하고 있습니다.
  - 하지만 금융회사의 클라우드 활용 증가로 제3자 리스크 (Operational Risk of Third Party) 또한 증대되고 있으며, 클라우드 사업자의 장애가 금융회사뿐만 아니라 전체 금융 인프라에 대한 집중 리스크 (Cloud Provider Concentration Risk) 로 작용할 수도 있습니다.
- 금융회사 등이 클라우드 관련 리스크를 관리할 수 있도록 클라우드 이용가이드에서 대응방안을 제시하는 한편, '18.7월「전자금융감독규정」개정시 금융회사와 전자금융업자가 클라우드컴퓨팅서비스를 통해 이용하려는 정보처리시스템에 대해 준수하여야할 절차를 마련하였습니다.
  - 이 때 클라우드컴퓨팅서비스의 이용대상이 되는 정보처리시스템은 전자금융업무를 포함하여 정보기술부문에 사용되는 하드웨어 (hardware) 와 소프트웨어(software)를 말하며 관련 장비를 포함합니다.(「전자금융감독규정」§2)
- 또한, 현행「전자금융거래법」제21조제2항에서는 전자금융거래의 안전성 확보를 위해 금융회사 및 전자금융업자로 하여금 전자금융업 뿐만 아니라 일반 정보기술 (IT) 부분 업무에 대해서도 일정한 기준을 준수하도록 규정하고 있는 바,

  * 금융회사 등은 전자금융거래의 안전성과 신뢰성을무 뿐만 아니라 일반 정보기술(IT)부문 업무에 대해서도 일정한 기준을 준수하고 확보할 수 있도록 전자적 전송이나 처리를 위한 건물, 설비, 전산실 등 시설 부문과 단말기, 전산자료, 정보처리시스템 및 정보통신망 등 정보기술부문 등의 기준을 마련(전자금융거래법§21②, 전자금융감독규정§7)

  - 귀 사께서 전자금융거래와 직접적으로 관련이 없는 업무라도 클라우드컴퓨팅서비스 등 정보기술(IT)을 이용하여 업무를 처리하고자 하는 경우「전자금융감독규정」제14조의2에 따른 클라우드컴퓨팅서비스 이용절차 등을 준수하여야 합니다.

※ 비조치의견서('23.10.24.)-230084

비조치의견서는 행정해석의 일종으로 최종 법적구속력은 없으며, 유권해석과는 달리 특정행위에 대해 해당 회사의 상황을 고려한 검토결과로써 일반적 효력을 가지지 아니하므로 참고자료로만 활용하시기 바랍니다.

요청대상 행위

- 금융회사 내부망에서 클라우드에 있는 외부 Open API(지도, 콘텐츠, ChatGPT)를 호출하는 경우 전자금융감독규정 위반인지 여부

판단

- 아래 내용을 참고하시기 바랍니다.

판단이유

- 금융회사는 전자적 침해행위로부터 방지하기 위해 내부통신망과 연결된 내부 업무용시스템을 외부통신망과 분리 차단 및 접속금지의 조치를 하여야 하나(전자금융감독규정 제15조제1항제3호),
- 내부 업무용시스템을 업무상 필수적으로 특정 외부기관과 특정 서비스번호(port)로 연결하는 경우에는 허용됩니다.(전자금융감독규정시행세칙 제2조의2제1항)
- 귀 사가 요청하신 행위는 업무상의 편의를 위해 내부망에서 지도, 콘텐츠, ChatGPT를 제공하는 Open API를 활용하는 것으로, 망분리 적용 예외 사유에 해당되지 않아 전자감독규정 제15조제1항제3호에 위반됩니다.

※ 비조치의견서('23.5.23.)-230024

비조치의견서는 행정해석의 일종으로 최종 법적구속력은 없으며, 유권해석과는 달리 특정행위에 대해 해당 회사의 상황을 고려한 검토결과로써 일반적 효력을 가지지 아니하므로 참고자료로만 활용하시기 바랍니다.

요청대상 행위

■ 금융회사가 콜센터시스템을 운영하기 위하여 클라우드컴퓨팅 서비스를 다음과 같은 방식*으로 이용할 경우, 「전자금융감독규정」 제14조의2(클라우드컴퓨팅서비스 이용절차 등)에 따른 절차를 이행해야 하는지 여부

* ① 클라우드컴퓨팅 서비스 제공자는 금융회사의 계열사에 해당
② 클라우드컴퓨팅시스템은 금융회사 전용 전산센터에 위치
③ 금융회사 이외의 사용자와 물리적으로 분리되어 금융회사 전용으로 사용
④ 금융회사가 매월 사용한 자원(서버, 스토리지 등) 만큼의 사용료를 계열사에 지급
⑤ 클라우드컴퓨팅 서비스는 광고를 통해 수익을 올리는 등 상업용으로 제공되지 않음

판단

■ 아래 내용을 참고하시기 바랍니다.

판단이유

■ 「전자금융감독규정」 제14조의2는 「클라우드컴퓨팅 발전 및 이용자 보호에 관한 법률」(이하 '클라우드법') 제2조 제3호에 따른 클라우드컴퓨팅서비스를 이용하고자 하는 경우에 적용되는 조항으로

- 「클라우드법」 제2조제3호에 정의하는 클라우드컴퓨팅서비스란 클라우드컴퓨팅을 활용하여 상용*으로 타인에게 정보통신자원을 제공하는 서비스를 의미합니다.

  * 클라우드컴퓨팅 주요법령 해설서(2017.11, 과학기술정보통신부)

> "상용"이란 무상 · 유상에 구애받지 않고 상업용으로 제공되는 것을 의미하므로 무상으로 제공되는 클라우드컴퓨팅서비스라도 상용으로 제공되고 있다면 포함될 수 있고, 무상으로 클라우드컴퓨팅서비스를 제공하더라도 광고를 통해서 수익을 올리고 있다면 상용에 해당합니다.
>
> 반면 전산시설 등의 사용 수수료를 내더라도 상용(商用)으로 제공되는 클라우드컴퓨팅서비스가 아니라면 이 법에서 말하는 클라우드컴퓨팅서비스에 해당하지 아니합니다. 예컨대 협회, 단체 등이 전용으로 구축한 클라우드컴퓨팅서비스는 포함되지 않습니다.

■ 귀사가 제공한 사실관계에 따르면, 귀사가 이용 예정인 클라우드컴퓨팅서비스는 귀사가 전용으로 이용하고 상용으로 제공되지 않아 「클라우드법」에서 말하는 클라우드컴퓨팅서비스에 해당되지 아니하므로,

- 「전자금융감독규정」 제14조의2에서 규율하는 클라우드컴퓨팅서비스에 해당되지 않는 것으로 판단됩니다.

■ 다만, 「전자금융감독규정」 제15조를 준수하는 등 관련 법규를 철저히 준수하시기 바랍니다.

※ 비조치의견서('24.10.4.)-240075

비조치의견서는 행정해석의 일종으로 최종 법적구속력은 없으며, 유권해석과는 달리 특정행위에 대해 해당 회사의 상황을 고려한 검토결과로써 일반적 효력을 가지지 아니하므로 참고자료로만 활용하시기 바랍니다.

요청대상 행위

■ 금융회사의 애플리케이션(APP) 내에서 외부 제휴사의 키워드 정제 서비스*를 이용자에게 제공하는 경우, 「금융회사의 정보처리 업무 위탁에 관한 규정」 및 「전자금융감독규정」 제14조의2에 따른 클라우드컴퓨팅 이용절차가 적용되는지 여부

* 이용자가 앱의 검색창에 글자를 입력하면 이용자 단말과 외부 제휴사 클라우드 서버 간 API 통신을 통하여 정제된 검색어가 단말로 전송되어 이용자가 검색어를 선택 가능

판단

■ 아래 내용을 참고하시기 바랍니다.

판단이유

■ 「전자금융감독규정」 제14조의2에 따른 클라우드서비스 이용은 금융회사의 "정보처리 위탁"에 해당하는 바(금융위원회 법령해석 190152),

- 동 규정은 금융회사가 자신의 정보처리 업무를 제3자로 하여금 계속적으로 처리하게 하는 "정보처리 위탁"시에 적용됩니다.

■ 문의하신 사실관계 하에서 귀사가 애플리케이션(APP) 내에서 외부 제휴를 통해 제공하려는 클라우드 기반의 검색어 키워드 정제 서비스는 이용과정에서 귀사의 정보처리시스템과 제휴사 클라우드 서버 간 통신 및 정보교환이 발생하지 않고,

- 귀사의 애플리케이션(APP) 이용자로 하여금 해당 서비스 제공을 위한 정보처리 주체가 제휴사임을 인지한 후에 선택적으로 이용할 수 있도록 한다면,
- 이를 귀사가 인가 등을 받은 업무를 영위함에 있어 요구되는 정보처리를 제3자에 계속적으로 위탁하는 것으로 보기 어렵습니다.

■ 「금융회사의 정보처리 업무 위탁에 관한 규정」에 따른 "정보처리 위탁"에 해당하지 않는 경우 「전자금융감독규정」 제14조의2는 적용되지 않습니다.

※ 비조치의견서('24.3.4.)-240011

비조치의견서는 행정해석의 일종으로 최종 법적구속력은 없으며, 유권해석과는 달리 특정행위에 대해 해당 회사의 상황을 고려한 검토결과로써 일반적 효력을 가지지 아니하므로 참고자료로만 활용하시기 바랍니다.

요청대상 행위

■ 금융회사가 정보주체의 동의를 받아 개인신용정보 등을 제3자에게 제공*하고, 제3자가 제공받은 정보를 자신의 업무 목적을 위하여 클라우드컴퓨팅서비스를 이용하여 처리하는 경우,

* 신용정보법, 개인정보보호법 등 개인정보 관계법령상의 '제공'에 해당

- 해당 금융회사가 「전자금융감독규정」 제14조의2에 따른 클라우드컴퓨팅서비스 이용절차를 준수해야 하는지 여부

판단

■ 아래 내용을 참고하시기 바랍니다.

판단이유

■ 「전자금융감독규정」 제14조의2에 따른 클라우드서비스 이용은 금융회사의 '정보처리 업무 위탁'시 적용되며 (금융위원회 법령해석 190152),

- '정보처리의 위탁'*이란 금융회사가 자신의 정보처리 업무를 제3자로 하여금 계속적으로 처리하도록 하는 행위를 의미합니다.

  * 「금융회사의 정보처리 업무 위탁에 관한 규정」 제2조제6항

■ 문의하신 사실관계 하에서 귀사가 제3자에게 정보를 제공한 시점부터 해당 정보의 지배관리권 및 책임이 제3자에게 이전되고, 제3자가 해당 정보를 귀사가 아닌 제3자의 업무 목적을 위하여 처리하는 점 등에 비추면,

- 귀사의 정보처리 업무를 제3자에게 위탁하는 것으로 보이지 않으므로 「전자금융감독규정」 제14조의2는 적용되지 않는 것으로 판단됩니다.

  ※ 요청대상행위에 대한 판단이유는 상기사항에 한정하며, 요청서에 기재된 신청인의 개별 의견에 대한 인정이 아님에 유의하시기 바랍니다.

※ 법령해석('21.12.22.)-210026

질의

■ 전자금융업무를 수행하지 않는 금융회사가 클라우드컴퓨팅서비스를 이용하여 업무 및 중요정보를 처리하고자 하는 경우, 전자금융감독규정 제14조의2가 적용되는지?

■ 적용된다면, 해당 금융회사는 전자금융거래법 제3조 제3항 각호에 해당하는 사항 또한 적용되는지?

회신

■ 전자금융업무를 수행하지 않는 여신전문금융회사 등은 「전자금융거래법」 제3조제3항 및 「전자금융거래법 시행령」 제5조제2항에 따라 「전자금융감독규정」 제14조의2에 따른 클라우드컴퓨팅서비스 이용절차가 적용되지 않습니다.

이유

■ 「전자금융거래법」 제3조제3항 및 「전자금융거래법 시행령」 제5조제2항에 따라 전자금융업무를 하지 않는 여신전문금융회사 등 금융회사는 「전자금융거래법」 제3조제3항 각 호의 사항을 적용받지 않습니다.

■ 특히, 「전자금융거래법」 제21조제2항에서는 전자금융거래의 안전성 확보를 위해 금융회사 및 전자금융업자로 하여금 전자금융업 뿐만 아니라 일반 정보기술(IT)부분 업무에 대해서도 일정한 기준을 준수하도록 규정하고 있는 것으로,

- 전자금융업무를 하지 않는 금융회사는 「전자금융거래법」 제21조제2항의 인력, 시설, 전자적 장치 등의 정보기술부문 및 전자금융업무에 관하여 금융위원회가 정하는 기준이 적용되지 않습니다.

※ 법령해석('20.5.4.)-200036

질의

■ 「전자금융거래법」상 금융회사 또는 전자금융업자가 클라우드컴퓨팅서비스 제공자와 계약을 맺고 클라우드컴퓨팅서비스를 이용하면서 정보보호와 관련된 업무 역시 위탁한 때, 전자금융감독규정 제60조 제4항의 요건을 갖춘 경우 금융회사의 정보보호와 관련된 업무를 재위탁하는 것이 가능한지 여부(특히, 금융회사 등이 클라우드컴퓨팅을 이용할 때, 위 감독규정 제60조 제4항 제2호의 요건 중 위탁회사의 전산실의 범위에 클라우드 전산센터가 포함되는지 여부)

회신

■ 「전자금융거래법」 제40조 제6항 단서에 따라 금융회사 등이 「전자금융감독규정」 제60조 제4항 제1호 및 제2호의 기준을 준수하는 경우에는 정보보호와 관련된 업무의 재위탁이 가능합니다.

- 한편, 금융회사 등이 제3자가 제공하는 클라우드컴퓨팅서비스를 이용하는 경우에도 「전자금융거래법」 제28조, 「전자금융감독규정」 제14조의2, 제50조 제1항 제2호 및 제4호에 따라 허가 · 등록의 요건으로서 전산설비 · 기기 등을 갖추었다고 볼 수 있으므로,
  - 「전자금융감독규정」 제60조 제4항 제2호의 요건과 관련한 위탁회사인 금융회사 등의 전산실의 범위에는 제3자인 클라우드컴퓨팅서비스 제공자의 전산센터도 포함된다고 판단됩니다.

이유

■ 「전자금융거래법」제40조 제6항의 정보보호 관련 업무의 재위탁 제한규정은 전자금융거래정보의 보호 및 안전한 처리를 목적으로 도입되었습니다.

- 「전자금융거래법」에서의 정보보호 관련 업무는 전자금융거래의 안정성 확보 및 이용자 보호를 위한 업무로서(「전자금융거래법」§21의2④ 등), 방화벽 운용, 시스템 모니터링 등 보안 인프라 운영과 취약점 분석평가, IT내부통제 관리 등의 업무를 포괄하며,
  - 정보의 외부유출 방지 등을 위해 금융회사 등의 정보보호최고책임자(CISO)가 통솔해야 하는 업무이므로 원칙적으로 재위탁을 제한하되, 단서규정을 두어 일정한 조건을 준수하는 경우에 한하여 제한적으로 재위탁을 허용하였습니다.

■ 아울러, 「전자금융감독규정」 제60조 제4항 각 호에서는 전자금융거래정보의 보호 목적 달성을 위해 다음과 같이 재위탁의 기준을 구체화하고 있으므로, 해당 기준을 준수하는 경우에는 재위탁이 가능합니다(「전자금융감독규정」 §60④ Ⅰ, Ⅱ).

ⅰ) 재수탁업자가 재위탁된 업무를 처리함에 있어 금융거래 정보의 변경이 필요한 경우에는 위탁회사 또는 원수탁업자의 개별적 지시에 따라야하고, 위탁회사 또는 원수탁업자는 변경된 정보가 지시 내용에 부합하는지 여부를 확인할 것

ⅱ) 위탁업무와 관련된 이용자의 금융거래정보는 "위탁회사의 전산실" 내에 둘 것(다만, 재수탁업자가 이용자의 이용자 정보를 어떠한 경우에도 알지 못하도록 위탁회사 또는 원수탁업자가 금융거래정보를 처리하여 제공한 경우에는 위탁회사의 관리 · 통제 하에 재수탁회사 등 제3의 장소로 이전 가능)

■ 이 경우 「전자금융감독규정」 제60조 제4항 제2호의 위탁회사의 "전산실"이라 함은 전산장비, 통신 및 보안장비, 전산자료 보관 및 출력장비가 설치된 장소를 의미하고(「전자금융감독규정」§2 Ⅰ),

- 금융회사 등이 제3자가 제공하는 클라우드컴퓨팅서비스를 이용하는 경우에도 「전자금융거래법」 제28조, 「전자금융감독규정」 제14조의2, 제50조 제1항 제2호 및 제4호에 따라 허가 · 등록의 요건으로서 전산설비 · 기기 등을 갖추었다고 볼 수 있으므로
  - 위탁회사인금융회사 등의 전산실의 범위에는 제3자인 클라우드 컴퓨팅서비스 제공자의 전산센터도 포함된다고 판단됩니다.

■ 다만, 클라우드 서비스 제공자가 위탁받은 업무를 재위탁하는 경우에는 금융회사 등과 체결된 클라우드컴퓨팅서비스 이용계약(위 · 수탁 계약) 및 「전자금융감독규정」제14조의2 제1항 제3호에 따라 마련된 금융회사 등의 자체 업무 위 · 수탁 운영기준을 준수하여야 합니다(금융보안원, 금융분야 클라우드컴퓨팅서비스 이용가이드 64면 등 참조).

- 또한, 재위탁에 따른 재수탁자도 전자금융거래법 제2조 제5호에 따른 전자금융보조업자의 범위에 포함되므로 법 제40조 및 감독규정 제60조에 따른 의무사항을 준수하여야 합니다.

※ 법령해석('19.3.20.)-190042

질의

1. 전자금융업자가 국내에 전산센터를 둔 해외 클라우드 사업자의 서비스를 이용하는 것이 가능한지?
2. 전자금융업자가 개인신용정보를 처리하는 경우에도 국내에 전산센터를 둔 해외 클라우드 사업자의 서비스를 이용할 수 있는지?
3. 전자금융업자와 클라우드제공자 간에 VPN을 사용하여 접속하는 것이 가능한지 여부
4. 클라우드서비스제공자 선정 시 정보보호위원회에서 심의해야 하는 평가항목은?
5. 전자금융업자의 시스템과 분리된 별도의 망에 구성된 시스템 간에 데이터/보안 암호키를 공유할 수 있는지?
6. 클라우드의 경우 논리적 망분리가 허용되는 것인지?

회신

■ 전자금융업자가 개인신용정보를 클라우드 서비스를 통해 처리하고자 할 경우 국내에 이미 전산센터를 갖춘 해외 클라우드의 사업자의 서비스를 이용하는 것이 가능합니다.
* 다만, 개인신용정보는 국내(전산센터)에서 처리되어야 함

- 또한, 고유식별정보, 개인신용정보를 제외한 비중요정보를 클라우드를 통해 처리하는 경우에는 해외 소재 클라우드도 이용할 수 있습니다(질의 1, 2에 대한 답변).

■ 전자금융업자가 클라우드 서비스에 연결해야 할 경우 VPN을 이용하는 것이 가능합니다(질의 3에 대한 답변).

■ 전자금융업자는 클라우드서비스를 이용할 경우 중요도 평가 결과, 자체 업무 위수탁 운영기준, 클라우드서비스 제공자 건전성 및 안전성 평가 결과에 대해 정보보호위원회를 개최하여 심의 · 의결하여야 합니다(질의 4에 대한 답변).

■ 전자금융업자의 시스템과 타 시스템간 정보 공유가 필요할 경우 해당 정보와 관련한 암호키를 공유할 수 있으나, 이 경우에도 해당 암호키는 접근통제 정책을 통해 안전하게 관리할 필요가 있습니다(질의 5에 대한 답변).

■ 전자금융업자가 클라우드컴퓨팅서비스 이용절차에 따라 클라우드서비스를 이용하는 경우에는 물리적 망분리의 예외가 인정됩니다(전자금융감독규정 제14조의2 제8항).

이유

- 현행 규정은 전자금융업자가 개인신용정보를 클라우드 서비스를 통해 처리하는 경우에는 해당 정보처리시스템을 국내에 설치토록 하고 있음(전자금융감독규정 제14조의2제8항)
  - 동 규정은 개인신용정보 보호, 감독가능성 확보를 위해 정보시스템의 위치를 국내로 제한한 것이므로, 전자금융업자는 국내에 이미 전산센터를 갖춘 해외 클라우드의 사업자의 서비스도 이용할 수 있음
  - 한편, 고유식별정보, 개인신용정보를 포함하지 않은 비중요정보 시스템에 한정된 클라우드 서비스를 이용할 경우에는 해외 소재 클라우드도 이용할 수 있음
- 전자금융업자의 업무용 단말기, 내부망 정보처리시스템을 클라우드서비스 제공자 구간에 위치한 내부망 정보처리시스템에 연결하거나, 관리용 단말기를 클라우드 서비스에 연결해야 하는 경우 VPN을 이용하는 것이 가능함(전자금융감독규정 제14조의2 제8항)
- 전자금융업자는 중요도 평가 결과, 자체 업무 위수탁 운영기준, 클라우드서비스 제공자 건전성 및 안전성 평가 결과에 대해 정보보호위원회를 개최하여 심의 · 의결하여야 함(전자금융감독규정 제14조의2제2항)
- 현행 규정은 전자금융업자로 하여금 암호 및 인증시스템에 적용되는 키에 대하여 주입 · 운용 · 갱신 · 폐기에 대한 절차 및 방법을 마련하여 안전하게 관리토록 하고 있음(전자금융감독규정 제31조)
  - 암호키에 대해 비인가접근을 방지하기 위해 암호키에 대한 접근제어 정책을 수립하여야 함
  - 즉, 암호화 키는 접근이 통제된 보안네트워크에 저장하고, 클라우드서비스 제공자의 직원이나 동일 클라우드 서비스를 이용하는 외부 기관이 접근할 수 없도록 조치가 필요
  - 전자금융업자의 시스템과 타 시스템간 정보 공유가 필요할 경우 해당 정보와 관련한 암호키를 공유할 수 있으나, 이 경우에도 해당 암호키는 접근통제 정책을 통해 안전하게 관리할 필요
- 전자금융업자가 클라우드컴퓨팅서비스 이용절차(전자금융감독규정 제14조의2)에 따라 클라우드서비스를 이용하는 경우에는 물리적 망분리의 예외가 인정됨(전자금융감독규정 제14조의2 제8항)

  * 망분리 예외와 관련한 구체적 사항은 전자금융감독규정 시행세칙상 망분리 대체 정보보호통제 수칙(전자금융감독규정 시행세칙 제2조의2), 금융분야 클라우드 이용가이드라인을 참조

※ 법령해석('21.12.22.)-200449

질의

- 클라우드 시스템 환경에 해당하는 해외 그룹사의 국외 인사관리 시스템에 직원의 고유 식별정보를 저장할 수 있는지 여부

회신

- 「금융회사의 정보처리 업무 위탁에 관한 규정」(이하 정보처리업무 위탁규정)제5조에 따라 금융회사가 정보 처리를 위탁하는 경우, 개인고객의 고유식별정보는 국외로 이전되지 않도록 하여야 합니다.
  - 따라서, 금융회사의 인사업무 처리를 위한 임직원의 고유식별정보는 정보처리업무위탁규정 제5조에 따라 국외 이전이 제한되는 개인고객의 고유식별정보에 해당하지 않습니다*.

    * 전자금융거래와 관련이 없고 고객정보와 무관한 정보는 「전자금융감독규정」 제14조의2에 따른 고유식별정보에 해당하지 않음
  - 다만, 「개인정보 보호법」 등 다른 법령에서 정보 주체의 사전동의 요구 등 정보의 이전을 제한하거나 별도의 규제가 있는 경우, 해당 법령을 준수해야 합니다.

이유

■ 「금융회사의 정보처리 업무 위탁에 관한 규정」(이하 정보처리업무 위탁규정)제5조에 따라 금융회사가 정보 처리를 위탁하는 경우, 개인고객의 고유식별정보는 국외로 이전되지 않도록 하여야 합니다.

- 따라서, 금융회사의 인사업무 처리를 위한 임직원의 고유식별정보는 정보처리업무위탁규정 제5조에 따라 국외 이전이 제한되는 개인고객의 고유식별정보에 해당하지 않습니다*.

  * 전자금융거래와 관련이 없고 고객정보와 무관한 정보는 「전자금융감독규정」 제14조의2에 따른 고유식별정보에 해당하지 않음

- 다만, 「개인정보 보호법」 등 다른 법령에서 정보 주체의 사전동의 요건 등 정보의 이전을 제한하거나 별도의 규제가 있는 경우, 해당 법령을 준수해야 합니다.

※ 비조치의견서('24.3.21.)-240004

비조치의견서는 행정해석의 일종으로 최종 법적구속력은 없으며, 유권해석과는 달리 특정행위에 대해 해당 회사의 상황을 고려한 검토결과로써 일반적 효력을 가지지 아니하므로 참고자료로만 활용하시기 바랍니다.

요청대상 행위

■ 「전자금융거래법」의 적용 대상이나 「금융회사의 정보처리 업무 위탁에 관한 규정」의 적용 대상이 아닌 금융회사 및 기타 금융업 또는 금융관련 업무를 영위하는 자가'클라우드컴퓨팅서비스' 이용계약을 신규로 체결하는 경우

- 금융감독원장에게 제출해야 하는 서류 중 「금융회사의 정보처리 업무 위탁에 관한 규정」제7조제1항 관련 서류를 생략해도 되는지 여부

판단

■ 아래 내용을 참고하시기 바랍니다.

판단이유

■ 「전자금융거래법」 및 동 법 시행령에 의하여 「전자금융감독규정」의 적용을 받는 금융회사는 클라우드컴퓨팅서비스 이용계약을 신규로 체결하는 경우 금융감독원장에게 관련 자료를 첨부하여 보고하여야 하며(「전자금융감독규정」 제14조의2제4항제1호) 첨부서류 중 일부에 대하여 「금융회사의 정보처리 업무 위탁에 관한 규정」 제7조제1항 각 호에서 명시하고 있습니다(전자금융감독규정 제14조의2제5항제1호).

- 위 서류는 클라우드컴퓨팅서비스 이용과 관련된 정보처리 업무 위탁 시 기대 효과, 책임 소재, 실질적 감독가능성, 피해자 구체절차 등을 명확히 하기 위해 제출하는 것으로 「금융회사의 정보처리 업무 위탁에 관한 규정」 제7조제1항의 서류를 인용한 것일 뿐 「금융회사의 정보처리 업무 위탁에 관한 규정」의 적용 대상인 금융회사에 대해서만 서류 제출 의무를 부과하겠다는 의미로 보기는 어렵습니다.

■ 귀 사가 「금융회사의 정보처리 업무 위탁에 관한 규정」 제2조제1항에서 정의하는 "금융회사"의 범위에서 제외되어 있다고 하더라도 「전자금융거래법」 및 동 법 하위규정인 「전자금융감독규정」의 적용 대상이므로

- 클라우드컴퓨팅서비스 이용과 관련하여 금융감독원장에게 보고 시 「전자금융감독규정」 제14조의2제5항 각 호에서 제시된 모든 서류를 빠짐없이 제출하여야 하므로 그중 하나인 「금융회사의 정보처리 업무 위탁에 관한 규정」 제7조제1항 각 호에 관한 서류 또한 제출하여 주시기를 바랍니다(전자금융감독규정 제14조의2제5항제1호).
- 다만, 「금융회사의 정보처리 업무 위탁에 관한 규정」제7조제1항제2호에 관한서류(「금융기관의 업무위탁 등에 관한 규정」 제3조의2에 따라 금융기관이 마련하고 준수하여야 할 '업무위수탁 운영기준')이 구비되어 있지 않은 경우 클라우드컴퓨팅서비스 관련 업무절차 등 그에 준하는 서류로 대체하여 제출하실 수 있음을 알려드립니다.

조치 사례('21.5.3. 등)

- 금융회사 및 전자금융업자는 클라우드를 이용하고자 하는 경우에 클라우드 이용 절차를 거쳐야 함에도
- 클라우드 이용 절차를 거치지 않고 일부 시스템 또는 서비스를 클라우드 환경에서 이용하여 적발된 다수 사례

개선요구 등 사례('24.10.25.)

- ○○회사는 결재승인 등 대내·외 전자금융거래 관련 업무처리를 위해 클라우드시스템을 이용중이고, 클라우드 서비스 업체에서 ○○회사의 자료를 보호하기 위한 백업을 수행하고 있으나,
- 회사 자체적으로 주요자료에 대한 백업은 수행하고 있지 않아, 회사측 과실로 인해 손실된 데이터는 복구가 어려울 가능성이 있으므로
- 클라우드시스템에서 제공하는 기능이나 별도의 솔루션 이용을 검토하여 주요정보는 회사 내부에 백업하도록 개선할 필요

제5절 정보보호부문

1. 해킹 등 방지대책

감독규정

제15조(해킹 등 방지대책) ① 금융회사 또는 전자금융업자는 정보처리시스템 및 정보통신망을 해킹 등 전자적 침해행위로부터 방지하기 위하여 다음 각 호의 대책을 수립·운용하여야 한다.

1. 해킹 등 전자적 침해행위로 인한 사고를 방지하기 위한 정보보호시스템 설치 및 운영
2. 해킹 등 전자적 침해행위에 대비한 시스템프로그램 등의 긴급하고 중요한 보정(patch)사항에 대하여 즉시 보정작업 실시
3. 내부통신망과 연결된 내부 업무용시스템은 인터넷(무선통신망 포함) 등 외부통신망과 분리·차단 및 접속 금지. 다만, 다음 각 목의 경우에는 그러하지 아니하다.
   가. 이용자의 고유식별정보 또는 개인신용정보(「신용정보의 이용 및 보호에 관한 법률」 제40조의2에 따른 가명처리에 관한 행위규칙을 준수한 가명정보는 제외)를 처리하지 않는 연구·개발 목적의 경우(단, 금융회사 또는 전자금융업자가 자체 위험성 평가를 실시한 후 금융감독원장이 정한 망분리 대체 정보보호통제를 적용하고 정보보호위원회가 승인한 경우에 한한다)
   나. 업무상 불가피한 경우로서 금융감독원장의 확인을 받은 경우
4. 내부통신망에서의 파일 배포기능은 통합 및 최소화하여 운영하고, 이를 배포할 경우에는 무결성 검증을 수행할 것
5. 전산실 내에 위치한 정보처리시스템과 해당 정보처리시스템의 운영, 개발, 보안 목적으로 직접 접속하는 단말기에 대해서는 인터넷 등 외부통신망으로부터 물리적으로 분리할 것. 다만, 다음 각 목의 경우에는 그러하지 아니하다.
   가. 이용자의 고유식별정보 또는 개인신용정보(「신용정보의 이용 및 보호에 관한 법률」 제40조의2에 따른 가명처리에 관한 행위규칙을 준수한 가명정보는 제외)를 처리하지 않는 연구·개발 목적의 경우(단, 금융회사 또는 전자금융업자가 자체 위험성 평가를 실시한 후 금융감독원장이 정한 망분리 대체 정보보호통제를 적용하고 정보보호위원회가 승인한 경우에 한한다)
   나. 업무상 불가피한 경우로서 금융감독원장이 인정하는 경우

② 제1항제1호의 규정에 따른 정보보호시스템의 안전한 운영을 위하여 금융감독원장이 정하는 사항을 준수하여야 한다.

③ 제1항 각 호의 정보보호시스템에 대하여 책임자를 지정·운영하여야 하며, 운영결과는 1년 이상 보존하여야 한다.

④ 금융회사 또는 전자금융업자는 해킹 등 전자적 침해의 예방, 피해 최소화 및 신속한 복구를 위한 대책을 수립·운용하여야 한다.

⑤ 삭제

⑥ 금융회사 또는 전자금융업자는 무선통신망을 설치·운용할 때에는 다음 각 호의 사항을 준수하여야 한다.

1. 무선통신망 이용 업무는 최소한으로 국한하고 법 제21조의2에 따른 정보보호최고책임자의 승인을 받아 사전에 지정할 것

2. 무선통신망을 통한 불법 접속을 방지하기 위한 사용자인증, 암호화 등 보안대책을 수립 · 운용할 것
3. 무선통신망에 인가되지 않은 정보처리시스템 및 단말기의 접속을 차단하여야 하며, 비인가 무선접속장비(Access Point: AP) 설치 · 접속여부, 중요 정보 노출여부를 주기적으로 점검할 것

⑦ 금융회사 또는 전자금융업자는 단말기에서 음란, 도박 등 업무와 무관한 프로그램 또는 인터넷 사이트에 접근하는 것에 대한 통제대책을 수립 · 운용하여야 한다.

시행세칙

제2조의3(망분리 적용 예외) ① 규정 제15조제1항제3호나목에서 감독원장의 확인을 받은 경우란 다음 각 호와 같다.

1. 내부 통신망에 연결된 단말기가 업무상 필수적으로 외부기관과 연결해야 하는 경우(다만, 이 경우 필요한 서비스번호(port)에 한하여 특정 외부기관과 연결할 수 있다).
2. 규정 제12조의 보안대책을 적용한 단말기에서 전용회선과 동등한 보안수준을 갖춘 통신망을 이용하여 외부망으로부터 내부 업무용시스템으로 원격접속 하는 경우

② 규정 제15조제1항제5호나목에서 감독원장이 인정하는 경우란 다음 각 호와 같다.

1. 「금융회사의 정보처리 업무 위탁에 관한 규정」에 따라 정보처리 업무를 국외 소재 전산센터에 위탁하여 처리하는 경우(다만, 해당 국외 소재 전산센터에 대해서는 물리적 방식 외의 방법으로 망을 분리하여야 하며, 이 경우에도 국내 소재 전산센터 및 정보처리시스템 등은 물리적으로 망을 분리하여야 한다)
2. 업무상 외부통신망과 연결이 불가피한 다음의 정보처리시스템(다만, 필요한 서비스번호(port)에 한하여 연결할 수 있다)
   가. 전자금융업무의 처리를 위하여 특정 외부기관과 데이터를 송수신하는 정보처리시스템
   나. DMZ구간 내 정보처리시스템과 실시간으로 데이터를 송수신하는 내부통신망의 정보처리시스템
   다. 다른 계열사(「금융회사의 정보처리 업무 위탁에 관한 규정」 제2조제3항의 "계열사"를 말한다)와 공동으로 사용하는 정보처리시스템
3. 규정 제23조의 비상대책에 따라 원격 접속이 필요한 경우
4. 전산실 내에 위치한 정보처리시스템의 운영, 개발, 보안 목적으로 직접 접속하는 단말기와 외부통신망과의 연결 구간, 규정 제15조제1항제3호의 내부 업무용 시스템과의 연결 구간을 각각 차단한 경우

③ 제1항 및 제2항의 규정은 금융회사 또는 전자금융업자가 자체 위험성 평가를 실시한 후 별표 7에서 정한 망분리 대체 정보보호통제를 적용하고 정보보호위원회가 승인한 경우에 한하여 적용한다.

제2조의6(정보보호시스템 운영) 규정 제15조제2항에 따라 감독원장이 정하는 사항은 다음 각 호와 같다.

1. 최소한의 서비스번호(port)와 기능만을 적용하고 업무목적 이외의 기능 및 프로그램을 제거할 것
2. 보안정책의 승인, 적용, 등록, 변경 및 삭제에 대해 기록 · 보관하고 적용된 보안정책의 적정성을 주기적으로 점검할 것
3. 정보보호시스템 원격관리를 금지할 것. 다만, 원격관리가 불가피한 경우 전용회선(전용회선과 동등한 보안수준을 갖춘 가상의 전용회선을 포함한다) 사용, 접근통제 등을 포함한 원격 접속 보안 대책을 수립 · 운용할 것
4. 정보보호시스템의 정상 작동 여부 확인을 위하여 시스템 상태의 감시, 경고가 가능하도록 모니터링시스템을 갖추고 시스템 장애, 가동중지 등 긴급사태에 대비하여 백업 및 복구 절차 등을 수립 · 운용할 것

■ 인터넷 등 공개된 외부 통신망과 접속되는 내부 통신망 및 내부 정보처리시스템을 해킹 등 전자적 침해행위로부터 보호하기 위하여 침입차단시스템 등 정보보호시스템을 설치

■ 침해사고 발생 즉시 이를 탐지하여 피해 최소화 및 신속 복구 등 대응할 수 있도록 체계 구축

■ 해설

● 내부정보처리시스템 및 정보통신망을 해킹 등 전자적 침해 행위로부터 보호하기 위해 침입차단시스템(Firewall), 가상사설망(VPN: Virtual Private Network), 침입탐지시스템(IDS: Intrusion Detection System), 침입방지시스템(IPS: Intrusion Prevention System) 등 정보보호시스템을 설치 및 운영(제1항제1호)

● 정보보호시스템의 안전한 운영을 위해서는 다음 사항을 준수(제1항제1호 및 제2항)

- 최소한의 서비스번호(port)와 기능만을 적용하고 업무목적 이외의 기능 및 프로그램을 제거(시행세칙 제2조의6제1호)

- 보안정책의 승인, 적용, 등록, 변경 및 삭제에 대해 기록·보관하고 적용된 보안정책의 적정성을 주기적으로 점검(시행세칙 제2조의6제2호)

- 정보보호시스템 원격관리를 금지할 것. 다만, 원격관리가 불가피한 경우 전용회선(전용회선과 동등한 보안수준을 갖춘 가상의 전용회선을 포함) 사용, 접근통제 등을 포함한 원격 접속 보안대책을 수립·운용(시행세칙 제2조의6제3호)

  ※ 수탁자가 그룹 전산센터에 상주하면서 계열사별 정보보호시스템에 1대1로 직접 접속하는 단말기를 사용하여 병렬적으로 정보보호시스템운영업무를 수행하는 것은 정보보호시스템의 원격관리에 해당하지 않음(비조치의견 240076)

- 정보보호시스템의 정상 작동 여부 확인을 위하여 시스템 상태의 감시, 경고가 가능하도록 모니터링 시스템을 갖추고 시스템 장애, 가동중지 등 긴급사태에 대비하여 백업 및 복구 절차 등을 수립·운용(시행세칙 제2조의6제4호)

● 운영체제 등 시스템프로그램 취약점을 이용한 침해에 대비하여 시스템프로그램의 보안 취약점 개선 등 긴급하고 중요한 사항은 즉시 보정작업 실시(제1항제2호)

● 백신 업데이트와 같은 내부통신망에서의 파일 배포기능은 통합 및 최소화하여 운영하고, 이를 배포할 경우에는 무결성 검증을 수행할 것(제1항제4호)

※ 비조치의견서('24.10.17.)-240076

비조치의견서는 행정해석의 일종으로 최종 법적구속력은 없으며, 유권해석과는 달리 특정행위에 대해 해당 회사의 상황을 고려한 검토결과로써 일반적 효력을 가지지 아니하므로 참고자료로만 활용하시기 바랍니다.

요청대상 행위

- 금융그룹 전산센터 내에 별도 통제구역*을 마련하여 각 계열 금융회사(위탁사) 정보보호시스템에 1대1로 직접 접속하는 단말기를 설치하고 해당 단말기와 각 계열 금융회사의 내부통신망을 전용회선으로 연결한 환경에서,
  * 해당 구역은 별도 출입통제 및 전산기기 반 · 출입통제, 단말통제 등 보안대책 적용
  - 금융그룹 전산센터에 상주하는 전산자회사(수탁사) 직원이 해당 단말기를 통하여 정보보호시스템 정책 등을 운영하는 경우 「전자금융감독규정」 제15조제2항제4호의 '정보보호시스템 원격관리 금지'에 위반하는지 여부

판단

- 아래 내용을 참고하시기 바랍니다.

판단이유

- 「전자금융감독규정」 제15조제2항제4호는 정보보호시스템의 원격관리를 원칙적으로 금지하고 있습니다.
- 문의하신 사실관계 하에서 귀사는 금융그룹 전산자회사로써 각 계열 금융회사(이하 '계열사')로 부터 정보보호시스템의 운영업무*를 수탁하고자 하고,
  * 정보보호시스템 모니터링, 패치 및 정책 관리, 사용자 문의 및 장애 대응 등
  - 귀사의 직원이 그룹 전산센터에 상주하면서 계열사별 정보보호시스템에 1대1로 직접 접속하는 단말기를 사용하여 병렬적으로 정보보호시스템 운영업무를 수행하고자 합니다.
- 상기 방식은「전자금융감독규정」 제15조제2항제4호가 금지하는 정보보호시스템의 원격관리에 해당하지 않는 것으로 보입니다.
  - 운영대상에 해당하는 계열사별 정보보호시스템과 그에 직접 접속하는 단말기가 장소적으로 동일한 그룹 전산센터 내에 각각 위치하고 있고,
  - 각 계열사가 상호배타적으로 지배 · 통제하고 있는 단일 폐쇄망 내에서 정보보호시스템의 운영을 위하여 전용 단말기로 직접 접속하는 것은 원격관리로 보기 어렵습니다.
- 단, 「전자금융감독규정」 제15조에 따라 각 계열사의 전산설비 및 통신망을 상호 간에 물리적으로 분리하는 등 관련 법규를 철저히 준수하시기 바랍니다.

조치 사례('22.11.30.)

- 금융회사는 전자적 침해행위에 대비해 시스템 프로그램 등의 긴급하고 중요한 보정(Patch) 사항에 대하여 즉시 보정작업을 실시하여야 하는데도(전자금융감독규정 제15조제1항제2호),
- ○○회사는 전산자원관리시스템의 보안취약점을 보정한 보안패치를 보정작업 대상 0,000대 중 00대에 대해서만 적용함에 따라, 공개용 웹서버의 취약점을 이용하여 내부통신망에 침투한 외부공격자가 악성코드(랜섬웨어) 파일을 업로드하여 배포 · 실행함에 따라 내부통신망 서버 등 총 000대가 악성코드에 감염되었음

※ 금융회사 등의 망분리(제1항 제3호 및 제5호)

(1) 망분리 대상

- 금융회사 등의 주된 업무가 전자금융업무가 아니고, 전자금융업무를 처리하는 망을 외부망 및 전자금융업무와 무관한 기타 내부 정보처리시스템을 처리하는 망과 분리하는 등 전자금융거래의 안전성에 미치는 영향이 없게 독립적으로 운영한다면, 전자금융업무를 처리하는 망에만 망분리 의무를 적용하고 그 외 망에는 망분리 의무를 적용하지 아니할 수 있음(비조치의견서 230112, 법령해석 200051)

- 금융회사가 망분리 규제가 적용되지 않은 자로부터 수탁한 정보처리시스템 운영업무를 수행하기 위하여 금융회사의 내부업무를 위한 통신망과 수탁업무를 위한 통신망을 물리적으로 분리하는 경우, 수탁업무를 수행하기 위한 망은 망분리 의무 적용대상이 아님(비조치의견서 240067)

- 클라우드컴퓨팅서비스 제공자의 정보처리시스템이 위치한 전산실에 대해서는 물리적 망분리를 적용되지 아니하나(제14조의2제7항) 논리적으로는 망을 분리하여야 하며(비조치의견서 240045),

  - 클라우드컴퓨팅서비스 제공자의 정보처리시스템이 금융회사 등의 내부통신망과 연결될 경우에도 클라우드컴퓨팅서비스 제공자의 정보처리시스템은 논리적 방식 등으로 외부통신과 차단되어야 함(비조치의견서 220042, 220049)

- 수탁자, 외주직원 등이 이용하는 단말기가 금융회사 등의 업무 처리 등을 위해 금융회사의 내부통신망에 연결되어 있는 경우 망분리 대상에 해당하나,

  - 내부망과 분리된 망(DMZ 등)에 위치한 시스템에만 접속하는 경우에는 망분리 적용대상에 포함되지 않음(비조치의견서 150359)

※ 비조치의견서('24.01.18.)-230112

비조치의견서는 행정해석의 일종으로 최종 법적구속력은 없으며, 유권해석과는 달리 특정행위에 대해 해당 회사의 상황을 고려한 검토결과로써 일반적 효력을 가지지 아니하므로 참고자료로만 활용하시기 바랍니다.

요청대상 행위

- 특정 업무 외에 전자금융업무를 수행하지 않는 금융회사가 해당 전자금융업무를 수행하는 부서에 한하여 전자금융업무용 단말기에 대한 업무망을 외부망 및 전자금융업무와 무관한 기타 내부 정보처리시스템('이하 기존 내부망')과 분리한 경우 전자금융감독규정 제15조제1항제3호 및 제5호 위반인지 여부

판단

- 아래 내용을 참고하시기 바랍니다.

판단이유

■ 금융회사는 정보처리시스템 및 정보통신망을 해킹 등 전자적 침해행위로부터 방지하기 위해 내부통신망과 연결된 내부 업무용시스템을 외부통신망과 분리 · 차단 및 접속금지의 조치를 하여야 합니다(전자금융감독규정 제15조 제1항제3호).

- 다만, 동 규정은 망분리 대상으로서 "내부통신망과 연결된 내부 업무용시스템"의 개념이나 범위를 특별히 규정하고 있지 않습니다.

■ 한편, 금융위원회는 금융회사가 전자금융업무를 부수적으로 수행할 뿐 내부 업무용시스템에서 처리되는 주된 업무의 본질적 성격이 전자금융업무의 수행과 관련이 없는 경우에 대하여,

- ①전자금융업무 수행을 위한 정보처리시스템이 외부망과 분리 · 차단되어 있고, ②주된 업무를 처리하는 정보처리시스템과 서로 연계되지 않는 등 독립적으로 분리 구성 · 운영됨으로써 전자금융거래의 신뢰성 · 안전성 확보에 영향을 주지 않는다면,
- 특별한 사정이 없는 한 전자금융업무가 아닌 주된 업무를 처리하는 내부 업무용시스템에 대해 동 규정이 적용되지 않는다고 해석한 바 있습니다. (법령해석 200051)

■ 문의하신 사실관계 하에서 귀사의 주된 업무의 성격이 전자금융업무에 해당하지 않고,

- 부수적으로 수행하는 전자금융업무에 대해 외부망 및 기존 내부망과 분리하는 등 독립적으로 운영한다면 전자금융감독규정 제15조제1항제3호를 위반하지 않은 것으로 볼 수 있습니다.
- 다만, 망분리 규정이 적용되는 전자금융업무에 대해 전산실 내에 위치한 정보처리시스템과 외부통신망을 물리적으로 분리하는 등 동규정 제15조제1항제5호를 준수하여 주시기 바랍니다.

※ 법령해석('20.5.22.)-200051

질의

■ 주권의 장외매매에 관한 업무 (K-OTC) 외의 전자금융업무를 수행하지 않는 ○○협회가 K-OTC 호가중개시스템 및 관련 업무용 단말기에 대한 업무망 분리를 이미 모두 완료한 상태에서 전자금융업무와 무관한 기타 내부 정보처리 시스템에 대해 전자금융감독규정 제15조제1항제3호에 따른 조치를 하지 않은 것이 전자금융거래법 제21조제2항에 따른 전자금융거래의 안정성과 신뢰성 확보 의무를 이행하지 아니한 것에 해당하는지 여부

회신

■ ○○협회는 「전자금융거래법」 제21조, 「전자금융감독규정」 제15조 등에 따른 안전성 확보 조치를 해야 하는 금융회사에 해당합니다(법§1, 시행령§2).

- 한편, 「전자금융감독규정」 제15조제1항제3호 등에 따른 망분리 의무는 법 제21조제2항을 근거로 금융회사 등의 안전성 확보 의무를 구체화 하고 있습니다.

■ 「전자금융감독규정」 제15조제1항제3호는 망분리 대상으로서 "내부통신망과 연결된 내부 업무용시스템"의 개념이나 범위를 특별히 규정하고 있지는 않고 있는 바, 동 규정의 의미를 밝히는 경우 입법취지와 목적, 제 · 개정 연혁 등을 종합 고려하여 구체적 타당성을 기할 필요가 있습니다.

- 동 규정은 대규모 금융전산사고 등을 배경으로 도입되었으며, 금융회사 등의 내부망 · 시스템의 악성코드 유입 등을 방지하고, 외부로의 정보유출을 사전에 차단함으로써, 전자금융거래의 신뢰성 · 안전성을 확보하려는 데에 그 입법목적이 있습니다.

❶ 따라서, 금융회사나 전자금융업자가 전자금융업무를 부수적으로 수행할 뿐 내부 업무용시스템에서 처리되는 주된 업무의 본질적 성격이 전자금융업무의 수행과 관련이 없는 경우로서,

❷ 금융회사 등의 전자금융업무 수행 을 위한 정보처리시스템 이 외부망과 분리 · 차단 되어 있을 뿐만 아니라, 위 ❶의 주된 업무를 처리하는 정보처리 시스템과도 서로 연계되지 않는 등 독립적으로 분리 구성 · 운영됨으로써 전자금융거래의 신뢰성 · 안전성 확보에 영향을 미치지 않는 경우라면,

- 전자금융업무가 아닌 주된 업무를 처리하는 내부 업무용시스템에 대해서는 특별한 사정이 없는 한 「전자금융감독규정」 제15조제1항제3호가 적용되지 않습니다.

■ ○○협회의 경우 「전자금융거래법」이 적용되지 않는 은행연합회 등과 같은 이익단체적 성격을 가지면서,

- 「자본시장과 금융투자업에 관한 법률」(이하 '자본시장법') 제286조제1항제1호 등에 따른 자율 규제 업무 등을 주된 업무로 수행하고, 전자금융업무로서 주권의 장외매매에 관한 업무(K-OTC 운영, 자본시장법286조 제1항 제5호) 등을 부수적인 업무로 수행하고 있는 것으로 판단됩니다.

■ 따라서, 질의하신 사실관계만으로는 명확하게 판단하기는 어렵지만, 부수적으로 수행 중인 K-OTC 운영 업무 등을 제외하면, ○○협회의 주된 업무의 성격이 전자금융업무라고 보기는 어려운 바,

- 주된 업무를 처리하는 내부업무용 시스템과 K-OTC 운영 시스템이 서로 연계되지 않고 독립적으로 분리 구성 · 운영*되는 등으로 인해 전자 금융거래의 안전성에 미치는 영향이 없는 경우라면,
- 전자 금융업무가 아닌 ○○협회의 주된 업무를 처리하는 내부 업무용 시스템에 대하여 까지 「전자금융감독규정」 제15조제1항제3호가 적용되는 것은 아니라 할 것입니다.
  - 그렇다면, 특별한 사정이 없는 한 ○○협회가 「전자금융거래법」 제21조제2항에 따른 안전성 확보 의무를 이행하지 않았다고 보기는 어렵습니다.

※ 비조치의견서('24.08.22.)-240067

비조치의견서는 행정해석의 일종으로 최종 법적구속력은 없으며, 유권해석과는 달리 특정행위에 대해 해당 회사의 상황을 고려한 검토결과로써 일반적 효력을 가지지 아니하므로 참고자료로만 활용하시기 바랍니다.

요청대상 행위

■ 금융회사가 계열사인 해외법인*으로부터 수탁한 정보처리시스템 운영업무를 수행하기 위하여 금융회사의 내부업무를 위한 통신망과 수탁업무를 위한 통신망을 물리적으로 분리하는 등 독립적으로 원격접속 환경을 구성하는 경우 전자금융감독규정 제15조제1항제5호를 반드시 준수해야 하는지 여부

* 해당 법인이 소재한 국가는 국내 전자금융감독규정과 같이 금융회사 등의 내부통신망을 인터넷 등 외부통신망으로부터 분리 · 차단할 것을 요구하는 별도 규제 등이 부재

판단

■ 아래 내용을 참고하시기 바랍니다.

판단이유

■ 「전자금융감독규정」은 「전자금융거래법」 및 동법 시행령에서 금융위원회에 위임한 사항과 그 시행에 필요한 사항 및 다른 법령에 따라 금융감독원의 검사를 받는 기관의 정보기술부문 안전성 확보 등을 위하여 필요한 사항을 규정함을 목적으로 하고 있고,

- 「전자금융거래법」 제3조제1항은 다른 법률에 특별한 규정이 있는 경우를 제외하고 모든 '전자금융거래'에 이 법을 적용하도록 하고 있으며,
- 동법 제2조제1호는 '전자금융거래'를 '금융회사 또는 전자금융업자'가 전자적 장치를 통하여 금융상품 및 서비스를 제공하고, 이용자가 금융회사 또는 전자금융업자의 종사자와 직접 대면하거나 의사소통을 하지 아니하고 자동화된 방식으로 이를 이용하는 거래로 정의하고 있습니다.
- 또한, 동법 제21조제2항은 전자금융거래의 안전성 확보를 위해 금융회사 및 전자금융업자가 전자금융업뿐만 아니라 일반 정보기술(IT)부분 업무에 대해서도 일정한 기준을 준수하도록 규정하고 있습니다.(법령해석 200337)

■ 문의하신 사실관계 하에서 귀사에 정보처리시스템 운영업무를 위탁하려는 해외법인은 「전자금융거래법」 제2조 제3호 및 제4호에서 정하고 있는 '금융회사'와 '전자금융업자'에 각각 해당하지 않고,
- 귀사가 해외법인으로부터 수탁하는 업무는 귀사 자신의 전자금융업무 또는 금융회사로써 수행하는 일반 정보기술(IT)부분 업무에도 해당하지 않는 것으로 보이므로,
- 해당 수탁업무 수행을 위한 정보처리시스템과 귀사의 전자금융업무 수행을 위한 정보처리시스템이 물리적으로 분리*되고 상호 독립적으로 운영되는 등 해당 수탁업무의 수행이 귀사가 제공하는 전자금융거래의 신뢰성 · 안전성 확보에 어떠한 영향도 주지 않는다면,
  * 단말 및 통신 인프라(회선, 스위치 등)를 포함한 전체 네트워크 구성을 물리적으로 분리
- 귀사가 해외법인으로부터 수탁하는 업무를 수행하기 위한 원격접속 환경에 한하여 「전자금융거래법」 제21조 제2항에 따른 안전성 확보 기준 중 하나인 「전자금융감독규정」 제15조제1항제5호의 준수대상이 아닌 것으로 판단됩니다.

※ 비조치의견서('22.09.23.)-220042

비조치의견서는 행정해석의 일종으로 최종 법적구속력은 없으며, 유권해석과는 달리 특정행위에 대해 해당 회사의 상황을 고려한 검토결과로써 일반적 효력을 가지지 아니하므로 참고자료로만 활용하시기 바랍니다.

요청대상 행위

■ 금융회사가 그룹 내 계열사가 공동으로 사용하는 그룹웨어*를 외부 클라우드컴퓨팅서비스(SaaS) 형태로 이용하기 위하여,
  * Microsoft Teams, Zoom, 리모트 미팅, 카카오워크 등
- 금융회사의 내부 업무용단말기로 전용선 · VPN이 아닌 공중망을 통해 클라우드서비스 제공자의 정보처리시스템에 접속하는 것이 가능한지 여부
- 클라우드서비스 제공자의 정보처리시스템이 「전자금융감독규정」 제15조 제1항 제3호의 적용 대상인지 여부

판단

■ 질의하신 내용에 대해 현행 법규를 기준으로 판단한 내용은 아래와 같으니 참고하시기 바랍니다.
- 다만, '금융분야 망분리 및 클라우드 규제개선 관련 FAQ('22.6월)'에 따르면 금융거래와 무관하고 고객거래 정보를 다루지 않는 비중요업무에 대한 SaaS 형태의 클라우드컴퓨팅서비스 사용의 경우 '23년 초 규제 샌드박스를 통해 일괄적으로 망분리 예외조치 허용 예정임을 안내드립니다.

판단이유

- 금융회사는 내부 업무용시스템을 클라우드서비스 제공자 구간에 위치한 정보처리시스템에 연결하는 경우 전용회선 또는 전용회선과 동등한 보안수준을 갖춘 가상의 전용회선(VPN 등)을 사용해야 합니다('금융분야 클라우드 컴퓨팅서비스 이용 가이드').
  - 귀사가 내부 업무용단말기로 클라우드서비스 제공자 구간에 위치한 정보처리시스템에 연결하는 것은, 망분리 대체정보보호통제를 준수하고 전용회선 또는 전용회선과 동등한 보안수준을 갖춘 가상의 전용회선(VPN 등) 사용하는 등 관련 법규 및 가이드라인을 준수할 경우 접속 가능함을 안내드립니다.

- 금융회사는 내부통신망과 연결된 내부 업무용시스템을 인터넷 등 외부통신망과 분리 · 차단 및 접속 금지해야 하고(「전자금융감독규정」 제15조 제1항 제3호), 금융위원회 법령해석 회신문(150359)에 따르면 외부통신망(클라우드서비스 제공자 구간 등)에 위치한 정보처리시스템이 금융회사의 내부통신망에 연결될 경우 「전자금융감독규정」 제15조 제1항 제3호의 적용대상에 해당합니다.
  - 따라서, 클라우드서비스 제공자의 정보처리시스템이 귀사의 내부통신망과 연결될 경우 「전자금융감독규정」 제15조 제1항 제3호의 적용대상에 해당합니다.

※ 법령해석('15.12.7.)-150359

질의

- 외부통신망에 위치한 보험설계사 및 GA대리점 사용 단말기의 경우에도 「전자금융감독규정」 제15조제1항제3호에 따라 인터넷 등 외부통신망과 분리 · 차단 및 접속금지 하여야 하는 대상에 해당되는지 여부

- 이 경우, 보험설계사 및 GA대리점 단말기에 대해 VPN을 통해 인증된 사용자에 한하여 접속하도록 하고 일부 사이트(타 보험사 홈페이지 및 일부 포털 등)에 한하여 제한적으로 외부망 접근을 허용한 경우 망분리를 준수하고 있다고 판단할 수 있는지 여부

회신

- 외부통신망에 위치한 보험설계사 및 GA대리점 사용 단말기가 업무 처리 등을 위해 보험회사의 내부통신망에 연결되어 있는 경우 「전자금융감독규정」 제15조제1항제3호의 망분리 적용대상에 해당합니다.
  - 다만, 보험설계사나 외주직원의 단말기가 내부망과 분리된 망(DMZ 등)에 위치한 시스템에만 접속하는 경우에는 망분리 적용대상에 포함되지 않습니다.

- 제한적이라 할지라도 보험회사의 내부망에 연결되어 있는 단말기에 외부망 접근을 허용하는 것은 망분리 원칙을 위배하고 있는 것으로 보이며, 해당 단말기는 보험회사의 본점 · 영업점 단말기 수준의 망분리 기준에 적합하도록 운영되어야 할 것입니다.

이유

- 보험설계사 및 GA대리점은 「보험업법」에 따라 보험계약의 체결을 대리하는 등의 업무를 수행하고 있으며 이에 따라 보험회사의 영업점과 같이 내부 업무용시스템에 접속하여 업무를 처리할 필요가 있을 것으로 판단되는바,
  - 이러한 범위 내에서 해당 단말기는 「전자금융감독규정」 제15조제1항제3호의 '내부통신망과 연결된 내부 업무용 시스템'에 해당되어 망분리 적용대상입니다.

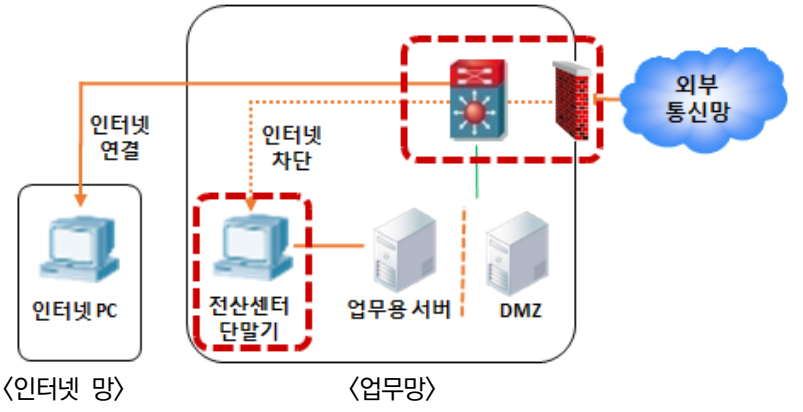
■ 보험설계사 및 GA대리점 사용단말기가 내부통신망에 연결되어 있는 경우 사실상 보험회사의 본점 · 영업점 단말기 역할을 수행하는 것으로 판단되므로 그와 동일한 수준의 보안통제가 필요할 것입니다.
  • 특히, 해당 단말기에서 보험회사 내부 전산망 이외에 외부 인터넷망을 동시에 사용하는 경우 악성코드 전파 등 비인가 접속 가능성이 있으므로 보험회사의 망분리 정책을 따르는 것이 적정합니다.

조치 사례('22.3.7.)

- 전자금융업자는 내부통신망과 연결된 내부 업무용시스템을 인터넷(무선통신망 포함) 등 외부통신망으로부터 분리하여야 하는데도(전자금융감독규정 제7조, 동 규정 제15조제1항제3호),
- ○○회사는 내부통신망에 연결된 본사 임직원의 업무단말기를 일부 외부통신망과 분리 · 차단하지 않고 접속한 상태로 운영한 사실로 지적받음

(2) 전산센터 망분리

- ① 전산센터 내에 위치한 정보처리시스템 및 ② 해당 정보처리시스템의 운영, 개발, 보안 목적으로 정보처리시스템(서버)에 직접 접속하는 단말기(전산센터 단말기)는 인터넷 등 외부통신망과 물리적으로 분리해야 함 (제1항제5호)
- 이에 소위 '물리적 망분리'라고 칭하기도 함. 물리적 망분리란 통신회선을 업무용과 인터넷용으로 물리적으로 분리하고 별도 단말기를 사용하여야 하는 것으로 방화벽 정책 설정만으로 분리하는 방식은 물리적 망분리라고 할 수 없음
  - 또한, 단일 단말기에서 가상화 솔루션을 이용하여 망을 분리한 경우에도 물리적 망분리라고 할 수 없음*(그림)



[그림] 방화벽 정책만을 이용한 전산센터 단말기의 망분리

* 내부망에서 서버 가상화를 이용하여 생성한 가상 운영서버를 DMZ구간에 할당하여 공개용 웹서버로 사용(비조치의견 240013), 네트워크가 분리된 두 개의 가상PC(전산센터 단말기(VDI), 인터넷 접속 단말기(VDI))를 연결하여 사용(비조치의견 230078)

- 내부망 내에서도 망분리를 완료한 시스템과 망분리 예외가 허용되어 외부통신망과 연결된 시스템이 같은 네트워크에 있는 경우, 외부통신망과 연결된 시스템을 통해 내부망에 악성코드 유입 등이 발생할 수 있으므로,
  - 물리적 망분리를 적용한 시스템과 외부통신망과 연결된 시스템 사이는 방화벽 등의 네트워크 장비로 차단필요
- 영업점 내 별도 통제구역에 설치한 단말기를 전산센터 내 정보처리시스템과 전용회선으로 연결하여 직접 접속하는 것은 내부통신망 내에서 발생하는 접속으로 볼 수 있음(비조치의견서 240066)
- 금융회사 내부통신망의 정보처리시스템과 인터넷 등 외부통신망과 분리한 클라우드컴퓨팅서비스를 전용선 또는 VPN으로 연결하는 것은 전산센터의 물리적 망분리 위반에 해당하지 않음 (비조치의견 240045)

※ 비조치의견서('16.8.4.)-160624

비조치의견서는 행정해석의 일종으로 최종 법적구속력은 없으며, 유권해석과는 달리 특정행위에 대해 해당 회사의 상황을 고려한 검토결과로써 일반적 효력을 가지지 아니하므로 참고자료로만 활용하시기 바랍니다.

요청대상 행위

- 전산센터 내에 정보처리시스템을 운영, 개발 및 보안 등을 위해 직접 접속하는 전산센터 (중요)단말기를 가상PC(VDI)로 구성하여 운영할 경우 물리적 망분리 요건을 충족하는지 여부

판단

- 정보처리시스템의 운영, 개발, 보안 목적으로 직접 접속하는 단말기(이하 '전산센터 단말기')를 가상PC(VDI)로 구성하는 것은 전산센터 단말기를 외부통신망으부터 물리적으로 분리한 것으로 볼 수 없어 관련 규정을 준수하지 못한 것으로 보입니다.

판단이유

- 금융회사는 정보처리시스템 등의 해킹 방지를 위해 전산실 내에 위치한 정보처리시스템 및 전산센터 단말기를 외부통신망으로부터 물리적으로 분리하여야 하나(전자금융감독규정 제15조 제1항 제5호),
  - 전산센터 단말기와 외부통신망 및 내부 업무용시스템과의 연결구간을 각각 차단한 경우 등 예외 사유에 해당할 경우 관련 규정에 따라 물리적으로 분리하지 않을 수 있습니다(동 규정 시행세칙 제2조의2 제2항 제4호).
- 전산센터 단말기를 내부 업무용시스템에 연결하여 가상PC(VDI)를 구성하면 동일한 단말기에서 전산실 내 정보처리시스템과 내부 업무처리시스템에 대한 접근이 가능해집니다.
  - 물리적 망분리는 별도의 회선과 단말기를 사용하는 것이므로 가상PC(VDI)를 구성하여 하나의 단말기로 내부 업무용시스템과 전산실 내 정보처리시스템에 접근 가능할 경우 동 단말기는 물리적으로 분리된 것으로 보기 어려우며,
  - 전산센터 단말기를 가상PC(VDI)로 구성하는 것은 내부 업무용시스템과의 연결 구간을 방화벽으로 차단한 것과 같은 것으로 보기에는 아직까지 충분히 실증되었다고 보기 어려우므로 물리적 망분리 예외에 해당하지는 않는 것으로 해석됩니다.

※ 비조치의견서('24.03.24.)-240013

비조치의견서는 행정해석의 일종으로 최종 법적구속력은 없으며, 유권해석과는 달리 특정행위에 대해 해당 회사의 상황을 고려한 검토결과로써 일반적 효력을 가지지 아니하므로 참고자료로만 활용하시기 바랍니다.

요청대상 행위

- 내부망에서 서버 가상화를 이용하여 생성한 가상 운영서버를 DMZ구간에 할당하여 공개용 웹서버로 사용하는 것이 전자금융감독규정 제17조제1항제1호에 위반하는지 여부

판단

- 아래 내용을 참고하시기 바랍니다.

판단이유

- 「전자금융감독규정」 제17조제1항제1호는 공개용 웹서버를 내부통신망과 분리하여 내부통신망과 외부통신망 사이의 독립된 통신망(이하 "DMZ구간")에 설치하고 네트워크 및 웹 접근제어 수단으로 보호하도록 하였으며,
  - 동규정 제15조제1항제5호는 전산실 내에 위치한 정보처리시스템과 해당 정보처리시스템의 운영 목적으로 직접 접속하는 단말기에 대하여 인터넷 등 외부통신망으로부터 물리적으로 분리하도록 하고 있습니다.
- 상기 규정에 비추면 전산실 내에 위치한 내부 서버는 인터넷 등 외부통신망*에 대하여 물리적으로 분리하여야 하므로,
  * DMZ구간은 외부통신망에 해당(전자금융감독규정시행세칙 제2조의2제2항제2호나목)
  - 문의하신 사실관계 하에서 귀사의 가상 운영서버 구성은 규정에 위반하는 것으로 보입니다.

※ 비조치의견서('24.09.05.)-240066

비조치의견서는 행정해석의 일종으로 최종 법적구속력은 없으며, 유권해석과는 달리 특정행위에 대해 해당 회사의 상황을 고려한 검토결과로써 일반적 효력을 가지지 아니하므로 참고자료로만 활용하시기 바랍니다.

요청대상 행위

- 금융회사가 IT직원의 상주 근무를 목적으로 영업점에 물리적 통제를 적용한 별도공간을 마련하여 정보처리시스템에 운영, 개발, 보안 목적으로 직접 접속하는 단말기를 설치하고, 해당 단말기와 전산센터를 전용회선으로 연결하는 등 본점수준의 통제를 적용하는 경우 「전자금융감독규정」 제15조제1항제5호에 위반하는지 여부

판단

- 아래 내용을 참고하시기 바랍니다.

판단이유

- 「전자금융감독규정」 제15조제1항제5호는 전산실 내에 위치한 정보처리시스템과 해당 정보처리시스템의 운영, 개발, 보안 목적으로 직접 접속하는 단말기에 대해서는 인터넷 등 외부통신망으로부터 물리적으로 분리하도록 하고 있습니다.
- 문의하신 사실관계 하에서 귀사가 영업점 내 별도 통제구역에 설치한 단말기를 전산센터 내 정보처리시스템과 전용회선으로 연결하여 직접 접속하는 것은 본점의 접속환경과 마찬가지로 내부통신망 내에서 발생하는 접속으로 보이고,
  - 해당 단말기를 외부통신망과 물리적으로 분리하는 등 본점에 위치한 단말기와 동일한 수준의 통제를 적용한다면 「전자금융감독규정」 제15조제1항제5호에 위반하지 않는 것으로 보입니다.
    ※ 동 의견서는 개별 금융회사의 업무환경 및 구체적인 사실관계에 따라 달리 적용될 수 있습니다.

※ 비조치의견서('24.7.8.)240045

비조치의견서는 행정해석의 일종으로 최종 법적구속력은 없으며, 유권해석과는 달리 특정행위에 대해 해당 회사의 상황을 고려한 검토결과로써 일반적 효력을 가지지 아니하므로 참고자료로만 활용하시기 바랍니다.

요청대상 행위

■ 금융회사가 내부통신망에 위치한 정보처리시스템과 외부통신망에 위치한 클라우드컴퓨팅서비스*를 전용선 또는 VPN으로 연결하여 이용하는 것이 전자금융감독규정 제15조제1항제5호 위반인지 여부

* 클라우드컴퓨팅서비스(IaaS) 제공자 구간의 내부망 정보처리시스템은 인터넷 및 외부기관과 통신망을 분리하고, 고유식별번호 및 개인신용정보를 처리하지 않음

- 클라우드컴퓨팅서비스 제공자 구간의 정보처리시스템에 연결된 통신망을 인터넷 등 외부기관과 분리한 방식(논리적/물리적)에 따라 위반여부가 달라지는지 여부
- 클라우드컴퓨팅서비스 제공자 구간의 정보처리시스템에서 처리하는 업무(비중요/중요)에 따라 위반 여부가 달라지는지 여부

판단

■ 아래 내용을 참고하시기 바랍니다.

판단이유

■ 전자금융감독규정 제15조제1항제5호는 전산실 내에 위치한 정보처리시스템과 해당 정보처리시스템의 운영, 개발, 보안 목적으로 직접 접속하는 단말기에 대해서는 인터넷 등 외부통신망으로부터 물리적으로 분리할 것(이하 "물리적 망분리")을 규정하고 있고,

- 전자금융감독규정 제14조의2제8항은 동조 제1항의 절차를 거친 클라우드컴퓨팅서비스 제공자의 정보처리시스템이 위치한 전산실에 대하여 물리적 망분리 규정의 적용을 예외로 하고 있습니다.

■ 문의하신 사실관계 하에서 귀사가 내부통신망에 위치한 정보처리시스템을 인터넷 등 외부통신망으로부터 물리적 방식 외의 방법으로 분리차단한 귀사 전용 클라우드컴퓨팅서비스와 전용선 또는 VPN으로 연결하는 것은 「전자금융감독규정」 제15조제1항제5호에 위반하지 않습니다.

- 다만, 인터넷에 연결되지 않더라도 귀사의 클라우드가 귀사의 통제범위를 벗어난 영역과 연결되거나 내부 사용자가 아닌 제3자 등의 접속을 허용하는 경우에는 외부통신망과 분리차단 및 접속금지 조치하였다고 볼 수 없으므로 동 규정에 위반합니다.
- 「전자금융감독규정」 제14조의2제8항에 따르면 클라우드컴퓨팅서비스 제공자의 정보처리시스템은 인터넷 등 외부통신망에 대한 물리적 망분리 규정을 적용받지 않아 방화벽 설치 등의 적정한 방법으로 망을 분리(논리적)할 수 있으므로 분리 방식에 따라 위반여부가 달라지지 않습니다.
- 「전자금융감독규정」 제15조제1항제5호는 클라우드컴퓨팅서비스 제공자 구간의 정보처리시스템에서 처리하는 업무가 비중요업무 혹은 중요업무인지에 따라 다르게 적용되지 않습니다.

● 망분리 예외 사유에 해당하는 경우 외부통신망과 연결이 허용될 수 있음(제1항 제5호 각 목, 시행세칙 제2조의3)

- 다만, 금융회사 또는 전자금융업자가 자체 위험성 평가를 실시한 후 별표 7에서 정한 망분리 대체 정보보호통제를 적용하고 정보보호위원회가 승인한 경우에 한하여 예외로서 허용(시행세칙 제2조의3 제3항)

〈전산센터 망분리 예외 사유〉

- 이용자의 고유식별정보 또는 개인신용정보(「신용정보의 이용 및 보호에 관한 법률」 제40조의2에 따른 가명처리에 관한 행위규칙을 준수한 가명정보는 제외)를 처리하지 않는 연구 · 개발 목적의 경우(단, 금융회사 또는 전자금융업자가 자체 위험성 평가를 실시한 후 금융감독원장이 정한 망분리 대체 정보보호통제를 적용하고 정보보호위원회가 승인한 경우에 한함)(제1항제5호가목)
  - 개발 환경 개선을 위하여 가명처리된 개인신용정보 활용이 허용되고, 연구 · 개발망을 통한 IT개발자 등의 재택근무가 가능할 수 있음
    ※「금융분야 망분리 개선 로드맵 연구·개발망 관련 Q&A」 참고
- 「금융회사의 정보처리 업무 위탁에 관한 규정」에 따라 정보처리 업무를 국외 소재 전산센터에 위탁하여 처리하는 경우(다만, 해당 국외 소재 전산센터에 대해서는 물리적 방식 외의 방법으로 망을 분리하여야 하며, 이 경우에도 국내 소재 전산센터 및 정보처리시스템 등은 물리적으로 망을 분리하여야 함)(시행세칙 제2조의3제2항제1호)
- 업무상 외부통신망과 연결이 불가피한 정보처리시스템(다만, 필요한 서비스번호(port)에 한하여 연결할 수 있다)(시행세칙 제2조의3제2항제2호 각 목)
  - 업무상 외부통신망과 연결이 불가피한지 여부는 망분리 환경에서 전자금융업무 처리가 불가능하거나 현저히 곤란한 경우를 의미하고, 업무 수행은 가능하나 불편 등을 개선하기 위한 경우는 포함되지 않음(비조치의견서 170012, 240014, 240041)
  - 금융지주회사의 계열사인 금융회사가 동일 지주회사의 타 계열사와 공동으로 사용하는 전자문서 시스템은 망분리의 예외사유에 해당(비조치의견서 190022)
- 감독규정 제23조의 비상대책에 따라 원격 접속이 필요한 경우(시행세칙 제2조의3제2항제3호)
  - 시스템 개발 목적으로 전산실 내에 위치한 정보처리시스템에 원격접속하는 것은 긴급한 상황*에서 업무지속성 확보를 위한 비상대책 이행시에만 가능 (비조치의견서 230111)
    * 긴급한 상황이라 함은 단순오류 수정, 일괄배치 오류 등 통상적인 오류상황이 아닌 시스템 혹은 서비스에 중대한 영향을 초래할 수 있는 심각한 오류 상황에 한정
  - 비상대책은 장애 · 재해 · 파업 · 테러 등 긴급한 상황 발생에 대비한 것으로 펌웨어 업그레이드 등 일상적인 상황에서의 정보처리시스템 유지보수 업무, 형상관리 업무 등은 비상대책에 포함되지 않음(비조치의견서 170107, 240040)
- 전산실 내에 위치한 정보처리시스템의 운영, 개발, 보안 목적으로 직접 접속하는 단말기와 외부통신망과의 연결 구간, 규정 제15조제1항제3호의 내부 업무용 시스템과의 연결 구간을 각각 차단한 경우(시행세칙 제2조의3제2항제4호)
  - DMZ 내 웹서버 운영을 위한 접속 등 업무상 불가피한 경우에 한정하여 물리적 망분리 적용 예외 가능

〈참고: 금융분야 망분리 개선 로드맵 연구 · 개발망 관련 Q&A〉

1 연구·개발망 일반

1. 연구 · 개발분야 주요 개선 내용은?

1 (망분리 예외 허용) 연구·개발망과 내부업무망간 논리적 망분리를 허용하고, 소스코드 등 연구·개발 결과물의 망간 이동 편의 확대

- (연구 · 개발망 ↔ 내부업무망[1])논리적 방식으로 망분리 가능
- (연구 · 개발망 → 전산실[2]) 개발산출물 등 망간 전송 허용(필수적인 경우 한정)

1) 내부업무망(3호망): 내부통신망과 연결된 내부 업무용 시스템(「전자금융감독규정 제15조1항3호」)
2) 전산실(5호망): 전산실 내 위치한 정보처리시스템과 해당 정보처리시스템의 운영, 개발, 보안목적으로 직접 접속하는 단말기(「전자금융감독규정 제15조1항5호」)

● **(강화된 보안대책 마련)** 망분리 예외 허용에 따른 강화된 보안대책 마련*

* 「전자금융감독규정 시행세칙」 [별표7] 망분리 대체 정보보호통제의 연구·개발 참고

2 (가명정보 허용) 개인신용정보를 가명 처리**한 개인신용정보에 한정하여 연구 · 개발망에서 활용 가능

** 「신용정보의 이용 및 보호에 관한 법률」에 따른 행위 규칙 준수 및 「금융분야 가명·익명처리 안내서」를 참고하여 안전한 방법으로 처리 필요

3 (재택근무 허용) 연구·개발망을 통한 IT개발자 등의 재택근무 가능

2. 연구 · 개발망이란?

■ 프로그램 개발 등 금융서비스의 연구·개발을 할 수 있도록 금융회사 등의 내부업무망, 전산실, 외부망으로부터 독립적으로 구성된 망

구분	내부업무망(3호망)	전산실(5호망)	연구·개발망	인터넷망
규제 내용	인터넷 등 외부 통신망과 분리 ·차단 및 접속금지	인터넷 등 외부 통신망과 물리적 분리(물리적 망분리)	망분리 예외 적용시 인터넷 접속 허용	인터넷 접속 허용
수행 업무	문서 작성, 인트라넷 접속, 민원 등 사무 업무	운영, 개발, 보안 관련 업무	개발(코딩, 테스트) 및 AI, SaaS 활용을 위한 연구 · 개발	인터넷 검색, e-mail 확인 등

3. 연구 · 개발망의 망분리 예외 적용 방법은?

- 금융회사 등의 물적 · 인적 요소 및 보안요소*를 고려하여 정보보호위원회 개최 등의 절차를 통해 선정한 업무에 한정하여 연구 · 개발망 예외 가능

  * 보안 역량, 보호 필요성, 외부망 연결 위험성 등

※ 연구 · 개발환경 구축 절차
① 자체 위험성 평가 실시
② 정보보호통제 및 추가 보안대책 적용
☞ [참고] 「전자금융감독규정 시행세칙」 [별표 7] 망분리 대체 정보보호통제 참고
③ 정보보호위원회 의결

※ 상세 구축 절차는 「연구 · 개발 목적의 망분리 예외 적용에 따른 보안 해설서」 참고

4. 연구 · 개발망에서 수행 불가한 업무는?

- 원칙적으로 연구·개발 목적 외 대고객 금융서비스, 임직원 대상 업무 처리 서비스 등 실제 업무를 처리하는 것은 불가
  - 특히, 베타 테스트 등 대고객을 대상으로 대외에 오픈되는 서비스 및 내부 보고서 작성 등 대외보안이 필요한 업무는 연구·개발망에서 수행 불가

5. 망분리 예외 적용 시 연구 · 개발망을 통해 접근 불가한 사이트는?

- 유해 사이트 및 연구·개발 목적 외 SaaS 등은 연구·개발망에서 접근 불가
  - 금융회사 등은 자사의 업무 환경 등을 고려하여 망분리 예외 적용으로 예상되는 보안 위협*을 자율 판단하여 인터넷 접근통제 대책을 마련 후 적용할 필요

    * SaaS(Software as a Service) 제공자 외부 해킹, 협업 도구를 통한 내부정보 유출 등

2 연구·개발망 구성

1. 연구 · 개발망과 전산실(5호망)은 반드시 물리적 망분리를 해야 하는지?

- 연구·개발망은 물리적 망분리 예외에 해당하나, 연구·개발 목적 이외 기존과 동일한 망분리 규제가 적용되므로,
  - 전산실에 위치한 정보처리시스템*은 연구·개발망과 물리적으로 분리 필요

    * 다만 소스코드 등 연구·개발 결과물에 한정하여 연구·개발망→전산실 망간 전송 허용

2. 연구 · 개발망 구성 시 구성 방법에 대한 구체적인 방식이 정해져 있는지?

- 연구·개발망은 내부업무망, 전산실, 외부망으로부터 모두 독립적으로 구성된 별도의 네트워크망으로서,
  - 연구·개발망 구성 시 내부업무망, 전산실과 분리는 엄격히 하되, 구체적인망 구성 방식은 금융회사 등이 자율적으로 구성 가능
  - 다만, 클라우드 환경에 연구 · 개발망을 구축할 경우 「전자금융감독규정」에서 정한 클라우드 이용 관련 사항 준수 필요

3. 연구 · 개발망에서 외부망의 SaaS 서비스나, Github 등과 직접 통신 및 사용이 가능한 것인지?

- 연구·개발 목적으로 망분리 예외 적용 시 인터넷 접속이 상시 허용됨에 따라 SaaS, Github를 통한 오픈소스 활용 가능
  - 다만 중요 소스코드 유출* 등 보안사고 발생에 대한 대응 절차 마련이 필요하며,

    * 소스코드 깃허브 등 공유 플랫폼에 무단 게시, 연구·개발망 모니터링 과정에서 유출 사실 확인, 퇴사 직원이 중요 소스코드를 무단 반출 등

  - 오픈소스를 통한 악성코드 유입**을 막기 위해 외부망에서 연구·개발망으로 전송되는 자료 대상으로 악성코드 감염 모니터링 등 정보보호통제 적용 필요

    ** 고의적으로 오픈소스 내부에 악성코드를 삽입하여 오픈소스 적용 시 프로그램의 민감정보를 획득하는 SW 공급망 공격 등

4. 자체 안전성 평가 및 보안대책을 적용한 이후 연구 · 개발망을 무선망으로 구성 가능한지?

- 「전자금융감독규정」 제15조 제6항 준수 및 사용자 인증 등 보안대책 적용 후 연구 · 개발망에서 무선통신망 활용 가능
  - 다만 전산실 내 설치되는 개발 관련 시스템 등은 무선통신망 접속차단 필요

5. 연구 · 개발망에서 내부업무망의 백신, DLP, DRM 등 보안솔루션, 관리서버를 같이 사용해도 되는지?

- 연구·개발망은 전자금융업무 시스템 등이 위치하는 금융회사 등의 내부 업무망과 분리하여 독립된 인프라로 구성·운영되어야 하므로,
  - 내부 업무망에서 활용 중인 자원을 연구 · 개발망과 연동하여 사용 불가

3 연구 · 개발 망간 전송

1. (연구 · 개발망 → 전산실) 망간전송 허용 등에 따른 개발산출물은 무엇을 의미하는지?

- 소스코드 등 연구·개발 목적으로 필요한 산출물로서 정보처리시스템 배포 등에 필요한 연구·개발 산출물을 의미

  * 사업수행계획서, 요구사항정의서, 화면설계서, 시험계획서 등 연구·개발 관리 및 수행산출물 등은 범위에서 제외

2. (연구 · 개발망 → 내부업무망) 망간 자료 전송이 가능한지?

- 망간 자료 전송*(연구·개발망 → 내부업무망)이 가능하며, 자료 전송과정에서 침해행위로 인한 사고를 방지하기 위한 통제 절차 적용**필요

  * 구체적인 방식은 금융회사 등이 자율적으로 구성
  ** 주 시스템과 분리된 환경(샌드박스 등)에서 악성코드 검사, 본문 변환(외부 링크, 스크립트, eml태그 등 제거), 이미지파일 등 침해 위협이 없는 파일을 제외한 첨부파일 제거 등
  ※ 다만, 망간자료전송 방식 중 스트리밍 방식은 불가(비조치의견서 240035, 180014, 170060)

3. (연구·개발망 → 전 산실) 개발산출물 전송 시 전송 채널 및 방법에 대한 구체적인 방식이 정해져 있는지?

- 인가된 서버(형상관리 역할을 하는 서버)만 전산실에 접속할 수 있도록 통제하고, 망간 자료전송에 대한 구체적인 방식은 금융회사 등이 자율적으로 구성 가능
  - 다만 자료전송 과정에서 악성코드 감염 모니터링, 시큐어코딩 점검 및 소스코드 무결성 검증 등 보호대책* 적용이 필요하며,
    * 취약한 전송 프로토콜 및 원격접속 프로토콜 사용 제한, 데이터 이동 내역 및 망분리 예외 정책 설정 사항 감사 등
  - **(전산실 → 연구 · 개발망)** 개발산출물 반출은 업무상 불가피한 경우에 한정하여 CISO 승인 및 정보보호위원회 의결 후 반출 허용

※ 다만, 망간자료전송 방식 중 스트리밍 방식은 불가(비조치의견서 240035, 180014, 170060)

> ※ 비조치의견서(180014)
> 내 · 외부망 간 실시간 데이터 연계가 가능한 스트리밍 방식의 경우 외부통신망과의 분리 · 차단 및 접속금지의 의무를 규정한 망분리 취지에 부합하지 않음

4 연구 · 개발망 원격 접속

1. (외부망 → 연구 · 개발망) 금융회사가 정보처리시스템 개발업무를 수행하기 위해 연구 · 개발망에 개발시스템을 두고 원격접속을 통해 개발업무를 원격으로 수행 가능한지?

- 외부 인터넷 환경(재택 및 해외 등)에서 연구·개발망 원격접속에 한정하여 연구·개발업무 수행 가능
  - 다만 「금융회사 재택근무 보안안내서」에 준하는 수준의 보안 환경을 갖춘 후 금융회사의 내부 환경에 따라 접속 방식*을 선택하여 운용 필요
    * [직접 접속] 외부 단말기에서 연구·개발망에 직접 접속 (가상사설망 등 활용)
      [간접 접속] 외부 단말기에서 회사 내부의 업무용 단말기를 경유하여 연구·개발망에 접속(VDI 방식, 원격접속 프로그램 방식 등 활용)

※ 서비스 지원이 종료된 원격 접속 프로그램은 사용 불가하며, MS社의 RDP(Remote Desktop Protocol)등 취약점이 지속 발표되고 있는 프로토콜을 사용하는 소프트웨어는 미사용 권고

2. (외부망 → 연구·개발망) 오피스 내 인터넷 환경에서 VPN 터널링을 통해 연구·개발망 연결 시에도 원격 접속으로 해석해야 하는지?

- 인터넷 환경(외부망)에서 VPN 터널링을 통해 연구·개발망 접속 시 원격접속에 해당

5 연구 · 개발망 가명정보 활용

1. 연구 · 개발망에서 가명정보 활용시 유의해야 할 점은?

■ 가명정보 관련 법령을 준수해야 하며, 연구·개발 목적으로만 가명정보 활용 가능

※ 가명정보 관련 법령
① 「전자금융감독규정」 제14조의2(클라우드컴퓨팅 서비스 이용절차 등) 제7항
② 「신용정보의 이용 및 보호에 관한 법률」 제32조(개인신용정보의 제공 · 활용에 대한 동의)제6항 9의2 등
③ 「개인정보보호법」 제28조의8(개인정보의 국외 이전)등

※ 가명정보 활용시 「전자금융감독규정」, 「개인정보보호법」에 따른 국외 이전 제한에 대해 유의할 필요

■ 안전한 가명정보의 활용을 위해 「신용정보의 이용 및 보호에 관한 법률」 제40조의2 가명 · 익명처리에 대한 행위규칙 준수 필요

● 가명정보 이용시 가명정보에 관한 보호조치 기준에 따라 기술적·물리적·관리적 보호조치 후 이용(「신용정보업감독규정」 [별표 8] 가명정보에 관한 보호조치 기준 참고)

2. 연구 · 개발망에서 가명정보 사용시 특정 개인을 알아볼 수 있게 된 경우 어떻게 해야 하는지?

■ 가명정보를 회수하여 처리를 중지하고, 특정 개인을 알아볼 수 있게 된 정보는 즉시 삭제 처리

6 서비스·기획 업무 활용

1. 연구 · 개발망에서 개발을 위한 서비스 기획 및 설계 업무도 가능한지? (스토리보드나 Figma 등 활용)

■ 연구·개발망에서 서비스 기획·설계 등 연구·개발 외의 업무 처리는 원칙적*으로 불가

* 금융회사 등의 내부정보 유출 등 내부 전산 자료를 보호하는 취지에서 서비스 기획·설계 등의 업무는 기존의 내부망을 활용

● 다만 연구·개발망에서 기획 · 설계(문서편집기 포함)업무 수행이 불가피한 경우에 한해서 보안대책을 마련하고 정보보호위원회 승인 후 한시적 사용 가능

2. 연구 · 개발망에서 문서편집기(워드프로세서 등) 사용이 가능한지?

- 연구·개발망에서 문서편집 업무 수행이 불가피한 경우에 한정하여 정보보호위원회의 승인을 받은 후 한시적으로 사용 가능
  - 문서편집의 경우 금융회사 등의 내부정보가 외부로 유출될 우려가 있어 필수적인 경우에만 제한적으로 사용

3. 연구 · 개발망에서 외부망을 통해 공개된 정보를 주기적으로 수집 · 분석하여 분석된 결과를 내부 업무망으로 전송하고 내부 게시판 등을 통해 직원들에게 공유가 가능한지?

- 연구·개발망 망분리 예외가 적용된 시스템을 통해 연구·개발 목적 외 대고객 금융서비스 등 실제 업무를 처리하는 것은 금지되며,

  (「연구 · 개발 목적의 망분리 예외 적용에 따른 보안 해설서」 참고)
  - 내·외부 이용자를 대상으로 서비스를 제공하는 경우 연구·개발 망분리 예외 적용 불가

※ 비조치의견서('24.3.4.)-240012

비조치의견서는 행정해석의 일종으로 최종 법적구속력은 없으며, 유권해석과는 달리 특정행위에 대해 해당 회사의 상황을 고려한 검토결과로써 일반적 효력을 가지지 아니하므로 참고자료로만 활용하시기 바랍니다.

요청대상 행위

- 금융회사가 연구 · 개발을 목적으로 5호 단말기에서 접속하는 폐쇄형 클라우드를 타 폐쇄형 클라우드와 전용선 또는 VPN으로 연결하고, 연결된 폐쇄형 클라우드에서 제공하는 특정 서비스 API를 연계하여 호출할시 전자금융감독규정 제15조제1항제5호를 위반하는지 여부

판단

- 아래 내용을 참고하시기 바랍니다.

판단이유

- 「전자금융감독규정」 제15조제1항제5호는 전산실 내에 위치한 정보처리시스템과 해당 정보처리시스템의 운영, 개발, 보안 목적으로 직접 접속하는 단말기(이하 "5호 단말기")에 대하여 인터넷 등 외부통신망으로부터 물리적으로 분리할 것을 정하고 있고,
  - 동호가목을 통하여 이용자의 고유식별정보 또는 개인신용정보를 처리하지 않는 연구 · 개발 목적의 경우*는 해당 규정의 적용을 예외하고 있습니다.
    * 단, 일반업무를 위한 내부망과 연구 · 개발망의 물리적 분리를 전제(비조치의견서 230050)

- 문의하신 사실관계 하에서 귀사가 고유식별정보 또는 개인신용정보 처리 없이 소스코드 리뷰 등 연구 · 개발 목적으로 복수의 폐쇄형 클라우드와 5호 단말기를 전용선 및 VPN으로 연결하는 것은 상기 규정에 위반하지 않은 것으로 보이며,
  - 다만, 자체 위험성 평가 실시 후 망분리 대체 정보보호통제* 적용 등 관련 규정을 모두 준수하여 충분한 안전성을 확보하시기 바랍니다.
    * 전자금융감독규정시행세칙 [별표7] 망분리 대체 정보보호통제

※ 비조치의견서('17.12.07.)-170101

비조치의견서는 행정해석의 일종으로 최종 법적구속력은 없으며, 유권해석과는 달리 특정행위에 대해 해당 회사의 상황을 고려한 검토결과로써 일반적 효력을 가지지 아니하므로 참고자료로만 활용하시기 바랍니다.

요청대상 행위

- 파일공유서버를 통해 별도의 승인절차 없이 전산센터 내 정보처리시스템의 운영 · 개발 · 보안 목적으로 직접 접속하는 단말기(이하 '전산센터 단말기')와 논리적으로 망분리된 본점 · 영업점 단말기 간 자료공유가 가능한지 여부

판단

- 파일공유서버를 통한 전산센터 단말기 및 본점·영업점 단말기 간 자료공유는 망분리 예외 사유에 해당하지 않아 허용되기 어렵습니다.

판단이유

- 금융회사는 정보처리시스템 등의 해킹 방지를 위해 전산실 내에 위치한 정보처리시스템 및 전산센터 단말기를 외부통신망으로부터 물리적으로 분리하여야 하며(전자금융감독규정 제15조제1항제5호),
  - 전산센터 단말기와 외부통신망과의 연결 구간, 규정 제15조제1항제3호의 내부 업무용 시스템과의 연결 구간을 각각 차단한 경우에는 예외를 허용하고 있습니다(전자금융감독규정시행세칙 제2조의2제2항제4호).
- 본점 · 영업점 단말기를 외부통신망과 물리적으로 분리하지 않은 상태에서 파일공유서버를 통해 전산센터 단말기와 본점 · 영업점 단말기 간 자료를 공유할 경우 전산센터 단말기와 내부 업무용시스템과의 연결 구간을 차단한 것으로 볼 수 없어 망분리 예외 사유에 해당하지 않습니다.

※ 비조치의견서('24.5.23.)-240041

비조치의견서는 행정해석의 일종으로 최종 법적구속력은 없으며, 유권해석과는 달리 특정행위에 대해 해당 회사의 상황을 고려한 검토결과로써 일반적 효력을 가지지 아니하므로 참고자료로만 활용하시기 바랍니다.

요청대상 행위

- 금융회사가 내 · 외부통신망이 물리적으로 분리된 환경에서 대고객 데이터 요약 서비스* 제공을 위하여 DMZ 구간에 위치한 중계서버를 통해 내부통신망에 위치한 서버와 외부 서비스를 실시간으로 연결하는 것이 전자금융감독규정 제15조제1항제5호 위반인지 여부

  * 금융, 경제 관련 뉴스 등 인터넷에 공개된 정보를 요약하여 고객에게 전달하는 서비스

판단

- 아래 내용을 참고하시기 바랍니다.

판단이유

- 「전자금융감독규정」 제15조제1항제5호는 전산실 내에 위치한 정보처리시스템과 해당 정보처리시스템의 운영, 개발, 보안 목적으로 직접 접속하는 단말기에 대해서는 인터넷 등 외부통신망으로부터 물리적으로 분리할 것을 규정하고 있고,
  - 다만, 「전자금융감독규정시행세칙」 제2조의2는 업무상 외부통신망과 연결이 불가피한 정보처리시스템에 한하여 망분리 적용을 예외로 하고 있습니다.
- 귀사가 DMZ 구간에 위치한 중계서버를 통해 내부망에 위치한 서버와 외부망에 위치한 서비스를 실시간으로 연결하는 것은 전자금융감독규정 제15조제1항제5호에 위반하는 것으로 보입니다.
  - 망분리 적용이 예외 되는 '업무상 불가피한 경우'란 망분리 환경에서 전자금융업무 처리가 불가능하거나 현저하게 곤란한 경우를 의미하며,
  - 문의하신 사실관계 하에서 귀사가 제공하는 서비스는 업무상 불가피하다고 볼 수 없으므로 물리적 망분리 적용 예외에 해당하지 않습니다.

※ 비조치의견서('18.1.26.)-170107

비조치의견서는 행정해석의 일종으로 최종 법적구속력은 없으며, 유권해석과는 달리 특정행위에 대해 해당 회사의 상황을 고려한 검토결과로써 일반적 효력을 가지지 아니하므로 참고자료로만 활용하시기 바랍니다.

요청대상 행위

- 전산센터 내 서버 및 스토리지 등의 장비에 대한 비상 상황에 대처하고 펌웨어 업그레이드 등 유지보수 작업을 위해 해외 벤더사로부터 인터넷(VPN 터널링 연결*)을 통해 원격 지원 서비스를 받을 수 있는지 여부
  * 가상사설통신망(Virtual Private Network)을 통한 암호화 통신

판단

- 장애 · 재해 등 정보처리시스템의 비상 상황에 대처하기 위한 원격 접속은 허용되나, 일상적인 유지보수 작업을 위한 원격 접속은 허용되기 어렵습니다.

판단이유

- 금융회사는 전산실 내에 위치한 정보처리시스템 및 전산센터 단말기를 외부 통신망으로부터 물리적으로 분리하여야 하나, 비상대책에 따라 원격접속이 필요한 경우 망분리 예외를 적용할 수 있습니다 (전자금융감독규정 제15조제1항제5호 및 동규정 시행세칙 제2조의2제2항제3호).
  - 여기서의 비상대책은 장애 · 재해 · 파업 · 테러 등 긴급한 상황 발생에 대비한 것으로 펌웨어 업그레이드 등 일상적인 상황에서의 정보처리시스템 유지보수 업무는 동 비상대책에 포함되지 않는 것으로 보입니다.

(3) 본점 · 영업점 망분리

● 내부통신망과 연결된 업무용 PC 및 프린터 등 주변 기기는 물리적 또는 논리적 방식으로 망분리 (제1항제3호)

- 감독규정 제15조 제1항 제3호의 '외부통신망과의 분리 · 차단'은 통신회선에서의 물리적인 분리에 대한 의무사항을 내포하지는 않음(비조치의견160425)

- 방화벽과 같은 보안장비를 이용하여 통제하더라도 외부망에서 업무망으로 접속할 수 있는 방법이 열려 있을 경우 하나의 솔루션을 인터넷망과 업무망 모두에서 사용하기 위해 네트워크 간 접속이 가능한 경우 망분리 규제 위배(비조치의견 160609)

● 예외 사유에 해당하는 경우 외부통신망과 연결이 허용될 수 있음(제1항 제3호 각 목, 시행세칙 제2조의3)

- 다만, 금융회사 또는 전자금융업자가 자체 위험성 평가를 실시한 후 별표 7에서 정한 망분리 대체 정보보호통제를 적용하고 정보보호위원회가 승인한 경우에 한하여 예외로서 허용(시행세칙 제2조의3 제3항)

〈본점 · 영업점 망분리 예외 사유〉

- 이용자의 고유식별정보 또는 개인신용정보(「신용정보의 이용 및 보호에 관한 법률」 제40조의2에 따른 가명처리에 관한 행위규칙을 준수한 가명정보는 제외)를 처리하지 않는 연구 · 개발 목적의 경우(단, 금융회사 또는 전자금융업자가 자체 위험성 평가를 실시한 후 금융감독원장이 정한 망분리 대체 정보보호통제를 적용하고 정보보호위원회가 승인한 경우에 한한다.)(제1항제3호가목)
- 내부 통신망에 연결된 단말기가 업무상 필수적으로 외부기관과 연결해야 하는 경우(다만, 이 경우 필요한 서비스번호(port)에 한하여 특정 외부기관과 연결할 수 있음)(시행세칙 제2조의3제1항 제1호)
  - '업무상 필수적으로 특정 외부기관과 연결해야 하는 경우'는 망분리 환경에서 업무 수행이 불가능하거나 현저히 곤란하여 불가피하게 내부 업무용시스템을 특정 외부기관에 연결할 필요가 있는 경우를 의미
  - '"해외거래소 공시자료 번역 · 요약 서비스", "내부망에서 지도, 콘텐츠, ChatGPT를 제공하는 Open API를 활용" 등과 같이 단순히 정보 취득 및 취득의 편의를 위한 것, "빅데이터 분석 목적" 등이라면 상기 망분리 적용 예외 사유에 해당하지 않음(비조치의견서 161200, 210041, 230083, 230084).

〈참고〉 특정 외부기관의 범위 (예시)

- 행정안전부, 금융협회, 금융결제원, 예탁결제원, 코스콤, 금융보안원, 공인인증기관 등의 정부 또는 금융유관기관
- 그 외 업무상 연결이 필요한 전자금융보조업자

※ 시행세칙 제2조의3의 취지는 망분리로 인한 업무의 비효율을 완화하고자 일부 필수적인 외부기관과의 연결을 허용하는 것으로, 불특정다수가 접속하는 인터넷 포탈 등은 제한

- 감독규정 제12조의 보안대책을 적용한 단말기에서 전용회선과 동등한 보안수준을 갖춘 통신망을 이용하여 외부망으로부터 내부 업무용시스템으로 원격접속 하는 경우(시행세칙 제2조의3제1항제2호)
  - '감독규정 제12조의 보안대책을 적용한 단말기'를 사용하는 외주직원도 재택근무 가능
  - 전산센터 단말기의 경우 위 사유에 따른 원격접속이 허용되지 않으나, 개발 · 보안 · 운영 업무가 아닌 이메일, 그룹웨어 등의 업무시스템 사용을 목적으로 원격 접속은 가능
  - 원격접속 기술 및 구현 방식은 제한되지 않고 금융회사등 시스템 환경에 따라 관련 기반기술과 방식을 자율적으로 선택하여 이용할 수 있음

- '전용회선과 동등한 보안 수준을 갖춘 통신망'은 가상사설망(VPN) 사용이 권고되나, ①전송 데이터의 기밀성 및 무결성 보장, ②클라이언트 및 서버 인증 처리, ③중간자 공격, 재생 공격을 예방할 수 있는 다른 방식의 암호 통신도 이용 가능

※ 비조치의견서('16.4.14.)-160425

비조치의견서는 행정해석의 일종으로 최종 법적구속력은 없으며, 유권해석과는 달리 특정행위에 대해 해당 회사의 상황을 고려한 검토결과로써 일반적 효력을 가지지 아니하므로 참고자료로만 활용하시기 바랍니다.

요청대상 행위

■ 지점 사용자 망분리 수행 시 지점과 전산센터간 통신회선을 1회선으로 구성하고 회선 양끝 연결을 VPN(내부망, 외부망)으로 구분하여 망분리 구성이 가능한지 여부

1. 통신 회선 : 1회선
2. VPN : 2대(내부망 1대, 외부망 1대)
3. 통신 방법
   - 내부망 : 업무PC → 내부망 VPN(지점) → 통신회선(공용) → 내부망 VPN(전산센터) → 내부시스템
   - 외부망 : 인터넷PC → 외부망 VPN(지점) → 통신회선(공용) → 외부망 VPN(전산 센터) → 인터넷

판단

■ 전자금융감독규정 제15조 제1항 제3호에 따라 내부통신망과 연결된 업무용시스템의 망분리가 이루어진 상태에서, VPN(가상사설망) 장비를 이용하여 하나의 통신 회선에서 내부망과 외부망을 분리하여 사용하는 경우 전자금융감독규정 제15조 제1항 제3호에 의한 망분리 의무 규정에 위배되지 않습니다.

판단이유

■ 지점 단말기는 전자금융감독규정 제15조 제1항 제3호에 따라 내부통신망과 연결된 내부 업무용시스템을 외부통신망과 분리 · 차단하거나 접속을 금지하여야 하며,

- 이와 같은 망분리는 외부통신망과의 분리 · 차단 등을 의미하는 것으로 통신회선에서의 물리적인 분리에 대한 의무사항을 내포하지는 않습니다.

■ 다만, 하나의 통신 회신에서 VPN 장비로 내 · 외부망을 분리할 경우 내부 업무용시스템을 외부통신망으로부터 분리하기 위한 VPN 정책설정에 유의하시기 바랍니다.

※ 비조치의견서('16.6.9.)-160609

비조치의견서는 행정해석의 일종으로 최종 법적구속력은 없으며, 유권해석과는 달리 특정행위에 대해 해당 회사의 상황을 고려한 검토결과로써 일반적 효력을 가지지 아니하므로 참고자료로만 활용하시기 바랍니다.

요청대상 행위

■ 망분리 관련 보안솔루션 적용시 보안망, 인터넷망, 업무망으로 분리하고 방화벽을 통해 각각의 보안솔루션을 포트만 오픈하며, 업무망 및 인터넷망을 관리하는 것이 가능한지 여부

판단

■ 요청하신 방식의 경우 「전자금융감독규정」제15조제1항제3호에 위배되는 것으로 판단됩니다.

판단이유

■ 금융회사는 전자금융거래의 안전성 확보 및 정보처리시스템 등의 해킹 방지를 위해 「전자금융감독규정」 제15조 제1항제3호에 따라 내부통신망과 연결된 내부 업무용시스템을 인터넷 등 외부통신망과 분리 · 차단하거나 접속을 금지시켜야 합니다.

■ 방화벽과 같은 보안장비를 이용하여 통제하더라도 외부망에서 업무망으로 접속할 수 있는 방법이 열려 있을 경우 외부망과 내부망을 분리 · 차단한 것에 해당하지 않으므로,

- 하나의 보안솔루션을 인터넷망과 업무망 모두에서 사용하기 위해 네트워크 간 접속이 가능한 경우 위 규정에 위배된다고 할 수 있습니다.

■ 아울러 금융전산 망분리 가이드라인('13.9월)은 존속기간이 경과하여 효력이 소멸하였음을 알려드립니다.

※ 비조치의견서('16.12.19.)-161200

비조치의견서는 행정해석의 일종으로 최종 법적구속력은 없으며, 유권해석과는 달리 특정행위에 대해 해당 회사의 상황을 고려한 검토결과로써 일반적 효력을 가지지 아니하므로 참고자료로만 활용하시기 바랍니다.

요청대상 행위

■ 지도서비스 제공 업체를 망분리 예외 규정에 의한 '특정 외부기관'으로 지정 하여 전자금융감독규정시행세칙 제2조의2 제1항에 따라 내부통신망과 연결된 내부업무용 시스템에서 접속 가능한지 여부

판단

■ 불특정 다수가 이용하는 지도서비스 제공 업체는 전자금융감독규정시행 세칙 제2조의2 제1항에 의한 '특정 외부기관'에 포함되지 않아 망분리 예외 대상으로 보기 어렵습니다.

판단이유

■ 금융회사는 정보처리시스템 등의 해킹 방지를 위해 내부통신망과 연결된 내부 업무용시스템에 대해 인터넷 등 외부통신망과 분리 · 차단 및 접속 금지 등의 조치를 하여야 하며 (전자금융감독규정 제15조 제1항 제3호),

- 내부 업무용시스템을 업무상 필수적으로 특정 외부기관과 연결해야 하는 경우, 예외적으로 망분리 대체 정보보호통제 적용, 정보보호위원회 승인 등의 절차를 거쳐 분리 · 차단 등의 조치를 하지 않을 수 있습니다 (전자금융감독규정시행세칙 제2조의2 제1항, 제4항).

■ 시행세칙 제2조의2 제1항에서 업무상 필수적으로 연결이 필요한 '특정 외부 기관'에는 정부, 금융유관기관 및 전자금융보조업자 등과 같이 전자금융업 무의 수행을 위해 반드시 필요한 기관이 포함되나

- 금융회사와 별도의 계약 등에 따라 보안이 관리되지 않고 불특정 다수가 접속하는 서비스 운영 업체의 경우에는 특정 외부기관으로 보기 어렵습니다.

(4) 망분리 예외 적용 절차

- 세칙 제2조의3 제1항 또는 제2항에 의하여 전산센터 및 본점 영업점망분리 예외를 적용하는 경우 ① 자체위험성 평가를 실시하고 ② 세칙 〈별표7〉에서 정한 망분리 대체 정보보호 통제를 적용하고 ③ 정보보호위원회 승인 후 적용(세칙 제2조의3 제3항)
- 외부기관과 내부통신망 연결시 유의사항(제3호, 제5호)
  - 업무 특성상 내부통신망과 외부통신망의 연결이 불가피한 경우 침입차단시스템 등 정보보호 시스템의 통제에 의해 필요한 서비스포트의 접근만 허용하고 그 외의 서비스는 차단하여 외부통신망에서 내부통신망으로 인가되지 않은 접근을 통제
  - 외부통신망 연결에 따른 보안취약성 해소를 위하여 접속 로그를 주기적으로 분석하고 수시로 보안도구를 이용한 정보통신망의 취약성을 점검
- 망분리 예외 적용 이후 일부 변경된 내용이 망분리 예외적용 관련 자체 위험평가 시 주요 고려대상에 해당되거나 해당될 가능성이 높아 해당 시스템의 외부연계 취약점이 커질 우려가 있는 경우 망분리 예외적용 절차를 다시 진행(비조치의견 180021)

〈망분리 대체 정보보호통제(세칙 별표7)〉

구분	통제 사항
공통	• 외부망에서 내부망으로 전송되는 전산자료를 대상으로 악성코드 감염여부 진단 · 치료 • 지능형 해킹(APT)차단 대책 수립 · 적용 • 전산자료 외부전송 시 정보유출 탐지 · 차단 · 사후 모니터링
메일 시스템	• 본문과 첨부파일 포함하여 메일을 통한 악성코드 감염 예방 대책 수립 · 적용 • 메일을 통한 정보유출 탐지 · 차단 · 사후 모니터링 대책 수립 · 적용
업무용 단말기	• 사용자의 관리자 권한 제거 • 승인된 프로그램만 설치 · 실행토록 대책 수립 · 적용 • 전산자료 저장 시 암호화
연구 · 개발	• 유해 사이트 차단 등 외부 인터넷 접근통제 대책 수립 · 적용 • 연구 · 개발망과 내부망간 독립적인*네트워크 구성 * 다만, 연구 · 개발망과 규정 제15조제1항제3호의 내부 업무용시스템간 연결에 한하여 논리적 방식으로 분리 가능 • 연구 · 개발 단말기 및 시스템에 대한 보호대책 수립 · 적용 및 중요정보(고유식별정보, 개인신용정보 등) 처리여부 모니터링 • 연구 · 개발망의 침해사고 예방 및 사고대응 대책 수립 · 적용 • 중요 소스코드 등에 대한 외부 반출방지 및 망간 전송* 허용 등에 따른 보안관리 대책 수립 · 적용 * 다만, 연구개발망과 규정 제15조제1항제5호의 전산실간 전송시 개발산출물 등 필수적인 경우에 한함

<table>
<tr><th>구분</th><th colspan="3">통제 사항</th></tr>
<tr><td rowspan="6">원격
접속</td><td rowspan="3">외부
단말기</td><td>공통</td><td>• 백신 프로그램 설치, 실시간 업데이트및 검사 수행
• 안전한 운영체제 사용 및 최신 보안패치 적용
• 로그인 비밀번호 및 화면 보호기 설정
• 화면 및 출력물 등으로 인한 정보유출 방지대책 적용</td></tr>
<tr><td>업무용 단말기를
경유하여 내부망에
접속하는 경우
(간접접속)</td><td>• 외부단말기와 업무용 단말기의 파일 송 · 수신 차단</td></tr>
<tr><td>외부 단말기에서
내부망에 직접
접속하는 경우
(직접접속)</td><td>• 인가되지 않은 S/W 설치 차단
• 보안 설정 임의 변경 차단
• USB 등 외부 저장장치 읽기/쓰기 차단
• 전산자료 (파일, 문서) 암호화 저장
• 단말기 분실 시 정보 유출 방지 대책적용(하드디스크 암호화, CMOS비밀번호 적용 등)</td></tr>
<tr><td>내부망
접근통제</td><td colspan="2">• 업무상 필수적인 IP, Port에 한하여 연결 허용
• 원격접속 기록 및 저장(예: 접속자 ID, 접속일자, 접속 시스템 등)</td></tr>
<tr><td>인증</td><td colspan="2">• 이중 인증 적용(예: ID/PW + OTP)
• 일정 횟수(예 : 5회) 이상 인증 실패 시 접속 차단</td></tr>
<tr><td>통신
회선</td><td colspan="2">• 안전한 알고리즘으로 네트워크 구간 암호화
• 내부망 접속시 인터넷 연결 차단 (단, 직접 내부망으로 접속하는 외부단말기는 인터넷 연결 상시 차단)
• 원격 접속 후 일정 유휴시간 경과 시 네트워크 연결 차단</td></tr>
<tr><td>기타</td><td colspan="2">• 원격접속자에 대한 보안서약서 징구
• 공공장소에서 원격 접속 금지</td></tr>
</table>

※ 비조치의견서('18.1.26.)-180021

비조치의견서는 행정해석의 일종으로 최종 법적구속력은 없으며, 유권해석과는 달리 특정행위에 대해 해당 회사의 상황을 고려한 검토결과로써 일반적 효력을 가지지 아니하므로 참고자료로만 활용하시기 바랍니다.

요청대상 행위

- 특정 외부기관의 홈페이지 접속관련 망분리 예외적용 처리 이후 해당기관의 인터넷 주소, IP주소 혹은 서비스번호(Port)가 변경되거나 서비스번호(Port) 추가 또는 망분리 예외적용 대상자를 추가하는 경우 망분리 예외적용 절차*를 다시 거쳐야 하는지 아니면 동일기관으로 보아 별도의 망분리 예외적용 절차 없이 망분리 예외를 허용할 수 있는 지 여부

  * 자체 위험평가 〉 망분리 대체통제 적용 〉 정보보호위원회 승인

판단

- 금융회사는 망분리 예외 적용 이후 일부 적용환경 등의 변경이 있는 경우 변경된 사항의 취약점 등을 종합적으로 판단하여 망분리 예외적용 절차의 재진행 여부를 결정해야 합니다.

판단이유

- 금융회사 특정 시스템에 대한 망분리 예외 적용 이후 일부 변경된 내용이 망분리 예외적용 관련 자체 위험평가 시 주요 고려대상에 해당되거나 해당될 가능성이 높아 해당 시스템의 외부연계 취약점이 커질 우려가 있는 경우에는 원칙적으로 망분리 예외적용 절차를 다시 진행하여야 합니다.
- 다만, 일부 변경된 내용이 망분리 예외적용 관련 자체 위험평가시 주요한 고려대상이 아니거나 취약점이 없다고 판단한 경우에는 망분리 예외적용 건의 변경사유, 변경사항의 취약성 판단 등을 포함한 문서를 관련내규에 따라 처리하는 것이 바람직할 것으로 판단됩니다.

(5) 망간 자료 전송

● 금융회사등은 업무상 필요에 따라 내부통신망과 외부통신망 간 자료 교환을 위해 보조기억장치 또는 망간 자료전송시스템 등을 이용할 수 있고,

- 외부통신망에서 망연계솔루션을 통하여 파일을 내부통신망으로 반입하는 것은 감독규정 제15조 제1항제3호 및 제5호에 위반하지 않음(비조치의견 240035)

- 단, 자료 전송 과정에서 침해행위에 대비한 통제로서 일반적으로 샌드박스 기반*의 악성코드 검사, 본문 변환(외부 링크, 스크립트, eml Tag 등 제거), 이미지화일 등 침해위험이 없는 파일을 제외한 첨부파일 제거 등의 절차가 필요(비조치의견 170060)

  * 외부에서 받은 자료를 별도로 지정된 보호 영역에서 실행하여 해당 자료로부터 발생할 수 있는 악성코드가 내부 시스템에 전파되지 않도록 보안을 강화하는 형태

- 한편, 내·외부망 간 실시간 데이터 연계가 가능한 스트리밍 방식의 경우 외부통신망과의 분리·차단 및 접속금지의 의무를 규정한 망분리 취지에 부합하지 않음(비조치의견 170060)

※ 비조치의견서('24.5.23.)-240035

비조치의견서는 행정해석의 일종으로 최종 법적구속력은 없으며, 유권해석과는 달리 특정행위에 대해 해당 회사의 상황을 고려한 검토결과로써 일반적 효력을 가지지 아니하므로 참고자료로만 활용하시기 바랍니다.

요청대상 행위

- 금융회사가 내 · 외부통신망이 물리적으로 분리된 환경에서 DMZ 구간에 위치한 서버가 생성*한 파일을 망연계솔루션을 통하여 내부망 서버로 전송**하는 것이 전자금융감독규정 제15조제1항제3호 및 제5호 위반인지 여부

  * 국가법령정보센터 등에서 최신 법령정보 및 업무규정 변경사항을 수집 · 가공(xml, json)

  ** 실시간 데이터 연계가 가능한 스트리밍 방식이 아닌 파일 송수신 방식

판단

- 아래 내용을 참고하시기 바랍니다.

판단이유

- 금융회사는 정보처리시스템 등의 해킹 방지를 위해 내부통신망과 연결된 내부 업무용시스템을 외부통신망과 분리 · 차단해야 하며, 전산실 내 위치한 정보처리시스템과 이에 직접 접속하는 단말기는 인터넷 등 외부통신망과 물리적으로 분리해야 합니다(「전자금융감독규정」 제15조제1항제3호 및 제5호).

- 문의하신 사실관계 하에서 귀사가 외부통신망에 해당하는 DMZ 구간에 위치한 서버에서 생성한 파일을 망연계솔루션을 통하여 내부통신망으로 반입하는 것은 전자금융감독규정 제15조제1항제3호 및 제5호에 위반하지 않는 것으로 보입니다.
  - 금융회사는 업무상 필요에 따라 내부통신망과 외부통신망 간 자료 교환을 위해 보조기억장치 또는 망간 자료전송시스템 등을 이용할 수 있고,
  - 이때 외부통신망에 있는 업무자료에 대하여 악성코드 검사 등 적절한 통제 절차를 적용하여 망간 자료전송시스템 서버 간에 실시간 데이터 연계가 가능한 스트리밍 방식이 아닌 파일 형태로 전송하는 것은 내부통신망과 외부통신망을 여전히 분리한 상태로 볼 수 있습니다.

※ 비조치의견서('17.08.01.)-170060

비조치의견서는 행정해석의 일종으로 최종 법적구속력은 없으며, 유권해석과는 달리 특정행위에 대해 해당 회사의 상황을 고려한 검토결과로써 일반적 효력을 가지지 아니하므로 참고자료로만 활용하시기 바랍니다.

요청대상 행위

- 물리적 망분리 환경에서 망간 자료전송시스템을 이용하여 인터넷망에서 수신한 이메일을 내부망으로 전송하거나 내부망에서 작성한 이메일을 인터넷망으로 전송하는 것이 전자금융감독규정 제15조 제1항 제3호에 위배되는지 여부

판단

- 외부로부터의 침해행위 대비한 내부적 통제 절차를 적용한 후 인터넷망에서 수신한 이메일을 망간 자료전송시스템을 통해 내부망으로 전송하거나 내부망에서 외부망으로 이메일을 전송할 경우 망분리 관련 규정을 위반한 것으로 보기 어렵습니다.

판단이유

■ 금융회사는 내부 업무용시스템이 악성코드에 감염되어 정보유출 · 자료파괴 등 해킹 공격에 노출되는 것을 방지하기 위하여 내부통신망과 연결된 내부 업무용시스템을 외부통신망과 분리 · 차단 및 접속금지의 조치를 하여야 하며(전자금융감독규정 제15조제1항제3호),

- 업무상 필요에 의한 내부망과 외부망 간 자료 교환을 위해 보조기억장치 또는 망간 자료전송시스템 등을 이용할 수 있습니다.

■ 따라서 외부통신망으로부터의 침해행위에 대비한 적절한 통제가 이루어지는 것을 전제로 망간 자료전송시스템을 이용하여 인터넷망에서 수신된 이메일을 파일 형태로 변환하여 내부망으로 전송하거나 내부망에서 작성한 이메일을 외부망으로 전송하는 것은 가능한 것으로 보입니다.

- 자료 전송 과정에서 침해행위에 대비한 통제로서 일반적으로 샌드박스 기반*의 악성코드 검사, 본문 변환(외부 링크, 스크립트, eml Tag 등 제거), 이미지화일 등 침해위험이 없는 파일을 제외한 첨부파일 제거 등의 절차가 필요할 것입니다.

  * 외부에서 받은 자료를 별도로 지정된 보호 영역에서 실행하여 해당 자료로부터 발생할 수 있는 악성코드가 내부 시스템에 전파되지 않도록 보안을 강화하는 형태

- 다만, 내 · 외부망 간 실시간 데이터 연계가 가능한 스트리밍 방식의 경우 외부통신망과의 분리 · 차단 및 접속금지의 의무를 규정한 망분리 취지에 부합하지 않는 것으로 보입니다.

※ 비조치의견서('23.08.21.)-230058

비조치의견서는 행정해석의 일종으로 최종 법적구속력은 없으며, 유권해석과는 달리 특정행위에 대해 해당 회사의 상황을 고려한 검토결과로써 일반적 효력을 가지지 아니하므로 참고자료로만 활용하시기 바랍니다.

요청대상 행위

■ 내 · 외부망이 분리된 망분리 환경에서 아래 같이 전송하는 것이 전자금융감독규정 제15조제1항제3호 위반인지 여부

① 인터넷망에 위치한 '외부메일시스템'에 수신된 이메일 본문을 변환*하고 첨부파일의 악성코드를 검사하여 망연계솔루션(스트리밍 방식)을 통해 내부통신망에 연결된 '내부메일시스템'으로 전송

* 메일 변환 솔루션을 통해 외부 리소스 제거(링크, 스크립트, eml tag 등)

② 인터넷망에 위치한 '외부메일 변환 솔루션'과 내부통신망에 연결된 '내부메일 변환 솔루션'을 연동*하여 내부망에서 '외부메일시스템'에 수신된 메일 현황 파악

* 방화벽에서 특정 port를 오픈하여 연결

판단

■ 아래 내용을 참고하시기 바랍니다.

판단이유

■ 금융회사는 정보처리시스템 및 정보통신망을 해킹 등 전자적 침해행위로부터 방지하기 위해 내부통신망과 연결된 내부 업무용시스템을 외부통신망과 분리 · 차단 및 접속금지의 조치를 하여야 하나(전자금융감독규정 제15조제1항제3호),

- 업무상 필요에 의한 내부망과 외부망 간 자료 교환을 위해 보조기억장치 또는 망간 자료전송시스템 등을 이용할 수 있습니다.

■ 요청대상행위 ①과 같이 인터넷망의 '외부메일시스템'에서 수신된 메일본문을 변환하고 첨부파일의 악성코드를 검사하는 등 적절한 통제 절차를 적용한 후 내부통신망의 '내부메일시스템'으로 전송하는 것은 가능하나,
- 내 · 외부망 간 실시간 데이터 연계가 가능한 스트리밍 방식의 경우 외부통신망과의 분리 · 차단 및 접속금지의 의무를 규정한 망분리 취지에 부합하지 않아 전자금융감독규정 제15조제1항제3호에 위반됩니다.
- 또한, 요청대상행위 ②와 같이 내 · 외부망을 연동하는 것은 동 규정을 준수한 것으로 볼 수 없습니다.

● 규정 제23조의 비상대책 등 수립 시 해킹 및 사이버테러 발생에 즉시대처 가능한 대응체계 및 비상연락망, 협조체계 등을 포함해야 하며, 정보처리시스템의 취약점에 대한 정기 진단, 분석 및 최신 보안취약점의 발생여부 파악을 실시하고 분석결과 문제점에 대한 보완대책을 수립 · 시행하여 해킹 및 취약점에 의한 피해를 최소화하고 신속히 복구가 가능하도록 조치(제15조 제4항)

● 무선통신망 설치 및 운용시 준수사항 (제15조제6항)

- 무선통신망 이용 업무는 최소한으로 국한하고 정보보호최고책임자의승인을 받아 사전에 지정
- 업무는 AP의 기능 단위가 아닌 분장 단위를 의미(청약업무, 민원처리업무, 상담업무 등)
- 비인가자에 의한 무선AP 접근을 방지하기 위하여 무선AP의 SSID 브로드캐스팅을 금지하고 숨김 기능을 적용하여 비인가자에게 무선AP가 노출되지 않도록 하며, 사용자 인증 강화를 위하여 사용자 ID/패스워드 이외에 단말기 MAC주소 인증 등을 추가한 인증방식을 적용
- 내부의 비인가 무선AP 설치 및 접속여부를 주기적으로 점검하고 통제하여 악의적인 의도로 설치된 비인가AP에 의한 중요정보 유출 방지
- 무선통신은 특성상 데이터가 실린 전파신호의 도청이 가능하여 무선통신망에서 데이터 암호화가 매우 중요하므로 보안이 취약한 WEP(Wired Equivalency Protocol) 방식보다는 WPA(Wi-Fi Protected Access)/WPA2방식 적용을 권장
- 이는 금융회사등이 무선통신망을 설치 · 운용할 때에 준수해야 하는 조항으로, 내 · 외부망과 분리된 무선통신망을 설치하여 회의 참석자, 방문자 등을 위한 '외부 고객용'으로 운영하는 경우에도 준수 필요(비조치의견서 230081)

● 직원들이 단말기를 이용하여 음란, 도박 등 업무와 관련이 없는 인터넷 사이트에 접근할 경우 동 사이트를 통하여 스파이웨어, 바이러스 등 악성코드에 감염되고 내부 통신망을 통해 조직 내에 전파될 우려가 있으므로 불필요한 사이트의 접근 통제대책을 강구(제15조제7항)

※ 비조치의견서('16.2.29.)-160197

비조치의견서는 행정해석의 일종으로 최종 법적구속력은 없으며, 유권해석과는 달리 특정행위에 대해 해당 회사의 상황을 고려한 검토결과로써 일반적 효력을 가지지 아니하므로 참고자료로만 활용하시기 바랍니다.

요청대상 행위

- 아래와 같은 통제를 전제로 당사 인터넷망을 무선통신망으로 사용하는 것이 전자금융감독규정 제15조제6항을 준수하는지 여부
  1. 인터넷망에 대한 무선통신망 이용에 대하여 CISO 사전 승인 처리하여 사용 예정
  2. 무선통신망 불법 접속을 막기 위해 승인된 무선AP/사용자/단말기만 접속할 수 있도록 통제 적용할 것이며, 암호화 적용 예정
  3. 현재 내부망에 연결된 단말기들은 무선통신망에 접속을 차단하는 솔루션을 적용하고 있으며, 비인가 무선AP들의 내부망 접속도 자동 차단되며, 실시간 모니터링 체계를 운영하고 있으며, 인터넷망도 동일한 통제 체계를 운영할 예정
  4. NAC(Network Access Control) 솔루션으로 비인가 무선AP의 설치 · 접속여부는 실시간으로 확인되며, 자동으로 당사 인터넷망 접속이 차단되도록 정책이 적용될 것이며, 주기적으로 무선AP에 대한 보안점검을 할 예정

판단

- 물리적 망분리가 이루어진 상태에서 무선통신망을 외부 인터넷망의 접속 용도로 사용을 제한하고, 질의 사항에서 정한 통제 조치가 적절히 적용될 경우 전자금융감독규정 제15조 제6항에 위배되지 않음

판단이유

- 전자금융감독규정 제15조의 취지는 금융회사 및 전자금융업자로 하여금 해킹과 같은 전자적 침해행위로부터 내부 업무망 및 이와 연계된 정보처리시스템을 보호하기 위한 것으로
  - 무선통신망을 인터넷망 접속 용도로 한정하여 이를 통한 내부망 접속이 차단될 경우, 귀사에서 제시한 통제장치가 적절히 적용됨을 전제로 전자금융감독규정 제15조 제6항에 위배되지 않습니다.
- 다만, 비인가 무선AP가 내부망에 접속할 경우 즉시 차단하는 조치, 내부망에 연결된 정보처리시스템의 무선AP 접속 차단 조치가 적절히 시행될 필요가 있습니다.

※ 비조치의견서('23.10.05.)-230081

비조치의견서는 행정해석의 일종으로 최종 법적구속력은 없으며, 유권해석과는 달리 특정행위에 대해 해당 회사의 상황을 고려한 검토결과로써 일반적 효력을 가지지 아니하므로 참고자료로만 활용하시기 바랍니다.

요청대상 행위

- 금융회사가 내 · 외부망과 분리된 무선통신망을 구축하여 '외부 고객용'*으로 운영하는 경우 「전자금융감독규정」 제15조제6항을 준수 필요 여부

  * 회의 참석자, 방문자 등 외부 고객에게 제공하는 무선통신망으로 내부 단말기의 접속은 차단

판단

- 아래 내용을 참고하시기 바랍니다.

판단이유

- 「전자금융감독규정」 제15조제6항은 금융회사가 무선통신망을 설치 · 운용할 때에 준수해야하는 조항으로,
  - 설치 목적이나 방식 등과 상관없이 무선통신망을 설치하여 운영하는 경우 적용됩니다(법령해석 160695).
- 따라서, 귀 사가 내 · 외부망과 분리된 무선통신망을 설치하여 회의 참석자, 방문자 등을 위한 '외부 고객용'으로 운영하는 경우
  - 불법 접속을 방지하고 비인가 무선접속장비 설치·접속여부, 중요정보 노출여부를 주기적으로 점검하는 등 전자금융감독규정 제15조제6항을 준수하여야 합니다.

2. 악성코드 감염 방지대책

감독규정

제16조(악성코드 감염 방지대책) 금융회사 또는 전자금융업자는 악성코드 감염 · 확산 방지, 피해 최소화 및 복구를 위한 대책을 수립 · 운용하여야 한다.

- 악성코드(Malicious Code)는 컴퓨터에서 사용자의 허락 없이 스스로를 복사하거나 변형한 뒤 정보유출, 시스템 파괴 등의 작업을 수행하여 사용자에게 피해를 주는 프로그램으로 웜, 바이러스, 트로이목마, 스파이웨어, 애드웨어, 루트킷 등으로 분류
  - 악성코드 감염경로는 이메일, 이동식저장매체, 악성코드가 포함된 웹페이지 접속, 메신저, P2P프로그램 등
  - 악성코드에 감염된 경우에는 전파 속도가 빠르고 치료 및 데이터복원을 위해 금전적 · 시간적 · 심리적인 손해뿐만 아니라 해당 금융회사의 신뢰도에 치명적인 영향을 줄 수 있으므로 실효성 있는 대책 마련 필요

- 해설
  - 금융회사 또는 전자금융업자는 악성코드 감염 · 확산 방지, 피해 최소화 및 복구를 위한 대책을 수립 · 운용하여야 함
    - 악성코드 감염을 방지하기 위한 예방 대책을 마련하여 단말기 및 정보처리시스템을 관리

〈악성코드 감염 방지 대책 마련시 고려사항 예시〉

- 출처, 유통경로 및 제작자가 명확하지 않은 응용프로그램은 악성코드 검색 프로그램 등으로 진단 후 사용하고, 허가받지 않은 프로그램의 다운로드 및 설치를 금지
- 전산시스템의 규모 및 중요성 등을 고려하여 필요한 경우 악성코드 탐지 솔루션 등 설치를 통해 외부 유입 메일 및 첨부파일 등에 대한 사전 검색 체계를 구축하고, 불분명한 이메일 및 파일 열람 금지
- 개인용 단말기 및 서버군의 악성코드 감염여부에 대하여 정기적으로 점검 실시 및 기록 보관
- 규정 제12조제3호에 따른 중요단말기에 대해 악성코드 감염여부를 매일 점검
- 악성코드 검색 및 치료 프로그램의 엔진 업데이트를 정기적으로 수행하도록 엔진 업데이트의 예약을 설정한 후 사용하고, 필요시 긴급 업데이트를 실시하는 등 악성코드 검색 및 치료 프로그램의 최신상태 유지
- 악성코드 검색 및 치료 프로그램의 실시간 감시 기능을 이용하여 정보처리시스템 보호

- 악성코드 감염이 발견된 경우 업무 담당자는 악성코드 확산 및 피해를 최소화하고, 신속히 복구하기 위하여 적절한 조치를 실행

〈악성코드 감염 확산 방지, 피해 최소화 및 복구 대책 마련시 고려사항 예시〉

- 악성코드 감염사실을 신속히 신고할 수 있도록 연락체계 구축
- 악성코드에 감염된 시스템의 사용중지 또는 내부망에서 분리, 네트워크 케이블 분리 등 감염 시 대응 절차 마련
- 악성코드 검색 및 치료 프로그램을 이용하여 악성코드 치료
- 감염확산 방지를 위하여 사용자에게 관련 사실 및 보안조치사항을 즉시 전달
- 감염의 재발을 방지하기 위하여 원인분석 및 예방조치 수행
- 시스템 초기화, 백업본을 활용한 복원 등 악성코드 감염시 복구 절차 수립 및 수행
- 대응보고서(발견일시, 대응절차 및 방법, 대응자, 방지대책 등) 작성

3. 홈페이지 등 공개용 웹서버 관리대책

감독규정

제17조(홈페이지 등 공개용 웹서버 관리대책) 금융회사 또는 전자금융업자는 공개용 웹서버의 안전한 관리를 위하여 다음 각 호를 포함한 적절한 대책을 수립 · 운용하여야 한다.

1. 공개용 웹서버를 내부통신망과 분리하여 내부통신망과 외부통신망사이의 독립된 통신망(이하 "DMZ구간"이라 한다)에 설치하고 네트워크 및 웹 접근제어 수단으로 보호할 것
2. 공개용 웹서버에 접근할 수 있는 사용자계정은 업무관련자만 접속할 수 있도록 제한하고 이중 인증수단을 적용할 것
3. 공개용 웹서버에서 제공하는 서비스를 제외한 다른 서비스 및 시험 · 개발 도구 등의 사용을 제한하고, DMZ구간 내에 이용자 정보 등 주요 정보를 저장 및 관리하지 아니할 것(다만, 거래로그를 관리하기 위한 경우에는 예외로 하되 고유식별정보는 반드시 암호화하며 그 외 이용자 정보는 별도의 보안대책을 수립하여 저장 · 관리하여야 한다)
4. 금융회사 또는 전자금융업자는 공개용 웹서버에 자료 게시 절차 · 내용에 관한 내부통제 방안과 개인정보 유출 및 위 · 변조를 방지하기 위한 보안조치 방안을 수립 · 운용하여야 한다.

■ 공개용 웹서버는 외부 이용자에게 홈페이지 및 업무서비스를 제공하기 위해 운영되는 서버로, 내부망 내 서버와 달리 외부로부터 접근이 허용되므로 보안상 취약점을 이용한 외부 공격에 취약하여 이에 대한 보안 조치가 필요

- 금융상품에 관한 약정 체결 조회를 위한 협력 업체용 웹사이트 운용 서버도 보안상 취약점에 대한 보안 조치가 필요한 공개용 웹서버에 해당(비조치의견서 170501)
- 공개용 웹서버를 설치하는 DMZ구간은 외부통신망에 해당(시행세칙 제2조의3 제2항 제2호 나목)
  - 내부망에서 서버 가상화를 이용하여 생성한 가상 운영서버를 DMZ구간에 할당하여 공개용 웹서버로 사용하는 것은 전산실 내에 위치한 내부 서버와 인터넷 등 외부통신망에 대하여 물리적으로 분리되었다고 보기 어려워 가능하지 않음(비조치의견서 240013)

■ 해설

- 웹서버, 메일서버 등 공개용 웹서버를 외부 해킹 등 악의적인 접근으로부터 보호하기 위해 1차 침입차단시스템과 2차 침입차단시스템 사이(DMZ구간)에 설치하고 네트워크 및 웹 접근제어 수단 등으로 보호(제1호)
  - 공개용 웹서버가 침해당하더라도 외부 유해 트래픽이 웹서버를 경유해서내부 네트워크로 침입이 불가능하도록 침입차단시스템 구성
- 공개용 웹서버에 접근할 수 있는 사용자계정은 업무관련자로 제한하고 보안강화를 위하여 이중인증 수단을 적용(제2호)

- 공개용 웹서버에 접근할 수 있는 사용자계정을 업무관련자만 접속할 수 있도록 제한하는 것이 규정의 목적이므로 이용하고자 하는 SMS인증 등도 업무관련자를 특정하는 경우에는 이용 가능(법령해석 140199)

● 공개용 웹서버 운영에 필요한 최소한의 서비스를 제외한 다른 서비스 및 시험 · 개발 도구 등의 사용을 제한(제3호)

- 공개용 웹서버에서는 개발 및 테스트 도구 등의 사용을 금지하며, 공개용 웹서버에 반영하기 위한 프로그램의 변경, 수정 및 테스트는 반드시 별도의 개발 및 테스트 서버에서 실시

● 공개용 웹서버 해킹에 의한 이용자 정보 등 주요정보 유출방지를 위하여 DMZ구간 내에는 이용자 정보 등 주요 정보의 저장 및 관리를 금지함. 다만, 거래로그 관리를 위해 이용자 정보 등의 저장이 필요한 경우에는 예외로 하되 고유식별정보는 반드시 암호화하며, 그 외 이용자 정보는 별도의 보안대책을 수립하여 저장 · 관리(제3호)

● 공개용 웹서버 자료 게시 절차 · 내용에 관한 내부통제 방안과 개인정보 유출 및 위 · 변조를 방지하기 위한 보안조치 방안을 수립 · 운용(4호)

※ 비조치의견서('18.01.16)-170501

비조치의견서는 행정해석의 일종으로 최종 법적구속력은 없으며, 유권해석과는 달리 특정행위에 대해 해당 회사의 상황을 고려한 검토결과로써 일반적 효력을 가지지 아니하므로 참고자료로만 활용하시기 바랍니다.

요청대상 행위

■ 금융상품 약정서를 수집하는 협력 업체가 실적 현황을 열람할 목적으로 접근하는 금융회사의 웹사이트에 대해 「전자금융감독규정」 제17조 및 제33조에 따른 의무를 준수하여야 하는지 여부

판단

■ 금융상품에 관한 약정 체결 조회를 위한 협력 업체용 웹사이트 운용 서버에 대해 「전자금융감독규정」 제17조에 따른 대책을 적용하여야 하지만, 같은 규정 제33조에 의한 의무사항은 적용하지 않을 수 있습니다.

판단이유

■ '공개용 웹서버'는 인터넷 이용자들이 웹페이지를 자유롭게 보고 웹서비스(월드 와이드 웹을 이용한 서비스를 말한다)를 이용할 수 있게 해주는 프로그램이 실행되는 장치를 의미하므로(「전자금융감독규정」 제2조제9호)
- 금융회사의 내부 정보처리시스템과 달리 외부로부터의 접근이 허용되어 보안상 취약점에 대한 보안 조치가 필요한 협력 업체용 웹사이트의 운용서버는 '공개용 웹서버'에 해당합니다.

■ '이용자'는 전자금융거래를 위하여 금융회사 또는 전자금융업자와 체결한 계약에 따라 전자금융거래를 이용하는 자를 의미하므로(「전자금융거래법」 제2조제7호),
- 협력 업체가 이용하는 웹사이트를 운용하는 서버에 대해서는 「전자금융감독규정」 제33조에서의 이용자 비밀번호 관련 규정을 적용하지 않을 수 있습니다.

※ 비조치의견서('19.02.07)-180044

비조치의견서는 행정해석의 일종으로 최종 법적구속력은 없으며, 유권해석과는 달리 특정행위에 대해 해당 회사의 상황을 고려한 검토결과로써 일반적 효력을 가지지 아니하므로 참고자료로만 활용하시기 바랍니다.

요청대상 행위

- 웹 프록시 기능*을 갖춘 네트워크 장비로 DMZ구간을 구성(공개용 웹서버는 내부통신망에 위치)하는 것이 전자금융감독규정 제17조제1항제1호**를 위반하는지 여부
  - * 외부에서 받은 트래픽을 내부로 전달
  - ** 공개용 웹서버를 내부통신망과 분리하여 내부통신망과 외부통신망 사이의 독립된 통신망에 설치하고 네트워크 및 웹 접근제어 수단으로 보호할 것

판단

- 요청대상 행위는 전자금융감독규정 제17조제1항제1호에 위반되는 것으로 판단됩니다.

판단이유

- 공개용 웹서버는 인터넷 이용자들이 웹페이지를 자유롭게 보고 웹서비스를 이용할 수 있게 해주는 프로그램이 실행되는 장치를 의미하는데,
  - 전자적 침해행위 등에 취약하여 웹 접근제어 수단으로 보호하는 등 보안정책을 적용해야 하고(감독규정 제17조 제1항 내지 제4항),
  - 내부 업무용 시스템을 보호하기 위해 공개용 웹서버를 내부통신망과 분리하여 운영해야 합니다.
- 해당 네트워크 장비가 웹 프록시 기능을 갖춘다 하더라도 공개용 웹서버의 모든 기능을 대체하지 못하고 규정에서 요구하는 보안정책을 적용할 수도 없으므로 요청대상 행위는 감독규정 제17조를 준수했다고 볼 수 없습니다.
  - 또한, 웹서버를 내부망에 구축하여 외부에서 들어오는 모든 요청 업무를 내부통신망에서 처리하는 것은 보안상 허용하기 어렵습니다.

※ 비조치의견서('24.3.4.)-240013

비조치의견서는 행정해석의 일종으로 최종 법적구속력은 없으며, 유권해석과는 달리 특정행위에 대해 해당 회사의 상황을 고려한 검토결과로써 일반적 효력을 가지지 아니하므로 참고자료로만 활용하시기 바랍니다.

요청대상 행위

- 내부망에서 서버 가상화를 이용하여 생성한 가상 운영서버를 DMZ구간에 할당하여 공개용 웹서버로 사용하는 것이 전자금융감독규정 제17조제1항제1호에 위반하는지 여부

판단

- 아래 내용을 참고하시기 바랍니다.

판단이유

- 「전자금융감독규정」 제17조제1항제1호는 공개용 웹서버를 내부통신망과 분리하여 내부통신망과 외부통신망 사이의 독립된 통신망(이하 "DMZ구간")에 설치하고 네트워크 및 웹 접근제어 수단으로 보호하도록 하였으며,
  - 동규정 제15조제1항제5호는 전산실 내에 위치한 정보처리시스템과 해당 정보처리시스템의 운영 목적으로 직접 접속하는 단말기에 대하여 인터넷 등 외부통신망으로부터 물리적으로 분리하도록 하고 있습니다.
- 상기 규정에 비추면 전산실 내에 위치한 내부 서버는 인터넷 등 외부통신망*에 대하여 물리적으로 분리하여야 하므로,

  * DMZ구간은 외부통신망에 해당(전자금융감독규정시행세칙 제2조의2제2항제2호나목)

  - 문의하신 사실관계 하에서 귀사의 가상 운영서버 구성은 규정에 위반하는 것으로 보입니다.

조치 사례('22.5.18)

- 금융회사는 공개용 웹서버의 안전한 관리를 위하여 DMZ구간 내에 이용자 정보 등 주요정보를 저장 및 관리하지 아니하여야 하고 거래로그를 관리하기 위한 경우에는 예외적으로 암호화하여 저장 · 관리하여야 하는데도(전자금융감독규정 제17조),
- ○○회사는 DMZ구간에서 운영하는 OO 서버의 로그파일에 총 000명의 이용자 정보(성명, 주민등록번호, 전화번호 등)를 암호화하지 않고 평문으로 저장하였음

조치 사례('22.6.28)

- 금융회사는 공개용 웹서버가 해킹공격에 노출되지 않도록 대응 조치하여야 하고, 공개용 웹서버를 웹 접근제어 수단으로 보호하여야 하는데도(전자금융감독규정 제17조),
- ○○회사는 OOOO.O.O.~OOOO.O.O. 기간 중 ◇◇◇시스템에 접속한 해외 IP에 대한 모니터링을 수행하지 않았으며,
- OOOO.O.O. 민원인의 제보로 해킹 발생 가능성을 인지했음에도 불구하고 해외IP 차단 등의 대응조치를 즉각 수행하지 않았고,
- OOOO.O.O.(시스템 가동시점)~OOOO.O.O.(검사종료일) 중 부주의로 인하여 웹서버에 대한 해킹공격을 방지할 수 있는 △△△시스템이 정상 동작하지 않도록 운영하였다는 사실로 지적받음

4. IP주소 관리대책

감독규정

제18조(IP주소 관리대책) 금융회사 또는 전자금융업자는 정보제공자 주소(이하 "IP주소"라 한다)의 안전한 사용을 위하여 주소 체계 · 할당 · 관리 등에 대한 내용을 포함한 적절한 대책을 수립 · 운용하고, 내부 IP주소 및 외부 IP주소의 인터넷 접속내용을 1년 이상 별도로 기록 · 보관하여야 한다.

IP주소의 안전한 사용을 위한 대책을 수립 · 운용하고, 내부 IP주소 및 외부 IP주소의 인터넷 접속내용을 1년 이상 기록 · 보관

해설

- IP주소 체계 · 할당 · 관리 등에 대한 내용을 포함한 대책을 수립 · 운용

〈IP주소 체계 · 할당 · 관리 등에 대한 대책 수립시 고려사항 예시〉

- 외부 접속용 IP는 공인 IP체계, 내부IP는 사설 IP체계를 사용
- 내부에서 외부로 접속시 NAT[4](Network Address Translation)기능을 이용하여 IP를 관리
- 개인별로 내부 IP주소를 부여하고 변경현황을 기록 관리
- 정보처리시스템의 개발담당, 운영담당, 외주직원 등 담당 업무특성별로네트워크를 분리하여 IP를 부여함으로써 각 네트워크별 업무특성에 따른 적절한 접근권한 통제 등 보안정책을 적용하여 보안 강화

- 내부직원이 인터넷접속 시 접속일시, 출발지 및 목적지 IP, 접속포트(Port), 사설IP 주소 등을 포함하여 1년 이상 기록·보관

개선요구 등 사례('19.11.1.)

- ○○회사는 근무지 기준으로 IP대역을 할당하여 중요 단말기와 일반 단말기, 내부인력과 외부인력, 직무 등과 상관없이 동일한 IP대역을 사용하여 IP대역별 보안정책 적용 시 업무와 상관없이 보안정책이 완화될 우려가 있음

4) 공개된 인터넷과 사설망 사이에 방화벽(Firewall)을 설치하여 외부 공격으로부터 사용자의 통신망을 보호하는 기본적인 수단으로 활용할 수 있음. 이때 외부 통신망 즉 인터넷망과 연결하는 장비인 라우터에 NAT를 설정할 경우 라우터는 자신에게 할당된 공인 IP주소만 외부로 알려지게 하고, 내부에서는 사설 IP주소만 사용하도록 하여 필요시에 이를 서로 변환시켜 줌. 따라서 외부 침입자가 공격하기 위해서는 사설망의 내부 사설 IP주소를 알아야 하기 때문에 공격이 불가능해지므로 내부 네트워크를 보호할 수 있음

■ 개선요구 등 사례('24.9.2.)

- ○○회사는 정보계, 채널계 전체 서버 중 일부는 운영 및 개발 서버의IP 대역이 혼재되어 있어, 악성코드 감염이나 보안 취약점으로 인한 보안사고 발생시 개발 서버의 피해가 운영 서버로 확산될 위험이 있으므로,
- 운영 서버 대역에 할당된 개발 서버에 대해서 IP변경을 완료하고, 네트워크 주소관리 대책에 대하여 주기적인 점검이 이루어질 수 있도록 관련 절차를 내규에 반영할 필요

5. 암호프로그램 및 키 관리 통제

감독규정

제19조(암호프로그램 및 키 관리 통제) ① 금융회사 또는 전자금융업자는 암호프로그램에 대하여 담당자 지정, 담당자 이외의 이용 통제 및 원시프로그램(source program) 별도 보관 등을 준수하여 유포 및 부당 이용이 발생하지 않도록 하여야 한다.

② 금융회사 또는 전자금융업자는 암호 및 인증시스템 등에 적용되는 키(Key)(프로그램 진위 및 무결성 확인에 사용되는 암호 또는 인증시스템 등에 적용되는 키를 포함한다)에 대하여 주입 · 운용 · 갱신 · 폐기에 대한 절차 및 방법을 마련하여 안전하게 관리하여야 한다.

암호프로그램과 암호키가 유출될 경우 금융거래에서 가장 중요한 고객정보인 주민등록번호, 계좌 비밀번호, 일회용비밀번호 등의 유출사고로 이어질 수 있으므로 일반프로그램보다 더욱 철저히 관리

해설

- 암호프로그램 및 암호키(프로그램 진위 및 무결성 확인에 사용되는 암호 또는 인증시스템 등에 적용되는 키를 포함하며, 이하 동일)는 전담 담당자를 지정하여 관리토록 하고, 전산부서 직원인 경우에도 담당자 이외에는 접근통제 철저(제1항)
  - 특히, 프로그램 내에 하드코딩된 키로 암호화하지 않도록 주의
- 암호프로그램의 소스는 보조저장매체를 이용하여 별도로 보관하여야 하며 서버, 개발자 PC 등에 소스 저장 금지, 또한 암호화프로그램이 복사된 보조저장매체는 비밀문서에 준하여 안전한 장소에 보관(제1항)
- 암호프로그램 관련 설계서도 암호프로그램과 동일하게 비밀문서에 준하여 관리(제1항)
- 암호프로그램을 외부주문에 의하여 개발한 경우 사용되는 키는 외부주문업체로부터 인수 즉시 변경하여야 하며 암호키의 생성, 운용, 주입및 폐기는 해당 금융회사 또는 전자금융업자의 지정된 담당자가 직접 수행(제2항)
- 실 시스템의 암호 및 인증시스템에서 이용하고 있는 키와 테스트 시스템에서 테스트용으로 사용되고 있는 키는 동일한 키의 사용 금지(제2항)

개선요구 등 사례('20.7.27.)

- ○○회사는 암호화키의 세부명세서를 수기로 관리함에 따라, 암호화키 명세서와 실제 시스템상의 암호화키 및 금고에 보관된 원본 암호화키 등이 상호 일치하지 않고 있으므로, 실제 시스템 상의 암호화키와 암호화키 세부명세서를 주기적으로 대사하여 관리하는 등 암호화키 관리통제 절차 등을 개선할 필요

6. 사용자 인증수단 관리

감독규정

제19조의2(사용자 인증수단 관리) 금융회사 또는 전자금융업자는 비밀번호, 생체정보 등 사용자 인증수단 유출을 방지하기 위하여 인증수단의 발급 · 보관 · 주기적 변경 및 인증오류 발생시 처리 절차 등을 포함한 관리방안을 수립 · 운용하여야 한다.

■ 사용자 인증수단은 정보처리시스템에 직접 접근하여 고객 정보, 금융거래 정보 등에 접근할 수 있는 권한을 부여하는 핵심 정보이므로 사용자 인증수단 유출방지 대책 마련

■ 해설

● 내부사용자의 비밀번호, 생체정보 등 사용자 인증수단의 유출을 방지하고 안전한 인증수단의 사용을 위한 관리방안을 수립 · 운용

※ 법령해석('18.08.06.)-180221

질의

■ 당사 내부사용자가 업무시스템 접속 시*, 아이디/비밀번호 입력 대신 FIDO기반 인증방법을 적용하는 경우, "「전자금융감독규정」 제32조 내부사용자 비밀번호 관리" 규정과 관련 보안수준이 동등하거나 높음으로 판단되어 적용할 수 있는지 검토 요청

* (예) 신용카드 모집인용 태블릿 로그인, 임직원 PC내 인트라넷 로그인 등

회신

■ 현행 「전자금융거래법」에서는 정보처리시스템에 대한 접속(인증)방법을 구체적으로 제한하지 않으며, 금융회사에서 자율적으로 보안수준을 판단하여 적용할 수 있습니다.

이유

■ 현재 「전자금융거래법」 제21조제3항에 따르면, 「전자금융거래법」은 전자금융거래상 내부사용자의 정보처리시스템 접속(인증)방법에 대해 특정 기술 또는 서비스 사용을 강제하지 않으므로 이에 관하여는 관련 규정을 준수하면서 안전하고 편리한 인증기술의적용이 가능합니다.

- FIDO기반 인증방법은 비밀번호를 대체하기 위한 인증기술로 「전자금융감독규정」 제32조 내부사용자 비밀번호 관리규정과 관련하여 담당업무에 따른 접근제한, 인증오류에 따른 접속제한 및 초기화 등 비밀번호 기반 인증방법에 준하는 방식으로 관리함으로써 보안성 및 안정성을 확보해야 할 것입니다.

제6절 사업부문

1. 정보처리시스템 구축 및 전자금융거래 관련 사업 추진

감독규정

제20조(정보처리시스템 구축 및 전자금융거래 관련 사업 추진) 금융회사 또는 전자금융업자는 정보처리시스템 및 전자금융거래와 관련된 사업 추진에 대한 내부통제 기준을 수립 · 운용하여야 한다.

- 대규모 IT사업 추진 시 불필요한 투자결정 및 과잉 중복투자 방지 등을 위하여 IT사업 추진에 대한 내부통제 기준을 수립 · 운용하여 IT사업 추진의 효율성 확보 및 투명성 제고

- 해설

  - 금융회사 또는 전자금융업자의 장기 발전방향, 금융환경의 변화 등을 반영하여 타당성 검토 및 효과 분석을 실시하는 등 사업 추진에 대한 내부통제 기준을 수립 · 운용

〈정보처리시스템 구축 및 전자금융거래 관련 사업 추진시 고려사항 예시〉

- 조직에 미치는 영향이 크거나 일정금액 이상의 사업 추진 시에는 사전에 충분한 타당성 검토를 실시
- 정보처리시스템 신규 구축및 통합 · 전환 · 재개발 등 주요 추진사업에 대하여 비용 대비 효과분석을 실시
- 타당성 검토와 비용 대비 효과분석 결과는 전산운영위원회 등 독립적인 조직에서 별도 내부 승인
- 정보처리시스템 구축 초기 단계에서 보안상 취약점이 발생하지 않도록 보안대책 등을 적극적으로 검토 · 반영

2. 정보처리시스템 구축 및 전자금융거래 관련 계약

감독규정

제21조(정보처리시스템 구축 및 전자금융거래 관련 계약) 금융회사 또는 전자금융업자는 정보처리시스템 구축 및 전자금융거래와 관련된 계약 체결시에 정보처리시스템의 안전성 · 신뢰성 및 계약의 공정성이 확보될 수 있도록 체결 · 이행 · 감사 등에 관한 내용을 포함한 내부통제 절차를 수립 · 운용해야 한다.

■ 정보처리시스템 도입, 구축, 운영 및 전자금융거래 관련 계약 시 정보처리시스템의 안전성 · 신뢰성 및 계약의 공정성 확보를 위해 객관적이고 합리적인 내부통제 절차를 수립 · 운용

〈정보처리시스템 구축 및 전자금융거래 계약 관련 내부통제 절차 수립시 고려사항 예시〉

- 객관적인 업체 선정 기준 및 절차를 마련 · 운용하고 동 기준 및 절차의 내용에는 정보보안 관련 사항을 포함
- 예정가격 산정 기준을 마련하여 가격의 타당성 확보
- 계약에 필요한 내용(금액, 일정, 납품 및 대금지급 방식 등)을 포함한 표준 계약서 기준 마련
- 구매 또는 개발한 제품의 소유권, 저작권 및 지적재산권 등을 명확히 하여 사후 분쟁을예방
- 납품 또는 개발 완료 후 공급업체 파산 등 비상 대비 대책 마련 · 운용
- 이해당사자*를 배제한 객관적인 검수 절차 운영
  * 계약자, 개발자 및 해당 부서를 포함하며, 검수조서 작성시에는 이해당사자를 완전히 배제
- 계약조항 불이행 사유 발생, 계약조항 변경시 검사부서 승인
- 내부감사규정에 따라 감사가 정한 금액 이상의 계약에 대하여는 자체 감사를 실시하거나 검사부서 승인

※ 비조치의견서('18.05.02.)-170093

비조치의견서는 행정해석의 일종으로 최종 법적구속력은 없으며, 유권해석과는 달리 특정행위에 대해 해당 회사의 상황을 고려한 검토결과로써 일반적 효력을 가지지 아니하므로 참고자료로만 활용하시기 바랍니다.

요청대상 행위

- 내부 계약규정에 명시된 수의계약을 통해 IT 전문 계열사와 IT 자원 통합구매 계약을 체결하고 IT 구매업무 등을 통합구매로 위탁하는 행위가 전자금융감독규정 제21조에 위반하는지 여부

판단

- 전자금융감독규정 제21조 위반 여부는 개별사안에서 거래상대방, 거래조건 등이 객관적으로 공정하게 결정되었는지 여부에 따라 판단될 사안임

판단이유

- 기본적으로 수의계약 방식인지 경쟁입찰 방식인지에 따라 전자금융감독규정 제21조 위반 여부가 결정되는 것은 아님(다만, 특별한 사정이 없는 한, 일반적으로 경쟁입찰이 수의계약에 비해 상대적으로 객관성과 공정성이 높을 것으로 보임)

조치 사례('20.2.10.)

- 금융회사는 정보처리시스템 구축과 관련된 계약 체결 시 적합한 업체를 공정하게 선정하기 위하여 객관적인 업체 선정 기준 및 절차를 마련·운용하여야 하는데도,
- OO회사는 ○○○○ 등 계약 0건(총 계약금액 000억원)을 추진하면서 0인 이상의 입찰대상자를 지명하지 않고 제조사가 추천한 소수의 협력사만을 입찰대상자로 지명하여 기타 업체의 입찰 참여를 제한하는 등 계약 체결 관련 업무를 부당하게 처리하였음

3. 정보처리시스템 감리

감독규정

제22조(정보처리시스템 감리) 금융회사 또는 전자금융업자는 정보처리시스템의 안전성 및 효율성 확보를 위한 정보처리시스템 감리 지침을 수립 · 운용하여야 한다.

■ 정보처리시스템 구축 및 관련 프로젝트 수행에 있어 안전성 및 효율성 향상을 위하여 전산감리 대상, 감리인 자격, 감리절차 등에 대한 실현가능한 합리적인 자체 기준을 수립하여 이행

■ 해설

● 일반적으로 감사는 위법, 부당, 부정에 대한 적발 및 지적과 시정에 목적을 두는 반면 전산감리는 성과의 극대화를 위하여 기술적인 측면에서 기획, 개발, 운영단계에 이르기까지 단계별 또는 종합적으로 합리성, 타당성, 신뢰성, 안전성 및 효율성 등을 조사하고 감독하는 평가행위로 감사부서의 전산감사 업무와 구별됨

〈감사와 감리 비교표〉

구 분	감 사	감 리
수행 업무	- 회계적 측면의 예산에 대한 바른 집행과 집행결과에 대한 합법성, 정당성, 적정성을 조사하고 검증 - 완료된 행위를 대상으로 잘못의 지적과 시정에 역점을 두며, 사후적인 성격이 강함	- 기술적 측면에서 프로젝트가 기본계획과 설계대로 되었으며 효율성, 신뢰성, 품질보증 등 기술적 요건이 보장되고 있는가를 감독, 지도하고 평가 - 성과의 극대화를 위한 관리적 성격이 강함

● 전산감리[5]에 대한 세부기준은 금융회사 또는 전자금융업자가 자율적으로 수립하고 감리수행은 외부감리인 또는 내부인력도 가능하나, 전산감리인은 해당 사업에 대하여 독립성 및 기술적 적격성 확보 필요

〈전산감리 지침 수립 · 운영시 고려사항 예시〉

- 자율적으로 감리지침을 마련하고, 동 지침에는 감리 목적 및 대상, 시기 및 절차 등을 포함
- 감리조직의 독립성 및 전문성 확보를 위해 감리인 자격요건 및 역할 (책임 및 권한 등) 사전 지정
- 정보처리시스템의 분석 및 설계, 개발 및 구현, 도입, 운용 등 수행 업무에 적절한 감리 지침을 수립하여 실시하고 감리 결과에 대해서는 보고서에 따라 필요한 시정조치 수행
- 전자금융거래에 미치는 영향이 크거나 외부주문에 의해 공급되는 전자금융업무 관련 정보처리시스템의 경우전자금융업무의 안전성 및 효율성 확보 등을 위해 철저히 감리 실시

5) 감리대상으로부터 독립성을 확보한 제3자가 안전성, 신뢰성, 보안성, 효율성, 경제성, 준거성 등의 다양한 관점에서 정보처리시스템 구축에 대한 종합적인 분석 및 평가를 통하여 문제점을 발견하고 개선하도록 하는 것을 의미

개선요구 등 사례('24.9.2.)

- ○○회사는 IT감리 실시 과정에서 시스템 구축 완료 후 종료 감리만 실시하고, 감리 영역을 실효성 있게 구분하지 않고 일부 영역(프로젝트관리 · 시스템개발)에 대해 체크리스트 점검 수준의 감리를 실시함에 따라, 분석 · 설계 단계의 부적합 사항이 발견될 경우 시정조치할 시간을 확보하지 못하거나 감리가 필요한 주요 부분에 대한 감리가 누락될 우려가 있으므로,
- IT감리 대상의 성격, 수행기간 등에 상응하는 감리가 적시에 실효성 있게 이루어질 수 있도록, IT감리지침에 감리 시점 및 유형 등을 명확히 규정하여 충분한 시정조치 시간을 확보하는 한편, 주요 사항에 대해 반드시 감리를 수행하도록 개선할 필요

제7절 업무지속성 부문

1. 비상대책

감독규정

제23조(비상대책 등의 수립 · 운용) ① 금융회사 또는 전자금융업자는 장애 · 재해 · 파업 · 테러 등 긴급한 상황이 발생하더라도 업무가 중단되지 않도록 다음 각 호의 내용을 포함한 업무지속성 확보방안을 수립 · 준수하여야 한다.

1. 상황별 대응절차
2. 백업 또는 재해복구센터를 활용한 재해복구계획
3. 비상대응조직의 구성 및 운용
4. 입력대행, 수작업 등의 조건 및 절차
5. 모의훈련의 실시
6. 유관기관 및 관련업체와의 비상연락체제 구축
7. 보고 및 대외통보의 범위와 절차 등
8. 비상지원인력의 확보 및 운영

② 삭제

③ 금융회사 또는 전자금융업자는 제1항의 규정에 따른 업무지속성 확보대책의 실효성 · 적정성 등을 매년 1회 이상 점검하여 최신상태로 유지하고 관리하여야 한다.

④ 「국가위기관리기본지침」에 따라 금융위원회가 지정한 금융회사는 금융위원회의 「금융전산분야위기대응실무매뉴얼」에 따라 위기대응행동매뉴얼(이하 "행동매뉴얼"이라 한다)을 수립 · 준수하고 이를 금융위원회에 알려야 한다.

⑤ 금융위원회가 별도로 지정하지 아니한 금융회사 또는 전자금융업자는 자연 재해, 인적 재해, 기술적 재해, 전자적 침해 등으로 인한 전산시스템의 마비 방지와 신속한 복구를 위한 비상대책을 수립 · 운용하여야 한다.

⑥ 제4항에 따른 행동매뉴얼 또는 제5항에 따른 비상대책에는 제1항의 규정에 따른 업무지속성 확보대책이 반영되어야 한다.

⑦ 금융회사 또는 전자금융업자는 중앙처리장치, 데이터저장장치 등 주요 전산장비에 대하여 이중화 또는 예비장치를 확보하여야 한다.

⑧ 다음 각 호의 금융회사 및 전자금융업자는 시스템 오류, 자연재해 등으로 인한 전산센터 마비에 대비하여 업무지속성을 확보할 수 있도록 적정 규모 · 인력을 구비한 재해복구센터를 주전산센터와 일정거리 이상 떨어진 안전한 장소에 구축 · 운용하여야 한다.

1. 「은행법」에 의해 인가를 받아 설립된 은행(다만,「은행법」 제58조에 의해 인가를 받은 외국금융회사의 국내지점은 제외한다)
2. 「한국산업은행법」에 의한 한국산업은행, 「중소기업은행법」에 의한 중소기업은행, 「농업협동조합법」에 의한 농협은행, 「수산업협동조합법」에 의한 수협은행
3. 「자본시장과 금융투자업에 관한 법률」에 의한 투자매매업자 · 투자중개업자(다만, 「자본시장과 금융투자업에 관한 법률」 제12조에 의해 인가를 받은 외국 투자매매업자 · 투자중개업자의 지점 등은 제외한다)
4. 「자본시장과 금융투자업에 관한 법률」에 의한 증권금융회사 및 한국예탁결제원

5. 「자본시장과 금융투자업에 관한 법률」에 의한 거래소
6. 「여신전문금융업법」에 의한 신용카드업자(다만, 법인신용카드 회원에 한하여 신용카드업을 영위하는 자는 제외한다)
6의2. 「여신전문금융업법」에 의한 시설대여업자, 할부금융업자, 신기술사업금융업자(다만, 시행령 제11조의4 제1항에 해당하는 회사에 한한다.)
7. 「보험업법」에 의한 보험요율산출기관
8. 「상호저축은행법」에 의한 상호저축은행중앙회 및 자체 전산시스템을 구축하여 운영하는 상호저축은행
9. 「신용협동조합법」에 의한 신용협동조합중앙회
10. 「보험업법」에 의한 보험회사
11. 「전자금융거래법」에 의한 전자금융업자(다만, 연간 전자금융거래 총액이 2조원 이상인 회사에 한정한다.)

⑨ 제8항 각 호의 금융회사는 업무별로 업무지속성 확보의 중요도를 분석하여 핵심업무를 선정하여야 하며, 업무별 복구목표시간을 정하여야 한다. 이 경우 핵심업무의 복구목표시간은 3시간 이내로 하되, 「보험업법」에 의한 보험회사의 핵심업무의 경우에는 24시간 이내로 한다.

⑩ 제8항의 규정에 따른 재해복구센터를 운영하는 금융회사는 매년 1회 이상 재해복구센터로 실제 전환하는 재해복구전환훈련을 실시하여야 한다.

정보처리시스템의 장애, 사고, 재해, 파업 등으로 인한 중단 사태에 대비하여 업무지속성 확보방안이 마련될 수 있도록 비상대책을 수립하고 이에 대한 정기적인 훈련을 실시

해설

- 금융회사 또는 전자금융업자는 비상대책(금융위원회가 지정한 경우는 위기대응행동매뉴얼)을 마련할 의무가 있으며, 해당 비상대책 또는 위기대응행동매뉴얼에는 업무지속성 확보방안(대책)이 반영되어야 함
- 장애, 재해, 파업, 전자적 침해 등 발생 가능한 모든 위험으로 부터 업무가 중단되지 않도록 다음의 사항을 포함한 업무지속성 확보방안을 수립(제1항)
  - 장애, 재해, 파업, 전자적 침해 등 각 비상 상황별 적절한 대응절차
  - 백업 또는 재해복구센터를 활용한 재해복구 계획
  - 사고 발생시 신속하게 대응할 수 있도록 비상대응조직 구성 및 운용
  - 비상상황 발생에도 지속적으로 업무처리가 가능하도록 입력대행, 수작업 등의 조건 및 절차 마련
  - 업무지속성 확보방안의 실효성이 제고될 수 있도록 정기적으로 상황별 모의훈련 실시
  - 발생 상황의 금융업계 파급 차단 및 신속한 해결을 위한 유관기관 및 관련업체와의 비상체계 구축
  - 상황발생에 대한 보고 및 대외통보의 범위와 절차 등

- 비상시에도 정상적인 정보처리시스템 운영 또는 신속한 원상복구가 가능하도록 비상시 복구 조직, 연락체계 등 비상지원인력(외부 전문업체 활용 가능)의 확보 및 운영*

  * 비상사태 발생시 업무수행이 원활하게 이루어질 수 있도록 전산시스템 운영에 필요한 운영지침서, 사용자 매뉴얼 등을 최신상태로 유지하고, 비상지원인력에 대해 담당업무 연수를 정기적으로 실시하는 방안도 고려

● 업무지속성 확보대책의 실효성 및 적정성 등을 매년 1회 이상 점검하고 최신상태를 유지하여 실제 비상사태 발생시 전자금융업무가 중단없이 서비스되도록 조치(제3항)

● 비상대책(위기대응매뉴얼 포함)의 내용은 장애 및 재해 유형에 따라 복구절차, 복구예상시간, 복구 우선순위, 담당자, 연락체계 등을 구분하여 수립(제4항, 제5항)

- 위기대응행동매뉴얼 또는 비상대책에는 업무지속성 확보대책을 반영(제6항)

〈예시〉 전산센터 마비에 대비한 비상대책 포함 요소

- 재해 선포 절차(예: 결정자, 선포자 등)
- 대체시스템 가동에 필요한 데이터 및 프로그램의 준비(예: 데이터 백업, 당일거래기록 백업, 관련프로그램 백업 등)
- 대체시스템 가동 절차(예: 업무별 담당자, 담당자별 처리절차, 시스템 및 통신망 가동절차, 대체시스템 확인 절차, 영업점 처리절차 등)
- 훈련 및 테스트 계획(예: 훈련 대상, 주기 등)
- 정상 시스템 전환 절차(예: 데이터 확인, 정상화 선언)

● 비상대책(위기대응매뉴얼 포함)은 모든 서비스를 동시에 대체할 수 있도록 계획할 수 있으나, 비용, 기기 용량, 신속성 등을 고려하여 긴급한 업무중심으로 대상을 선정 할 것인지 모든 서비스를 대상으로 선정 할 것인지에 대하여 자율적으로 결정하며, 위기대응매뉴얼을 수립한 금융회사는 금융위원회에 알림(제4항)

● 비상대책(위기대응매뉴얼 포함)은 수립 및 문서화하는 것으로 완료 된 것이 아니고 이에 대한 정기적인 훈련이 더욱 중요하며, 시스템 환경이 변화된 경우 이를 즉시 비상대책에 반영하여야 함(제3항, 제5항)

● 서버, 데이터 저장장치, 통신 중계 장치 등의 주요 전산장비 및 통신회선에 대하여는 장애발생에 대비하여 이중화 또는 예비 장비를 확보하여야 하며, 예비 장비를 보유하고 있지 않을 경우에는 납품업체 또는 제조업체와 계약을 통하여 예비 장비를 우선 수급 받을 수 있도록 조치(제7항)

● 주 전산센터 가동중단에 대비하여 구축한 재해복구센터는 재해발생시 주 전산센터와 동일한 재해에 영향을 받지 않도록 주 전산센터로부터 일정거리 이상 떨어진 안전한 장소에 구축 · 운영(제8항)

- 연간 전자금융거래 총액이 2조원 이상인 전자금융업자, 총자산이 2조원 이상이고 상시 종업원수가 300명 이상인 여신전문금융회사(리스 · 할부금융 · 신기술), 자체 전산시스템을 구축하여 운영하는 저축은행 또한 재해복구센터 구축 의무 대상에 해당함을 유의

● 제8항의 규정에 따라 재해복구센터 구축의무가 있는 금융회사 및 전자금융업자는 자체적으로 업무지속성 확보의 중요도를 분석하여 핵심업무를 선정하여야 함(제9항)

- 핵심업무가 주센터를 통한 서비스가 곤란한 경우에도 재해복구센터를 이용하여 복구목표 시간내에 서비스가 가능하도록 업무지속성이 확보되어야 함

- 핵심업무의 복구목표시간은 3시간 이내이며, 보험회사는 24시간 이내임

〈핵심업무 예시〉

1. 핵심업무 선정 고려사항 예시
   - 동일수준 성능으로 대체되지 않는 한 수행될 수 없는 업무
   - 수작업으로 대체할 수 없는 업무
   - 업무중단에 따른 손실이 막대하여 회사에 치명적인 영향을 주는 업무
   - 서비스 업무가 아닌 금전거래가 발생하는 업무 우선
   - 후선업무 보다는 대고객 접점 업무 우선
   - 동일업무에 대하여 수동업무처리보다 전산화처리 우선

2. 금융회사 업권별 핵심업무 예시

(은행) 개인 여신 · 수신, 기업 여신 · 수신, 어음 / 수표, 연금, 방카슈랑스, 환전, 외화예금, 수출입, FX / 파생상품, 송금, SWIFT, 모바일 · 인터넷 뱅킹, CD / ATM, 텔레뱅킹, 금융결제원 공동망(CD, 전자금융, 타행환, ARS) 등

(증권) 주식, 채권, 선물 / 옵션, 기타파생상품, 펀드, 입출금관리, 입출고관리, 소액지급, 모바일 · 인터넷뱅킹, 모바일 · 인터넷 트레이딩. CD / ATM, 텔레뱅킹 / ARS, 계좌개설, 계좌원장, 잔고관리 등

(보험) 사고접수, 사고조사, 보험금지급, 대출신청, 대출심사, 대출금지급, 신규계약, 계약심사, 계약변경 등

(카드) 국내 · 외 온라인 승인, 국내 · 외 오프라인 승인, 회원한도 관리, 회원정보 관리, 신용정보 관리, 카드 정산 · 청구, 실시간 입금 · 자동이체, 가맹점 대금지급 · 정보관리, 매입 심사 · 연계, 현금서비스(이체 / 지급), 신용판매(일시불 / 할부), 온라인결제[승인], ISP인증, 모바일카드, 카드 발급 · 조회 등

● 제8항의 규정에 의거 재해복구센터를 구축 · 운영하는 금융회사는 매년1회 이상 재해복구센터로 실제 전환하는 재해복구전환훈련을 실시(제10항)

- 재해복구전환훈련은 규정 제24조에 따른 비상대응훈련에 포함되어 실시 가능

● 비상대책에 따라 원격 접속이 필요한 경우 물리적 망분리에 대한 예외 인정(감독규정 제15조 제1항 제5호 나목, 시행세칙 제2조의3 제2항 제3호)

※ 비조치의견서('18.5.2.)-170007

비조치의견서는 행정해석의 일종으로 최종 법적구속력은 없으며, 유권해석과는 달리 특정행위에 대해 해당 회사의 상황을 고려한 검토결과로써 일반적 효력을 가지지 아니하므로 참고자료로만 활용하시기 바랍니다.

요청대상 행위

- 전자금융업무를 하지 않는 금융회사(보험업법에 따른 보험회사)가 백업자료를 활용한 재해복구계획이 있다면, 전자금융감독규정 제23조 제8항에서 요구하는 재해복구센터를 반드시 구축하여야 하는지 여부

판단

- 전자금융업무를 하지 않는 보험회사는 재해복구센터 구축의무를 규정한 전자금융감독규정 제23조 제8항을 준수할 의무가 없습니다.

판단이유

- 전자금융업무를 하지 않는 은행, 증권사, 보험사 등은 전자금융거래법 제21조 제2항의 적용을 받지 않으며(전자금융거래법 제3조, 동법 시행령 제5조), 재해복구센터 구축에 관한 규정인 전자금융감독규정 제23조의 적용 또한 받지 않습니다.
  - 따라서 전자금융업무를 하지 않고 재해복구계획이 있는 보험사가 동 규정을 준수하지 않더라도 규정을 위반한 것으로 볼 수 없을 것입니다.

조치 사례('21.3.29.)

- 금융회사는 장애 등 긴급한 상황이 발생하더라도 업무가 중단되지 않도록 상황별 대응절차, 비상대응 조직의 구성 및 운용, 보고 및 대외통보의 범위와 절차 등이 포함된 업무지속성 확보 방안을 수립·준수하여야 하는데도(전자금융감독규정 제23조 제1항),
- ○○회사는 프로그램 오류 발생사실이 일부 영업점으로부터 ○○본부에 보고되었으나 장애상황 등을 부서장 등 차상위자에게 보고하지 않고, 비상대응 담당조직에 통보하지 않은 결과, 장애복구가 적시에 실시되지 않았음

개선요구 등 사례('24.11.26.)

- ○○회사는 주전산센터 내의 서버 및 회선 등의 사용현황 대비 재해복구센터 서버 용량 및 회선 등이 일부 부족하여 재해발생 시 재해복구센터로 전환 운영하더라도 전자금융거래 업무의 지연 또는 중단이 우려되므로
- 주전산센터의 정보처리시스템의 자원 사용 현황 및 추이 분석 등을 통해 재해복구센터 서버 및 회선 등에 필요한 적정 용량을 정기적으로 산정하여 필요한 자원을 추가하거나 미사용 자원의 배분을 실시하는 등 재해복구센터 운용·관리를 강화할 필요

개선요구 등 사례('24.6.7.)

- ○○회사는 핵심업무를 선정함에 있어 전사적 관점에서 업무영향분석을 수행하지 않고 ○○본부가 핵심업무와 관련 시스템을 단독으로 정하고 있어 업무중단으로 인한 잠재적 손실 등의 영향도 분석 절차가 미흡하며, 핵심업무 선정을 위한 정성적·정량적 평가항목과 기준이 마련되어 있지 않으므로,
- 전사적 관점에서 업무영향분석을 실시하고 각 업무부서가 도출한 단위 업무와 연관 시스템, 복구목표 시간 등을 □□본부와 ○○본부가 함께 검토하는 한편, 핵심업무 선정과 관련한 세부 평가항목과 객관적인 기준을 마련할 필요

2. 비상대응훈련

감독규정

제24조(비상대응훈련 실시) ① 금융회사 또는 전자금융업자는 제23조제4항에 따른 행동매뉴얼 또는 같은 조 제5항에 따른 비상대책에 따라 연 1회의 비상대응훈련을 실시하고 그 결과를 금융위원회에 보고하여야 한다. 이때, 제23조 제10항에 따른 재해복구전환훈련을 포함하여 실시할 수 있다.

② 금융위원회는 금융분야의 비상대응능력을 강화하기 위하여 금융회사 또는 전자금융업자를 선별하여 금융분야 합동비상대응훈련을 실시할 수 있다.

③ 금융위원회는 제2항의 규정에 따른 합동비상대응훈련을 실시할 때, 다음 각 호의 기관에게 지원을 요청할 수 있다.

1. 「정부조직법」 제17조에 따른 "국가정보원(국가사이버안전센터)"
2. 「국가경찰과 자치경찰의 조직 및 운영에 관한 법률」 제12조에 따른 "경찰청(사이버수사국)"
3. 침해사고대응기관
4. 그밖에 비상대응훈련의 실효성 확보를 위하여 금융위원회가 필요하다고 인정하는 기관

④ 금융회사 또는 전자금융업자는 제1항 및 제2항에 따른 의무의 이행을 위하여 전자금융보조업자에게 협조를 요청할 수 있다.

■ 위기대응행동매뉴얼 및 비상대책을 수립한 금융회사 또는 전자금융업자는 위기대응행동매뉴얼 또는 비상대책에 따라 비상대응훈련을 연 1회 실시하여 재해, 장애 등 비상사태 발생시에도 업무지속성 확보

■ 해설

● 금융회사 또는 전자금융업자는 장애, 재해, 파업, 전자적 침해 등 발생 가능한 모든 위험으로부터 업무 중단방지 및 신속한 복구를 위하여 위기대응행동매뉴얼 및 비상대책에 따라 연 1회 비상대응훈련을 실시하여야 하며, 이때 재해복구훈련을 포함하여 실시할 수 있으며, 훈련실시 결과를 금융위원회에 보고(제1항)

〈비상대응훈련 및 재해복구전환훈련시 고려사항 예시〉

- 계획 수립 시 재해복구센터로의 물리적 이동시간, 실제 비상상황 등을 감안하고, 로그인 인증수단 동작 여부, 이중화 여부 등 대고객 서비스 전반을 감안
- 비상대응훈련 수행 시 훈련 대상 업무 또는 시스템과 관련하여 해당 업무 소관 부서(영업점 포함) 및 전산시스템 담당 부서 참여, 전산센터 화재/하드웨어 고장/일부 정보시스템 장애/전력공급 중단 등 다양한 비상상황 발생에 대비한 훈련 진행
- 비상대응훈련 결과 발견된 미흡한 사항에 대해 보완대책 마련하고 동 대책을 업무지속성 확보방안의 상황별 대응절차 등에 반영하며, 비상대응훈련결과에 대해 검증 및 보고 절차 마련
- 재해복구전환훈련은 핵심업무 전체에 대하여 정기적으로 시행될 수 있도록 재해복구전환훈련 계획 수립 시 대상 업무 선정
- 핵심업무에 금융결제원, 예탁결제원 등 중요 대외기관과의 연계 기능이 포함되어 있는 경우, 해당 업무에 대한 재해복구훈련 시 중요 대외기관과의 연계 기능을 재해복구훈련 대상에 포함하고, 훈련을 위한 협조 노력에도 불구하고 중요 대외기관의 훈련지원이 불가능한 경우 대외기관 통신과 동일 또는 유사한 환경의 구조로 대체하여 훈련

● 금융위원회는 금융분야의 비상대응능력을 강화하기 위하여 금융회사 또는 전자금융업자를 선별하여 금융분야 합동비상대응훈련을 실시할 수 있으며(제2항),

- 이 경우, 금융회사 또는 전자금융업자는 비상대응 훈련 및 금융분야 합동비상대응훈련 실시 이행을 위하여 필요시 전자금융보조업자에게 협조를 요청할 수 있음(제4항)

〈 훈련간 비교 〉

훈련 구분	재해복구전환훈련	비상대응훈련	침해사고 대응 · 복구훈련
관련규정	규정 제23조	규정 제24조	규정 제37조의6
훈련목적	재해복구센터를 운영하는 금융회사의 경우 전산센터 마비시 재해복구센터로 전환하기 위한 대응능력 확보	장애, 재해, 파업, 전자적 침해 등 발생가능한 모든 위험으로으로 인한 업무 중단 방지와 신속한 복구	침해사고에 대한 대응능력 확보
훈련주기	연 1회 이상	연 1회	연 1회 이상
훈련실시	금융회사등의 재해복구전환계획에 따라 실시	금융회사 등의 위기대응행동매뉴얼 또는 비상대책에 따라 실시	금융회사등의 침해사고대응 · 복구훈련계획에 따라 실시
훈련결과	-	금융위원회에 보고	침해사고대응기관의 장에 제출

3. 정보처리시스템의 성능관리

감독규정

제25조(정보처리시스템의 성능관리) 금융회사 또는 전자금융업자는 정보처리시스템의 장애예방 및 성능의 최적화를 위하여 정보처리시스템의 사용 현황 및 추이 분석 등을 정기적으로 실시하여야 한다.

■ 최적의 정보처리시스템 용량 확보를 통한 장애예방 및 성능 최적화를 실현함으로써 시스템의 가용성 확보 및 대고객 서비스를 제고하고, 효과적인 자원 활용을 통한 비용 절감 등을 동시에 추구하기 위하여 정기적으로 정보처리시스템 자원의 사용현황 및 추이 분석 실시

■ 해설

● 정보처리시스템의 용량 부족으로 인한 서비스 지연, 장애 등을 방지하기 위하여 다음과 같은 조치를 시행하고 결과를 기록보관

- 전산기기에 대한 용량분석(Capacity Planning)
- 피크타임(peak time) 기준의 시스템 상태, 이용도 모니터링 및 응답 시간 지연 등의 이상 징후 발생시 원인 분석
- 시스템 용량 확장 시점 예측을 위한 이용도 분석(CPU, Storage Memory, I/O Channel, 네트워크 어댑터 등)
- 신규업무 개발시 전산시스템의 수용능력을 평가하여 기 운영 업무에 영향을 주지 않도록 조치
- 미사용 시스템의 자원분석을 통하여 적정배분 사용

● 성능관리 실시의 범위는 금융회사 또는 전자금융업자의 정보처리시스템 전체에 대해 적용하되, 개발·테스트용 시스템, 인사·지식정보(Wiki)·내부 메신저 등 임직원 전용 시스템 및 비중요 시스템 등 대고객 서비스에 영향이 없는 시스템에 대해서는 CIO 등의 승인 절차를 거쳐 적용 범위에서 제외하는 것이 가능

● 금융회사 또는 전자금융업자는 정보처리시스템 전반의 사용현황 분석 및 성능관리를 담당하는 조직을 구성·운영하고 성능관리 담당 조직의 업무 수행과 관련하여 전산시스템 성능 관리 및 용량 관리 절차 등의 내용을 포함한 내규를 수립·운용

〈성능관리 내규 포함사항 예시〉

- 성능관리 대상이 되는 전산자원의 적용대상 및 범위
- 성능관리 담당 조직 구성 및 운영
- 전산자원별 임계치 구분 기준 및 책임자 보고 등 조치 절차
- 전산시스템 성능 관리 및 용량 관리 절차 (전산자원별 성능 · 용량 현황, 사용량 추이, 성능 관련 장애 발생 · 조치 현황 등에 대한 모니터링, 분석 보고서 작성, 보고 진행 등)
- 대형 이벤트 기준(추가 증가 예상 이용자 수) 및 대형이벤트 시 대응방안 등 절차
- 성능관리 비상대책, 용량 부족시 용량 증설 절차, 장애 예방을 위한 단계별 대응방안

조치 사례('22.10.31.)

- 금융회사는 정보처리시스템의 장애예방 및 성능의 최적화를 위하여 정보처리시스템의 사용 현황 및 추이 분석 등을 정기적으로 실시하여야 하는데도(전자금융감독규정 제25조),
- ○○회사는 스마트뱅킹 신규 가입자 수가 꾸준히 증가하였음에도 시스템 부하 성능 추이 분석을 실시하지 않았음

제8절 정보기술부문 내부통제

1. 전산원장 통제

감독규정

제27조(전산원장 통제) ① 금융기관 또는 전자금융업자는 장애 또는 오류 등에 의한 전산원장의 변경을 위하여 별도의 통제절차를 수립 · 운용하여야 한다.

② 제1항의 절차에는 변경 대상 및 방법, 변경 권한 자 지정, 변경 전후내용 자동기록 및 보존, 변경내용의 정당여부에 대한 제3자 확인 등이 포함되어야 한다.

③ 금융회사 또는 전자금융업자는 대차대조표 등 중요 자료의 계상액과 각종 보조부 · 거래기록 · 전산원장파일의 계상액에 대한 상호일치 여부를 전산시스템을 통하여 주기적으로 확인하여야 한다.

④ 금융회사 또는 전자금융업자는 제3항에 따른 확인 결과 불일치가 발견된 때에는 그 원인 및 조치 내용을 전산자료의 형태로 5년간 보존하여야 한다.

⑤ 금융회사 또는 전자금융업자는 이용자 중요원장에 직접 접근하여 중요원장을 조회 · 수정 · 삭제 · 삽입하는 경우에는 작업자 및 작업내용 등을 기록하여 5년간 보존하여야 한다.

■ 전산원장은 금융회사의 가장 중요한 정보로 고객 본인의 정상적인 거래시에만 변경되어야 하나 프로그램 오류, 거래오류, 시스템 장애 등으로 인하여 변경이 불가피한 경우에는 엄격한 통제절차에 의하여 변경이 이루어지도록 하고 사후 철저한 검증 실시

■ 해설

● 전산시스템 장애 또는 프로그램 오류 등에 의한 전산원장 통제절차 수립 시 다음 사항을 고려

- 변경대상 및 방법 명시 : 사전에 변경대상을 지정하여 변경 대상정보에 대하여만 변경토록 하고, 만약 절차에 지정된 변경 대상 이외의 정보에 대하여 변경이 필요한 경우에는 통제절차에 변경 대상 및 방법을 추가(제1항)

- 변경전후 내용의 자동기록 및 보존 : 온라인 이외의 방법으로 변경이 일어날 경우 거래 Log에 기록이 되지 않기 때문에 별도의 프로그램이 작성되어 있지 않을 경우 변경 내용에 대한 확인이 불가능하므로 반드시 변경 전·후 내용이 기록되도록 프로그램이 준비되어 있어야 하고, 동 기록은 5년간 보관·관리(제5항)

● 원장수정은 불법수정과 고객정보 유출, 시스템 장애 등의 사고예방을 위하여 전담자를 지정하며 독립적 부서(감사부서 등)의 상시감시대상에 포함하여 모니터링 실시(제2항)

- 전산원장 수정의 경우에는 제3자가 수정의 정당성을 사전 승인토록 하고, 원장 수정 전후내역을 전산기록(logging)하고 5년간 보존(제2항, 제5항)
  - 전산원장 변경시 제3자의 범위는 객관적으로 확인이 가능한 자로 감사부서, IT자체감사 부서, 준법감시팀 등이 해당됨
  - 정기적으로 실행되는 일괄작업(BATCH)의 경우 최초 1회시에만 적용하여도 가능
- 주요 자료의 계상액과 각종 보조부, 거래기록, 전산원장 파일의 계상액이 상호불일치 할 경우 불일치 내용, 원인, 조치 사항을 전산시스템으로 5년간 보관하여 추후 사고 발생시 근거자료로 활용(제4항)
- 사고발생시 사고원인 추적 및 근거자료로 활용이 가능하도록 중요전산원장 접근(조회, 수정, 삭제, 삽입 등) 로그를 작업자, 작업일시, 작업내용 등의 전산자료 형태로 5년간 기록·보관(제5항)

조치 사례('24.8.2.)

- ○○회사는 전산 장애 또는 오류 등의 사유로 총 000건의 중요 데이터가 저장된 전산원장을 변경하면서 전체 변경 건에 대하여 변경 전후 내용을 자동 기록·보존하지 않았으며, 외부주문업체 소속 직원이 동 전산원장에 저장된 중요 데이터(000건)를 직접 변경한 사실이 있음

※ 법령해석('18.11.6.)-180152

질의

- 「신용정보법」 제20조의2에 따라 삭제 또는 분리보관하는 개인(신용)정보가 「전자금융감독규정」 제27조에 따른 '전산원장'에 해당한다면, 삭제 또는 분리보관 작업 후 전산원장에 대한 수정(변경)전·후 내용을 기록하고 5년간 보존해야 하는지 여부

회신

- 「전자금융감독규정」 제27조제5항에 따라 금융회사 또는 전자금융업자는 상거래가 종료된 신용정보주체의 개인신용정보를 삭제하는 경우 작업자 및 작업내용 등을 기록하여 5년간 보존하여야 합니다.
  - 다만, 작업자 및 작업내용 등을 기록하여 보존하는 경우 「신용정보법」 제20조의2제3항에 따라 분리보관하는 등 엄격하게 관리하여야 합니다.

이유

- 「신용정보법」 제20조의2에서는 상거래가 종료된 날로부터 최장 5년 이내에 해당 신용정보주체의 개인신용정보를 관리대상에서 삭제하도록 정하고 있습니다.
  - 다만, 타 법령에 근거하여 보존이 필요한 경우에는 보존이 가능하며, 신용정보 주체의 개인신용정보와 분리하는 등 엄격한 관리가 요구됩니다.
- 「전자금융거래법」 제21조 및 「전자금융감독규정」 제27조제5항은 전자금융거래의 안전성과 신뢰성을 확보하기 위하여 금융회사등이 중요원장을 조회·수정·삭제·삽입하는 경우 작업자 및 작업내용 등을 기록하여 5년간 보존하도록 규정하고 있습니다.

2. 거래통제

감독규정

제28조(거래통제 등) ① 금융회사 또는 전자금융업자는 사고위험도가 높은 거래에 대하여는 책임자 승인거래로 처리토록 하는 등 전산시스템에 의한 이중확인이 가능하도록 하여야 한다.

② 금융회사 또는 전자금융업자는 전산원장, 주요정보 또는 이용자 정보 등이 저장된 정보처리시스템에 대한 중요작업 수행 시 책임자가 이중확인을 해야 한다.

■ 일정금액 이상의 고액인출, 각종 사고신고, 계좌일괄조회, 정정거래 등 사고위험도가 높거나 이상거래의 개연성이 있는 업무에 대해서는 업무 담당자가 단독으로 처리할 경우 사고 위험이 높으므로 책임자가 정보처리시스템에 의하여 이중확인

■ 해설

- 책임자 승인거래 업무 범위에 대하여 사전에 지정하고, 신규업무 개발 시에는 책임자 승인거래 대상 여부를 확인하여 해당되는 업무는 반드시 추가하고 현재 운영되고 있는 책임자 승인거래 대상 및 범위에 대하여 확인(제1항)
- 책임자승인 방식은 책임자의 개입 없이 담당자가 단독으로 업무를 처리할 수 없도록 비밀번호 방식 보다는 물리적 수단(카드키, 지문, OTP 등)에 의한 인증 방식의 적용을 권고하고 책임자 부재 등 부득이한 경우에는 책임자가 사전에 지정한 업무대행자가 확인하도록 전산시스템을 개발
- 전산원장, 이용자정보, 전자금융거래 정보 등이 저장되어 있는 정보처리시스템에 대한 중요작업 수행시 정보유출 등의 사고 예방을 위하여 책임자가 작업내용 이중 확인(제2항)

3. 프로그램 통제

감독규정

제29조(프로그램 통제) 제29조(프로그램 통제) 금융회사 또는 전자금융업자는 프로그램 등록 · 변경 · 폐기 등에 관하여 금융감독원장이 정하는 사항을 포함한 절차를 수립 · 운용하여야 한다.

시행세칙

제2조의7(프로그램 통제) 규정 제29조에 따라 감독원장이 정하는 사항은 다음 각 호와 같다.

1. 적용대상 프로그램 종류 및 등록 · 변경 · 폐기 방법을 마련할 것
2. 프로그램 변경 전후 내용을 기록 · 관리할 것
3. 프로그램 등록 · 변경 · 폐기내용의 정당성에 대해 제3자의 검증을 받을 것
4. 변경 필요시 해당 프로그램을 개발 또는 테스트 시스템으로 복사 후 수정할 것
5. 프로그램에 대한 접근은 업무담당자에 한정하되, 적절한 접근권한(읽기 · 쓰기 · 실행 등 포함)을 설정하고 중요 조작에 대한 책임자 사전 승인을 받도록 하는 등 기밀성 · 무결성 · 가용성 등이 훼손되지 않도록 예방조치를 실시할 것
6. 프로그램 반출, 실행프로그램의 생성 및 운영시스템 적용은 해당 프로그램 담당자 이외의 자가 수행할 것
7. 운영시스템 적용은 처리하는 정보의 기밀성 · 무결성 · 가용성 및 전자금융거래의 안전성과 신뢰성이 훼손되지 않도록 충분한 테스트 및 관련 책임자 승인 후 실시할 것
8. 운영체제, 데이터베이스관리프로그램 등의 시스템 프로그램도 응용프로그램과 동일한 수준으로 관리할 것
9. 프로그램 설명서, 프로그램 목록 및 사용자 · 운영자 지침서 등 프로그램 유지보수에 필요한 문서를 작성 · 관리할 것
10. 전자금융거래에 사용되는 프로그램은 분석, 설계 단계에서부터 안전성과 신뢰성을 확보할 수 있는 대책을 마련하고, 운영시스템 적용 전에 충분히 검증하고 적용할 것

프로그램은 전산업무처리의 근본으로 이에 대한 관리 및 변경은 신중하게 통제되어야 하며 특히, 보유 프로그램 목록 관리, 프로그램 변경 및 접근통제 실시

해설

- 정보처리시스템에서 사용되고 있는 모든 프로그램에 대하여 목록을 작성(전자파일 포함)하여 관리하고(시행세칙 제2조의7 제1호)
- 프로그램 변경시 프로그램 소스 관리를 위하여 현재 사용 중인 최신버전의 프로그램(소스)을 변경하여야 하며, 구 버전의 프로그램을 변경하지 않도록 프로그램 변경관리절차를 수립하여 운영하여야 하고 가급적 자동화된 프로그램 소스 관리툴(형상관리 도구)을 활용(시행세칙 제2조의7 제2호)
- 프로그램의 변경은 변경사유가 명확하여야 하고, 변경내용에 대한 확인 및 실시스템(Production System) 적용은 해당 프로그램 개발자가 아닌 제3자에 의하여 정확히 이루어 질 수 있도록 절차를 마련(시행세칙 제2조의7 제3호)

- 보관중인 프로그램 소스에 대한 접근은 업무담당자로 한정하되 적절한 접근권한을 설정하고, 전자금융업무에 지장을 줄 수 있거나 부정한 목적으로 악용될 수 있는 접근·조작 등 중요 조작에 대해서는 사전 승인 등 예방조치 실시(시행세칙 제2조의7 제5호)
- 사용 중인 프로그램 변경을 위한 반출, 실행프로그램 생성 및 운영시스템 적용을 개발담당자가 직접 수행하는 것은 금지되며, '해당 프로그램 담당자 이외의 자'에는 전산자료 관리자, 시스템 운영자, IT감사자, 내부 감사자, 내부통제 담당자 등이 포함되고, 이해상충 방지 차원에서 개발 담당자와 동일 조직에서 개발업무에 관하여 동일한 권한 또는 지위를 가진 인력은 제외 (시행세칙 제2조의7 제6호)

〈프로그램 통제 절차 및 조직 예시〉

① 개발 및 운용중인 모든 프로그램에 대하여 등록·변경·폐기하는 절차 일체를 내규에 반영하고, 프로그램 긴급 변경 절차 및 대상 등 긴급 상황관련 절차도 모두 내규에 반영한 후 운영
② 프로그램 등록·변경·폐기 내용의 정당성에 대해 검증하는 절차를 내규에 반영
③ 프로그램 등록·변경·폐기 내용의 정당성에 대해 검증하는 검증 담당 조직을 구성하고, 등록·변경·폐기 수행시에는 건별로 검증 담당 조직이 검증 절차를 수행
④ 검증 담당 조직을 IT개발 경력 일정 연차이상인 자로 구성. 다만, IT개발 경험 인력이 부족한 경우 최고정보책임자(CIO) 등 개발 담당 임원의 승인하에 검증 담당 조직 구성을 변경 가능
⑤ 프로그램 등록·변경·폐기 내용의 정당성에 대해 검증하는 제3자의 범위에서 해당 프로그램의 개발자·책임자·관리자, 프로그램의 업무 담당자(현업), 프로그램의 인수 담당자·책임자를 제외

- 프로그램 변경에 따른 영향도를 파악하고, 다양한 시나리오 및 사용자 환경 등을 고려한 충분한 테스트를 실시하여야 하며, 운영시스템 적용은 관련 책임자 승인 후 실시(시행세칙 제2조의7 제7호)
- 중요도가 높은 시스템 운영체제, 데이터베이스관리프로그램 등의 시스템 프로그램의 변경 또는 패치프로그램 적용 시 충분한 테스트를 실시하고 관리 권한을 최소한으로 한정하는 등 관리통제를 강화하여 업무서비스 장애 발생 가능성 최소화(시행세칙 제2조의7 제8호)
- 프로그램 담당자의 사직, 유고, 업무이동 등으로 담당자가 변경되는 경우 프로그램 관리가 원활하게 이루어 질 수 있도록 관련 문서를 상세히 작성하고 최신 상태 유지(시행세칙 제2조의7 제9호)
- 전자금융거래용 전산프로그램은 보안 취약성을 내포하는 경우 해커에 의한 침입경로 및 악성코드 유포 수단으로 사용될 수 있으므로 실 운영시스템에 반영하기 전에 도입, 분석, 설계 단계부터 프로그램에 대한 자체 보안성 검증 등 안전성·신뢰성 확보대책을 마련하여 실시(시행세칙 제2조의7 제10호)

조치 사례('23.12.21.)

- 금융회사는 프로그램을 운영시스템에 적용하는 경우 처리하는 정보의 기밀성 · 무결성 · 가용성을 고려하여 충분한 테스트 및 관련 책임자 승인 후 실시하여야 하며, 프로그램 등록 변경 · 폐기내용의 정당성에 대해 제3자의 검증을 받아야 하는데도
- ○○회사는 임대서버 6대를 운영환경에 적용시키기 위해 네트워크 구성을 포함한 시스템 프로그램을 변경하면서 가용성 테스트를 수행하지 않고, 제3자 검증도 받지 않은 사실이 있음

조치 사례('24.6.7.)

- ○○회사는 간편인증시스템을 도입하면서 프로그램을 운영시스템에 적용할 때 접속자 수에 따른 전산자원(CPU · MEM · 트래픽 유입량) 사용률 분석을 통해 간편인증시스템이 중단 없이 정상적으로 운영 가능하도록 동시 접속자 수를 산정하는 가용성 테스트를 실시하지 아니하여 접속자수 증가에 따른 시스템 부하발생 여부 등을 적정히 검증하지 못하였음

개선요구 등 사례('24.12.27.)

- ○○회사는 인터넷뱅킹, 모바일뱅킹 등 전자금융 관련 정보처리시스템에 다수의 오픈소스 프로그램을 운영하고 있으나 오픈소스 프로그램 사용에 대한 관리 방안, 통제 절차 등 거버넌스 체계가 마련되어 있지 않고, 오픈소스 사용 현황에 대한 정기적인 점검 절차가 없어, 법적 분쟁 및 보안상 리스크가 발생할 우려가 있으므로,
- 오픈소스 프로그램의 도입 · 활용 · 유지보수 등 소프트웨어 생명주기 전반에 관한 리스크 관리체계를 마련하고, 정기적으로 오픈소스 현황 관리 및 취약점 분석 등 관련 통제 활동을 수행할 필요

4. 일괄작업에 대한 통제

감독규정

제30조(일괄작업에 대한 통제) 금융회사 또는 전자금융업자는 안전하고 체계적인 일괄작업(batch)의 수행을 위한 절차를 수립 · 준수하여야 한다.

- 일괄작업의 경우 다수의 작업이 한 번에 처리되는 과정에서 데이터 무결성 · 신뢰성 · 정확성 저하 등이 발생할 수 있으므로 작업처리에 대한 철저한 통제가 필요하며, 일괄작업으로 전산원장을 변경하는 경우 규정 제30조 뿐만 아니라 규정 제27조도 함께 준수 필요

〈안전하고 체계적인 일괄작업(batch)의 수행을 위한 절차 수립 시 고려사항 예시〉

- 일괄작업은 작업요청서에 의한 책임자의 승인을 받은 후 수행
- 일괄작업은 최대한 자동화하여 오류를 최소화
- 일괄작업 수행 과정에서 오류 발생 시 책임자 확인 필요
- 일괄작업의 작업내용을 기록 · 관리
- 책임자는 일괄작업 수행자의 주요업무 관련 행위를 모니터링
- 일괄작업 스케쥴링 시 대체공휴일 등 영향 검토

- 개선요구 등 사례('24.9.27.)

  - ○○회사는 일괄작업을 즉시 실행해야 하거나 야간작업이 필요한 긴급 · 예외 상황에 대해서는 내규에 일괄작업 수행 대상 및 절차를 별도로 규정하고 있지 않으며, 긴급 일괄작업 중 일부는 책임자가 제대로 확인하지 않은 상태에서 승인이 되었을 우려가 있으므로
  - 내규에 긴급 · 예외 일괄작업 대상 및 관련 절차 등을 마련하고, 긴급 일괄작업의 사후 승인이 자동으로 처리되지 않도록 책임자 확인 및 승인 절차를 개선하며, 긴급작업 원인 및 조치내역을 충실하게 기록 · 관리할 수 있도록 내규를 개정할 필요

- 개선요구 등 사례('24.12.13.)

  - ○○회사는 일부 일괄작업에서 유사한 오류가 반복적으로 발생하고 있고, 오류원인 분석 및 조치가 장기간 미정리되는 사례가 발생하는 등 일괄작업 오류에 대한 사후관리가 다소 미흡하므로
  - 동일 오류가 반복적으로 발생하는 일괄작업 프로그램에 대하여 주기적으로 오류유형 및 원인 등을 분석하고 보완 조치한 결과를 정기적으로 보고하는 등 일괄작업 오류처리 관련 업무절차를 체계적으로 개선할 필요가 있음

제9절 전자금융업무

1. 전자금융거래 시 준수사항

감독규정

제34조(전자금융거래 시 준수사항) 금융회사 또는 전자금융업자는 전자금융거래와 관련하여 다음 각 호의 사항을 준수하여야 한다.

1. 전화 등 거래수단 성격상 암호화가 불가능한 경우를 제외한 전자금융거래는 암호화 통신을 할 것(다만, 전용선을 사용하는 경우로서 제36조의 규정에 따라 자체 보안성심의를 실시한 경우에는 그러하지 아니하다)
2. 전자금융사고를 예방하기 위하여 비대면 전자금융거래를 허용하지 않는 계좌 개설, 중요거래정보에 대한 문자메시지 및 이메일(e-mail) 통지 등의 서비스를 이용자가 요청하는 경우, 동 서비스를 제공할 수 있도록 시스템을 갖출 것
3. 전자금융거래에 사용되는 접근매체를 발급받기 위해서는 반드시 실명확인 후 교부할 것.
4. 금융회사 또는 전자금융업자는 전자금융거래에서 이용자에게 제공하거나 거래를 처리하기 위한 전자금융거래 프로그램(거래전문포함)의 위 · 변조 여부 등 무결성을 검증할 수 있는 방법을 제공할 것

■ 전자금융거래는 인터넷 등 공개된 통신망을 이용한 비대면 거래로 데이터 전송 중 고객정보 유출, 타인으로 위장한 거래, 거래정보의 송수신 과정에서 위·변조 등의 위험이 상존하기 때문에 안전한 전자금융거래 보호대책 마련 필요

■ 해설

● 전자금융거래에 사용되는 전자적 장치 중 유선전화기와 같이 암호화를 적용 시킬 수 없는 경우를 제외한 모든 전자금융거래는 송 · 수신 정보를 암호화 하여 통신회선에서의 불법적인 정보유출 방지 및 유출 시에도 알 수 없도록 조치(제1호)

- 다만, 금융회사 또는 전자금융업자와 이용자 간(법인 포함) 전용회선을 설치하여 정보를 송 · 수신 하는 경우로써 자체 보안성 심의를 받은 경우에는 암호화 예외 가능(법령해석 190193)

● 전자금융거래 이용을 원하지 않는 이용자의 예금과 금융거래 정보를 보호하기 위하여 금융회사는 모든 예금계좌(요구불, 저축성, 신탁 등)를 보안계좌[6]로 설정 또는 개설이 가능하도록 시스템 구축(제2호)

6) 온라인거래 수단인 "인터넷뱅킹, 텔레뱅킹, 모바일뱅킹, 온라인 계좌이체(전자상거래), 콜센터 또는 전화를 통한 거래"로 이체조회 등 모든 거래가 불가능한 계좌를 말하며 상기 업무를 제외한 나머지 업무는 일반계좌와 동일(영업점에서 직접 대면을 통한 거래(조회, 이체, 입금 등) 및 CD/ATM거래, 입금거래 등은 제한이 없음) 특히, 고객이 영업점에 전화를 걸어 계좌의 조회를 요청하는 경우에도 보안계좌인 경우에는 거래내역을 유선상으로 알려줄 수 없음

- 전자금융거래 이용자가 주요 금융거래 내역 및 제3자의 부정사용 여부에 대한 모니터링을 할 수 있도록 거래내역을 실시간으로 확인할 수 있는 문자메세지(SMS 서비스) 및 이메일(e-Mail) 알림 서비스를 요구하는 경우 서비스 제공이 가능하도록 시스템 구축(제2호)

- 전자자금이체 거래 시 접근매체(전자식 카드 및 전자적 정보, 이용자의 생체정보 등)를 발급하는 경우 금융회사 또는 전자금융업자는 전자금융거래 이용자 본인의 실명을 확인한 후 교부(제3호)

  - 다만, 단순히 접근매체를 저장하는 단말기 등을 변경하는 행위의 경우에는 '접근매체의 발급'으로 보기 어려우므로 실명 확인절차를 거칠 필요는 없음(법령해석 180288)

  - 실명은 주민등록표에 기재된 성명과 주민등록번호로 확인할 수 있으며 비대면 실명확인 방법*으로도 확인 가능(법령해석 170092)

    * ① 신분증 사본 제출, ② 영상통화, ③ 접근매체 전달시 확인, ④ 기존계좌 활용, ⑤ 기타 이에 준하는 새로운 방식(생체인증 등) 중 2가지 의무 적용

- 전자금융거래를 위해 이용자에게 제공하거나 거래처리에 이용되는 전자금융거래 프로그램(거래 전문포함)을 해킹이나 악성코드 감염 등에 의한 위·변조 사고를 예방하기 위하여 전자금융거래프로그램에 대한 무결성 검증 방법 제공(제4호)

※ 법령해석('19.12.3.)-190193

질의

- 1. 전자금융감독규정 제 34 조의 전자금융거래라 함은 고객이 상품 구매시에만 해당하는 부분인지, PG사와 가맹점간의 거래결과 데이터 전송 등에 대해서도 포함되는 영역인지 여부
  2. 전용회선을 통해 통신하는 것이 암호화통신을 수행하는 것으로 볼 수 있는지 여부
  3. 2번 질의에서 전용회선이 암호화통신으로 인정되지 않는다면, 전자결제(PG) 에 가입된 해당 가맹점의 정산 데이터 전송 등의 전자금융거래가 완료되었다는 통보를 전용회선+VPN(Virtual Private Network)의 구조로 외부와 통신하는 경우 등*에는 암호화통신으로 볼 수 있는지 여부
     * 전용회선+VPN(Virtual Private Network)의 구조로 외부와 통신하거나, HTTPS나 SETP로 처리할 경우에는 암호화통신으로 볼 수 있는지 여부

회신

- 전자결제대행업체(PG사)가 가맹점 간의 전자금융거래 정보를 송·수신하는 것은 전자금융거래에 포함됨을 알려드립니다.
- 「전자금융감독규정」 제34조 제1호의 내용과 구조를 고려할 때, 단순히 전용선을 사용하는 것을 암호화 통신으로 보기는 어렵습니다.
- 암호화 통신을 위한 보안기술은 금융회사가 자율적으로 선택하여 사용할 수 있음을 알려드립니다.

이유

- 「전자금융거래법」제2조 제1호에 따라, "전자금융거래"란 금융회사 또는 전자금융업자가 전자적 장치를 통하여 금융상품 및 서비스를 제공하는 것으로 정의하고 있으므로,
  - 전자결제대행업체(PG사)가 가맹점 간의 전자금융거래 정보를 송 · 수신하는 것은 전자금융거래에 포함되는 것으로 볼 수 있습니다.
- 「전자금융감독규정」제34조제1호는 전자금융거래 시 암호화 통신을 의무화하고 있으며, 다만 전용선을 사용하면서 자체 보안성심의를 실시한 경우 예외를 인정하고 있습니다.
  - 같은 규정에서 암호화 통신과 전용선을 구분하여 원칙과 예외사항으로 나누어 기술하고 있다는 점을 고려할 때, 단순히 전용선을 사용하는 것을 암호화 통신으로 보기는 어렵습니다.
- 「전자금융거래법」제21조 제3항 및 전자금융감독규정 제37조의 내용 등을 고려*할 때 금융회사 및 전자금융업자는 전자금융거래에 사용되는 보안기술과 인증수단을 자율적으로 선택할 수 있습니다.

  * 특정 기술 또는 서비스의 사용을 강제하지 않는 '기술 중립성 원칙'이 도입하여 금융회사가 자율적으로 금융보안 수단을 결정할 수 있도록 함

  - 현행 규정에서 암호화 통신에 대한 세부적인 내용을 정하고 있지 않는바, 암호화 통신을 위한 보안기술은 금융회사가 자율적으로 선택하여 사용할 수 있습니다.

※ 법령해석('18.9.5.)-180288

질의

- 무매체 기반의 접근매체(스마트 보안카드, 모바일OTP등) 이용자가 이용 하고자 하는 단말기를 변경하는 경우에도 전자금융감독규정 제34조 제3호의 '접근매체 발급'으로 보고 실명확인 절차를 거쳐야 하는지 여부

회신

- 단순히 접근매체를 저장하는 단말기 등을 변경하는 행위의 경우에는 '접근매체의 발급'으로 보기 어려우므로 접근매체 발급에 따르는「전자금융감독규정」 제34조 제3호의 실명 확인절차를 거칠 필요는 없습니다.

이유

- 「전자금융거래법」 제2조제10호에 따르면 "접근매체"란 전자금융거래에 있어서 거래지시를 하거나 이용자 및 거래내용의 진실성과 정확성을 확보하기 위하여 사용되는 일련의 수단 또는 정보를 의미합니다.
- 따라서 전자금융거래상 거래지시 또는 진실성과 정확성 확보에 사용되는 수단 및 정보가 동일한 경우, 해당 접근매체를 저장하는 단말기 등이 변경되었다고 하더라도 새롭게 접근매체를 발급한 것으로 보기 어렵습니다.

※ 법령해석('17.5.18.)-170092

질의

■ 「전자금융감독규정」 제34조 제3호에서 접근매체 발급시 '실명확인'하도록 하고 있는데 다양한 인증기술을 활용한 본인확인 절차로도 접근매체 발급이 가능한지 여부

* 「전자금융거래법」 제6조 제2항 : 접근매체 발급시 '본인확인'을 하도록 규정

회신

■ 접근매체를 발급하기 위해서는 반드시 실명확인(비대면 실명확인 포함)을 거쳐야 합니다.

이유

■ 「전자금융거래법」제6조 제2항 및 「전자금융감독규정」 제34조 제3호를 종합하여 볼 때 접근매체를 발급하기 위해서는 본인확인이 필요하며, 그 중에서도 실명을 확인할 수 있는 방법에 따라야 한다고 보는 것이 타당할 것입니다.

- 실명은 주민등록표에 기재된 성명과 주민등록번호로 확인할 수 있으며 비대면 실명확인 방법*으로도 확인 가능하나, 그 밖의 방법은 현재로서는 인정되지 않습니다.

  * ① 신분증 사본 제출, ② 영상통화, ③ 접근매체 전달시 확인, ④ 기존계좌 활용, ⑤ 기타 이에 준하는 새로운 방식(생체인증 등) 중 2가지 의무 적용('15.12월 유권해석)

조치 사례('22.10.31.)

- 금융회사는 전자금융거래에서 이용자에게 제공하거나 거래를 처리하기 위한 전자금융거래 프로그램(거래전문포함)의 위·변조 여부 등 무결성을 검증할 수 있는 방법을 제공하여야 하는데도,
- ○○회사는 스마트뱅킹시스템을 구축하면서, 거래전문의 이중처리를 방지하기 위한 무결성 검증방법 중 일부를 전자금융거래에 제공하지 아니한 채 운영하였음

2. 인증방법 사용기준

감독규정

제34조의2(인증방법 사용기준) 금융회사 또는 전자금융업자는 전자금융거래의 종류 · 성격 · 위험수준 등을 고려하여 안전한 인증방법을 사용하여야 한다.

- 금융회사 또는 전자금융업자가 전자금융거래 이용자 신원확인, 거래내용의 위 · 변조, 거래사실의 부인방지 등을 위해 전자금융거래 시 적용하였던 공인인증서의 사용의무가 폐지되고, 금융회사 등이 전자금융거래의 종류 · 성격 · 위험수준 등을 고려하여 전자금융거래의 안전성 및 정당성 확보에 가장 적합하다고 판단되는 인증방법 사용

※ 법령해석('18.10.10.)-180313

질의

- 2) 당사의 외국인 전용 앱을 통한 무기명카드 충전시 회원은 해외발행 신용카드를 사용하도록 되어 있고, 이용자는 해외발행 신용카드의 정보(카드번호, 카드 유효기간, cvc번호, 카드 비밀번호 앞 두자리)를 기입하고 해외신용카드사의 결제 승인에 따라 무기명 카드를 충전할 수 있음. 이러한 방식이 안전한 인증방법을 사용하도록 한 전자금융감독규정 제37조에 위배되는지 여부

회신

- 전자금융감독규정 제37조의 경우 금융회사 또는 전자금융업자가 전자금융거래의 종류, 성격, 위험수준 등을 감안하여 전자금융거래에 사용되는 안전한 인증방법을 자율적으로 선택하여 사용할 수 있도록 규정하고 있습니다.

이유

- 전자금융감독규정 제37조는 전자금융거래에 있어 특정한 인증방법(예 : 공인인증)을 한정하고 있지 않으므로 금융회사 또는 전자금융업자의 판단과 책임 하에 전자금융거래의 종류, 성격, 위험수준 등을 고려하여 안전한 인증 방법을 적절히 선택하여 사용할 수 있습니다.

※ 법령해석('16.5.2.)-160603

질의

- 공인인증서 대신 가상번호(○○○○토큰) 인증을 인터넷뱅킹의 인증방법으로 사용하는 것이 가능한지 여부

회신

- 전자금융거래에 있어서 공인인증서 대신 「전자금융감독규정」 제37조(인증방법 사용기준)에 따라 안전하다고 판단되는 인증방법을 사용하는 것이 가능합니다.

이유

- 「전자금융거래법」 제21조(안전성의 확보의무)는 전자금융거래의 안전성 및 신뢰성을 확보하는 것을 전제로 특정 기술 또는 서비스의 사용을 강제하지 않는 '기술중립성 원칙'을 명확히 하고 있으며, 「전자금융감독규정」 제37조도 전자금융거래에 있어 특정한 인증방법(예 : 공인인증서)을 한정하고 있지 않으므로 금융회사 또는 전자금융업자의 판단과 책임 하에 안전한 인증방법을 적절히 선택하여 사용할 수 있다고 봄이 타당합니다.

※ 비조치의견서('16.5.27.)-160607

비조치의견서는 행정해석의 일종으로 최종 법적구속력은 없으며, 유권해석과는 달리 특정행위에 대해 해당 회사의 상황을 고려한 검토결과로써 일반적 효력을 가지지 아니하므로 참고자료로만 활용하시기 바랍니다.

요청대상 행위

■ 인터넷/스마트뱅킹을 통한 전자자금이체 거래시 ㅇㅇ안심보안카드*를 인증방법으로 사용할 경우,

* ○○안심보안카드를 스마트폰에 접촉하여 본인임을 인증하고, 이체 거래시 보안카드번호를 입력하는 2단계 인증 절차를 수행

• 동 인증방법이 전자금융감독규정 제37조에서 정한 안전한 인증방법에 해당하는지 여부

판단

■ 금융회사는 전자금융거래에 사용되는 인증방법을 자율적으로 선택하여 사용할 수 있습니다.

• 다만, 개정 법규의 취지에 따라 금융회사 자체적으로 보안 및 인증방법에 대한 안전성을 확보해야 하오니 이 점 유념하시기 바랍니다.

판단이유

■ 전자금융거래법 제21조 제3항 및 전자금융감독규정 제37조의 내용을 고려*할 때 금융회사는 전자금융거래에 사용되는 인증방법을 자율적으로 선택할 수 있습니다.

* 특정 기술 또는 서비스의 사용을 강제하지 않는 '기술 중립성 원칙'이 도입됨에 따라 경쟁촉진적인 인증기술 사용을 위해 전자금융거래시 공인인증서 등을 사용하도록 한 의무를 폐지(금융위원회 고시 제2015-7호)

조치 사례('23.12.21.)

● 금융회사는 전자금융거래의 안전성과 신뢰성을 확보할 수 있도록 전자금융거래의 종류 · 성격 · 위험 수준 등을 고려하여 안전한 인증방법을 사용하여야 하는데도

● ○○회사는 모바일 앱에 대하여 취약점 분석 · 평가 전문기관을 통해 이용자 인증 등에 대한 취약점을 진단한 결과, 타인명의의 휴대폰에서 모바일 앱 가입을 위해 본인 인증시 휴대폰번호를 위 · 변조하는 수법으로 인증방법을 우회할 수 있는 취약점이 발견되었음에도 불구하고 추가인증 등의 안전한 인증방법을 사용하지 아니하여,

● 불상자가 스마트폰 피싱 등의 방법을 이용해서 수집한 것으로 추정되는 고객정보를 도용하여 본인인증을 우회함으로써 신용카드를 부정 사용하는 결과를 초래하였음

3. 이용자 비밀번호 관리

감독규정

제34조의3(이용자 비밀번호 관리) ① 금융회사 또는 전자금융업자는 정보처리시스템 및 전산자료에 보관하고 있는 이용자의 비밀번호를 암호화하여 보관하며 동 비밀번호를 조회할 수 없도록 하여야 한다. 다만, 비밀번호의 조회가 불가피하다고 인정되는 경우에는 그 조회사유 · 내용 등을 기록 · 관리하여야 한다.

② 금융회사 또는 전자금융업자는 이용자의 비밀번호 유출을 방지하기 위하여 다음 각 호의 사항을 정보처리시스템에 반영하고 이를 준수하여야 한다.

1. 제3자가 쉽게 유추할 수 없는 비밀번호 작성규칙 및 등록 · 변경 절차를 수립 · 운영할 것
2. 미리 정한 횟수 이상의 비밀번호 입력 오류가 발생한 경우 즉시 해당 비밀번호를 이용하는 거래를 중지시키고 본인 확인절차를 거친 후 비밀번호 재부여 및 거래 재개(이체 비밀번호 등 동일한 비밀번호가 다양한 형태의 전자금융거래에 공통으로 이용되는 경우, 입력오류 횟수는 이용되는 모든 전자금융거래에 대하여 통산한다)
3. 신규 거래, 비밀번호 변경, 이체 신청과 같이 비밀번호를 등록 · 사용하는 경우 사전에 신청서 등에 기입하지 않고, 핀패드 등 보안장치를 이용하거나 이용자가 사후에 전자적 장치를 이용하여 직접 입력하는 방식으로 운영할 것
4. 이용자 비밀번호 변경 시 본인확인 절차를 수행할 것

이용자*의 비밀번호는 예금거래, 주식거래, 보험청약 등에서 핵심이 되는 정보로서 금융회사 직원이라 하여도 임의로 조회 금지

* "이용자"는 "전자금융거래를 위하여 금융회사 또는 전자금융업자와 체결한 계약에 따라 전자금융거래를 이용하는 자"를 의미하며(법 제2조 제7호), "사용자"는 금융회사 또는 전자금융업자가 인가 · 허가 또는 등록 등을 받은 금융업(또는 전자금융업)을 영위함에 있어 해당 업무의 수행을 위해 정보처리시스템을 사용하는 자로서 임직원 및 외주직원을 포함

- 이용자는 여러 종류의 비밀번호를 암기하기가 어려워 본인의 신상과 관련이 있는 숫자를 사용하는 것이 일반적이므로 전산 시스템에서 유추가능한 비밀번호의 등록을 제한하고, 일정횟수 이상의 입력 오류 발생 시에는 사용을 정지시킴으로써 전자금융 사고 예방

규정 개정으로 이용자 비밀번호 유출 방지를 위한 사항을 정보처리시스템 "반영"에서 나아가 "준수"를 요구하고 있으므로 유의

해설

- 접속용 비밀번호, 원장비밀번호, 현금카드 비밀번호 등과 같은 이용자 비밀번호는 암호화 하도록 하고, 정보처리시스템에 저장하여 금융회사 업무담당자도 조회가 불가능하도록 운영(제1항)
  - 비밀번호 조회가 불가피할 경우 조회 사유 · 내용 등을 기록 · 관리

- 제3자가 쉽게 유추할 수 없는 비밀번호 작성규칙 및 등록·변경 절차를 수립·운영(제2항 제1호)
- 이용자가 전자금융수단을 이용하여 비밀번호를 입력시 금융회사가 사전에 정한 일정횟수(예 : 5회 등)를 초과 입력한 비밀번호에 대하여 입력 오류가 발생한 경우 즉시 해당 비밀번호를 이용하는 거래를 중지시키고 본인 확인절차를 거친 후 비밀번호 재부여(제2항 제2호)
- 계좌원장 비밀번호, 이체 비밀번호 등 비밀번호가 인터넷뱅킹, 자동화기기(CD/ATM), 텔레뱅킹 등과 같이 다양한 형태의 전자금융거래에서 공통으로 이용되는 경우 입력오류 횟수를 모든 전자금융거래에 대하여 통산하여 적용(제2항 제2호)
- 신규 거래, 비밀번호 변경, 이체 신청과 같이 비밀번호를 등록·사용하는 경우 사전에 신청서 등에 기입하지 않고, 핀패드 등 보안장치를 이용하거나 이용자가 사후에 전자적 장치를 이용하여 직접 입력하는 방식으로 운영(제2항 제3호)
  - ACS(Auto Call System)를 통한 비밀번호 입력방식은 핀패드(Pin-Pad)와 동등 또는 유사한 방식으로 인정
- 이용자 비밀번호 변경 시 본인확인 절차를 수행(제2항 제4호)
  - 본인확인 절차는 원칙적으로 지점방문을 통한 대면 확인만을 의미하는 것은 아니며, 비대면 인증기술을 통한 비대면 본인확인도 가능

※ (참고) 비밀번호 오류시 거래 제한

유형	설명
계좌원장 비밀번호 오류	이체, 출금, 조회(계좌원장 비밀번호를 입력하는 경우에 한정) 등 계좌원장 비밀번호를 이용하는 전자금융거래 제한
일회용비밀번호 오류	인터넷뱅킹, 텔레뱅킹 등에서 일회용비밀번호를 사용하는 전자금융거래 제한
특정 전자금융거래에서만 사용하는 비밀번호 오류	해당 전자금융거래만 제한 예) ARS 전용 이체비밀번호 오류횟수 초과시 ARS 이체만 불가, 조회 가능

※ 법령해석('18.10.10.)-180313

질의

- 1-1) 무기명 선불전자지급수단의 충전 및 사용내역 조회를 위한 외국인 전용 앱은 비밀번호 분실시 회원가입단계에서 입력한 이용자 이메일계정으로 비밀번호를 통지함. 이러한 방식이 전자금융감독규정 제33조 제2항 제3호 및 제35조 제4호에 위배되는지 여부
  * 회원가입단계에서 입력한 아이디(이메일 계정)와 비밀번호로 가입이 가능
- 1-2) 외국인 전용 앱에서 충전 기능을 제외하고 무기명카드 사용내역 조회만 가능하도록 설계하는 아래의 방식이 전자금융감독규정 제33조 제2항 제3호 및 동규정 제35조 제4호에 위배되는지 여부
  - 이용자가 로그인 절차만을 통해서 앱에 등록된 무기명카드의 사용내역(결제내역, 충전내역, 충전잔액)을 조회
  - 회원가입단계 절차 없이 비회원 접속을 통해 무기명카드 정보(카드 번호, 유효기간, cvc 입력)를 입력하여 무기명카드 사용내역(결제내역, 충전내역, 충전잔액)을 조회

회신

- 전자금융거래법상의 본인 확인의무는 원칙적으로 계좌를 기반으로 하는 거래 등 이용자가 누구인지 신원확인이 필요한 거래에 적용되는 의무라고 할 수 있으며,
  - 전자금융감독규정 제33조 제2항 제3호에 따른 본인확인절차는 특정방식을 한정하고 있지 않으므로, 금융회사 또는 전자금융업자의 판단에 따라 적절한 본인 확인절차를 적용할 수 있습니다.
    * 다만, 비밀번호 등 개인정보를 보호하기 위하여 준수하여야 할 정보통신망법 등 관계 법령을 준수할 필요

이유

- 전자금융거래법상의 본인 확인의무는 원칙적으로 계좌를 기반으로 하는 거래 등 이용자가 누구인지 신원확인이 필요한 거래에 적용되는 의무라고 할 수 있습니다.
  - 또한, 전자금융감독규정 제33조 제2항 제3호는 본인확인절차를 대면 또는 '실명증표의 확인' 등 특정방식으로 한정하고 있지 않으므로, 금융회사의 판단에 따라 적절한 본인확인절차를 적용할 수 있습니다(한편, 제35조 제4호는 이용자 유의사항 공지에 관한 사항으로 이와 동일).

※ 법령해석('15.3.11.)-150004

질의

- ACS(Auto Call System)를 통한 비밀번호 입력방식이 전자금융감독규정 제33조(이용자 비밀번호 관리) 제2항제4호 내지 5호에서 규정하고 있는 '핀패드 등 보안장치 또는 전자적 장치'에 해당하는지 여부

회신

- 귀 사의 ACS는 전자금융감독규정 제33조제2항제4호 또는 제5호에서 규정하고 있는 핀패드(Pin-Pad)와 동등 또는 유사한 방식으로 판단됩니다.

이유

- 핀패드는 통상 고객의 통장개설 신청서, 전표 등에 기재된 비밀번호가 금융회사 직원의 업무처리 또는 전표 폐기과정에서 유출되는 것을 방지하기 위하여,
  - 고객이 거래용지 등에 비밀번호를 쓰는 대신 손으로 직접 입력할 수 있게 하는 장치(금융용어사전, 금융감독원)를 의미합니다.

- 귀 사의 ACS는 고객이 비밀번호를 신청서, 전표 등에 기재하지 않고 고객의 단말기를 이용하여 직접 입력한다는 점에서 본질적으로 핀패드와 동등 또는 유사한 방식으로 판단됩니다.
  - 다만, 귀 사의 ACS는 통상 금융회사의 비밀번호 입력기를 사용하는 통상적 핀패드와 달리 고객의 단말기를 사용한다는 점에서 더욱 엄격한 관리가 필요할 것으로 판단됩니다.

※ 법령해석('15.10.23.)-150267

질의

- 이용자의 계좌원장 비밀번호 입력 오류로 인해 「전자금융감독규정」 제33조제2항제3호에 따른 본인확인절차가 필요한 경우, 동 조항상 본인확인 절차가 '지점 방문을 통한 대면 확인'만을 의미하는 것인지 여부

회신

- 「전자금융감독규정」 제33조제2항제3호에 따른 본인확인절차는 원칙적으로 지점 방문을 통한 대면 확인만을 의미하는 것은 아니며, 비대면 인증기술을 통한 비대면 본인확인도 가능합니다.

이유

- 「전자금융감독규정」 제33조제2항제3호는 본인확인절차를 대면 또는 '실명증표의 확인' 등으로 특정 방식으로 한정하고 있지 않은바, 금융회사의 판단에 따라 적절한 본인확인 절차를 적용토록 함이 바람직합니다.

4. 이용자 유의사항 공지

감독규정

제35조(이용자 유의사항 공지) 금융회사 또는 전자금융업자는 전자금융거래의 안전한 수행을 위하여 이용자에게 필요한 사항을 공지하여야 한다.

전자금융거래이용자가 안전한 전자금융거래를 수행할 수 있도록 이용자에게 필요한 정보를 공지

해설

- 전자금융거래 이용자 유의사항을 홈페이지 게시 등 전자적인 방법 또는 우편물 등을 통하여 이용자에게 공지
- 유의사항은 금융회사 또는 전자금융업자가 안전성 확보 차원에서 탄력적으로 판단

〈이용자 유의사항 공지 예시〉

- 비밀번호 유출위험 및 관리에 관한 사항
- 비밀번호 변경 절차(변경은 본인확인 절차를 거쳐 가능하며, 변경 시 같은 번호 재사용 불가)
- 이용자 보호제도에 관한 사항
- 해킹 · 피싱 등 전자적 침해 방지에 관한 사항

5. 자체 보안성심의

감독규정

제36조(자체 보안성심의) ① 금융회사 또는 전자금융업자는 다음 각 호의 행위를 하고자 하는 경우 금융감독원장이 정하는 기준과 절차에 따라 보안성심의를 실시하여야 한다.

1. 정보통신망을 이용하여 이용자를 대상으로 신규 전자금융업무를 수행
2. 복수의 금융회사 또는 전자금융업자가 공동으로 전자금융거래 관련 표준을 제정

② 금융회사 또는 전자금융업자는 제1항에 따른 심의(이하 "자체 보안성심의"라 한다)를 마친 후 제1항 각 호의 행위를 수행한 날로부터 30일 이내에 금융감독원장이 정하는 자체 보안성심의 결과보고서를 금융감독원에 제출하여야 한다. 다만, 제1항제1호에 따른 보안성심의의 경우 신규 전자금융업무가 제공 또는 시행된 날을 기준으로 과거 1년 이내에 전자금융사고가 발생하지 않은 기관으로서 금융감독원장이 정하는 기준에 해당하는 금융회사 또는 전자금융업자는 그러하지 아니하다.

③ 금융감독원장은 제2항에 따라 제출받은 자체 보안성심의 결과보고서를 검토한 결과, 보안수준이 충분하지 않다고 인정되는 경우에는 금융회사 또는 전자금융업자에 대하여 개선 · 보완을 요구할 수 있다.

④ 제2항 및 제3항에도 불구하고 다음 각 호의 기관은 제1항제1호에 따른 자체 보안성심의 결과보고서의 제출을 하지 아니할 수 있다.

1. 「우체국예금 · 보험에 관한 법률」에 의한 체신관서
2. 「새마을금고법」에 의한 새마을금고 및 새마을금고중앙회
3. 「공공기관의 운영에 관한 법률」 제4조에 따른 공공기관

시행세칙

제3조(자체 보안성심의 기준 등) ① 규정 제36조제1항에 따른 감독원장이 정하는 기준과 절차란 다음 각 호를 말한다.

1. 정보통신망을 이용하여 신규전자금융업무를 수행하는 경우 별표 1의 기준에 따라 보안성심의를 실시한 후 정보보호최고책임자의 승인을 받을 것
2. 공동으로 전자금융거래 관련 표준을 제정하는 경우 별표 1의2의 기준에 따라 보안성심의를 실시할 것(다만, 이 경우 특정 금융회사 또는 전자금융업자가 다른 금융회사등을 대표하여 규정 제36조제2항에 따른 자체 보안성심의 결과보고서를 제출할 수 있음).

② 금융회사 또는 전자금융업자가 규정 제36조제2항에 따라 제출하는 자체 보안성심의 결과보고서의 양식은 제1항제1호의 경우 별지 제3호서식에, 제1항제2호의 경우 별지 제4호서식에 각각 따른다.

③ 금융회사 또는 전자금융업자는 제1항에 따른 자체 보안성심의를 수행함에 있어 필요한 경우 규정 제37조의6제1항의 침해사고대응기관, 「정보통신기반보호법」 제16조제1항의 정보공유 · 분석센터 등 외부기관에 보안대책의 적정성 여부 등에 대한 검토를 의뢰할 수 있다.

④ 규정 제36조제2항 단서에서 "금융감독원장이 인정하는 기준"이란 다음 각 호에서 정하는 요건을 충족하는 것을 말한다.

1. 전자금융업자 : 법 제28조에 따라 금융위원회로부터 허가를 받았거나 금융위원회에 등록한 날 및 전자금융업무를 신규로 수행한 날로부터 1년이 경과하였을 것.
2. 금융회사 : 전자금융업무를 신규로 수행한 날로부터 1년이 경과하였을 것

■ 금융회사 또는 전자금융업자의 정보통신망을 이용하여 이용자를 대상으로 신규로 전자금융업무를 수행하는 경우 전자금융업무의 안전성이 확보될 수 있도록 금융감독원장이 정한 거래당사자 인증, 거래정보의 기밀성 및 무결성, 정보유출 방지대책 등 기준과 절차에 따라 자체 보안성심의를 실시하여 전자금융업무의 보안 문제점을 제거

■ 해설

● 금융회사 또는 전자금융업자는 전자금융업무를 신규로 추진하고자 하는 경우 금융감독원장이 정한 자체 보안성심의 기준에 따라 보안성심의를 실시하고 정보보호최고책임자의 승인을 받은 후 전자금융업무가 제공 또는 시행된 날로부터 30일(캘린더데이) 이내에 보안성심의 결과 보고서를 금융감독원에 제출

신규 전자금융업무의 제공 또는 시행일 기준으로 과거 1년 이내에 전자금융사고가 발생하지 않은 금융회사 등은 자체 보안성심의 결과를 금융감독원 제출 면제(제1항 제1호)

- 다만, 신규등록한 전자금융업자 또는 전자금융서비스를 최초 제공한지 1년이 지나지 않은 금융회사는 '1년 이내 전자금융사고가 발생하지 않은 기관'에 포함되지 않음(시행세칙 제3조 제4항)
- 즉, 자체 보안성심의가 면제되는 대상은 해당 전자금융업무를 신규로 수행한지 1년이 넘은 금융회사나 전자금융업자 중 최근 1년 동안 전자금융사고가 발생하지 않은 회사
- 여기서의 '전자금융업무'란 PG업, 에스크로업과 같이 전자금융업 등록 단위가 아닌 계좌이체, 멤버십 기능 추가, 본인인증 방식 추가 등 세부적 단위의 업무를 의미

● 금융회사 또는 전자금융업자 공동으로 표준 제정시 보안성심의 실시 및 사후 보고 필요(제1항 제2호)

- 공동 표준안 제정시 보안성심의에 관한 자료는 표준 제정에 참여한 금융회사 중 대표 금융회사가 제출 가능

● 전자금융업무에 대한 자체 보안성심의 기준 및 절차는 금융감독원장이 정한 심의 기준〈시행세칙 별표1〉에 따라 보안성심의를 실시하고 정보보호최고책임자의 승인을 받는 것을 의미(세칙 제3조 제1항 제1호)

- 공동 표준 제정에 대한 자체 보안성심의는 〈시행세칙 별표1의2〉에 따라 실시(세칙 제3조 제1항 제2호)

● 금융회사 등이 자체 보안성심의를 실시할 때 필요한 경우 침해사고대응기관, 정보공유·분석센터(금융보안원) 등 외부 전문기관에 의뢰하여 심의대상 전자금융업무에 대한 보안대책의 적정성 여부 검토 가능

※ 법령해석('16.1.12.)-150405

질의

- 「전자금융감독규정」상 자체 보안성 심의 대상인 "신규 전자금융업무"의 구체적 의미

회신

- 금융당국에서는 금융회사 및 전자금융업자의 부담을 완화하고 자율적인 보안수준 확보 노력을 유도하고자 과거 금융감독원에서 수행하는 보안성심의 제도를 폐지하고 자체 보안성심의를 수행 보고토록 하고 있으며, 자체 보안성 심의 대상은 「전자금융감독규정」 제36조에서 "신규 전자금융업무"로 규정하고 있습니다.

- 이때 '전자금융업무'란 PG업, 에스크로업과 같이 전자금융업 등록 단위가 아닌 계좌이체, 멤버십 기능 추가, 본인인증 방식 추가 등 세부적 단위의 업무를 뜻합니다.
  따라서 예시하신 (i)신규로 전자금융업 중 하나를 등록하면서 약관도 제정하여 신고하는 경우, (ii)기존에 전자금융업으로 등록하고 약관 신고도 마친 전자금융서비스를 영위 중 기존 전자금융업 서비스 중 일부서비스에 새로운 유형의 전자금융서비스를 추가하여 출시하는 경우, (iii)기존 전자금융업 등록한 서비스와 동일 유형의 전자금융서비스를 추가로 출시하는 경우와 더불어 (iv)기존 전자금융업으로 등록한 서비스의 전자금융업무 유형을 유지하면서 관련한 서비스를 추가로 출시하는 경우, (v)기존 전자금융업으로 등록된 서비스의 일부 변경, 개편, 기능추가 등의 경우에도 새로운 서비스가 추가된다면 신규에 해당하는 것으로 볼 수 있습니다.
  다만, (iv), (v)의 경우 단순 메뉴 추가, 디자인 변경 등 신규성이 있다고 보기 어려운 경우도 많습니다. 이런 경우 보안성심의의 목적에 맞게 보안리스크가 상당히 증가하는 경우에만 신규성이 있다고 판단하고 있습니다.

- 또한, 금융당국은 자율 보안수준 확보라는 목적에 맞춰 금융회사 및 전자금융업자가 자체 보안리스크 평가 기준을 내규화하여 평가결과에 따라 신규성을 판단하도록 유도하고 있습니다.

- 따라서 명백히 신규성이 있다고 판단되는 (i), (ii), (iii)의 경우 및 (iv), (v)의 경우 중 자체 내규에 따라 신규성이 있다고 판단되는 경우 자체보안성심의를 실시하시면 됨을 알려드립니다.

이유

- 「전자금융감독규정」 제36조의 자체 보안성심의는 보안성 수준에 대한 심의를 하는 것으로 신규성의 기준은 보안관점에서 볼 때 신규성입니다.
  * (예시) 당초 조회기능만 제공하던 모바일금융서비스 앱에서 신규로 이체 등 거래를 추가할 경우 보안리스크가 증가하고 증가한 수준이 보안에 미치는 영향이 상당하다고 판단될 때 이를 신규로 판단하여 자체 보안성심의 실시 및 금융감독원 제출 필요

※ 법령해석('16.5.2.)-160529

질의

- 은행의 「핀테크 오픈플랫폼」에서 제공하는 API를 활용하여 핀테크 기업이 제작한 핀테크 서비스가 신규 전자금융업무에 해당할 경우,
  - 동 핀테크서비스에 대해 은행이 보안성심의 실시 및 결과보고를 해야 하는지 여부

회신

- 신규 전자금융업무를 수행하는 핀테크 기업이 전자금융업자에 해당하는 경우「전자금융감독규정」 제36조의 자체 보안성 심의를 실시하여야 합니다.
- 은행이 핀테크 기업에 API를 제공하는 데에 그치고 직접 전자금융업무를 수행하지 않는 경우에는 해당 조항에 따른 보안성 심의 실시 및 결과보고 의무의 적용을 받지 않습니다.

이유

- 「전자금융감독규정」 제36조(자체 보안성심의)는 금융회사 또는 전자금융업자가 신규 전자금융업무를 수행하는 경우 자체적으로 보안성심의를 실시하도록 규정하고 있습니다. 따라서 '금융회사 또는 전자금융업자'가 아닌 경우 또는 직접 '전자금융업무를 수행'하지 않는 경우에는 해당 조항의 적용을 받지 않는 것으로 판단됩니다.
- 다만, 보안성심의 실시 주체와 별개로 핀테크 기업과 협약을 맺어 API를 제공하는 은행의 신뢰 유지 및 금융소비자 보호 등의 측면을 고려하여 금융보안원을 통한 보안 컨설팅 등 해당 서비스의 안정성 확보에 충분한 노력을 기울여야 할 것입니다.

※ 법령해석('17.2.3.)-170008

질의

- 당사의 '○○○ 자동장부*' 서비스가 신규 전자금융업무에 해당하여, 전자금융감독규정 제36조에 의거하여 자체 보안성심의를 필요로 하는지 여부
  * 가맹점의 매출과 거래내역(통장 거래내역, 카드사용내역, 현금영수증 내역, 카드매출내역 등) 등의 자료를 이용하여 해당 가맹점주가 간편하게 세무장부 작성 및 세무신고를 할 수 있도록 하는 부가서비스로서 결제 · 이체 등의 지급기능은 없음

회신

- ○○○ 자동장부는 '신규' 전자금융업무에는 해당하지 않아 자체 보안성 심의대상이 아님을 알려드립니다.

이유

- 금융회사 또는 전자금융업자는 「전자금융감독규정」 제36조 제1항 제1호에 따라 정보통신망을 통해 이용자를 대상으로 신규 전자금융업무를 수행하는 경우 자체 보안성심의를 실시하여야 하고, 그 결과를 신규 전자금융업무를 수행한 날로부터 7일 이내에 금융감독원에 제출하여야 합니다.
- 전자금융업무란 전자금융거래법 제2조 제1호에 따라 전자적 장치를 통하여 이용자에게 금융상품 및 서비스를 제공하는 것을 의미합니다.
  - '○○○ 자동장부' 서비스의 경우 금융거래내역을 이용하여 가맹점주(이용자)에게 금융서비스를 제공한다는 측면에서 전자금융업무에 해당합니다.
  - 다만, 상기 서비스는 금융회사로부터 조회된 거래정보를 그대로 이용한 서비스로서 신규성이 있다고 보기 어렵기 때문에 '신규' 전자금융업무에는 해당하지 않아 자체 보안성 심의대상이 아님을 알려드립니다.
  - 참고로, 자체 보안성 심의대상이 아니라 할지라도 서비스 관련 정보처리시스템 및 이용자 정보 등의 보호를 위한 보안규정을 준수하여 주시기 바랍니다.

금융감독원장이 정한 자체 보안성심의 기준(신규 전자금융업무)

	심의기준
1	거래 당사자 인증
2	거래정보의 기밀성 및 무결성
3	정보처리시스템 보호대책
4	고객 단말기 보호대책
5	정보유출 방지대책
6	이상금융거래 방지대책
7	시스템 가용성 확보 및 비상대책
8	시스템 설치장소에 대한 물리적 접근통제

※ 전자금융업무 유형에 따라 자체적으로 심의기준 추가 · 수정 가능

금융감독원장이 정한 자체 보안성심의 기준(공동 표준안)

	심의기준
1	컴플라이언스 준수
2	사용자 접근성
3	호환성 지원
4	서비스 품질 보장(안정성)
5	불필요한 기능 제거(간결성)
6	표준화 그룹 체계 관리

※ 공동 표준안의 유형에 따라 자체적으로 심의기준 추가 · 수정 가능

조치 사례('22.6.28.)

- 금융회사는 정보통신망을 이용하여 신규 전자금융업무를 수행하는 경우 자체 보안성심의를 실시하여야 하는데도(전자금융감독규정 제36조제1항제1호),
- ○○회사는 ○○○금융시스템에 대하여 보안취약점 노출 여부 등을 점검하기 위한 자체 보안성심의를 수행하지 않았음

6. 정보기술부문 계획서

감독규정

제36조의2(정보기술부문 계획서 제출 절차 등) ① 시행령 제11조의3에 따라 금융위원회에 정보기술부문 계획서를 제출해야 하는 금융회사 또는 전자금융업자는 현실적이고 실현 가능한 장·단기 정보기술부문 계획을 매년 수립·운용하여야 하며, 정보기술부문 계획서 제출에 관한 세부적인 절차, 양식 등에 관해서는 금융감독원장이 정하는 바에 따른다.

② 금융위원장은 금융감독원장으로 하여금 정보기술부문 계획서의 적정성 등을 평가한 후 관련보고서를 제출하게 할 수 있다.

- 정보화는 많은 투자비용이 소요되고, 전산화 방향이 금융회사 및 전자금융업자의 경영전략에 부합되지 않을 경우에는 대외 경쟁력을 상실하게 될 뿐만 아니라 기 투자된 비용을 회수하기가 곤란하여 예산낭비를 초래하므로 이를 방지하기 위해 적절하고 타당한 장·단기 계획을 수립·운용하여 정보화 추진

- 해설

  - 정보화계획은 전략기획(장기계획)과 운용계획(단기계획)으로 구분하여 실현가능한 장·단기 정보기술부문 계획을 매년 수립(제1항)하여 대표자의 확인·서명을 받아 금융감독원에 제출

※ 관계 법령

법

제21조(안전성의 확보의무) ④ 대통령령으로 정하는 금융회사 및 전자금융업자는 안전한 전자금융거래를 위하여 대통령령으로 정하는 바에 따라 정보기술부문에 대한 계획을 매년 수립하여 대표자의 확인·서명을 받아 금융위원회에 제출하여야 한다.

시행령

제11조의3(정보기술부문 계획수립의 대상 금융회사 등) ② 법 제21조제4항에 따른 정보기술부문에 대한 계획에는 다음 각 호의 사항이 포함되어야 한다.

1. 정보기술부문의 추진목표 및 추진전략
2. 정보기술부문의 직전 사업연도 추진실적 및 해당 사업연도 추진계획
3. 정보기술부문의 조직 등 운영 현황
4. 정보기술부문의 직전 사업연도 및 해당 사업연도 예산
5. 그 밖에 안전한 전자금융거래를 위하여 정보기술부문에 필요한 사항으로서 금융위원회가 정하여 고시하는 사항

③ 법 제21조제4항에 따른 정보기술부문에 대한 계획은 매 사업연도 초일(初日)부터 3개월 이내에 금융위원회에 제출하여야 한다.

④ 제2항에 따라 정보기술부문에 대한 계획에 포함되어야 하는 사항의 세부내용이나 제출방법 등에 관하여 필요한 사항은 금융위원회가 정하여 고시한다.

제30조(권한의 위탁) ①금융위원회는 법 제48조에 따라 다음 각 호의 업무를 「금융위원회의 설치 등에 관한 법률」에 따른 금융감독원의 장에게 위탁한다.

1의2. 법 제21조제4항에 따른 정보기술부문에 대한 계획의 접수

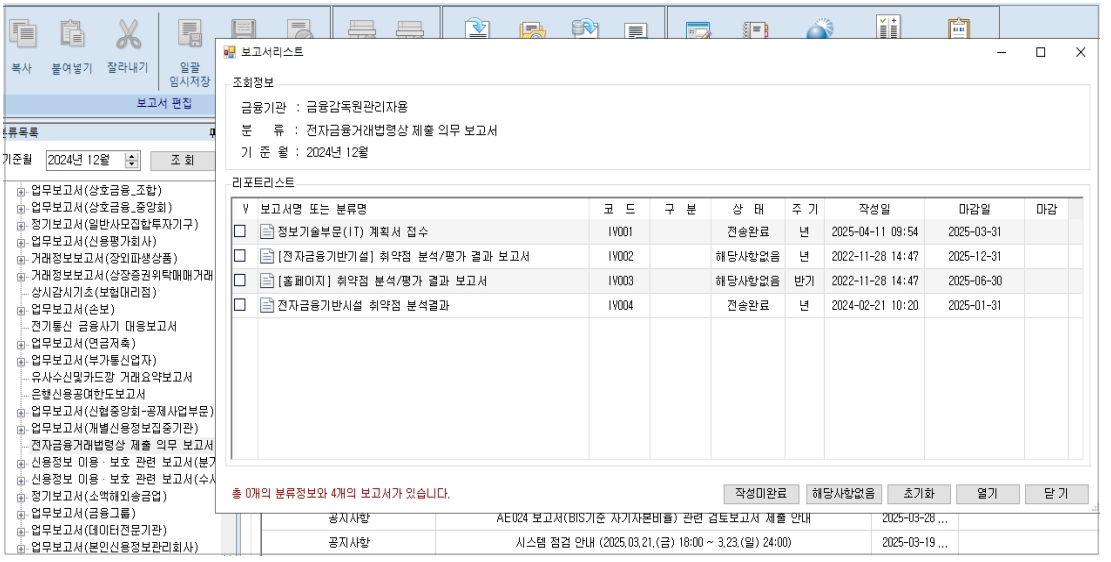
■ 정보기술부문 계획서는 금융정보교환망*의 「금융감독원 보고서 작성기」를 이용하여 제출

* 금융정보교환망 : fines.fss.or.kr, 헬프데스크 : 02)3145-5401/5413

■ 기준월을 회계연도 마감월로 선택하여 조회를 누르면, 업무보고서(전자금융거래법령상 제출 의무 보고서)가 선택되며,

● 이 중 '정보기술부문(IT) 계획서 접수'를 선택하여 보고서 제출 전 자체 체크리스트 점검 후 보고서를 제출

※ 보고서 제출은 회계연도 마감 이후 3개월 이내에 회계연도 마감월의 보고서 항목을 조회하여 제출(마감 이후 제출 불가)



(참고) 정보기술부문 계획서 제출 유의사항

■ 정보기술부문 계획서 양식*을 준수하고, 제출 전 체크리스트를 통해 스스로 필수 제출 항목의 이행 여부의 확인

* 「전자금융감독규정시행세칙」 별지 제8호 서식 참고

● 직전 사업연도 추진 실적 작성 시 미완료의 경우 사유를 상세 추진내용에 함께 작성

● 또한, 작성한 정보기술부문 계획서 내용의 전자금융거래법령 및 규정 준수 여부에 대해 스스로 점검 후 제출

〈정보기술부문 계획서 점검 자체 체크리스트〉

평가 항목	평가 근거	정보기술부문 계획서 자체 점검	
		제출 포함 여부	법규 준수여부
① 제출 기한 준수 (3개월 이내 제출)	令 §11의3③	YES/NO/대상외	-
② 대표이사의 확인 후 제출	法 §21 ④	YES/NO/대상외	-
③ 정보보호위원회의 심의 · 의결	規 §8의2 ③	YES/NO/대상외	-
④ (내용) 추진 목표 및 전략	令 §11의3②	YES/NO/대상외	적정/부적정
⑤ (내용) 직전 사업연도 추진 실적	令 §11의3②	YES/NO/대상외	적정/부적정
⑥ (내용) 해당 사업연도 추진 계획	令 §11의3②	YES/NO/대상외	적정/부적정
⑦ (내용) 조직 등 운영 현황	令 §11의3②	YES/NO/대상외	적정/부적정
⑧ (내용) 직전 및 해당 사업연도예산	令 §11의3②	YES/NO/대상외	적정/부적정

제10절 취약점 분석 및 사고 대응 등

1. 전자금융기반시설의 취약점 분석 · 평가주기, 내용 등

감독규정

제37조의2(전자금융기반시설의 취약점 분석 · 평가 주기, 내용 등) ① 전자금융기반시설의 취약점 분석 · 평가는 총자산이 2조원 이상이고, 상시 종업원 수(「소득세법」에 따른 원천징수의무자가 근로소득세를 원천징수한 자를 기준으로 한다. 이하 같다) 300명 이상인 금융회사 또는 전자금융업자이거나 「수산업협동조합법」, 「산림조합법」, 「신용협동조합법」, 「상호저축은행법」 및 「새마을금고법」에 따른 중앙회의 경우 연 1회 이상(홈페이지에 대해서는 6개월에 1회 이상) 실시하여야 한다.

② 금융회사 및 전자금융업자는 취약점 분석 · 평가를 위하여 정보보호최고책임자(정보보호최고책임자가 없는 경우 최고경영자가 지정한다)를 포함하여 5인 이상으로 자체전담반을 구성하여야 하며, 구성원 중 100분의 30 이상은 「정보보호산업의 진흥에 관한 법률 시행규칙」 제8조의 정보보호 전문서비스 기업 지정기준에서 정한 고급 기술인력 이상의 자격을 갖춘 자이어야 한다. 다만, 제37조의3제1항에 따른 평가전문기관에 위탁하는 경우에는 자체전담반을 구성하지 아니할 수 있다.

③ 제1항에 따른 금융회사 및 전자금융업자 이외의 자의 경우 연 1회 이상(홈페이지에 대해서는 6개월에 1회 이상) 실시하되 자체전담반을 구성하지 아니할 수 있다. 이 경우 취약점 분석 · 평가의 내용은 금융감독원장이 정한다.

④ 금융회사 및 전자금융업자는 해당 주기 내에 평가 대상 시설과 평가기간을 나누어 평가할 수 있다.

⑤ 금융회사 또는 전자금융업자는 취약점 분석 · 평가에 따라 이행계획을 수립 · 시행하여야 하며 다음 각 호의 사항을 준수하여야 한다.

1. 취약점 분석 · 평가 결과에 따른 취약점의 제거 또는 이에 상응하는 조치의 시행
2. 취약점의 제거 또는 이에 상응하는 조치가 불가한 경우에는 최고경영자 승인을 득할 것
3. 이행계획의 시행 결과는 최고경영자에게 보고할 것

⑥ 금융회사 또는 전자금융업자는 제1항 또는 제3항에 따른 의무의 이행을 위하여 전자금융보조업자에게 협조를 요청할 수 있다.

시행세칙

제7조의2(전자금융기반시설의 취약점 분석 · 평가의 내용) 규정 제37조의2제3항에 따라 감독원장이 정하는 취약점 분석 · 평가의 내용는 별표 3과 같다.

※ 관계 법령

법

제21조의3(전자금융기반시설의 취약점 분석 · 평가) ① 금융회사 및 전자금융업자는 전자금융거래의 안전성과 신뢰성을 확보하기 위하여 전자금융기반시설에 대한 다음 각 호의 사항을 분석 · 평가하고 그 결과(「정보통신기반 보호법」 제9조에 따른 취약점 분석 · 평가를 한 경우에는 그 결과를 말한다)를 금융위원회에 보고하여야 한다.

1. 정보기술부문의 조직, 시설 및 내부통제에 관한 사항

2. 정보기술부문의 전자적 장치 및 접근매체에 관한 사항
3. 전자금융거래의 유지를 위한 침해사고 대응조치에 관한 사항
4. 그 밖에 대통령령으로 정하는 사항

② 금융회사 및 전자금융업자는 제1항에 따른 전자금융기반시설의 취약점 분석 · 평가 결과에 따른 필요한 보완조치의 이행계획을 수립 · 시행하여야 한다.

③ 금융위원회는 소속 공무원으로 하여금 제1항에 따른 전자금융기반시설의 취약점 분석 · 평가 결과 및 제2항에 따른 보완조치의 이행실태를 점검하게 할 수 있다.

④ 제1항에 따른 전자금융기반시설의 취약점 분석 · 평가의 내용 및 절차와 제2항에 따른 이행계획의 수립 · 시행, 그 밖에 필요한 사항은 대통령령으로 정한다.

시행령

제11조의5(전자금융기반시설 취약점 분석 · 평가의 내용) 법 제21조의3제1항제4호에서 "대통령령으로 정하는 사항"이란 다음 각 호의 사항을 말한다.

1. 정보기술부문과 연계된 전자금융보조업자의 정보처리시스템 등에 관한 사항
2. 그 밖에 전자금융거래의 안정성과 신뢰성을 확보하기 위하여 필요한 사항으로서 금융위원회가 정하여 고시하는 사항

제11조의6(전자금융기반시설 취약점 분석 · 평가의 절차 및 방법 등) ① 금융회사 및 전자금융업자는 법 제21조의3제1항에 따라 전자금융기반시설의 취약점 분석 · 평가를 하려는 경우에는 자체전담반을 구성하여 실시하거나 전문성을 갖춘 외부 기관에 의뢰하여 실시하여야 한다. 이 경우 자체전담반의 구성기준과 의뢰할 수 있는 외부 기관의 기준은 금융위원회가 정하여 고시한다.

② 법 제21조의3제1항에 따른 전자금융기반시설의 취약점 분석 · 평가는 사업연도마다 1회 이상 하여야 한다. 다만, 다음 각 호의 어느 하나에 해당하는 경우에는 지체 없이 취약점 분석 · 평가를 하여야 한다.

1. 법 제21조의5제1항에 따른 침해사고가 발생하여 그 피해 및 피해 확산을 방지하기 위한 긴급한 조치가 필요한 경우
2. 정보처리시스템이나 인터넷 홈페이지 구축 등 정보기술부문 관련 사업을 실시하였거나 정보기술부문의 기능개선 · 변경을 수행한 경우

③ 금융회사 및 전자금융업자는 법 제21조의3제1항에 따라 전자금융기반시설의 취약점 분석 · 평가를 하였을 때에는 다음 각 호의 사항이 포함된 결과보고 및 보완조치 이행계획서를 그 취약점 분석 · 평가 종료 후 30일 이내에 금융위원회에 제출하여야 한다.

1. 취약점 분석 · 평가의 사유, 대상, 기간 등 실시개요
2. 취약점 분석 · 평가의 세부 수행방법
3. 취약점 분석 · 평가 결과
4. 취약점 분석 · 평가 결과에 따른 필요한 보완조치의 이행계획
5. 그 밖에 취약점 분석 · 평가의 적정성을 확보하기 위하여 필요한 사항으로서 금융위원회가 정하여 고시하는 사항

④ 제1항부터 제3항까지의 규정에도 불구하고 금융위원회는 전자금융거래의 빈도, 총자산 및 상시 종업원 수 등을 고려하여 금융위원회가 정하여 고시하는 기준에 미달하는 금융회사 및 전자금융업자에 대하여 다음 각 호의 사항을 완화하여 적용할 수 있는 기준을 정하여 고시할 수 있다.

1. 제1항에 따른 취약점 분석 · 평가의 방법
2. 제2항 각 호 외의 부분 본문에 따른 취약점 분석 · 평가의 실시 주기
3. 제3항에 따른 결과보고 및 보완조치 이행계획서의 제출 시기 및 제출 시 포함되어야 하는 사항

■ 금융회사 또는 전자금융업자는 전자금융기반시설에 대하여 관리적, 물리적, 기술적 취약점을 연 1회 이상(홈페이지는 6개월에 1회 이상) 점검하여 식별된 보안 취약점을 제거 또는 보완함으로써 전자금융기반시설의 기밀성, 가용성, 무결성 확보를 통해 대내외 위협으로부터 조직의 정보자산을 안전하게 보호하고 이용자에게 안전한 전자금융거래 서비스를 제공

■ 해설

- 총자산이 2조원 이상이고 상시종업원이 300명 이상인 금융회사 또는 전자금융업자와 수산업협동조합, 산림조합, 신용협동조합, 상호저축은행법 및 새마을금고법에 따른 중앙회는 정보보호최고책임자를 포함한 5인 이상(30%이상은 고급기술인력 이상의 자격을 갖출 것)으로 자체 전담반을 구성하거나, 규정 제37조의3제1항에 따른 외부 평가전문기관에 위탁하여 전자금융기반시설에 대한 취약점 분석·평가를 연 1회 이상(홈페이지는 6개월에 1회 이상)실시 (제1항, 제2항)
- 제37조의2제1항에 해당하지 않는 금융회사 또는 전자금융업자는 연 1회 이상(홈페이지는 6개월에 1회 이상)실시하되 자체 전담반을 구성하지 않고 취약점 분석·평가 실시 가능, 이 경우 금융감독원장이 정한 취약점분석·평가 내용에 따라 실시(제3항)

전자금융기반시설 취약점 분석·평가 내용〈시행세칙 별표3〉

평가 부문	평가 항목
관리적 보안	- 정보보호 정책 - 정보보호 조직 및 인력 - 내부통제 - 정보보호 교육 및 훈련 - 자산관리 - 업무연속성 관리 - 사고관리 - 정보시스템 도입·개발·유지보수
물리적 보안	- 전산설비 보안 - 전산센터 보안
기술적 보안	- 인터넷 전자금융 보안 - 모바일 전자금융 보안 - 접근통제 - 전산자료 보안 - 서버 보안 - 데이터베이스 보안 - 웹 서비스 보안 - 단말기 보안 - 네트워크 보안 - 정보보호시스템 보안

● 금융회사 또는 전자금융업자는 해당 주기 내에 평가대상 시설과 평가기간을 나누어 시행 가능하며, 취약점 분석·평가에 따라 이행계획을 수립·시행하며 다음 사항을 준수(제4항, 제5항)

- 취약점 분석·평가 결과에 따른 취약점의 제거 또는 이에 상응하는 조치 시행
- 취약점의 제거 또는 이에 상응하는 조치가 불가한 경우는 최고경영자 승인
- 이행계획의 시행 결과는 최고경영자에게 보고

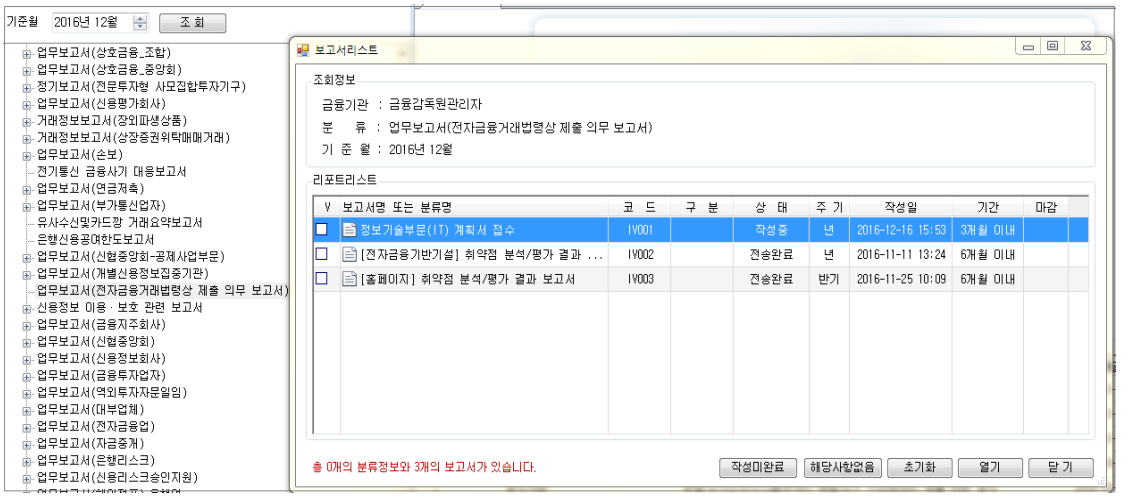
■ 취약점·분석 평가 결과 보고서는 금융정보교환망*의 「금융감독원 보고서 작성기」를 이용하여 제출

* 금융정보교환망 : fines.fss.or.kr, 헬프데스크 : 02)3145-5401/5413

● 기준월을 회계연도 마감월로 선택하여 조회를 누르면, 업무보고서(전자금융거래법령상 제출 의무 보고서)이 선택되며, 이 중 '취약점 분석·평가 결과 보고서'를 선택하여 보고서 제출 전 자체 체크리스트 점검 후 보고서를 제출

※ 홈페이지 취약점 평가 보고서의 경우 "회계연도 마감월", "회계연도 마감월+6개월"으로 1년에 2번 보고서 제출이 필요함

예) 12월이 회계마감월인 경우, 매년 12월, 6월 기준월 업무보고서를 검색하여 제출



※ 법령해석('15.10.15.)-150273

질의

- 금융거래정보 미포함 홈페이지의 경우 전자금융기반시설의 취약점 분석 · 평가 대상에서 제외되는지 여부

* (사실관계) ○○자산운용의 경우 전자금융거래가 발생하는 펀드거래시스템 일체(거래 전용 홈페이지 포함)를 ○○○에 외주를 주고 있으며, 해당 시스템에 대해서는 매년 취약점을 분석하여 보고하고 있음
그러나 ○○자산운용의 홈페이지는 금융거래와 관련한 정보는 일체 보유하고 있지 않으며 ○○○에서 위탁운용하고 있는 펀드거래시스템에 단순 링크만 해놓고 있음

회신

- 「전자금융거래법」 제21조의3제1항에 따르면 금융회사 및 전자금융업자는 전자금융거래의 안전성과 신뢰성을 확보하기 위하여 '전자금융기반시설'에 대하여 취약점 분석 · 평가를 실시하고 그 결과를 금융위원회에 보고하여야 하나,
- 금융회사 및 전자금융업자가 운영하는 홈페이지가 「전자금융거래법」 제2조제21호의 '전자금융기반시설'에 해당되지 않을 경우, 즉 전자금융거래에 이용되지 않거나 정보를 수집 · 가공 · 저장 · 검색 · 송신 또는 수신하는 정보통신체계가 없는 경우에는 같은 법 제21조의3제1항에 따른 취약점 분석 · 평가 대상이 아닙니다.

이유

- 「전자금융거래법」 제21조의3제1항은 금융회사 및 전자금융업자에 대해 전자금융거래의 안전성과 신뢰성을 확보하기 위해 전자금융기반시설에 대하여 취약점 분석 · 평가를 실시하도록 하고 있습니다.
- 한편, 같은 법 제2조제21호에서는 '전자금융기반시설'에 대하여 '전자금융거래에 이용되는 정보시스템 및 「정보통신망 이용촉진 및 정보보호 등에 관한 법률」 제2조제1항제1호에 따른 정보통신망'으로 정의하고 있고, 「정보통신망 이용촉진 및 정보보호 등에 관한 법률」 제2조제1항제1호에서는 '정보통신망'에 대하여 '전기통신설비와 컴퓨터 및 컴퓨터의 이용기술을 활용하여 정보를 수집 · 가공 · 저장 · 검색 · 송신 또는 수신하는 정보통신체제'로 정의하고 있습니다.
- 이상 각 법률의 정의에 따라 금융회사 및 전자금융업자가 운영하는 홈페이지가 전자금융거래에 이용되지 않거나 정보의 수집 · 가공 · 저장 · 검색 · 송신 또는 수신하는 정보통신체제를 사용하지 않는 경우 「전자금융거래법」 제21조의3제1항에 따른 취약점 분석 · 평가 의무가 없습니다.

조치 사례('21.1.6.)

- 전자금융업자는 취약점 분석 · 평가에 따라 이행계획을 수립 · 시행함에 있어 이행계획의 시행 결과를 최고 경영자에게 보고하여야 하는데도(전자금융감독규정 제37조의2제5항제3호),
- ○○회사는 전자금융기반시설 취약점 분석 평가에서 발견된 취약점 중 일부에 대한 이행계획을 수립 및 보완조치 완료하였으나, 동 시행 결과를 최고경영자에게 보고하지 않음

개선요구 등 사례('24.8.2.)

- ○○회사는 전자금융기반시설 취약점 점검 대상을 선정하는 기준 및 절차 등이 마련되어 있지 않아 취약점 분석 · 평가 담당자의 주관적 판단에 따라 임의적으로 선정될 우려가 있으므로, 전자금융거래에 이용되는 정보처리시스템(서버, 네트워크장비, 정보보호시스템 등) 현황을 정기적으로 현행화하고, 취약점 점검 대상 선정시 해당 시스템이 누락되지 않도록 업무 절차를 개선할 필요
- ○○회사는 홈페이지 취약점 분석 · 평가를 실시한 결과 ○○○○ 등 중대한 취약점이 홈페이지에서 최초 발견되어 취약점 보완 조치를 완료하였으나, 홈페이지 이외에 다른 채널에도 동일한 취약점이 있는지 여부를 확인하지 않는 등 사후 관리를 소홀하게 운영하고 있으므로 중대취약점 발견시 해당 기능이 구현되어 있는 다른 영역(동일 기능 페이지 등)에도 동일 취약점이 존재하는지 확인하여 조치할 수 있도록 업무 프로세스를 개선할 필요

개선요구 등 사례('24.12.13.)

- ○○회사는 고위험 전자금융기반시설 취약점에 대한 이행계획을 1년 이상으로 정하고 이행결과를 지속적으로 추적 · 관리하지 않아 차기 취약점 분석 · 평가 기간까지 취약점이 제거되지 않는 등 보안 취약점이 장기간 잔존하고 있으며, 매년 동일한 유형의 취약점이 전자금융 서비스에서 반복적으로 발견되는 등 취약점 조치와 관련한 사후관리가 미흡하므로,
- 취약점 이행계획 수립 시 보안 리스크 등을 고려하여 취약점이 조기에 제거될 수 있도록 이행기한을 합리적으로 정하고 기한 내 조치가 불가할 경우에는 지속적으로 추적 · 관리하여 최종 조치결과를 경영진에게 보고하는 한편, 반복적으로 발견되는 취약점은 업무담당자를 대상으로 보안 교육을 실시하는 등 취약점 분석 · 평가의 사후관리 절차를 개선할 필요

개선요구 등 사례('24.7.22.)

- ○○회사는 불가피한 경우가 아닌데도 기술적으로 조치가 가능한 일부취약점을 위험수용 사항으로 분류하고 있으며, 위험수용 대상을 정보보호위원회 심의 · 의결 안건에 포함하여 최고경영자에게 전부 일괄하여 보고 · 승인하고 있으므로, 취약점을 제거하지 않아 발생 가능한 문제점을 최고경영자가 명확하게 인지하지 못할 우려가 있으므로,
- 추후 조치가 가능할 것으로 판단되는 취약점은 위험수용이 아닌 조치예정 취약점으로 분류하여 이행점검 및 관리토록 하고, 위험수용 취약점에 대해 보고 시 최고경영자가 위험수용하는 취약점의 문제점을 명확히 파악할 수 있도록 분리하여 보고할 필요

2. 전자금융기반시설의 취약점 분석 · 평가 전문기관의 지정 등

감독규정

제37조의3(전자금융기반시설의 취약점 분석 · 평가 전문기관의 지정 등) ① 전자금융기반시설의 취약점 분석 · 평가를 위한 평가전문기관은 다음 각 호의 자로 한다.

1. 「정보통신기반 보호법」 제16조에 따라 금융분야 정보공유 · 분석센터로 지정된 자
2. 「정보보호산업의 진흥에 관한 법률」 제23조에 따라 지정된 정보보호전문서비스 기업
3. 침해사고대응기관
4. 금융위원장이 지정하는 자

② 금융회사 및 전자금융업자는 시행령 제11조의5제3항에 따른 전자금융기반시설의 취약점 분석 · 평가 결과보고서를 금융위원장에게 제출하여야 하며, 금융감독원장은 결과보고서를 분석하여 매분기 1개월 이내에 금융위원장에게 보고하여야 한다.

③ 금융위원장은 취약점 분석 · 평가 결과보고서에 근거하여 필요시 금융회사 및 전자금융업자에 대하여 개선 · 보완을 요구할 수 있다.

- 금융회사 또는 전자금융업자가 취약점 분석 · 평가 실시를 위탁 가능한 외부평가전문기관을 지정하고, 그 실시 결과를 금융위원회에 보고하도록 하여 전자금융기반시설에 대한 취약점 분석 · 평가의 실효성 제고

- 해설

  - 전자금융기반시설에 대한 취약점 분석 · 평가를 자체 실시하거나 외부평가전문기관에 위탁하여 실시한 후 그 결과보고서를 금융감독원에 제출

※ 관계 법령

시행령

제11조의5(전자금융기반시설 취약점 분석 · 평가의 내용) 법 제21조의3제1항제4호에서 "대통령령으로 정하는 사항"이란 다음 각 호의 사항을 말한다.

1. 정보기술부문과 연계된 전자금융보조업자의 정보처리시스템 등에 관한 사항
2. 그 밖에 전자금융거래의 안정성과 신뢰성을 확보하기 위하여 필요한 사항으로서 금융위원회가 정하여 고시하는 사항

제11조의6(전자금융기반시설 취약점 분석 · 평가의 절차 및 방법 등)

③ 금융회사 및 전자금융업자는 법 제21조의3제1항에 따라 전자금융기반시설의 취약점 분석 · 평가를 하였을 때에는 다음 각 호의 사항이 포함된 결과보고 및 보완조치 이행계획서를 그 취약점 분석 · 평가 종료 후 30일 이내에 금융위원회에 제출하여야 한다.

1. 취약점 분석 · 평가의 사유, 대상, 기간 등 실시개요
2. 취약점 분석 · 평가의 세부 수행방법
3. 취약점 분석 · 평가 결과
4. 취약점 분석 · 평가 결과에 따른 필요한 보완조치의 이행계획
5. 그 밖에 취약점 분석 · 평가의 적정성을 확보하기 위하여 필요한 사항으로서 금융위원회가 정하여 고시하는 사항

3. 침해사고 통지의 방법

감독규정

제37조의4(침해사고 통지의 방법) 금융회사 및 전자금융업자는 법 제21조의5에 따른 침해사고가 발생한 사실을 안 때에는 지체없이 사고 내용, 사고에 따른 영향 등을 〈별지 제7호서식〉에 기재하여 금융위원회에 보고하여야 하며, 정당한 사유 없이 그 사실을 안 때부터 24시간을 경과하여서는 아니된다.

※ 관계 법령

법

제21조의5(침해사고의 통지 등) ① 금융회사 및 전자금융업자는 전자적 침해행위로 인하여 전자금융기반시설이 교란·마비되는 등의 사고(이하 "침해사고"라 한다)가 발생한 때에는 금융위원회에 지체 없이 이를 알려야 한다.
② 금융회사 및 전자금융업자는 침해사고가 발생하면 그 원인을 분석하고 피해의 확산을 방지하기 위하여 필요한 조치를 하여야 한다.

- 금융회사 및 전자금융업자는 전자적 침해행위로 인하여 전자금융기반시설이 교란·마비되는 등의 사고(이하 "침해사고")가 발생한 사실을 안 때에는 금융위원회에 지체없이 보고하여야 하며 정당한 사유 없이 침해사고가 발생한 사실을 안 때부터 24시간을 경과하여서는 안됨

- 해설

  - 전자금융거래와 무관한 정보처리시스템 및 정보통신망에 침해사고가 발생하였다고 하더라도 침해사고로 인하여 전자금융기반시설에 교란·마비 등의 사고가 발생할 경우를 포함

    - 다만, 외부에서 발생한 침해사고 등의 영향으로 전자금융기반시설 교란·마비 등 사고가 발생한 경우 침해사고 보고대상은 아니나, 정보기술부문 및 전자금융 사고보고 해당시 별도 보고해야 함

4. 정보기술부문 및 전자금융 사고보고

감독규정

제37조의5(정보기술부문 및 전자금융 사고보고) ① 금융회사 및 전자금융업자는 정보기술부문 및 전자금융과 관련된 사고에 관하여 다음 각 호를 준수하여야 한다.

1. 사고의 유형 분류, 처리단계, 조치방법, 영향도 및 심각도 평가 방법 등이 포함된 절차를 마련 · 운영
2. 금융감독원장이 정하는 사고가 발생한 경우에는 지체없이 금융감독원장에게 보고

② 금융회사 및 전자금융업자는 제1항제2호에 따른 사고보고를 고의로 지연하거나 숨긴 자에 대하여 소정절차에 따라 징계 등 필요한 조치를 취하여야 한다.

③ 금융감독원장은 제1항제2호에 따라 보고 받은 내용을 지체 없이 금융위원장에게 보고하여야 한다.

④ 제1항제2호의 사고보고와 관련하여 사고보고 대상, 절차 및 방법 등 세부사항은 금융감독원장이 정하는 바에 따른다.

시행세칙

제7조의4(정보기술부문 사고보고) ① 규정 제37조의5제4항에 따라 감독원장이 정하는 사고보고 대상은 다음 각 호와 같다.

1. 정보처리시스템 또는 통신회선 등의 장애로 인하여 다음 각 목 중 하나에 해당하는 사고가 발생한 경우
   가. 전자금융업무 지연 · 중단 시간이 30분 이상인 경우
   나. 전자금융업무 지연 · 중단 시간이 10분 이상이고 해당 전자금융서비스 가입자가 1만명 이상인 경우
2. 전산자료 또는 프로그램의 조작 및 오류와 관련된 사고가 발생한 경우
3. 전자적 침해행위로 인해 정보처리시스템에 사고가 발생하거나 이로 인해 이용자가 금전적 피해를 입었다고 금융회사 또는 전자금융업자에게 통지한 경우
4. 법 제9조제1항의 규정에서 정하는 사고가 발생한 경우

② 제1항에도 불구하고 다음 각 호에 해당하는 경우는 사고보고 대상에서 제외한다.

1. 제1항제1호에 해당하는 사고 중 영업점 내 장애의 경우 1개 영업점에 국한된 전자금융업무 중단 · 지연
2. 제1항제1호에 해당하는 사고 중 이용자에게 단순 정보 제공을 위한 공개용 웹서버 등의 장애 또는 금융상품 및 서비스와 무관한 장애
3. 법 제9조제1항제1호 또는 제3호의 사고가 발생하였으나 사고금액이 100만원 미만인 경우

③ 금융회사 및 전자금융업자는 제1항의 사고가 발생한 경우 별지 제2호서식 별첨1에 따라 지체 없이 보고하여야 하며, 정당한 사유없이 그 사실을 안 때부터 24시간을 경과하여서는 아니된다. 다만, 법 제9조제1항제1호의 사고 중 사고금액이 3억원 미만인 사고의 경우 매월 발생한 사고를 익월 15일까지 별지 제2호서식 별첨2에 따라 일괄 보고할 수 있다.

④ 제3항에 따른 사고보고는 최초보고, 중간보고 및 종결보고로 구분한다.

1. 최초보고 : 사고를 인지 또는 발견한 때로부터 24시간 이내에 전자금융사고대응시스템(Electronic Financial Accident Response System : EFARS)으로 보고한다. 단, 전산장애, 금융정보교환망 미연결 등 부득이한 경우에는 서면, 팩시밀리 또는 유선으로 보고할 수 있으며, 이 경우에 전자금융사고대응시스템(EFARS)으로 보고 가능한 즉시 전자금융사고대응시스템(EFARS)으로 보고한다.
2. 중간보고 : 제1호의 최초보고 후 사고내용을 보완할 필요가 있는 경우에는 즉시 중간보고를 하여야 하며, 제3호의 조치완료 시까지 2월 이상 소요될 경우에는 인지 · 발견일로부터 2월 이내 및 종결 시까지 매 6월마다 제1호의 방법에 따라 보고한다. 다만, 최초보고 후 조치완료 시까지 2월 미만이 소요될 경우에는 중간보고를 생략할 수 있다.

3. 종결보고 : 사고발생 원인 파악 및 조치, 재발방지 대책 마련 등이 완료(사고금액에 대한 배상책임이 있는 경우에는 배상조치까지 포함)되어 정상적인 업무를 수행하게 된 때 제1호의 방법에 따라 보고한다. 다만, 최초보고 시 조치가 이미 완료된 경우에는 종결보고를 생략할 수 있다.

⑤ 감독원장은 금융회사 및 전자금융업자 정보기술부문의 사고보고 등을 전담할 비상연락 담당자를 회사별로 지정할 수 있다.

⑥ 금융회사 및 전자금융업자는 비상연락 담당자가 제5항에 따라 지정되거나 변경된 경우에는 제4항제1호에서 정한 보고방법에 따라 감독원장에게 즉시 보고하여야 한다.

⑦ 감독원장은 제4항에 따라 보고 받은 내용이 제1항제3호의 사고 발생인 경우에는 규정 제37조의6제1항 각 호에 따른 침해사고대응기관에도 알려야 한다.

개요

- 전자금융사고의 확산을 차단하고 유사사고의 재발을 예방하기 위하여 전자금융사고 발생시 금융회사 및 전자금융업자에 보고의무를 부과하고 이를 위한 세부사항을 정함
- 금융회사 및 전자금융업자는 전자금융사고에 관하여 사고의 유형 분류, 처리단계, 조치방법, 영향도 및 심각도 평가 방법 등이 포함된 절차를 마련하여 운영하여야 함
- 전산장애사고, 침해사고, 전자금융사기사고 등 사고보고 대상의 전자금융사고가 발생한 경우 지체없이 금융감독원장에게 보고하여야 하며, 사고보고는 정당한 사유없이 그 사실을 안 때부터 24시간을 경과하여서는 안됨

〈사고보고 대상〉

사고구분		상세설명
전산장애사고	포함	▶ 정보처리시스템 또는 통신회선 등의 장애로 인하여 다음에 해당하는 사고가 발생한 경우 - 전자금융업무 지연 · 중단 시간이 30분 이상(전자금융서비스 가입자 1만명 이상인 경우 10분 이상) ▶ 전산자료 또는 프로그램의 조작 및 오류와 관련된 사고가 발생한 경우
	제외	▶ 영업점 내 장애의 경우 1개 영업점에 국한된 전자금융업무 중단 · 지연 ▶ 이용자에게 단순 정보 제공을 위한 공개용 웹서버 등의 장애또는 금융상품 및 서비스와 무관한 장애
침해사고	포함	▶ 전자적 침해행위로 인해 정보처리시스템에 사고가 발생하거나 이로 인해 이용자가 금전적 피해를 입었다고 금융회사 또는 전자금융업자에게 통지한 경우
전자금융사기 사고	포함	▶ ① 접근매체의 위조나 변조로 발생한 사고 ▶ ② 계약체결 또는 거래지시의 전자적 전송이나 처리 과정에서 발생한 사고 ▶ ③ 전자금융거래를 위한 전자적 장치 또는 「정보통신망 이용촉진 및 정보보호 등에 관한 법률」 제2조제1항제1호에 따른 정보통신망에 침입하여 거짓이나 그 밖의 부정한 방법으로 획득한 접근매체의 이용으로 발생한 사고
	제외	▶ ① 또는 ③의 사고가 발생했으나 “사고금액이 100만원 미만인경우

사고보고 방법 및 세부유형

- 사고보고시에는 사고를 인지 또는 발견한 때로부터 지체없이(24시간 이내) 전자금융사고대응시스템(EFARS)으로 보고하여야 함
  - 최초보고 기한 내 원인과 영향을 정확히 파악할 수 없는 경우에는 사고 개요 등만 간략히 보고하고 상세한 내용은 중간 또는 종결보고를 통해 보완 작성
  - 조사결과 보고 대상 여부가 변경되면 변경을 인지하는 즉시 보고하거나 보고를 회수하여 조정

〈사고보고 제출 방법〉

보고구분	상세설명
최초보고	▶ 사고 인지 후 즉시(24시간 이내) 보고 실시 ▶ EFARS 접속이 불가하는 등의 불가피한 경우에 서면, 팩시밀리 또는 유선으로 보고할 수 있음. 단, EFARS 접속이 가능한 즉시 EFARS로 보고
중간보고	▶ 최초보고 후 사고내용을 보완할 필요가 있는 경우(즉시 보고) ▶ 종결시까지 2개월 이상 소요될 경우 - 사고인지 · 발견일로부터 2월 이내에 최초보고의 방법에 따라 보고하고 종결 시까지 매 6월마다 보고
종결보고	▶ 사고발생 원인 파악 및 조치, 재발방지 대책 등이 완료(사고금액에 대한 배상책임이 있는 경우에는 배상조치까지 포함)되어 정상적인 업무를 수행하게 된 때 최초보고의 방법에 따라 보고 - 최초보고 시 조치가 이미 완료된 경우에는 생략할 수 있음

- 접근매체의 위조나 변조로 발생한 사고(법 제9조제1항제1호) 중 일정금액(3억원 미만) 이하의 사고의 경우 익월 15일까지 일괄 보고가 가능함
  - 다만, 사고금액이 3억원 이상인 경우 또는 전산장애사고나 침해사고의 보고대상과 연계된 경우 지체없이 보고하여야 함
- 여러 회사에서 동일한 원인으로 사고가 동시에 발생한 경우, 특정 회사 또는 협회 · 중앙회 등이 대표로 사고보고 가능
  - 다만, 대표 사고보고시 사고가 발생한 다른 회사명을 함께 기술해야 하며, 이후 피해 규모가 추가 확인되는 경우 중간보고를 통해 추가 확인된 사항을 보고하여야 함
- 금융회사 및 전자금융업자에게 각 회사별로 사고보고 등을 전담할 비상연락 담당자를 지정하고 지정된(또는 변경된) 담당자를 최초보고 방법에 따라 즉시 보고하여야 함

● 전자금융사고대응시스템(EFARS)을 통하여 보고하는 경우 사고의 내용에 따라 시행세칙 별지2의 서식에서 정한 사고유형으로 구분하여 보고하여야 함

〈전자금융 사고보고 세부 유형〉

사고구분	세부유형
전산장애사고	① 업무처리 프로그램 오류 : 로직, 데이터 오류로 인한 장애 ② 시스템 장애 : 시스템(OS, DBMS, 미들웨어, 보안, WAS 등) 장애 또는 H/W(서버, 네트워크, 저장장치, 전원설비 등) 장애 ③ 시설 · 설비 장애 : 전원공급이 차단되거나 통신회선 훼손 등으로 인한 장애 ④ 외부요인으로 인한 장애 : 클라우드 업체, 통신 업체, 제휴업체 등에서 발생한 문제로 인한 장애 ⑤ 미정(파악중 등) : 최초보고 기한 내 원인 파악이 어려운 경우(중간 • 종결 보고 시 세부유형 변경 필요)
침해사고	① 공격대상 : 내부망, DMZ, 기타 등 ② 공격방법 : 악성코드, 서비스거부공격, 보안 취약점 해킹, 무단 접속 및 조작 등 ③ 공격에 따른 피해 : 시스템 및 서비스 중단, 정보유출, 중요정보 조작, 금전적 손실 등
전자금융사기 사고	① 피싱/파밍 : 이용자가 위장한 사이트로 접속하도록 유도하여 정보를 탈취한 경우(피싱, 파밍, 스미싱 등) ② 전자상거래/매체 위변조 : 전자상거래 시 악성코드에 의한 결제 프로그램 변조, 타인이 접근매체*를 위 · 변조하거나 발급받아 도용한 경우 등 * ID • PW, 인증서, 바이오 인증정보, 신용 • 체크카드 등 ③ 신종 전자금융사기 사고 : ①, ②를 제외한 전자금융사기사고 ④ 원인미정 : 최초보고 기한 내 원인 파악이 어려운 경우(중간 • 종결 보고 시 세부유형 변경)

사고보고 기준 및 예시

① 전산장애사고(전자금융업무 지연 · 중단)

- 정보처리시스템 또는 통신회선 등의 장애로 ㉮30분 이상 또는 ㉯해당서비스 가입자가 1만명 이상인 경우에는 10분 이상 전산업무가 지연 또는 중단된 경우 보고
- 대고객 금융상품 및 서비스 제공 관련 시스템에서 발생한 사고가 보고대상이며, 내부직원용 인트라넷 시스템(이메일 등), 단순 정보 제공 웹페이지, 금융상품과 무관한 서비스(여행, 공연예약 등) 장애 등은 제외
- 영업점 내 장애의 경우 2개 점포 이상 동시 영향 시 보고 대상

예시		보고대상
통신사 회선 장애로 대고객 ARS 인증 서비스 10분*간 불능		O
ELW LP시스템 장애로 호가제출이 10분*간 정지		O
인터넷 뱅킹 서비스 중 적금계좌 조회가 10분*간 불능		O
자행 인증서 로그인은 가능하지만, 타행 인증서 로그인이 10분*간 불가		O
A은행 여의도 지점 내 ATM기 2대 장애로 30분간 사용 불능		X
건물 일시 정전으로 인해 여의도 지점의 업무가 30분간 정지		X
직원 E-Mail서버가 다운되어 30분간 관련 업무 불가		X
주말 · 야간 시스템 점검 등 고객에게 사전 공지한 업무중단의 경우		X
수탁사의 시스템 장애의 여파로 위탁사인 A카드사의 카드 결제 업무 불가 (수탁사가 금융회사 또는 전자금융업자로 시스템 장애에 대한 사항 및 A카드사의 결제업무 불가 사항을 포함하여 EFARS에 기 보고 완료)		X
수탁사의 시스템 장애의 여파로 위탁사인 B은행 모바일 뱅킹이 40분간 정지 (수탁사가 금융회사 등이 아니어서 사고 보고 주체가 아닌 경우)		O
카드사 시스템 장애로 해외 사용이 10분*간 불가(국내 사용은 가능)		O
1시간 동안 이체, 보험금 지급 등 전자금융서비스와 연계된 SMS 안내문이 발송되지 않거나 일부 정보가 누락되어 발송		O
고객이 금융회사 등의 콜센터로 문의전화를 하는 inbound call 시스템에 10분*이상 장애가 발생한 경우		O
금융회사가 텔레마케팅을 위해 고객에게 전화를 거는 outbound call 시스템에 30분이상 장애가 발생한 경우		X
A카드사에서 운영하는 'OO투어' 사이트에 장애가 발생하여 여행상품 예약이 불가능한 경우		X
5대의 서버를 이용하여 하나의 금융서비스를 제공하던 중 한 대의 서버에서 10분*이상 장애가 발생	(CASE1) 고객 일부분이라도 사고에 대한 영향을 받은 경우	O
	(CASE2) Active-Standby 모드 전환 등으로 고객에게 미치는 영향이 없는 경우	X

* 서비스가입자가 1만명 미만인 경우 30분 적용

② 전산장애사고(전산자료 및 프로그램 조작)

- 전자금융거래 관련 전산자료 또는 대고객 금융상품 및 서비스 제공 관련 프로그램에서 전산자료 또는 프로그램 조작 및 오류와 관련된 금융사고 발생시 보고
- 조작의 고의성과 상관없이 보고하되, 업무 처리과정에서 일상·반복적으로 발생하는 사고로서 고객이 인지하지 못했거나 피해가 발생하지 않는 경우는 제외

예시	보고대상
프로그램 오류로 인해 보통예금 계좌의 이자 100원이 누락된 경우	O
고의적으로 내부망에 침투하여 DB 원장정보의 일부를 삭제	O
개발자의 실수로 인해 DB 정보가 잘못 업데이트 되어 서비스에 영향	O
새벽 1시 이자지급을 위한 배치작업 수행 후 결과를 확인하는 과정에서 오류가 발견되어 배치작업 재수행	X
새벽 1시 배치작업 수행 중 조작상의 실수로 에러가 발생하였으나 이를 즉시 수정하지 못하여 오후 1시까지 서비스 이용이 중단됨	O
선불전자지급수단(포인트) 이벤트를 위한 프로그램 개발과정에서 오류가 있었으나 이벤트 개시전 해당 오류를 수정한 경우	X
선불전자지급수단(포인트) 이벤트를 위한 프로그램 개발과정에서 오류가 발생하여 일부 고객에 대해 포인트가 충전되지 않거나 오충전된 경우	O
시스템 조작 실수로 금융상품설명서에 금액 등이 잘못 기재되어 고객에게 배포된 경우	X
프로그램 오류로 개인신용정보가 포함된 대출금리 변경 모바일 안내장을 다른 고객에게 잘못 발송하여, 일부 고객이 타인의 안내장을 열람(개인신용정보 노출)	O

③ 침해사고

- 전자적 침해행위로 인해 정보처리시스템에 사고가 발생하거나 이로 인해 이용자가 금전적 피해를 입었다고 금융기관에 통지한 경우 보고
- 전자적 침해행위(해킹, 컴퓨터 바이러스, 논리폭탄, 메일폭탄 등)로 인해 정보유출, 정보처리시스템 장애 등의 사고가 발생한 경우 보고하여야 하며, 이용자에게 금전피해(2차 금전사고)가 발생한 경우에도 사고보고 대상임

예시	보고대상
해킹으로 인해 금융회사 홈페이지가 변조	O
해킹으로 인해 금융회사 고객정보가 유출	O
고객정보가 담긴 출력물, USB를 외주직원이 유출 * 전자금융사고보고 대상은 아니나, 소관 검사국에는 보고	X
DDoS 공격이 30분간 발생했으나 시스템 지연 등 피해 없음	X
DDoS 공격이 30분간 발생하여 5분간 시스템 접속 지연	O
금융회사 공개용 웹서버가 악성코드에 감염되어 5분간 작동이 중단된경우	O
고객 PC 또는 모바일에 대해 전자적 침해행위로 사고가 발생한 경우	X
은행VAN사가 운영하는 CD/ATM기에 대한 해킹으로 제휴 금융회사의 고객 정보가 유출된 경우	O
금융회사 시스템에 대한 해킹으로 계좌정보 등이 유출된 고객으로부터 금전피해가 접수된 경우	O
A카드사 홈페이지 기프트카드 잔액 조회 화면에 대한 반복적 대입공격으로 기프트카드 정보가 유출되어 부정사용 신고가 발생한 경우	O

④ 전자금융사기사고(법 제9조제1항)

- 접근매체의 위조나 변조(카드위변조), 보이스 피싱, 파밍, 악성코드 등 부정한 방법으로 획득한 접근매체(인증서 등)를 이용하여 전자금융거래(계좌이체, 온라인 결제 등)가 발생한 경우 또는 계약체결 또는 거래지시의 전자적전송이나 처리 과정에 발생한 금전사고 발생시 보고
- 접근 매체의 위변조, 부정발급 등으로 발생한 금전사고금액 100만원(단건) 이상의 경우 보고하여야 하며, 계약체결이나 거래지시의 전자적전송이나 처리 과정에서 발생한 금전사고는 금액과 상관없이 신고한 경우 보고하여야 함

예시	보고대상
고객 모바일에 대한 악성코드를 심어 카드정보를 획득하고 이를 이용하여 게임사이트에서 결제한 경우(100만원 이상)	O
부정한 방법으로 취득한 타인의 정보를 이용하여 공동인증서를 재발급받고 동 인증서를 이용하여 재화를 구매한 경우(100만원 이상)	O
보이스피싱으로 피해자가 직접 계좌이체를 수행한 경우* * 전기통신금융사기에 해당하는 경우 전자금융사고보고 대상은 아니며, 소관부서에는 보고	X
ATM기 투입구에 복제기를 물리적으로 부착하여 복제 카드를 만들고 이를 이용하여 ATM에서 인출한 경우	O
사고 원인을 알 수 없으나 피해금액이 100만원 미만으로 사고보고를 하지 않았으나 조사 결과 침해사고와 연계된 금전사고로 밝혀진 경우	O
사고 원인을 알 수 없으나 피해금액이 100만원 이상으로 사고보고를 하였으나 조사 결과 보이스피싱에 의한 사기로 밝혀진 경우 ☞ 보고회수	X

5. 침해사고대응기관 지정 및 업무범위

감독규정

제37조의6(침해사고대응기관 지정 및 업무범위 등) ① 침해사고에 대응하기 위한 침해사고대응기관은 다음 각 호의 자로 한다.

1. 금융보안원
2. 삭제
3. 금융위원장이 지정한 자

② 침해사고대응기관은 다음 각 호의 업무를 수행한다.

1. 침해사고에 관한 정보의 수집 · 전파를 위한 정보공유체계의 구축
2. 침해사고의 예보 · 경보 발령내용의 전파
3. 침해사고의 원인분석과 신속한 대응 및 피해 확산방지를 위해 필요한 조치
4. 금융회사 및 전자금융업자와 관련된 해킹 등 전자적 침해행위 정보를 탐지 · 분석하여 즉시 대응 조치를 하기 위한 기구(이하 "금융권 통합 보안관제센터"라 한다)의 운영
5. 금융회사 및 전자금융업자의 침해사고 예방, 대응을 위한 자율기준의 마련 및 운영

③ 금융위원장은제37조의4 및 제37조의5제3항에 따라 보고받은 내용으로서 전자적 침해행위가 원인이거나 원인으로 의심되는 경우 사고 조사 및 피해확산 방지를 위해 침해사고대응기관을 포함하여 침해사고조사단을 구성 · 운영할 수 있다.

④ 금융위원장은 제2항에 따른 침해사고 긴급대응을 위한 침해사고대응기관의 업무 수행 또는 제3항에 따른 침해사고 원인분석 및 긴급조치를 위하여 금융회사 및 전자금융업자, 전자금융보조업자에 협조를 요청할 수 있다.

⑤ 금융회사 및 전자금융업자는 침해사고에 대한 대응능력 확보를 위하여 연 1회 이상 침해사고 대응 및 복구훈련 계획을 수립 · 시행하여야 하며 그 계획 및 결과를 침해사고대응기관의 장에게 제출하여야 한다. 다만 다음 각 호의 어느 하나에 해당하는 금융회사는 그러하지 아니한다.

1. 법 제2조제3호가목의 금융회사 중 신용협동조합
2. 법 제2조제3호다목 · 라목의 금융회사
3. 시행령 제2조제4호부터 제6호까지의 조합
4. 시행령 제5조제2항의 요건을 충족한 금융회사

⑥ 금융위원장은 침해사고대응기관의 장으로 하여금 침해사고 대응 · 복구 및 훈련결과를 점검하고 보완이 필요하다고 판단되는 경우 개선 · 보완을 요구할 수 있다.

⑦ 금융위원장은 침해사고대응기관의 장으로 하여금 시행령 제11조의6제1항제4호에 따른 보안취약점 통보를 위하여 금융회사 및 전자금융업자가 사용하고 있는 소프트웨어에 대한 조사 · 분석을 실시하게 할 수 있다.

- 금융위원회는 침해대응기관을 지정하여 금융회사 또는 전자금융업자의 침해사고에 대한 정보공유체제 구축, 예보 및 경보 발령내용 전파, 원인분석과 신속한 대응을 통한 피해 확산 방지, 금융회사 또는 전자금융업자의 침해사고 대응능력 확보를 위해 침해사고 대응 및 복구 훈련 계획을 수립 · 시행

해설

- 금융회사 또는 전자금융업자는 해킹, 악성코드, 서비스 거부(DDoS) 공격등 전자적 침해에 대한 대응능력 확보를 위해 연 1회 이상 침해사고 대응 및 복구 훈련 계획을 수립하여 시행하고 그 결과를 침해사고대응기관(금융보안원)의 장에게 제출(제5항)

〈전자적 침해행위(예시)〉

위기유형	상세설명
해킹	접근권한이 없거나 접근권한을 초과하여 전산시스템 및 전산망에 접근하여 테이터를 조작·파괴·은닉 또는 유출
악성코드	컴퓨터바이러스·논리폭탄 등 악성 프로그램을 투입하여 전산시스템 및 전산망의 운영 방해 또는 데이터 파괴
서비스 거부	일시에 대량의 선호를 보내거나 부정한 명령의 처리 등을 통해 전산시스템 및 전산망 운영 방해 또는 정보처리 오류 발생

〈침해사고 대응 및 복구훈련 계획 항목〉

유 형	세부항목(예시)
훈련계획	훈련목적, 훈련참여자, 훈련기간, 훈련대상 - 훈련조직 구성(담당자 임무부여 포함) - 유관기관 및 관련업체와의 비상연락체제 구축
	훈련 시나리오, 훈련 절차 및 방법 등 - 상황별 대응절차 · 방안(수립된 비상대책 준용)
훈련결과	수립한 훈련계획에 대한 이행여부
	내부평가 및 개선사항 도출 등
	개선이행 계획 수립 등

- 침해사고대응기관(금융보안원)은 침해사고 대응 및 복구 훈련 계획 및 결과를 점검하고 점검결과와 필요한 경우 개선 · 보완 사항을 포함하여 제출기관에게 전달
- 금융회사 또는 전자금융업자는 훈련 실효성 확보를 위하여 통지 받은 개선 · 보완 사항을 차기년도 훈련 계획에 반영 · 실행

6. 금융위가 정하는 보관자료 및 거래기록 등

감독규정

제38조(금융위원회가 정하는 보관자료 및 거래기록 등) 시행령 제12조제1항제2호다목에서 "금융위원회가 정하여 고시하는 거래기록"이라 함은 제4조제1호의 기록을 말한다.

- 이용자가 전자금융거래에 오류가 있음을 인지하여 금융회사 또는 전자금융업자에게 정정을 요구하거나, 금융회사 또는 전자금융업자 스스로가 오류를 인지하여 조치하는 경우, 오류정정 요구사실 및 처리결과에 관한 사항을 1년간 보존

※ 관계 법령 및 규정

법

제8조(오류의 정정 등) ① 이용자는 전자금융거래에 오류가 있음을 안 때에는 그 금융회사 또는 전자금융업자에게 이에 대한 정정을 요구할 수 있다.

② 금융회사 또는 전자금융업자는 제1항의 규정에 따른 오류의 정정요구를 받은 때에는 이를 즉시 조사하여 처리한 후 정정요구를 받은 날부터 2주 이내에 오류의 원인과 처리 결과를 대통령령으로 정하는 방법에 따라 이용자에게 알려야 한다.

③ 금융회사 또는 전자금융업자는 스스로 전자금융거래에 오류가 있음을 안 때에는 이를 즉시 조사하여 처리한 후 오류가 있음을 안 날부터 2주 이내에 오류의 원인과 처리 결과를 대통령령으로 정하는 방법에 따라 이용자에게 알려야 한다.

시행령

제12조(전자금융거래기록의 보존기간 · 보존방법 및 파기 절차 · 방법 등) ① 법 제22조제1항 및 제3항에 따른 전자금융거래기록의 종류별 보존기간은 다음 각 호와 같다.

1. 〈생략〉
2. 다음 각 목의 전자금융거래기록은 1년간 보존하여야 한다.
   가. 건당 거래금액이 1만원 이하인 전자금융거래에 관한 기록
   나. 전자지급수단의 이용과 관련된 거래승인에 관한 기록
   다. 그 밖에 금융위원회가 정하여 고시하는 전자금융거래기록

감독규정

제4조(확인에 필요한 구체적인 거래내용) 시행령 제7조제4항제6호에서 "금융위원회가 정하여 고시하는 사항"이란 다음 각 호를 말한다.

1. 법 제8조에 따른 오류정정 요구사실 및 처리결과에 관한 사항
2. 전자금융거래 신청, 조건변경에 관한 내용

7. 전자지급수단의 이용한도

감독규정

제39조(전자지급수단의 이용한도) 시행령 제13조제2항 부터 제4항에 따라 금융위원회가 정하는 전자지급수단의 구체적인 이용한도는 〈별표 3〉과 같다.

※ 관계 법령

법

제23조(전자지급수단 등의 발행과 이용한도) ① 금융위원회는 전자지급수단의 특성을 감안하여 대통령령이 정하는 바에 따라 금융회사 또는 전자금융업자에게 다음 각 호에 규정된 한도를 제한하거나 그 밖에 필요한 조치를 할 수 있다.

1. 전자화폐 및 선불전자지급수단의 발행권면 최고한도
2. 전자자금이체의 이용한도
3. 직불전자지급수단의 이용한도

② 금융위원회는 대통령령으로 정하는 바에 따라 금융회사 또는 전자금융업자에게 전자적 장치로부터의 현금 출금 최고한도를 제한하거나 그 밖에 필요한 조치를 할 수 있다.

시행령

제13조(이용한도 등) ② 법 제23조제1항제2호에 따른 전자자금이체의 이용한도는 100억원의 범위에서 금융위원회가 정하여 고시한다. 다만, 금융회사 또는 전자금융업자와 이용자 간에 별도의 계약이 있는 경우에는 그 이용한도를 달리 정할 수 있다.

③ 법 제23조제1항제3호에 따른 직불전자지급수단의 이용한도는 1억원의 범위에서 금융위원회가 정하여 고시한다. 다만, 금융회사 또는 전자금융업자와 이용자 간에 별도의 계약이 있는 경우에는 그 이용한도를 달리 정할 수 있다.

④ 법 제23조제2항에 따른 전자적 장치로부터의 현금 출금 최고한도는 1천만원의 범위에서 금융위원회가 정하여 고시한다. 다만, 금융회사 또는 전자금융업자와 이용자 간에 별도의 계약이 있는 경우에는 그 최고한도를 달리 정할 수 있다.

전자지급수단의 세부적 이용한도(감독규정 별표3)

가. 전자화폐 및 선불전자지급수단 발행권면 최고한도

(단위: 만원)

구 분	발행권면 한도	
	무기명식[1]	기명식[2]
전자화폐	5	200
선불전자지급수단	50	200

1) 실지명의 확인이 없거나 예금계좌와 연결되지 않고 발행된 전자화폐 내지 선불전자지급수단
2) 실지명의가 확인되거나 예금계좌와 연결되어 발행된 전자화폐 내지 선불전자지급수단

나. 전자자금이체한도(지급이체의 경우)

(단위: 억원)

구 분		1회 이체한도	1일 이체한도
현금카드[1]	인출한도	0.01	0.06
	이체한도	0.06	0.3
텔레뱅킹[2]	개인	0.5	2.5
	법인	1	5
인터넷뱅킹[3]	개인	1	5
	법인	10	50
모바일뱅킹[4]		1	5
메일뱅킹[5]		0.1	0.5

1) 금융회사의 자동화기기(CD/ATM)에서 현금을 인출하기 위해 사용하는 접근매체
2) 유선전화를 통하여 예금조회, 자금이체 등의 업무를 수행하는 전자금융방식
3) 유무선 인터넷을 통해 예금조회, 자금이체 등의 업무를 수행하는 전자금융방식
4) 이동통신용 기기에 IC칩을 넣거나 뱅킹용 프로그램을 다운로드하여 예금조회, 자금이체 등의 업무를 수행하는 전자금융방식
5) 예금계좌와 연결된 전자우편 주소(기타 전화번호)를 통해 자금이체 등의 업무를 수행하는 전자금융방식
* 전자자금이체시 제34조 및 제37조의 규정에서 정한 사항을 준수하여야 한다.

다. 직불전자지급수단 이용한도

(단위: 만원)

구 분	1회 이용한도	1일 이용한도
직불전자지급수단	10000	10000
실명증표확인 외의 본인확인수단을 이용하여 발급된 직불전자지급수단	200	200

8. 약관교부 방법 및 관련 보고

감독규정

제40조(약관교부 방법 등) ① 전자금융업무를 수행하는 금융회사 및 전자금융업자는 전자금융거래와 관련한 약관(이하 "약관"이라 한다)을 별도로 마련하여야 한다.

② 금융회사 또는 전자금융업자는 이용자와 전자금융거래의 계약을 체결함에 있어 이용자의 요청이 있는 경우 전자문서의 전송(전자우편을 이용한 전송을 포함한다), 모사전송, 우편 또는 직접 교부의 방식으로 전자금융거래 약관의 사본을 이용자에게 교부하여야 한다.

③ 금융회사 또는 전자금융업자는 이용자와 전자금융거래의 계약을 체결함에 있어 이용자가 약관의 내용에 대한 설명을 요청하는 경우 다음 각 호의 어느 하나의 방법으로 이용자에게 약관의 중요내용을 설명하여야 한다.

1. 약관의 중요내용을 이용자에게 직접 설명
2. 약관의 중요내용에 대한 설명을 전자적 장치를 통하여 이용자가 알기 쉽게 표시하고 이용자로부터 해당 내용을 충분히 인지하였다는 의사표시를 전자적 장치를 통하여 수령

④ 금융회사 또는 전자금융업자는 약관을 변경하는 때에는 그 시행일 1월 전에 변경되는 약관을 해당 전자금융거래를 수행하는 전자적 장치(해당 전자적 장치에 게시하기 어려울 경우에는 이용자가 접근하기 용이한 전자적 장치로서 당해 금융회사등이 지정하는 대체장치를 포함한다. 이하 이 조에서 같다)에 게시하고 이용자에게 통지하여야 한다. 다만, 이용자가 이의를 제기할 경우 금융회사 또는 전자금융업자는 이용자에게 적절한 방법으로 약관 변경내용을 통지하였음을 확인해 주어야 한다.

⑤ 금융회사 또는 전자금융업자가 법령의 개정으로 인하여 긴급하게 약관을 변경한 때에는 변경된 약관을 전자적 장치에 최소 1월 이상 게시하고 이용자에게 통지하여야 한다.

제41조(약관 제정 또는 변경에 따른 보고 등) ① 법 제25조제1항 단서에서 "금융위원회가 정하는 경우"란 다음 각 호와 같다.

1. 이용자의 권익을 확대하거나 의무를 축소하기 위한 약관의 변경
2. 금융감독원장에게 보고된 약관의 내용과 동일하거나 유사한 약관의 제정 또는 변경
3. 그 밖에 이용자의 권익이나 의무에 불리한 영향이 없는 경우로서 금융감독원장이 정하는 약관의 제정 또는 변경

② 금융회사 또는 전자금융업자가 전자금융거래 약관을 제정 또는 변경하고자 하는 경우에는 해당 약관 및 약관내용을 이해하는데 필요한 관련서류를 시행예정일 45일 전까지 금융감독원장에게 제출하여야 한다. 이 경우 약관 및 관련서류는 전자문서로 제출할 수 있다.

③ 금융감독원장은 제2항의 규정에 따라 제출받은 약관을 심사하고 건전한 금융거래질서의 유지를 위하여 약관내용의 변경이 필요하다고 인정하는 경우 해당 금융회사 또는 전자금융업자에 대하여 약관의 변경을 권고할 수 있다.

④ 제3항의 규정에 따라 변경권고를 받은 금융회사 또는 전자금융업자는 권고의 수락여부를 금융감독원장에게 보고하여야 한다.

■ 전자금융거래와 관련한 약관 교부방법 및 약관제정 또는 변경에 따른 보고 사항 등을 상세히 규정

■ 해설

● 금융회사와 전자금융업자는 약관 제정 · 변경시 약관 시행예정일 45일 전까지 관련서류를 감독원장에게 제출하여야 함

● 다만, 이용자의 권익이나 의무에 불리한 영향이 없는 다음의 경우에는 약관의 제정 또는 변경 후 10일 이내에 보고할 수 있음

- 이용자의 권익을 확대하거나 의무를 축소하기 위한 약관의 변경
- 금융감독원장에게 보고된 약관의 내용과 동일하거나 유사한 약관의 제정 또는 변경
- 법령의 개정 또는 금융위원회의 명령에 따른 약관의 변경
- 이용자의 권익이나 의무사항을 제외한 사항으로서 단순히 업무편의를 위한 약관의 변경
- 사업자단체의 표준약관을 원용하는 약관의 제정 또는 변경

〈사후보고 약관 사례〉

구분	주요 사례
서비스 제공주체 변경	사명 변경, 서비스 이관
분쟁처리 방법 변경	연락처, 업무 담당부서(직원) 변경
이의제기 기한 확대	선불전자지급수단의 해외 이용시 이의제기 기한 확대
인증방식 확대	서비스 제공을 위한 회원 인증 수단 확대
서비스 이용시간 확대	당일 18시 까지 → 24시간
업계 공통 약관 일괄 제정	오픈뱅킹서비스, 계좌통합관리서비스 관련 약관 제 · 개정 ※ 단, 해당 약관을 최초 보고하는 회사는 사전보고 절차를 이행

● 금융감독원장은 제출받은 약관을 심사하고 약관변경이 필요하다고 판단한 경우 해당 금융회사 또는 전자금융업자에 약관변경을 권고할 수 있으며, 해당 기관은 변경권고 수락여부를 보고해야 함

● 전자금융업무를 수행하는 금융회사 또는 전자금융업자는 전자금융거래와 관련한 별도의 약관을 마련하여 이용자의 요청이 있을 경우 전자문서의 전송, 모사전송(FAX), 우편 또는 직접교부 방식으로 전자금융거래 약관의 사본을 이용자에게 교부하여야 함

- 이용자가 약관의 내용에 대한 설명을 요청할 경우 중요 내용을 직접 설명하거나 또는 전자적 장치를 통하여 이용자가 알기 쉽게 표시하고 이용자로부터 해당 내용을 충분히 인지하였다는 의사표시를 전자적 장치를 통하여 수령*하여야 함

  * 금융회사 및 전자금융업자는 이용자에게 Pop-up창을 띄우거나 이메일 통지를 통한 전자서명 동의방식, 기타 인터넷창에서 동의 의사표시를 직접 받을 수 있음

- 약관 변경시 그 시행일 1월 전에 변경되는 약관을 해당 전자금융거래를 수행하는 전자적 장치(게시가 어려울 경우 이용자가 접근하기 용이한 전자적 장치로서 당해 금융회사 등이 지정하는 대체장치)에 게시하고 이용자에게 통지하여야 함

  - 다만, 이에 관해 이용자가 이의를 제기할 경우 금융회사 또는 전자금융업자는 변경내용 게시·통지 사실에 관해 입증하여야 함(※ 입증하지 못할 경우 약관 변경효력이 없음)

※ 비조치의견서('17.12.1.)-170097

비조치의견서는 행정해석의 일종으로 최종 법적구속력은 없으며, 유권해석과는 달리 특정행위에 대해 해당 회사의 상황을 고려한 검토결과로써 일반적 효력을 가지지 아니하므로 참고자료로만 활용하시기 바랍니다.

요청대상 행위

- 사용자인증 및 결제대행서비스를 제공하는 전자지급결제대행업자와의 제휴를 통해 가맹점을 대상으로 정산대행 서비스를 제공하는 경우 이용자에게 전자금융거래에 관한 약관을 명시하고 동의를 구하여야 하는지 여부

판단

- 전자지급결제대행업을 영위하는 제휴업체로부터 전자금융거래정보를 수신하여 가맹점에 정산대행 서비스를 제공할 경우 이용자에게 약관을 명시하고 약관과 관련하여 법규에서 정한 절차를 준수하여야 할 것으로 보입니다.

판단이유

- 금융회사 및 전자금융업자는「전자금융거래법」 제24조, 제25조 등에 따라 전자금융거래의 계약 체결에 있어 약관을 명시하고 사본을 교부하거나, 미리 금융감독원에 보고하는 등 관련 법규에서 정한 절차를 준수하여야 합니다.

- 전자지급결제대행 업무와 관련하여 가맹점에 대해 정산대행 업무를 수행하며 전자금융거래정보를 처리한다면, 전자지급결제대행에 관여하여 이용자에게 전자금융업무를 제공하는 것으로 볼 수 있으므로 이용자에게 약관을 명시하는 등 약관과 관련하여 법규에서 정한 절차를 준수하여야 할 것으로 보입니다.
  ※ 여기에서의 "가맹점"은 신청인의 표현에 따른 것으로 전자지급결제대행업자가 정산대행서비스를 제공하는 대상을 의미하며, 전자금융거래법 제2조제20호에서의 "가맹점"과는 다른 개념입니다.

※ 법령해석('16.8.16.)-160766

질의

■ 스마트폰 App기반의 서비스인 '○○멤버스'의 약관 변경 등 중요사항을 고객에게 통지하고자 하는 경우
- 「전자금융감독 규정」 제40조제2항에서 정하고 있는 전자문서의 전송, 모사전송, 우편 또는 직접교부의 방식 외에 고객 편의성이 높은 방식으로 확대할 필요가 있음

회신

■ 스마트폰 App기반의 서비스 이용을 위한 전자금융거래 계약을 체결하거나 해당 서비스의 전자금융거래 약관을 변경하는 경우
- 이용자에게 해당 전자금융거래를 수행하는 전자적장치 등을 이용하여 약관의 내용에 대한 설명 또는 변경내용을 전달, 통지할 수 있습니다.

이유

■ 「전자금융감독 규정」 제40조제2항은 이용자의 요청이 있는 경우 전자금융거래 약관의 사본을 전자문서, 모사전송, 우편 또는 직접 교부의 방식으로 교부할 것을 정한 것으로
- 전자금융거래의 계약 체결이나 약관변경시 반드시 이 방법만을 이용하여 이용자에게 약관의 중요사항 등을 전달해야만 하는 것은 아닙니다.

■ 같은 조 제3항은 금융회사 또는 전자금융업자는 이용자와 전자금융거래 계약 체결시 이용자가 약관의 내용에 대한 설명을 요청하는 경우
① 약관의 중요내용을 이용자에게 직접 설명하거나,
② 중요내용에 대한 설명을 전자적 장치를 통해 이용자가 알기쉽게 표시하고, 이용자로부터 해당 내용을 충분히 인지했다는 의사표시를 수령하는 방식으로 설명하도록 정하고 있습니다.
- 따라서 이용자가 해당 서비스에 가입하고자 하는 경우 스마트폰 또는 해당 App을 통하여 중요내용에 대한 설명을 이용자에게 통지하고 전자금융거래의 계약을 체결할 수 있습니다.

■ 또한 같은 조 제4항에 따라 약관 변경시에는 시행일 1월전에 해당 전자금융거래를 수행하는 전자적 장치에 게시하고 이용자에게 통지하도록 하고 있습니다.
- 따라서 해당 서비스의 약관 변경시 변경 사항을 해당 App를 통해 게시하거나 문자메세지 등으로 통지하는 방식이 가능한 것으로 판단됩니다.

※ 법령해석('16.9.2.)-160838

질의

■ 은행은 은행권 공동 오픈플랫폼 이용기관(핀테크 기업 등)이 제공하는 서비스를 통한 출금, 잔액. 거래내역조회 등 전자금융거래에 관한 약관을 제정하는 경우 미리 금융위원회에 보고하지 않고 해당 약관 제정 후 10일 이내에 금융위원회에 보고하는 것이 가능한지 여부
* ○○은행은 7.6일 금융감독원장 약관심사를 완료

회신

■ 해당 약관이 이용자의 권익이나 의무에 불리한 영향이 없고 그 내용이 금융감독원장의 심사를 마친 약관(예: 상기 ○○은행 약관)과 동일 또는 유사한 경우에는 약관 제정 후 10일 이내에 금융위원회에 보고하는 것이 가능할 것으로 판단됩니다.

이유

■ 「전자금융거래법」 제25조 제1항 단서는 약관의 제정. 변경시 이용자의 권익이나 의무에 불리한 영향이 없는 경우로서 금융위원회가 정하는 경우 미리 금융위원회에 보고하지 않고 해당 약관 제정. 변경 후 10일 이내에 금융위원회에 보고할 수 있도록 규정하고 있습니다.

- 또한, 「전자금융감독규정」 제41조 제1항은 약관 제정 후 10일 이내에 금융위원회에 보고할 수 있는 사유로 '금융감독원장에게 보고된 약관의 내용과 동일하거나 유사한약관의 제정 또는 변경' 등을 들고 있습니다.

■ 따라서, 해당 약관이 이용자의 권익이나 의무에 불리한 영향이 없고 그 내용이 금융감독원장의 심사를 마친 약관(예: 상기 ○○은행 약관)과 동일 또는 유사한 경우에는 약관 제정 후 10일 이내에 금융위원회에 보고하는 것이 가능할 것으로 판단됩니다.

- 다만, 이용자의 권익이나 의무에 불리한 영향이 있는지 여부 등은 구체적인 약관의 내용이 확인된 이후 판단이 가능할 것입니다.

조치 사례('23.4.7.)

● 금융회사는 전자금융거래 약관 변경시 시행일 1월 전에 해당 전자금융거래를 수행하는 전자적 장치에 게시하고 이용자에게 통지하여야 하는데도(전자금융감독규정 제40조 제4항),

● ○○회사는 전자금융거래 약관을 변경하면서 홈페이지에 지연 공시하는 한편, 이용자에게 통지하지 않거나 지연통지하였음

제5장 전자금융업의 허가와 등록 및 업무

FSS
FINANCIAL SUPERVISORY SERVICE

제5장 전자금융업의 허가와 등록 및 업무

1. 개요

- 이용자 보호 및 전자금융거래의 안정성 확보를 위해 전자금융업 영위시 허가와 등록을 의무화하고 있으며, 영위할 업종에 따라 허가와 등록 대상을 구별하고 있음
  - 전자금융업을 영위하는 기관이 금융회사인 경우 전자금융업종에 따라 일부 허가 또는 등록을 면제받을 수 있으며, 선불전자지급수단의 발행 및 관리업의 경우 발행잔액 및 연간 총발행액의 규모 등에 따라 등록을 면제하고 있음

- 미허가 및 미등록 영업시 벌금 등의 처벌을 통해 허가 및 등록을 강제

※ 미허가 또는 미등록 영업시 3년 이하의 징역 또는 2천만원 이하의 벌금에 처할 수 있음(법 제49조제5항제5호)

2. 허가 대상 업무 및 면제요건

가. 법령상 근거

- 전자화폐의 발행 및 관리업무를 행하고자 하는 자는 금융위원회의 허가를 받아야 함(법 제28조)

나. 법 및 시행령 해설내용

- 법에서는 전자화폐의 발행 및 관리 업무를 수행하고자 하는 경우 금융위원회의 허가를 받도록 하는 한편,
  - 은행법상 금융회사 등 특정 금융회사에 대해 허가를 면제하고 있음

- 전자화폐 발행 및 관리업 허가면제 금융회사
  - 은행법에 따른 금융회사(은행)
  - 우체국예금 · 보험에 관한 법률에 따른 체신관서
  - 새마을금고법에 따른 새마을금고 및 새마을금고중앙회
  - 상호저축은행 및 그 중앙회, 신용협동조합 및 그 중앙회, 농협은행, 수협은행
  - 여신전문금융업법에 따른 여신전문금융회사 중 신용카드사업자
  - 한국산업은행, 중소기업은행, 한국수출입은행, 산림조합 및 그 중앙회의 신용사업부문, 농업협동조합, 수산업협동조합

제1절 허가 및 등록의 대상과 절차

1. 발행잔액 및 연간 총 발행액의 산정방법 등

감독규정

제42조(발행잔액 및 연간 총발행액의 산정방법 등) ① 시행령 제15조제5항에 따른 선불전자지급수단의 발행잔액 및 연간 총발행액은 다음 각 호의 방법에 따라 산정한다.

1. 발행잔액: 등록신청일이 속하는 사업연도의 직전 사업연도 1분기(직전 사업연도 1분기말 이후에 사업을 개시한 경우에는 사업개시한 날이 속하는 분기를 말한다)부터 등록신청일 직전 분기까지 각 분기말 미상환 발행잔액의 단순평균으로 한다. 다만, 사업기간이 3월 미만인 경우에는 등록신청일 직전 월말 미상환 발행잔액으로 한다.
2. 연간 총발행액: 등록신청일이 속하는 사업연도의 직전 사업연도(등록신청일이 속하는 사업연도에 사업을 개시한 경우에는 당해 사업연도를 말한다)에 발행된 선불전자지급수단의 총 발행금액

② 법 제28조제3항제1호다목에 따라 금융위원회에 등록하지 아니하고 선불전자지급수단을 발행하는 자는 매분기말 기준으로 선불전자지급수단의 미상환잔액 등을 평가하여 이를 시행령 제15조제6항에 따른 지급보증, 상환보증보험 또는 공제에 반영하여야 한다.

제42조의2(거래금액 기준) ① 법 제30조제3항제1호에서 "금융위원회가 정하는 기준"이라 함은 당해 전자금융업에 대한 분기별 결제대행금액(이용자가 지급한 재화 및 용역의 매출총액), 결제대금예치금액 또는 전자고지결제금액이 30억원 이하에 해당하는 경우를 말한다.

② 법 제30조제4항에서 "금융위원회가 정하는 기한"이라 함은 신고한 때로부터 6월 이내를 말한다.

③ 등록 자본금 초과시 신고와 관련한 절차 및 방법 등 세부사항은 금융감독원장이 정하는 바에 따른다.

시행세칙

제8조의3(거래금액 기준 초과시 신고 등) ① 법 제30조제3항제1호에 해당하는 전자금융업자는 분기별 거래 총액(결제대행금액, 결제대금예치금액 또는 전자고지결제금액)이 규정 제42조의2제1항에 따른 거래금액 기준을 초과한 경우 해당 분기 종료 후 45일 이내에 별지 제5호 서식에 따라 감독원장에게 초과 내역 및 자본금 증액 계획을 신고하여야 한다.

② 제1항에 따른 신고를 마친 자는 법 제30조제4항에 따른 자본금 요건을 갖춘 후, 신고한 때부터 6개월 이내에 자본금 납입 증명서류 등 관련 서류를 감독원장에게 제출하여야 한다.

※ 법령해석('25.1.22.)-240083

질의

- 본래 발행자로부터 재화 또는 용역을 구입하는데 이용되도록 발행된 게임캐시를 채널링 서비스(제3자거래)에서도 사용 가능할 경우 게임캐시가 전자금융거래법 제2조제15호의 선불전자지급수단에 해당한다면, 동법 제28조제3항 제1호 나목에서 규정하는 선불전자지급수단의 발행잔액 및 연간 총발행액을 ① 게임캐시 전체를 기준으로 산정하여야 하는지, ② 채널링 서비스에서 사용되는 부분만을 기준으로 산정해야 하는지 여부

회신

- 법상 선불전자지급수단의 정의를 고려시 발행인 외의 제3자로부터 재화 또는 용역을 구입하고 그 대가를 지급하는데 사용될 수 있는 금액은 모두 선불전자지급수단에 해당하므로 게임캐시 전체를 기준으로 선불전자지급수단의 발행잔액 및 연간 총발행액을 판단해야 할 것으로 판단됩니다.

이유

- 「전자금융거래법」제2조제14호에서 "선불전자지급수단"에 대해 이전 가능한 금전적 가치가 전자적 방법으로 저장되어 발행된 증표(전자적 방법으로 변환되어 저장된 증표를 포함한다) 또는 그 증표에 관한 정보로서 발행인(대통령령으로 정하는 특수관계인을 포함한다) 외의 제3자로부터 재화 또는 용역을 구입하고 그 대가를 지급하는데 사용되는 것으로 규정하고 있습니다.
- 따라서, 법상 선불전자지급수단의 정의를 고려시 발행인 외의 제3자로부터 재화 또는 용역을 구입하고 그 대가를 지급하는데 사용될 수 있는 금액은 모두 선불전자지급수단에 해당하므로 게임캐시 전체를 기준으로 선불전자지급수단의 발행잔액 및 연간 총발행액을 판단해야 할 것으로 판단됩니다.

※ 관계 법령

법

제30조(자본금) ①~② (생략)

③ 제28조제2항제4호 · 제5호 및 제29조의 규정에 따라 등록할 수 있는 자는 「상법」 제170조에서 정한 회사 또는 「민법」 제32조에서 정한 법인으로서 업무의 종류별로 자본금 · 출자총액 또는 기본재산이 다음 각 호의 구분에 따른 금액 이상이어야 한다.

1. 분기별 전자금융거래 총액이 30억원 이하의 범위에서 금융위원회가 정하는 기준 이하로 운영하고자 하는 자(제29조에 따라 등록을 하고자 하는 자는 제외한다): 3억원 이상으로 대통령령으로 정하는 금액
2. 제1호 외의 자: 5억원 이상으로 대통령령으로 정하는 금액

④ 제3항제1호에 해당하는 자가 제28조에 따라 등록을 한 후 2분기 이상 계속하여 제3항제1호의 금융위원회가 정하는 기준을 초과하는 경우에는 그 내용을 금융위원회에 신고하고 금융위원회가 정하는 기한 내에 제3항제2호에서 정하는 자본금요건을 갖추어야 한다.

개정된 전자금융거래법은 핀테크 활성화를 위해 소규모 전자금융업자에 대해서는 등록 자본금을 완화

해설

- 소규모 전자금융업자로 등록한 후 2분기 이상 연속하여 기준 초과시에는 6개월 내에 자본금을 증액하여야 함('16.3.29. 법개정)

2. 허가등 절차의 구분

감독규정

제43조(허가등 절차의 구분) 다음 각 호의 허가 또는 인가(이하 "허가등"이라 한다)의 절차는 허가등 사항에 대한 사전심사 및 확실한 실행을 위하여 허가등의 이전에 예비적으로 행하는 의사표시(이하 "예비허가등"이라 한다)와 허가등으로 구분한다.

1. 법 제28조제1항의 규정에 의한 전자화폐의 발행 및 관리 업무의 허가
2. 법 제45조에 의한 합병 등의 인가

3. 예비허가 등

감독규정

제44조(예비허가등) ① 예비허가등을 신청하고자 하는 자는 금융감독원장이 정하는 바에 따라 〈별지 제3호 서식〉에 따른 관련 신청서 및 첨부서류를 금융위원회에 제출하여야 한다.

② 금융위원회는 예비허가등의 심사를 위하여 필요하다고 인정하는 때에는 예비허가등의 신청에 대하여 이해관계인의 의견을 요청할 수 있고, 금융시장에 중대한 영향을 미칠 우려가 있다고 판단되는 경우 공청회를 개최할 수 있다.

③ 금융위원회는 제2항의 규정에 의하여 접수된 의견 중 신청인에게 불리한 의견에 대하여는 신청인에게 소명하도록 기한을 정하여 통보할 수 있다.

④ 금융감독원장은 예비허가등의 신청내용에 대한 진위여부를 확인하고 이해관계인, 일반인 및 관계기관 등으로부터 제시된 의견을 감안하여 신청내용이 관련 법령과 이 장 제2절에서 규정하는 허가등 세부기준에 부합되는지 여부를 심사하여야 한다.

⑤ 금융감독원장은 사업계획의 타당성을 평가하기 위하여 평가위원회를 구성 · 운영할 수 있으며 신청내용의 확인, 발기인 및 경영진과의 면담 등을 위하여 실지조사를 실시할 수 있다.

⑥ 금융위원회는 예비허가등의 신청에 대하여 관련 법령과 이 장 제2절에서 규정하는 허가의 세부기준을 감안하여 예비허가등의 여부를 결정한다.

⑦ 금융위원회는 예비허가등 시에 조건을 붙일 수 있으며 예비허가등을 거부하는 경우 이를 서면으로 신청인에게 통보하여야 한다.

⑧ 금융위원회는 합병, 영업양도 등 구조조정 및 이용자보호 등을 위하여 신속한 처리가 필요하거나 예비허가등의 신청 시 허가등의 요건을 갖추었다고 판단되는 때에는 예비허가등의 절차를 생략할 수 있다.

4. 허가 등

감독규정

제45조(허가등) ① 신청인은 예비허가등의 내용 및 조건을 이행한 후 금융감독원장이 정하는 바에 따라 〈별지 제4호 서식〉에 따른 관련 신청서 및 첨부서류를 금융위원회에 제출하여야 한다.
② 금융위원회는 허가등의 신청에 대하여 관련 법령과 이 장 제2절에서 규정하는 허가의 세부기준에 따라 심사하여 허가여부를 결정한다.
③ 허가등에는 조건을 붙일 수 있으며 허가를 거부하는 경우에는 이를 서면으로 신청인에게 통보하여야 한다.
④ 금융위원회는 예비허가등의 내용 및 조건의 이행여부를 확인하기 위하여 실지조사를 실시할 수 있으며, 신청인은 이에 적극 협조하여야 한다.
⑤ 신청인은 예비허가등 또는 허가등 시에 부과된 조건이 있는 경우 그 이행상황을 이행기일 경과 후 지체 없이 금융위원회에 보고하여야 한다.

제46조(보완서류 등의 제출) 금융위원회는 예비허가등 또는 허가등의 심사 시 보완서류 등의 추가자료가 필요한 경우 신청인에게 기한을 정하여 그 자료의 제출을 요구할 수 있다.

제47조(허가등 사실의 공고) 금융위원회는 허가등의 신청을 승인한 경우에는 지체 없이 그 내용을 관보에 공고하고 인터넷 등을 이용하여 일반인들에게 알려야 한다.

■ 허가 또는 인가(이하 "허가등" 이라함)의 절차는 허가등 사항에 대한 사전심사 및 확실한 실행을 위하여 허가 등의 이전에 예비적으로 행하는 의사표시(이하 "예비허가등" 이라함)와 허가등으로 절차를 구분하고 있음

● 신청인은 예비허가 등의 내용 및 조건을 이행한 후 허가 등 신청서 및 첨부서류를 금융위에 제출하여 심사를 받음

■ 해설

● 예비허가 및 예비인가제도

- 허가 및 인가에 있어 신청인의 예측가능성을 제고하고 행정의 효율성을 확보하기 위해 사전인·허가 제도를 도입하여 신청인의 편익을 도모하고자 함

● 예비허가 및 예비인가 대상(전자화폐발행 및 관리업에 한함)

- 전자화폐발행 및 관리업무의 허가
- 전자화폐발행 및 관리업자의 다른 금융회사 또는 및 전자금융업자와의 합병 인가
- 전자화폐발행 및 관리업의 해산 또는 전자금융업무의 폐지인가
- 전자화폐발행 및 관리업 전부 또는 일부의 양도와 양수 인가

- 금융위는 허가의 세부기준에 따라 심사하여 허가여부를 결정
  - 허가 등에는 조건을 붙일 수 있으며, 허가를 거부할 경우에는 반드시 서면으로 신청인에게 통보하여야 함
  - 금융위는 예비허가 등의 내용 및 조건의 이행여부를 확인하기 위해 실지조사를 실시할 수 있음
- 금융위는 예비허가 등 또는 허가 등의 심사시 보완서류 등의 추가자료가 필요한 경우 신청인에게 기한을 정하여 그 자료의 제출을 요구할 수 있고,
  - 허가 등의 신청을 승인할 경우에는 지체없이 그 내용을 관보에 공고하여 일반인에게 알려야 함

5. 등록

감독규정

제48조(등록) ① 법 제28조 및 제29조에 따라 등록을 신청하고자 하는 자는 금융감독원장이 정하는 바에 따라 〈별지 제5호 서식〉에 따른 등록신청서를 금융감독원에 제출하여야 하며 금융감독원장은 등록신청일로부터 20일 이내에 서면으로 등록여부를 통지한다. 이 경우 등록신청서에 흠결이 있는 때에는 보완을 요청할 수 있다.

② 금융감독원장은 제1항의 등록 여부를 결정할 때 다음 각 호의 어느 하나에 해당하는 사유가 없으면 등록을 거부하여서는 아니 된다.

1. 법 제31조에 따른 등록 요건을 갖추지 아니한 경우
2. 제1항의 등록신청서를 거짓으로 작성한 경우
3. 제1항의 보완 요청을 이행하지 아니한 경우

③ 금융감독원장은 등록의 내용 및 조건의 이행여부를 확인하기 위한 실지조사를 실시할 수 있다.

④ 금융감독원장은 등록 신청을 수리한 경우에는 지체 없이 그 내용을 관보에 공고하고 인터넷 등을 이용하여 일반인들에게 알려야 한다.

⑤ 제1항의 기간을 산정함에 있어 다음 각 호의 기간은 산입하지 아니한다.

1. 제1항의 등록신청서 보완에 걸린 기간
2. 제3항의 실지조사에 걸린 기간
3. 법 제32조의 등록 결격사유를 확인하기 위해 다른 기관 등으로부터 필요한 자료를 제공받는 데에 걸리는 기간

■ 등록 신청인은 등록신청서를 금융감독원에 제출하여야 하며 감독원장은 등록신청일로부터 20일 이내에 서면으로 등록여부를 통지함

■ 해설

- 금융감독원장은 신청인의 등록 신청에 대하여 자본금, 재무건전성 및 인적·물적 요건 등의 심사기준에 따라 등록 여부를 결정
- 등록신청서에 흠결이 있는 경우 보완을 요청할 수 있고 등록의 내용 및 조건의 이행여부를 확인하기 위한 실지조사를 실시할 수 있음
- 등록을 완료한 경우에는 지체 없이 그 내용을 관보에 공고 및 인터넷 등을 이용하여 일반인들에게 알림

6. 기재가 생략되는 출자자의 범위

감독규정

제49조(기재가 생략되는 출자자의 범위) 시행령 제20조제1항제3호에서 "금융위원회가 정하여 고시하는 소액 출자자"라 함은 허가 또는 등록대상 전자금융업자가 되고자 하는 법인의 의결권 있는 발행주식총수의 100분의 1 이하의 주식을 소유하는 자를 말한다.

〈참고〉

전자금융업 등록 관련 절차

1. 등록 협의 : 방문 또는 이메일 등으로 자료제출하여 등록업무 상담

⬇

2. 등록 신청 : 금융감독원에 신청서 제출

⬇

3. 등록 심사 : 등록신청(접수)일 기준 20일 이내 여부통보
   - 서류 심사 : 제출서류 심사
   - 실지 조사 : 등록신청업체 현장 조사
   - 신원 조회 : 신청인 및 대주주 등에 대한 결격사유 조회
   - 보완 요청 : 등록 관련 서류 보완요청

⬇

4. 등록 완료
   - 등록완료통보 : 등록신청 업체 공문발송(우편)
   - 관보공고요청 : 금융위에 관보공고 요청
   - 홈페이지공고 : 홈페이지에 등록사실 공고

※ 법령해석('25.2.18.)-240281

질의

■ 전자금융거래법에서 등록이 면제되는 선불업자에는 하나의 가맹점에서만 사용되는 선불전자지급수단을 발행하는 자가 있는데, 이 때의 가맹점은 사업자가 아닌 "일반 개인"도 해당되는지 여부

회신

■ 선불업자는 가맹점을 모집함에 있어 가맹점이 되고자 하는 자의 영업여부를 확인하여야 하며, 영업을 하는 경우에만 "가맹점"으로 모집할 수 있는 것으로 판단됩니다.

이유

■ 「전자금융거래법」 제28조제2항에서는 선불전자지급수단의 발행 및 관리업무를 하려는 자가 금융위원회에 등록하도록 하되,

- 동법 제28조제3항제1호가목에서 하나의 가맹점(가맹점의 사업주가 동일한 경우로 한정한다)에서만 사용되는 선불전자지급수단을 발행하는 자는 등록의무를 면제하고 있습니다.

■ 또한, 「전자금융거래법」 제2조제20호에서 "가맹점"에 대해 금융회사 또는 전자금융업자와의 계약에 따라 직불전자지급수단이나 선불전자지급수단 또는 전자화폐에 의한 거래에 있어서 이용자에게 재화 또는 용역을 제공하는 자 등을 규정하고 있으며,

- 동법 제38조제1항에서 금융회사 또는 전자금융업자가 가맹점을 모집하는 경우에는 가맹점이 되고자 하는 자의 영업여부 등을 확인하도록 규정하고 있습니다.

■ 따라서, 선불업자는 가맹점을 모집함에 있어 가맹점이 되고자 하는 자의 영업여부를 확인하여야 하며, 영업을 하는 경우에만 "가맹점"으로 모집할 수 있는 것으로 판단됩니다.

※ 법령해석('25.3.12.)-240309

질의

■ 전자금융거래법 제28조제3항제1호가목은 "하나의 가맹점(가맹점의 사업주가 동일한 경우로 한정한다)"에서만 사용되는 선불전자지급수단을 발행하는 자는 금융위원회에 등록하지 아니하고 선불전자지급수단을 발행할 수 있다고 규정하고 있는데 "하나의 가맹점"에 프랜차이즈 업이 포함되는지 여부

회신

■ 프랜차이즈 본사가 사업주가 동일하지 않은 가맹점으로부터 재화 또는 용역을 구입하고 그 대가를 지급하는데 사용되는 선불전자지급수단의 발행 및 관리 업무를 행하고자 하는 경우에는「전자금융거래법」제28조제3항제1호에서 규정하는 면제사유에 해당하지 않는 한 금융위원회에 등록해야 할 것으로 판단됩니다.

이유

■ 「전자금융거래법」제2조제14호에서 "선불전자지급수단"이라 함은 이전 가능한 금전적 가치가 전자적 방법으로 저장되어 발행된 증표(전자적 방법으로 변환되어 저장된 증표를 포함한다) 또는 그 증표에 관한 정보로서 발행인 외의 제3자로부터 재화 또는 용역을 구입하고 그 대가를 지급하는데 사용되는 것을 말한다고 규정하고 있습니다.

- 또한, 동법 제28조제2항에 따라 선불전자지급수단의 발행 및 관리 업무를 행하고자 하는 자는 금융위원회에 등록하도록 규정하고 있습니다.
- 다만, 동법 제28조제3항제1호가목에 따라 하나의 가맹점(가맹점의 사업주가 동일한 경우로 한정한다)에서만 사용되는 선불전자지급수단을 발행하는 자는 선불업 등록이 면제됩니다.

■ 따라서, 프랜차이즈 본사가 사업주가 동일하지 않은 가맹점으로부터 재화 또는 용역을 구입하고 그 대가를 지급하는데 사용되는 선불전자지급수단의 발행 및 관리 업무를 행하고자 하는 경우에는 「전자금융거래법」 제28조제3항제1호에서 규정하는 면제사유에 해당하지 않는 한 금융위원회에 등록해야 할 것으로 판단됩니다.

※ 법령해석('25.2.18.)-240172

질의

■ 오픈마켓이 PG를 통해 결제한 오픈마켓 입점사의 카드결제 대금을 PG사의 지급대행 서비스를 사용하여, PG사 가상계좌에서 입점사의 계좌로 바로 지급되도록 하는 행위가 전자금융거래법 제28조제3항제2호에서 말하는 전자지급거래의 정보만을 단순히 전달하는 행위인지 여부

회신

■ 오픈마켓이 전자금융거래와 관련된 자금을 수수하거나 수수를 대행하지 아니하고 전자지급거래에 관한 정보만을 PG사에 단순히 전달하는 업무만 수행하는 경우에는 금융위원회에 등록하지 않고 해당 업무를 수행할 수 있는 것으로 판단됩니다.

이유

■ 「전자금융거래법」제2조제19호에서 "전자지급결제대행"에 대해 전자적 방법으로 재화의 구입 또는 용역의 이용에 있어서 지급결제정보를 송신하거나 수신하는 것 또는 그 대가의 정산을 대행하거나 매개하는 것으로 정의하고 있습니다.
- 또한, 「전자금융거래법」제28조제3항제2호에서 자금이동에 직접 관여하지 아니하고 전자지급거래의 전자적 처리를 위한 정보만을 전달하는 업무 등 대통령령이 정하는 전자지급결제대행에 관한 업무를 수행하는 자는 금융위원회에 등록하지 않고 "전자지급결제대행" 업무를 수행할 수 있도록 규정하고 있습니다.
- 동법 시행령 제15조제7항에서는 "대통령령이 정하는 전자지급결제대행에 관한 업무"라 함은 전자금융거래와 관련된 자금을 수수하거나 수수를 대행하지 아니하고 전자지급거래에 관한 정보만을 단순히 전달하는 업무로 규정하고 있습니다.

■ 따라서 오픈마켓이 전자금융거래와 관련된 자금을 수수하거나 수수를 대행하지 아니하고 전자지급거래에 관한 정보만을 PG사에 단순히 전달하는 업무만 수행하는 경우에는 금융위원회에 등록하지 않고 해당 업무를 수행할 수 있는 것으로 판단됩니다.
- 다만, 상기의 판단은 구체적인 사실관계에 따라 달라질 수 있는 점을 참고하여 주시기 바랍니다.

제2절 허가 및 등록의 세부요건

1. 인력 및 물적 시설 세부요건

감독규정

제50조(인력 및 물적 시설 세부요건) ① 법 제28조 및 제29조에 따라 허가를 받거나 등록을 하고자 하는 자는 인력과 물적 시설에 대한 다음 각 호의 요건을 모두 갖추어야 한다.

1. 신청 당시 전산업무 종사 경력이 2년 이상인 임직원을 5명 이상 확보하고 있거나 허가·등록 시점에 확보 가능할 것
2. 전자금융업을 원활히 영위하는데 필요한 전산기기를 갖출 것
3. 전산장애 발생 시 전산자료 손실에 대비한 백업(backup)장치를 구비할 것
4. 전자금융업의 원활한 영위를 위한 각종 프로그램을 갖출 것
5. 전산자료 보호 등을 위한 적절한 정보처리시스템 관리방안을 확보하고 정보보호시스템 등 감시운영체제를 구축할 것
6. 전산실 등의 구조 및 내장, 설비 등의 안전성을 확보하고 적절한 보안대책을 수립할 것

② 국외에서 주로 영업하는 국외 사이버몰("국외 사이버몰"이란 컴퓨터 등과 정보통신설비를 이용하여 재화 등을 거래할 수 있도록 설정된 가상의 영업장으로서 운용자의 사무소가 국외에 있는 경우를 말한다. 이하 같다)에서의 상거래에 수반한 전자지급결제대행업을 영위할 목적으로 전자금융업을 등록하고자 하는 자는 제50조제1항의 규정에도 불구하고 다음 각 호의 요건을 모두 충족한 경우 등록할 수 있다.

1. 국외에 소재한 계열사(「금융회사의 정보처리 업무 위탁에 관한 규정」 제2조제3항의 "계열사"를 말한다. 이하 같다)와 이용계약을 체결하였고, 계열사의 인력 및 물적 시설이 제50조제1항 각 호의 세부요건을 충족할 것
2. 제1호의 규정에도 불구하고 전자금융업을 등록하고자 하는 자는 신청 당시 법령 준수업무와 이용자 민원처리 업무를 담당할 3명 이상의 임직원(전산업무 종사 경력이 2년 이상인 임직원 1명을 포함하여야 한다)은 직접 확보하고 있거나 등록시점에 확보 가능할 것
3. 신청 당시 계열사의 인력 또는 물적시설을 통해 5개국 이상의 국가에서 전자지급결제대행업무가 수행되고 있을 것

③ 제2항에 따라 등록을 하려는 자가 계열사의 인력 또는 물적시설의 이용계약을 체결하는 경우에는 「금융회사의 정보처리 업무 위탁에 관한 규정」을 적용한다. 다만, 동 규정의 제7조는 적용하지 아니한다.

■ 전자금융업의 원활한 수행을 위해 필요한 최소한의 인적/물적 시설요건을 규정함

전자금융업 물적 설비 현황 점검리스트(참고)

항 목		제출서류
1. 전자금융업을 원활히 영위하는데 필요한 전산기기 보유		
	① 전자금융업을 원활히 영위하는데 필요한 주전산기기, 어플리케이션 서버, DB서버, 웹서버, 저장장치 및 출력장치 등을 갖출 것	전산기기 목록
	② 대외 금융회사, 가맹점 또는 지점 등과 자료의 송수신 등을 위한 통신제어장치, 통신서버, 통신회선 등 전자금융업무를 지원하기 위한 내·외부 통신망 구축	통신기기 목록
2. 전산장애 발생시 전산자료 손실에 대비한 백업장치 구비		
	① 백업장치를 구비하고 중요도에 따라 프로그램, 데이터, 로그 등 전산자료를 정기백업 및 안전지역에 소산	백업계획서
	② 자연 재해, 인적 재해, 기술적 재해, 전자적 침해 등으로 인한 전산시스템 마비 방지, 자료 손실 방지 및 신속한 복구를 위한 비상대책 수립	비상계획서
	③ 중앙 처리장치, 데이터저장장치 등 주요 전산장비 및 통신망에 대하여 이중화 또는 예비 장치를 확보	주요 전산장비·통신회선 등의 이중화 구성도
3. 전자금융업의 원활한 영위를 위한 각종 프로그램을 갖출 것		
	① 주요 업무별·기능별 각종 프로그램을 갖출 것	프로그램 보유 현황
	①-1 전자금융거래 내용을 추적·검색하거나 그 내용에 오류가 발생할 경우 이를 확인할 수 있도록 전자금융거래기록을 생성하여 보관할 것	전자금융기록 현황 - 전자금융거래기록 대상, 보관방법, 보관기간, 보관절차
	② 프로그램 등록·변경·폐기 시 통제방안 마련	프로그램 등록·변경·폐기 절차
4. 전산자료 보호 등을 위한 정보처리시스템 관리방안 확보		
	① 사용자계정과 비밀번호를 개인별로 부여하고 등록·변경·폐기 등에 관하여 체계적으로 관리(외부사용자에게 사용자계정을 부여하는 경우 적절한 통제장치 마련)	계정·비밀번호 부여 절차 및 관리현황
	② 담당업무에 따른 전산자료의 입력·출력·열람 등 접근권한 통제	전산자료 접근 권한 부여절차 및 관리현황

항 목		제출서류
	②-1 전산원장의 변경통제	전산원장 현황, 전산원장 변경절차
	③ 전산자료 및 전산장비의 반출 · 입 통제	전산자료 반출·입 관리 대장
	④ 이용자 정보의 조회 · 출력에 대한 통제를 하고 테스트 시 이용자 정보사용을 금지(불가피한 경우 이용자 정보를 변환하여 사용하고 테스트 종료 즉시 삭제)	이용자 정보보호방안, 프로그램 개발 및 테스트 시 이용자 정보 이용 절차
	⑤ 단말기를 통한 이용자정보 조회시 사용자, 사용일시, 변경 또는 조회내용, 접속방법 등이 정보처리시스템에 자동 기록되도록 하고, 그 기록을 1년 이상 보존	이용자 정보 이용 기록 및 보관 현황
	⑥ 공개용 웹서버를 내부통신망과 분리하여 내부통신망과 외부통신망 사이의 독립된 통신망(DMZ)에 설치하고 네트워크 및 웹 접근 제어 수단으로 보호	DMZ을 포함한 네트워크 구성도
	⑦ 공개용 서버에 접근할 수 있는 사용자계정은 업무관련자만 접속할 수 있도록 제한하고 아이디 · 비밀번호 이외에 추가인증 수단을 적용	공개용 웹서버 이중인증 적용 현황
	⑧ 개인정보의 유출, 위 · 변조 방지를 위한 보안조치	개인정보 보유현황, 정보유출 방지 대책
	⑨ 공개용 웹서버가 해킹공격에 노출되지 않도록 취약점에 대하여 적절한 대응 조치 강구	전자금융업무 시스템 취약점에 대한 점검결과
5. 정보보호시스템 등 감시운영체제 구축		
	① 전산자료 보호 등을 위한 적절한 정보처리시스템 관리방안을 확보하고 정보보호시스템 등 감시운영체제를 구축	정보보호시스템 (침입차단시스템, 침입탐지시스템, VPN 등)구축 현황
	② 내부통신망과 연결된 내부 업무용시스템은 인터넷 등 외부통신망과 분리 · 차단 및 접속 금지하고, 전산실 내에 위치한 정보처리시스템과 해당 정보처리시스템의 운영, 개발, 보안 목적으로 직접 접속하는 단말기에 대해서는 인터넷 등 외부통신망으로부터 물리적으로 분리	망분리 현황
	③ 악성코드 감염 방지대책 마련	악성코드 감염 방지 프로그램 현황 및 복구 절차서

항 목		제출서류
6. 전산실 안전성 확보 및 적절한 보안대책 수립		
	① UPS, 항온항습기, 자가발전설비, 자동소화설비, 접지 시설 등 안정적인 전산실 운영에 필요한 기본 설비 확보	전산실 설비 목록
	② 화재·수해 등의 재해 및 외부로부터의 위해 방지대책 수립 · 운용	비상대책
	③ 전산실, 전산자료보관실, 정보보호시스템 설치장소 등 보안관리가 필요한 정보처리시스템 설치장소를 보호구역 설정	보호구역 지정 현황
	④ 전산실 출입문은 한 곳으로 정하며 상시출입은 업무와 직접 관련이 있는 자에 한하여 허용하고, 그 밖의 출입자에 대하여는 관리책임자의 승인을 받아 출입하도록 하며 출입자 관리기록부 기록 · 보관	전산실 출입절차, 전산실 출입자 관리기록부
	⑤ 전산실의 규모, 설치장소 등을 감안하여 무인감시카메라 또는 출입자동기록시스템을 설치하여 사후확인이 가능하도록 조치	출입자 감시장치 운영현황
	⑥ 전산실 출입문은 2중 안전장치로 보호하며 외벽이 유리인 경우 유리 창문을 통하여 접근할 수 없도록 조치	전산실 배치도

2. 국외 사이버몰을 위한 전자지급결제대행업

감독규정

제50조의2(국외 사이버몰을 위한 전자지급결제대행업) ① 제50조제2항에 따라 등록하고자 하는 경우 시행령 제20조제2항제8호에 따라 다음 각 호의 서류를 제출하여야 한다.

1. 「금융회사의 정보처리 업무 위탁에 관한 규정」 제7조제1항 각 호의 서류
2. 등록신청자 및 계열사의 수탁업무 수행 과정에서의 법·시행령 및 이 규정 등 준수에 대한 확약서
3. 신청 시점에 전자지급결제 대행업무를 수행하고자 하는 국외 사이버몰에 대한 다음 각 목의 사항(해당 국가의 법령 등에서 이와 유사한 것으로 인정되는 사항을 포함한다)을 기재한 서류
   가. 「전자상거래 등에서의 소비자보호에 관한 법률」 제10조제1항 각 호의 서류
   나. 신청일 직전연도에 사이버몰에서 체결된 전자상거래 중 국내에 소재한 소비자와 사업자 간 거래의 비중

② 제50조제2항에 따라 등록을 한 자는 국외에서 주로 영업하는 국외 사이버몰을 통한 상거래에 대해서만 전자지급결제대행업을 영위하여야 한다.

③ 금융감독원장은 국외에서 주로 영업하는 국외 사이버몰의 판단기준 등 필요한 사항을 정할 수 있다.

시행세칙

제8조의2(국외에서 주로 영업하는 국외 사이버몰의 판단기준) 규정 제50조의2제3항에 따라 감독원장은 국외에서 주로 영업하는 국외 사이버몰을 판단하는데 있어 다음 각 호의 사항 등을 고려한다.

1. 사이버몰 운용자의 사무소, 인적·물적 시설의 소재지
2. 사이버몰에서 이루어지는 상거래 대상 국가의 수
3. 사이버몰에 대한 국외 감독당국, 규제기관의 감독·규제여부
4. 사이버몰에서 체결된 전자상거래 중 국내에 소재한 소비자와 사업자간 거래의 비중
5. 규정 제50조의2제2항에 따른 제한을 회피하기 위한 사이버몰 여부

※ 법령해석('25.1.22.)-240065

질의

■ 국외사이버몰을 위한 전자지급결제대행업 등록시 부채비율 입증과 관련하여 해외 계열회사의 재무제표에 대해 국내회계법인이 아닌 해외 계열회사 소재 국가의 회계법인 확인이 가능한지 여부

회신

■ 전자금융감독규정에서 국외사이버몰 등록요건인 부채비율 산정시 기준이 되는 대차대조표에 대해 명시적으로 국내 회계법인의 확인을 받도록 규정하고 있지는 않으나 지급결제의 안정성 제고와 이용자 보호 등을 위해 신청회사의 재무건전성을 확인하도록 한 취지를 고려하여 충분한 전문성을 가진 회계법인으로부터 국제회계기준에 따른 검증이 필요할 것으로 판단됩니다.

이유

■ 전자금융업감독규정 제50조제2항은 국외에서 주로 영업하는 국외 사이버몰("국외 사이버몰"이란 컴퓨터 등과 정보통신설비를 이용하여 재화 등을 거래할 수 있도록 설정된 가상의 영업장으로서 운용자의 사무소가 국외에 있는 경우를 말한다.)에서의 상거래에 수반한 전자지급결제대행업을 영위할 목적으로 전자금융업을 등록하고자 하는 자의 인력 및 물적 시설 세부요건에 대한 등록요건을 규정하고 있습니다.

- 또한, 재무건전성 요건에 대해서는 동 규정 제51조제1항제2호에서 금융산업의 구조개선에 관한 법률에 따른 금융회사에 해당하지 아니하는 기관의 경우 자기자본 대비 부채총액의 비율(부채비율)이 100분의 200 이내일 것으로 규정하고 있으며,
- 제51조제2항에서 부채비율은 신청일이 속하는 사업연도의 직전 사업연도말 대차대조표 상의 자기자본 및 부채총액을 이용하여 산출하도록 규정하되, 최근 대차대조표를 사용하고자 하는 경우에는 신청일 최근 분기말 대차대조표 또는 회계법인의 확인을 받은 신청일 최근 월말 대차대조표상의 자기자본 및 부채총액을 산출하는 것으로 규정하고 있습니다.

■ 따라서 전자금융감독규정에서 등록요건인 부채비율 산정시 기준이 되는 대차대조표에 대해 명시적으로 국내 회계법인의 확인을 받도록 규정하고 있지는 않으나 지급결제의 안정성 제고와 이용자 보호 등을 위해 신청회사의 재무건전성을 확인하도록 한 취지를 고려하여 충분한 전문성을 가진 회계법인으로부터 국제회계기준에 따른 검증이 필요할 것으로 판단됩니다.

3. 재무건전성 세부기준 및 계산방법

감독규정

제51조(재무건전성 세부기준 및 계산방법 등) ① 시행령 제18조제1항 및 제2항에 따라 금융위원회가 정하는 재무건전성 기준은 다음 각 호와 같다.

1. 시행령 제18조제1항의 규정에 따른 기관 중 「금융산업의 구조개선에 관한 법률」 제2조제1호의 금융회사에 해당하는 기관은 그 기관의 설립 · 운영 등에 관한 법령상 경영개선권고, 경영개선요구 또는 경영개선명령 등의 요건이 되는 재무기준에 해당하지 아니할 것
2. 제1호 이외의 경우에는 다음 각 목의 요건을 충족할 것
   가. 시행령 제18조제1항의 규정에 따른 금융회사 중 「금융산업의 구조개선에 관한 법률」 제2조제1호의 금융회사에 해당하지 않는 기관은 자기자본 대비 부채총액의 비율이 100분의 200 이내일 것. 다만, 금융회사 업무의 성격 및 재무 구조 등을 감안할 때 부채비율 기준을 적용하지 아니하고, 「금융산업의 구조 개선에 관한 법률」 제2조제1호 각 목 중 어느 하나의 금융회사(이하 "기준 금융회사"라 한다)의 재무건전성 기준을 적용하는 것이 적절하다고 금융위원회가 승인하는 경우에는, 기준 금융회사의 설립, 운영 등에 관한 법령에 따라 산출한 재무 비율이 같은 법령상의 경영개선권고, 경영개선요구 또는 경영개선명령 등의 요건이 되는 기준에 해당하지 아니할 것
   나. 법 제28조제1항에 따른 허가대상 전자금융업일 경우에는 자기자본 대비 부채총액의 비율이 100분의 180 이내일 것
   다. 법 제28조제2항 및 제29조에 따른 등록대상 전자금융업일 경우에는 자기자본 · 출자총액 또는 기본재산 대비 부채총액의 비율이 100분의 200 이내일 것

② 제1항제2호, 제5항 및 제6항의 부채비율은 신청일이 속하는 사업연도의 직전 사업연도말 대차대조표(최근 대차대조표를 사용하고자 하는 경우에는 신청일 최근 분기말 대차대조표 또는 회계법인의 확인을 받은 신청일 최근 월말 대차대조표) 상의 자기자본 및 부채총액을 이용하여 산출한다. 이 경우 전자화폐 · 선불전자지급수단의 미상환잔액 및 전자자금이체 · 전자지급결제대행 · 결제대금예치 · 전자고지결제 · 「정보통신망 이용촉진 및 정보보호 등에 관한 법률」 제2조제10호에 따른 통신과금서비스 등의 업무를 영위하는 자가 이용자와의 거래 관계에서 일시 보관하는 금액(이하 "미정산 잔액"이라 한다)은 부채총액에서 차감한다.

③ 제1항에도 불구하고 다음 각 호의 요건을 모두 갖춘 신청인의 재무건전성 기준은 자기자본 대비 부채총액의 비율이 100분의 1500 이내일 것으로 한다.

1. 정부등이 자본금 · 출자총액 또는 기본재산의 100분의 10 이상을 소유하고 있거나 출자하고 있을 것
2. 신청인의 사업 수행이 곤란하게 되는 경우 정부등이 해당 사업을 인수할 것을 확약하는 등 그 사업의 연속성에 대하여 정부등이 보장하고 있을 것
3. 사업 개시 후 5년 이내 제1항의 재무건전성 기준을 충족하는 것을 내용으로 하는 실현가능한 재무구조개선계획을 수립하여 관련서류와 함께 제출할 것

④ 제1항에도 불구하고 시행령 제18조제2항제2호의 규정에 따른 신청인의 재무건전성 기준은 「항공사업법」 제8조제1항제3호에 따른 재무능력을 갖춘 것으로 한다.

⑤ 시행령 제22조의2제1항제4호에서 "금융위원회가 정하여 고시하는 재무건전성 기준"이란 제51조제1항제2호나목에 따른 부채비율을 말한다.

⑥ 시행령 제22조의4제1항에서 "금융위원회가 정하여 고시하는 재무건전성 기준"이란 제51조제1항제2호다목에 따른 부채비율을 말한다.

■ 감독규정은 법 및 시행령의 위임을 받아 재무건전성 기준을 구체적으로 정하고 있음

■ 해설

가) 재무건전성 요건

● 금융감독원의 검사 대상기관

- 「금융산업의 구조개선에 관한 법률」 제2조제1호의 금융회사*에 해당하는 기관(적기시정조치 적용 대상 금융회사)은 그 기관의 설립·운영 등에 관한 법령상 경영개선권고, 경영개선요구 또는 경영개선명령 등의 요건이 되는 재무기준에 해당하지 아니하여야 하며,

  * 은행, 중소기업은행, 투자매매업자 · 투자중개업자, 집합투자업자, 투자자문업자·투자일임업자, 보험회사, 상호저축은행, 신탁업자, 종금사, 금융지주회사, 여신전문금융회사, 주택저당채권유동화회사

- 「금융산업의 구조개선에 관한 법률」 제2조제1호의 금융회사에 해당하지 않는 기관(적기시정조치 미적용 대상 금융회사)은 자기자본 대비 부채총액의 비율이 200% 이내이어야 함

  다만, 적기시정조치 대상이 아닌 금융회사에 대해, 금융위가 승인하는 경우 동 부채비율(200% 이내)을 적용하지 않고 해당 금융회사의 설립, 운영 등에 관한 법률에 따라 산출한 재무비율이 동법상의 적기시정조치 기준에 해당하지 않으면 재무건전성 요건은 충족한 것으로 간주

● 검사 대상기관이 아닌 경우

- 허가대상 전자금융업(전자화폐의 발행 및 관리업)의 경우 부채비율이 180%이내이어야 하고, 그 외 등록대상 전자금융업의 경우 부채비율이 200%이내이어야 함

나) 부채비율에 관한 특례

● 정부 관련 사업에 있어 이용자 보호 및 거래안전 확보를 위한 다음 요건을 모두 갖춘 경우 부채비율이 1,500%이하이면 등록을 허용

- 정부 등(지자체 포함)이 자본금·출자총액 또는 기본재산의 100분의 10 이상을 소유하고 있거나 출자하고 있을 것

- 신청인의 사업 수행이 곤란하게 되는 경우 정부 등이 해당 사업을 인수할 것을 확약하는 등 그 사업의 연속성에 대하여 정부 등이 보장하고 있을 것

- 사업 개시 후 5년 이내 해당 전자금융업이 요구하고 있는 재무건전성 기준을 충족하는 것을 내용으로 하는 실현가능한 재무구조개선계획을 수립하여 관련서류와 함께 제출할 것

다) 부채비율의 산정방식 및 산정시점

● 산정방식

- 부채비율은 자기자본(기본재산 또는 출자총액) 대비 부채총액으로서, 전자화폐·선불전자지급수단의 미상환잔액 및 전자자금이체·전자지불결제대행·결제대금예치·전자고지결제 등의 업무를 영위하는 자가 이용자와의 거래 관계에서 일시 보관하는 금액은 부채총액에서 차감하여 산정

● 산정시점

- 원칙적으로 신청일이 속하는 사업연도의 직전 사업연도말 대차대조표를 기준으로 하되, 신청일 최근 분기말 대차대조표(또는 재무상태표, 이하 동일)도 사용할 수 있으며, 회계법인의 확인을 받은 경우 신청일 최근 월말 대차대조표를 기준으로 할 수 있음

4. 사업계획에 관한 요건

감독규정

제52조(사업계획에 관한 요건) 법 제28조에 따라 허가를 받고자 하는 자의 사업계획은 다음 각 호의 요건을 모두 갖추어야 한다.

1. 영업개시 후 3년간 추정재무제표 및 수익전망이 전자화폐 내지 선불전자지급수단 발행업계의 과거 수익상황 등에 비추어 타당성이 있고 그 내용이 해당 신청회사의 영업계획에 부합할 것
2. 전자화폐 발행업을 원활히 영위하는데 필요한 이용자 확보계획이 구체적이고 타당하며 실현가능성이 있을 것
3. 영위하고자 하는 영업의 내용이 법령에 위반되지 아니하고 투자자보호나 건전한 금융질서를 저해할 우려가 없을 것

■ 허가대상 업무인 전자화폐의 발행 및 관리업의 경우 이용자 보호 필요성에 따라 업무의 연속성, 안정성을 확보할 수 있는 보장 장치가 필요한 바, 허가시 사업계획에 관해 신청인의 수익전망, 이용자 확보 계획 및 투자자 보호 가능성에 대한 심사를 의무화

■ 해설

● 사업계획에 관한 요건

- 영업개시 후 3년간 추정재무제표 및 수익전망이 전자화폐 내지 선불전자지급수단 발행업계의 과거 수익상황 등에 비추어 타당성이 있고 그 내용이 해당 신청회사의 영업계획에 부합할 것
- 전자화폐 발행업을 원활히 영위하는데 필요한 이용자 확보계획이 구체적이고 타당하며 실현가능성이 있을 것
- 영위하고자 하는 영업의 내용이 법령에 위반되지 아니하고 투자자보호나 건전한 금융질서를 저해할 우려가 없을 것

5. 주요출자자에 관한 요건

감독규정

제53조(주요출자자에 관한 요건) 주요출자자(시행령 제18조제3항에 따른 주요출자자를 말한다)는 〈별표 4〉에서 정한 요건을 충족하여야 한다.

6. 허가 및 등록신청 결격자

감독규정

제54조(허가 및 등록신청 결격자) 법 제32조제4호의 규정에서 "금융위원회가 정하는 자"라 함은 「신용정보의 이용 및 보호에 관한 법률」 제25조 제2항 제1호의 종합신용정보집중기관에 다음 각호 중 어느 하나의 신용정보가 등록된 자를 말한다.

1. 어음 · 수표 거래정지처분 또는 부도거래정보
2. 대출금 등의 용도 외 유용 사실
3. 부정한 방법으로 대출을 받는 등 금융거래질서를 문란하게 한 사실

■ 전자금융업 허가·등록을 신청하려는 자가 신용정보법상 연체정보·금융질서문란정보 등이 기록되어 있는 경우 허가등록신청 결격사유로 처리하고 있음

■ 해설

● '약정한 기일 내에 채무를 변제하지 아니한 자'라 함은 종합신용정보집중기관에 "신용판단정보"*등이 기록된 자를 말함

* 1) 대출금 등의 연체 내용 2) 대위변제 · 대지급 발생 사실, 3) 어음 또는 수표의 거래정지처분을 받은 사실, 4) 대출금등을 용도 외로 유용한 사실 및 부정한 방법으로 대출을 받는 등 신용질서를 문란하게 한 사실 등을 의미함

※ 신용정보의 이용 및 보호에 관한 법률 시행령 (별표 2) 참조

종합신용정보집중기관을 통하여 집중관리 · 활용되는 신용정보의 범위 〈별표2〉

(신용정보의 이용 및 보호에 관한 법률 시행령 제21조제3항 관련)

1. 개인

구분	집중관리 · 활용 대상 정보
가. 식별정보	성명 및 개인식별번호
나. 신용거래정보	1) 대출 · 당좌거래 등에 관한 거래정보로서 다음 가)부터 다)까지의 정보 가) 대출 현황(신청, 심사 사실 및 대출 약정의 이행 현황을 포함한다) 나) 당좌예금 · 가계당좌예금의 개설 및 해지 사실 다) 담보 및 채무보증 현황 2) 신용카드에 관한 거래정보로서 다음 가)부터 다)까지의 정보 가) 신용카드의 발급 · 해지 사실 및 결제 · 미결제 금액 나) 2개 이상의 신용카드를 소지한 신용정보주체의 신용카드 이용금액, 이용한도, 신용카드에 의한 현금융통한도 다) 신용카드의 분실 · 도난 등 사고 발생, 그 발생한 사고 종결에 따른 보상, 그 밖의 사고 종결의 처리 사실 3) 보험상품에 관한 거래정보로서 다음 가) 및 나)의 구분에 따른 정보. 이 경우 보험계약자가 기업, 법인 및 단체인 경우에도 피보험자 또는 보험금청구권자(보험수익자, 피보험자 또는 손해보험계약의 제3자 등으로서 보험금을 청구할 권리가 있는 자를 말한다. 이하 같다)가 개인인 경우에는 그 보험상품을 포함한다. 가) 보험계약의 체결에 관한 정보: 보험계약 현황, 보험계약의 피보험자 또는 보험금청구권자에 관한 정보(성명, 개인식별번호, 직업 및 보험계약자와의 관계에 관한 정보를 말한다) 및 해당 보험계약을 모집한 모집업무수탁자에 관한 정보 나) 보험금의 청구 및 지급에 관한 정보: 보험금의 청구 · 지급 현황, 보험금의 지급 사유(질병에 관한 정보, 손해보험계약에 따른 보험목적에 생긴 손해 사실, 그 밖의 보험사고에 관한 정보를 포함한다), 보험금청구권자(책임보험계약에 따라 손해를 보상받는 피해자를 포함한다)에 관한 정보(성명, 개인식별번호, 피보험자와의 관계에 관한 정보를 말한다)
다. 신용도판단정보 등	1) 대출금, 신용카드 대금, 시설대여 이용료 등의 연체 사실 2) 대위변제 · 대지급 발생 사실 3) 어음 · 수표의 거래정지처분을 받은 사실 및 그 부도 사실 4) 증권의 투자매매업 · 투자중개업에 관한 정보로서 다음 가) 및 나)의 정보 가) 증권시장에 상장된 증권의 매매와 관련하여 투자중개업자에게 매수대금 또는 매도증권을 결제일까지 납입하지 아니한 사실 나) 증권시장에 상장된 증권의 매매를 위하여 투자자에게 제공하는 매수대금의 융자 또는 매도증권의 대여 거래에 관한 정보로서 상환 또는 납입기일까지 그 거래에 따른 채무를 이행하지 아니한 사실

구분	집중관리 · 활용 대상 정보
	5) 금융질서 문란 정보로서 다음 가)부터 라)까지의 정보 가) 대출금 등을 용도 외로 유용한 사실 및 부정한 방법으로 대출을 받는 등 신용질서를 문란하게 한 사실 나) 거짓이나 그 밖의 부정한 방법으로 신용카드를 발급받거나 사용한 사실 다) 보험사기 사실 라) 그 밖에 가)부터 다)까지의 사실과 비슷한 것으로서 금융질서를 문란하게 한 사실 6) 공공기관이 만들어 낸 정보로서 다음 가)부터 마)까지의 정보 가) 법원의 회생 · 간이회생 · 개인회생과 관련된 결정, 파산선고 · 면책 · 복권과 관련된 결정, 채무불이행자명부의 등재 · 말소 결정, 성년후견 · 한정후견 · 특정후견과 관련된 심판을 받은 사실 나) 국세 · 지방세 · 관세 또는 국가채권과 벌금 · 과태료 · 과징금 · 추징금 등의 체납 관련 정보 및 임금 체불정보 다) 사회보험료 · 공공요금 또는 수수료 등 관련 정보 라) 주민등록 관련 정보로서 출생 · 사망 · 이민 · 부재에 관한 정보, 주민등록번호 · 성명의 변경 등에 관한 정보 마) 다른 법령에 따라 국가, 지방자치단체 또는 공공기관으로부터 받은 행정처분에 관한 정보 중에서 금융거래 등 상거래와 관련된 정보
라. 신용거래능력 판단정보	개인의 소득 총액과 관련된 정보(직장직업 정보, 연소득정보, 연소득추정정보 및 주거형태 등에 관한 정보를 말한다)

2. 기업 및 법인

구분	집중관리 · 활용 대상 정보
가. 식별정보	기업 및 법인의 상호 및 명칭, 사업자등록번호, 법인등록번호 및 고유번호, 본점 · 영업소 및 기관의 소재지, 종목, 대표자의 성명 · 개인식별번호
나. 신용거래정보	1) 대출 · 당좌거래 등에 관한 거래정보로서 다음 가)부터 사)까지의 정보 가) 대출 · 지급보증 등 신용공여 현황 나) 시설대여 현황 다) 신용보증 현황 라) 보증보험 현황 마) 담보(동산 담보를 포함한다) 및 채무보증 현황 바) 당좌예금 · 가계당좌예금의 개설 및 해지 사실 사) 가)부터 바)까지의 정보로서 해당 기업 및 법인의 기술과 관련된 기술성 · 시장성 · 사업성 등을 종합적으로 평가함으로써 만들어진 정보 2) 신용카드에 관한 거래정보로서 다음 가) 및 나)의 정보

구분	집중관리 · 활용 대상 정보
	가) 신용카드의 발급 · 해지 사실 및 이용 · 결제 · 미결제 금액(결제금액은 해당 신용정보를 보유한 신용카드업자가 동의하는 경우만 해당한다) 나) 신용카드의 분실 · 도난 등 사고 발생, 그 발생한 사고 종결에 따른 보상, 그 밖의 사고 종결의 처리 사실
다. 신용도판단정보(제2조 제1항제3호 각 목의 어느 하나에 해당하는 자의 정보도 포함한다)	1) 기업 및 법인의 신용도 판단 정보로서 다음 가)부터 바)까지의 정보 가) 대출금, 신용카드 자금, 시설대여 이용료 등의 연체 사실 나) 대위변제 · 대지급 발생 사실 다) 신용보증기금이 대위변제한 사실 라) 어음 · 수표의 거래정지처분을 받은 사실 및 그 부도 사실 마) 무보증사채의 상환불이행 사실 바) 가)부터 마)까지의 정보로서 해당 기업 및 법인의 기술과 관련된 기술성 · 시장성 · 사업성 등을 종합적으로 평가함으로써 이루어진 대출, 신용보증 등에 대하여 연체, 대위변제 등이 발생한 사실 2) 증권의 투자매매업 · 투자중개업에 관한 정보로서 다음 가) 및 나)의 정보 가) 증권시장에 상장된 증권의 매매와 관련하여 투자중개업자에게 매수대금 또는 매도증권을 결제일까지 납입하지 아니한 사실 나) 증권시장에 상장된 증권의 매매를 위하여 투자자에게 제공하는 매수대금의 융자 또는 매도증권의 대여 거래에 관한 정보로서 상환 또는 납입기일까지 그 거래에 따른 채무를 이행하지 아니한 사실 3) 금융질서 문란 정보로서 다음 가)부터 라)까지의 정보 가) 대출금 등을 용도 외로 유용한 사실 및 부정한 방법으로 대출을 받는 등 신용질서를 문란하게 한 사실 나) 거짓이나 그 밖의 부정한 방법으로 신용카드를 발급받거나 사용한 사실 다) 보험사기 사실 라) 그 밖에 가)부터 다)까지의 사실과 비슷한 것으로서 금융질서를 문란하게 한 사실 4) 공공기관이 만들어 낸 정보로서 다음 가)부터 마)까지의 정보 가) 법원의 회생 · 간이회생 · 개인회생과 관련된 결정, 파산선고 · 면책 · 복권과 관련된 결정, 채무불이행자명부의 등재 · 말소 결정 사실 나) 국세 · 지방세 · 관세 또는 국가채권과 벌금 · 과태료 · 과징금 · 추징금 등의 체납 관련 정보 및 임금체불정보 다) 사회보험료 · 공공요금 또는 수수료 등 관련 정보 라) 주민등록 관련 정보로서 출생 · 사망 · 이민 · 부재에 관한 정보, 주민등록번호 · 성명의 변경 등에 관한 정보 마) 다른 법령에 따라 국가, 지방자치단체 또는 공공기관으로부터 받은 행정처분에 관한 정보 중에서 금융거래 등 상거래와 관련된 정보

구분	집중관리 · 활용 대상 정보
라. 신용거래능력 판단정보 등	1) 계열기업체 현황 등 회사의 개황 2) 사업의 내용 3) 재무제표 등 재무에 관한 사항 4) 자본금 증자 및 사채 발행 현황 5) 기업의 영업에 관한 정보로서 다음 가) 및 나)의 정보 가) 정부조달 실적 또는 수출 · 수입액 등의 관련 정보 나) 기술신용정보 및 이와 관련된 신용정보 6) 기업등록 관련 정보로서 설립, 휴업 · 폐업, 양도 · 양수, 분할 · 합병, 주식 또는 지분 변동 등에 관한 정보 7) 동산담보정보 및 이와 관련된 신용정보

7. 신청에 따른 등록말소 및 이용자보호조치

감독규정

제55조(신청에 따른 등록말소 및 이용자 보호조치) ① 법 제34조에 따라 등록의 말소를 신청하고자 하는 전자금융업자는 〈별지 제6호 서식〉에 따른 등록말소신청서를 금융위원회에 제출하여야 한다.

② 법 제34조에 따라 등록의 말소를 신청하고자 하는 전자금융업자는 신청 이전에 이용자 보호조치 계획을 금융위원회에 제출하여야 한다.

③ 금융위원회는 제1항의 전자금융업자가 제출한 계획이 이용자 보호에 충분하지 않은 경우에 그 보완을 요구할 수 있다.

■ 전자금융업자의 등록 말소로 인한 이용자의 피해를 방지하기 위해 전자금융업자는 등록말소 신청 이전에 이용자 보호조치 계획을 금융위에 제출하여야 함

■ 해설

- 금융위에 제출된 이용자 보호조치 계획이 이용자 보호에 충분하지 않을 경우 금융위는 보완을 요구할 수 있으며,
- 동 요구사항이 충분히 이행되지 않을 경우 전자금융업자에 대한 등록 말소는 완료될 수 없음

※ 업자가 자기의사에 따라 전자금융업을 폐지하려는 등록말소와 달리 등록취소는 일정한 요건*에 해당될 경우 업자의 의사와 상관없이 감독당국이 취하는 행정행위를 말함

* 법 제43조 제1항 제1호~제5호에 해당하는 경우

제3절 전자금융업의 업무

1. 전자화폐 발행업자의 겸업가능 업무

감독규정

제56조(전자화폐 발행업자의 겸업가능 업무) 시행령 제22조제1항제3호에서 "금융위원회가 정하여 고시하는 업무"란 다음 각 호의 어느 하나에 해당하는 업무를 말한다.

1. 전자화폐 발행 및 관리를 위한 가맹점의 모집
2. 전자화폐 발행 및 관리를 위한 인터넷 홈페이지의 운영 및 이를 통한 통신판매 중개

감독규정에서 전자화폐발행업자가 겸업가능한 업무의 범위를 정함

해설

- 전자화폐발행업자는 원칙적으로 겸업이 금지됨
- 겸업이 허용되는 업무
  - 등록 대상 전자금융업무(등록을 전제)
  - 전자금융업과 관련된 정보처리시스템 및 소프트웨어의 개발·판매·대여
  - 금융회사 및 전자금융업자를 위한 전자금융업무의 일부 대행
  - 전자화폐 발행 및 관리를 위한 가맹점의 모집
  - 전자화폐 발행 및 관리를 위한 인터넷 홈페이지의 운영 및 이를 통한 통신판매 중개

2. 선불업자의 소액후불결제업무 겸영

감독규정

제56조의3(소액후불결제업무 겸영의 승인신청) 법 제35조의2제1항의 규정에 따라 승인을 받으려는 선불업자가 금융위원회에 제출하여야 하는 승인신청서는 〈별지 제8호 서식〉에 따른다.

선불업자는 금융위의 승인을 얻어 소액후불결제업무를 겸영할 수 있음

해설

- 선불업자는 겸영요건을 갖추어 신청서를 제출하여야하며, 겸영승인 신청업자의 승인요건에 대하여 평가위원회 등을 개최하여 심사

3. 수수료 및 준수사항 등의 고지방법

감독규정

제57조(수수료 및 준수사항 등의 고지방법) 법 제38조제3항 각 호의 사항은 다음 각 호의 방법 중 제1호의 방법을 포함한 둘 이상의 방법으로 가맹점에게 알려야 한다.

1. 가맹점에의 개별 통보
2. 전국적으로 보급되는 일간신문에의 공고
3. 해당 금융회사 또는 전자금융업자 영업장 및 인터넷 홈페이지에의 게시

제6장 전자금융업무의 감독

FSS
FINANCIAL SUPERVISORY
SERVICE

제6장 전자금융업무의 감독

1. 금융회사의 정보기술부문 실태평가

감독규정

제58조(금융회사의 정보기술부문 실태평가 등) ① 금융감독원장은 금융회사의 정보기술부문의 건전성 여부를 감독하여야 한다.

② 금융감독원장은 업무의 성격 및 규모, 정보기술부문에 대한 의존도 등을 감안하여 〈별표 5〉에 규정된 금융회사(이하 이 조에서 '은행등'이라 한다)에 대하여 검사를 통해 정보기술부문 운영 실태를 평가하고 그 결과를 경영실태평가 등 감독 및 검사업무에 반영하여야 한다.

③ 제2항에 의한 실태평가는 1등급(우수), 2등급(양호), 3등급(보통), 4등급(취약), 5등급(위험)의 5단계 등급으로 구분한다.

④ 금융감독원장은 제2항에 따른 정보기술부문 실태평가 결과 종합등급이 4등급인 경우에는 해당 은행등에게 이의 개선을 위한 확약서 제출을 요구할 수 있으며, 종합등급이 5등급이거나 직전 정보기술부문 실태평가 결과에 비해 평가등급이 2등급 이상 하향된 경우에는 취약점 개선대책의 수립 · 이행을 내용으로 하는 양해각서를 체결할 수 있다.

⑤ 제4항의 확약서는 대표자의 승인을 받아 제출하고, 양해각서는 해당 은행등의 이사회 재적이사 전원의 서명을 받아 체결한다.

⑥ 금융감독원장은 확약서 또는 양해각서의 이행상황을 점검하여 그 이행이 미흡하다고 판단되는 경우에는 확약서를 다시 제출받거나 양해각서를 다시 체결할 수 있다.

⑦ 확약서 또는 양해각서의 효력발생일자, 이행시한 및 이행상황 점검주기는 각 확약서 또는 양해각서에서 정한다. 다만, 이행상황 점검주기를 따로 정하지 않은 경우 은행등은 매분기 익월말까지 분기별 이행상황을 금융감독원장에게 보고하여야 한다.

⑧ 제2항에 따른 정보기술부문 실태평가 결과는 경영실태평가 세부 평가항목 중 경영관리 또는 위험관리 항목의 평가비중에서 최소 100분의 20 이상 반영되어야 하며, 금융감독원장은 정보기술부문 실태평가 결과가 4등급 이하인 은행등에 대해 경영실태평가 2등급 이상으로 평가할 수 없다.

⑨ 제2항에 의한 정보기술부문의 실태평가를 위한 세부 사항은 금융감독원장이 정한다.

시행세칙

제9조(정보기술부문 실태평가 방법 등) ① 규정 제58조에 따른 정보기술부문 실태평가는 검사기준일 현재 평가대상기관의 정보기술부문 실태를 IT감사, IT경영, 시스템 개발 · 도입 · 유지 보수, IT서비스 제공 및 지원, IT보안 및 정보보호의 부문별로 구분 평가하고 부문별 평가결과를 감안하여 종합평가한다.

② 제1항의 규정에 따른 부문별 세부 평가 항목은 별표 4와 같다.

③ 규정 제58조제3항의 평가등급별 정의는 별표 5와 같다.

■ 금융회사 정보기술부문 실태평가는 금융회사의 정보기술부문에 대하여 종합적이고 체계적인 평가기준으로 평가를 실시하고 일정한 등급을 산정함으로써 일반부문경영실태평가(CAMEL-IR 등)를 보완하고 나아가 금융회사의 정보기술부문 및 전자금융거래의 안전성을 확보하고 금융회사의 건전성을 제고하는데 의의가 있음

■ 해설

● 기본운용 방향

- 정보기술부문실태평가는 일반 업무검사와 분리하여 금융회사의 정보기술부문을 별도로 평가하는 독립평가체제임

- 정보기술부문실태평가는 정보기술분야의 전문성 및 특수성에 상응하는 평가기준('정보기술부문 실태평가용 체크리스트')에 의해 평가등급을 일반부문 경영실태평가결과와는 별개로 독립적으로 부여하고, 필요시에는 전산자회사 등의 정보기술부문 운영실태를 파악하기 위한 연결검사를 실시함

● 평가대상 금융회사

- 정보기술부문 실태평가는 일반업무의 성격 및 규모, 정보기술부문에 대한 의존도등에 비추어 정보기술부문 리스크가 높은 금융회사와 네트워크가 집중된 금융 유관기관 등을 대상으로 실시

  * 전자금융업자는 규정에서 정한 정보기술부문 실태평가 대상이 아님

- 정보기술부문 리스크가 높은 금융회사

  · 은 행 : 국내 시중은행, 지방은행, 특수은행

  · 증 권 : 국내 증권회사

  · 보 험 : 국내 생명보험사, 국내 손해보험사

  · 중 소 : 신용카드사, 자산 2조원 이상인 여신전문금융회사 및 상호저축은행

- 네트워크가 집중되어 있는 금융 유관기관

  · 증권 : 한국거래소, 한국예탁결제원, 증권금융회사

  · 보 험: 보험개발원

  · 중 소: 상호저축은행중앙회, 신협중앙회

  · 기 타: 신용정보집중기관

  ※ 금융감독원의 검사대상 금융회사 및 전자금융업자 중 정보기술부문실태평가대상에서 제외된 중소형 금융회사 및 전자금융업자의 경우에는 별도의 검사방법에 의거하여 수시검사를 실시함

● 평가부문 및 평가 항목

- 정보기술부문을 IT감사(Audit), IT경영(Management), 시스템 개발 · 도입 · 유지보수, IT서비스 제공 · 지원, IT 보안 및 정보보호의 5개 부문으로 분류하여 평가한 후, 이를 토대로 종합평가를 실시

- 위의 5개 부문에 대하여 총 25개의 평가항목을 설정하되 IT업무의 특성상 모두 비계량 지표를 기준으로 평가

〈정보기술부문 평가항목〉

평가 부문	평가 항목수(대분류)
IT감사	3
IT경영	6
시스템 개발 · 도입 · 유지보수	4
IT서비스 제공 및 지원	7
IT 보안 및 정보보호	5
계	25

● 평가 등급

- 개별 금융회사의 정보기술부문 실태평가는 절대평가방식으로 이루어지며, 세부항목평가, 부문별 평가, 종합등급평가 등 각 단계마다 1등급(우수), 2등급(양호), 3등급(보통), 4등급(취약), 5등급(위험)의 5단계로 구분하여 평가등급을 부여

● 가중치

- 각 부문별 평가항목 및 세부평가항목에 가중치는 부여하지 않으나, 검사반장이 각 부분별 등급평가 및 종합등급 평가시에 해당 금융회사의 업무형태, IT리스크 등을 반영하여 등급평가를 할 수 있도록 함으로써 해당 금융회사의 특수성을 평가에 반영할 수 있도록 함

● 평가 시기

- 금융회사에 대한 정보기술부문 실태평가는 IT검사부서의 독자적인 검사계획에 따라 실시하되, 원칙적으로 금융회사 관련 소관 검사부서의 본점 정기검사 시기에 맞추어 실시하여 정보기술부문 실태평가결과를 적기에 일반부문 경영실태평가에 반영할 수 있도록 함

- 다만, 다음과 같은 경우에는 정보기술부문 실태평가를 실시하기 위한 검사를 일반부문 정기검사 실시 시기보다 앞당기거나 늦추어 실시하는 등 탄력적으로 운영함

· 일반부문 정기검사가 특정 시기에 집중되어 IT검사부서의 인력 사정으로 금융회사 관련 소관 검사부서의 본점 정기검사 시기에 맞추어 검사를 실시하기 곤란한 경우

· 일반부문 정기검사와 IT검사를 동시에 실시하는 경우 피검사기관의 제한된 IT인력으로는 일반부문 검사요구자료 및 IT검사 수검자료 작성 등이 중복되어 수검 부담이 과중하다고 판단되는 경우 등

● 평가결과의 활용

- 종합평가가 1등급인 금융회사에 대해서는 향후 정보기술부문 실태평가를 위한 검사를 생략하거나, 검사를 실시하는 경우에도 검사기간을 단축하고, 검사범위를 축소하는 등 우대 조치함

- 종합평가가 2등급인 금융회사에 대해서는 향후 정보기술부문 실태평가시 검사기간을 단축하고 취약부문 위주의 수시검사를 실시함

- 종합평가가 3등급인 금융회사에 대해서는 전산부문 취약부문에 대해 자체적으로 개선계획을 수립·추진토록 하며, 이행 사항에 대하여 다음 검사시 중점 점검함

- 종합평가가 4등급인 금융회사에 대해서는 일반부문 경영실태평가등급 산정시 IT취약분야를 적극 반영토록 하고, 필요시 약정서를 요구하거나 양해각서를 체결할 수 있으며, 향후 정보기술부문 실태평가시 검사기간을 확대할 수 있음

- 종합평가가 5등급인 금융회사에 대해서는 해당 취약부문 또는 전체전산업무에 대하여 즉각 개선토록 조치하고, 일반부문 경영실태 평가등급의 하향조정 등을 해당 검사국에 요청

· 정보기술부문실태평가 및 취약분야에 대한 검사를 타 금융회사에 최우선하여 실시하고, 필요시에는 약정서를 요구하거나 양해각서를 체결할 수 있음

〈정보기술부문 실태평가 부문별 평가항목〉

평가 부문	평가 항목
1. IT 감사	- IT감사조직 및 요원 - IT감사 실시 내용 - IT감사 사후관리 및 기타
2. IT 경영	- IT부서 조직 및 요원 - IT관련 내규(규정, 지침, 절차, 편람 등) - IT계획 및 방향제시 - 비상계획 - 경영정보시스템(MIS) - IT 인력 및 예산의 적정성
3. 시스템 개발, 도입 및 유지보수	- 시스템 개발, 도입 및 유지보수 관련 조직 및 요원 - 시스템 개발, 도입 및 유지보수 관련 내규(규정, 지침, 절차 등) - 시스템 개발, 도입, 유지보수 현황 - 내부통제용 시스템, 시스템통합 등
4. IT서비스 제공 및 지원	- IT서비스 제공/지원 관련 조직 및 요원 - IT서비스 제공/지원 관련 내규(규정, 지침, 절차 등) - 시설 및 장비 - 운영통제 - 통신망 - 최종사용자컴퓨팅 - 전자금융거래 등
5. IT 보안 및 정보보호	- IT 보안 절차 - IT 보안 리스크 평가 - IT 보안 및 정보보호전략 - IT 보안 통제 구현 - IT 보안 모니터링

2. 외부주문등에 대한 기준

감독규정

제60조(외부주문등에 대한 기준) ① 금융회사 또는 전자금융업자는 전자금융거래를 위한 외부주문 등의 경우에는 다음 각 호의 사항을 준수하여야 한다.

1. 외부주문 등에 의한 정보처리시스템의 개발업무에 사용되는 업무장소 및 전산설비는 내부 업무용과 분리하여 설치 · 운영
2. 금융회사와 이용자 간 암호화정보 해독 및 원장 등 중요 데이터 변경 금지
3. 계좌번호, 비밀번호 등 이용자 금융정보 무단보관 및 유출 금지
4. 접근매체 위 · 변조, 해킹, 개인정보유출 등에 대비한 보안대책 수립
5. 금융회사와 전자금융보조업자 간의 접속은 전용회선(전용회선과 동등한 보안수준을 갖춘 가상의 전용회선을 포함한다)을 사용
6. 정보처리시스템 장애 등 서비스 중단에 대비한 비상대책 수립
7. 외부주문등의 입찰 · 계약 · 수행 · 완료 등 각 단계별로 금융감독원장이 정하는 보안관리방안을 따를 것
8. 업무지속성을 위한 중요 전산자료의 백업(backup)자료 보존 및 백업설비 확보 등 백업대책 수립
9. 정보관리의 취약점을 최소화하고 보안유지를 위한 내부통제방안을 수립 · 운용하고, 통제는 제8조제1항제2호의 조직에서 수행
10. 전자금융보조업자에 대한 재무건전성을 연1회 이상 평가하여 재무상태 악화에 따른 도산에 대비하고 전자금융보조업자의 주요 경영활동에 대해 상시 모니터링을 실시
11. 전자금융보조업자가 제공하는 서비스의 품질수준을 연1회 이상 평가할 것
12. 전자금융보조업자가 사전 동의 없이 다시 외부주문등 계약을 체결하거나 계약업체를 변경하지 못하도록 하고, 사전 동의시 해당 계약서에 제7호의 사항을 기재하도록 통제
13. 업무수행인력에 대하여 사전 신원조회 실시(이 경우 신원보증보험 증권 징구로 갈음할 수 있다) 또는 대표자의 신원보증서 징구, 인력변경시 인수인계에 관한 사항 등을 포함한 업무수행인력 관리방안 수립
14. 외부주문등은 자체 보안성검토 및 정기(금융감독원장이 정하는 중요 점검사항에 대해서는 매일) 보안점검 실시

② 금융회사 또는 전자금융업자는 제1항제10호 및 제11호의 평가결과를 금융감독원장에게 보고하여야 한다.

③ 금융감독원장은 제2항의 규정에 따른 평가결과 보고를 접수하고, 그 평가실시 여부를 제58조제2항의 규정에 따른 정보기술부문 실태평가에 반영할 수 있다.

④ 법 제40조제6항 단서에서 "금융위원회가 인정하는 경우"란 전자금융거래정보의 보호와 관련된 전산장비 · 소프트웨어에 대한 개발 · 운영 및 유지관리 업무를 재위탁하는 경우로서 다음 각 호의 사항을 준수하는 경우를 말한다.

1. 재수탁업자가 재위탁된 업무를 처리함에 있어 금융거래 정보의 변경이 필요한 경우에는 위탁회사 또는 원수탁업자의 개별적 지시에 따라야 하며, 위탁회사 또는 원수탁업자는 변경된 정보가 지시 내용에 부합하는지 여부를 확인하여야 함
2. 위탁업무와 관련된 이용자의 금융거래정보는 위탁회사의 전산실 내에 두어야 함. 다만, 재수탁업자가 이용자의 이용자 정보를 어떠한 경우에도 알지 못하도록 위탁회사 또는 원수탁업자가 금융거래정보를 처리하여 제공한 경우에는 위탁회사의 관리 · 통제 하에 재수탁회사 등 제3의 장소로 이전 가능함

⑤ 금융회사 또는 전자금융업자는 제14조의2제1항제2호에 따른 평가를 위하여 제37조의6제1항 각 호의 어느 하나에 해당하는 기관에 지원을 요청할 수 있다.

시행세칙

제9조의2(외부주문등에 대한 기준) ① 규정 제60조제1항제7호에 따라 감독원장이 정하는 보안관리방안은 별표 5-2와 같다.

② 규정 제60조제1항제14호에 따라 감독원장이 정하는 중요 점검사항은 별표 5-3과 같다.

※ 관계 법령

법

제40조(외부주문등에 대한 감독 및 검사) ① 금융회사 및 전자금융업자는 전자금융거래와 관련하여 전자금융보조업자와 제휴, 위탁 또는 외부주문(이하 이 조에서 "외부주문등"이라 한다)에 관한 계약을 체결하거나 변경하는 때(전자금융보조업자가 다른 전자금융보조업자와 외부주문등에 관한 계약을 체결하거나 변경하는 때를 포함한다)에는 전자금융거래의 안전성 및 신뢰성과 금융회사 및 전자금융업자의 건전성을 확보할 수 있도록 금융위원회가 정하는 기준을 준수하여야 한다.

② 금융위원회는 제1항의 규정에 따른 계약 내용이 금융회사 또는 전자금융업자의 경영의 건전성 및 이용자의 권익을 침해하는 것이라고 인정하는 때에는 그 금융회사 또는 전자금융업자에 대하여 관련 계약 내용의 시정 또는 보완을 지시할 수 있다.

③ 금융감독원장은 제1항의 규정에 따른 외부주문등과 관련하여 금융회사 또는 전자금융업자에 대한 검사를 하는 경우에는 금융위원회가 정하는 기준에 따라 그 전자금융보조업자에 대한 자료제출을 요구할 수 있다.

④ 금융감독원장은 전자금융보조업자가 제3항에 따른 자료를 제출하지 아니하거나 부실한 자료를 제출한 경우에는 해당 전자금융보조업자에 대하여 조사를 할 수 있다.

⑤ 금융감독원장은 제4항에 따른 조사를 위하여 필요하다고 인정하는 경우에는 전자금융보조업자에게 다음 각 호의 사항을 요구할 수 있다.

1. 조사사항에 관한 진술서의 제출
2. 조사에 필요한 장부 · 서류, 그 밖의 물건의 제출
3. 관계인의 출석

⑥ 정보기술부문의 정보보호와 관련된 업무를 위탁받은 전자금융보조업자는 해당 업무를 제3자에게 재위탁하여서는 아니 된다. 다만, 전자금융거래정보의 보호 및 안전한 처리를 저해하지 아니하는 범위에서 금융위원회가 인정하는 경우에는 그러하지 아니하다.

⑦ 제4항에 따른 조사에 관하여는 제39조제4항을 준용한다.

- 금융회사 및 전자금융업자는 전자금융거래와 관련 전자금융보조업자와 제휴, 위탁 또는 외부주문(이하 "외부주문등")에 관한 계약을 체결하거나 변경하는 때 전자금융거래의 안전성 및 신뢰성과 금융회사 및 전자금융업자의 건전성을 확보할 수 있도록 금융위가 정하는 기준 준수(법 제40조)

- 금융회사 또는 전자금융업자가 IT업무의 전부 또는 일부를 전자금융보조업자와 외부주문등을 하는 경우, 동 외부주문 등으로 인한 고객정보 유출 및 정보처리시스템의 장애등의 방지를 위하여 관련기준을 정함

해설

- 금융회사의 핵심업무가 외부업체에 종속되지 않도록 필요최소조건을 마련하여 관련 리스크를 최소화할 필요
- 전자금융거래와 연관성이 없는 업무(예: 회계법인, 법무법인, 보안컨설팅, 정보보호인증, 개인정보 영향평가 등)는 전자금융거래를 위한 외부주문 등에 포함되지 않음(법령해석 160855)
- 정보처리시스템의 설치 장소에 대한 통제와 관련해서는 규정 제9조 내지 제11조를 준수
- 정보처리시스템에 대한 유지보수를 위해 상주하는 인력(SM, System Maintenance)의 경우, 개발업무를 수행하지 않고 정보처리시스템의 기반시설 및 자원 운영업무를 외부주문하는 경우에는 외부주문등에 의한 정보처리시스템의 개발업무에 해당하지 않음(법령해석 150144, 240033)
  - 다만, 해당 인력이 일부 개발업무를 병행할 경우에는 개발업무를 수행하는 것으로 보아야 하며 개발업무에 사용되는 전산설비를 내부업무용과 분리하여야 하므로 정보보호최고책임자의 승인을 통해 별도의 공간에 업무망과 분리된 전용단말기를 설치하고 비인가 접근 및 변경 위험 방지 등의 철저한 단말기 보안관리를 적용하는 등의 조치를 실시하여 사고등을 방지하고 및 책임을 명확히 하여야 함(비조치의견서 170001, 법령해석 150308, 150003).
- 외부주문업체에 의한 컴퓨터 기록 또는 통신상 자료의 유출방지와 유출되더라도 그 내용을 확인할 수 없도록 중요 자료를 암호화하여 보관하여야 함(제3호, 제4호)
- 외부주문업체는 계약서상 사용하도록 인정된 사항 이외의 금융회사 또는 전자금융업자의 정보를 임의로 사용하거나 공개하지 못함(규정제60조)
- 불가피하게 이용자 정보 등이 필요한 경우 규정 제13조(전산자료 보호대책) 준수(예시1 : 테스트 시 이용자 정보를 변환하여 사용하고 테스트 종료시 즉시 삭제, 예시2: 이용자정보 조회시 사용자, 사용일시, 변경·조회 내용, 접속방법이 정보처리시스템에 자동적으로 기록되도록 하고 그 기록을 1년 이상 보존)
- 외부주문업체가 자료의 생성, 전송, 처리, 유지 및 저장되는 동안에 물리적 또는 논리적 통제절차를 통해 비인자의 접근, 수정, 파괴 정보의 공개 등을 방지하도록 물리적·논리적 보안 대책을 수립(제4호)
- 금융회사는 제휴 또는 외부주문업체와의 접속은 전용회선(물리적 전용회선에 준하는 VPN방식 포함)을 이용(제5호)
  - 금융회사와 전자금융보조업자 간의 접속은 전용회선(전용회선과 동등한 보안수준을 갖춘 가상의 전용회선을 포함한다)을 사용하여야 하며, 인터넷을 통한 SSL(Secure Sockets Layer) 인증 방식은 이에 해당하지 않음(법령해석 230054)

- 외부주문업무의 화재, 홍수, 해킹 등 재난으로 인한 서비스 중단과 외부주문 업체의 도산으로 인한 서비스 중단으로 구분하여 형태별 비상대책을 수립하여야 함(제6호)
- 외부주문 계약 단계별로 금융감독원장이 정하는 보안관리방안을 준수해야 함(제7호, 시행세칙 제9조의2)

[전자금융감독규정시행세칙 <별표 5-2>] 보안관리방안

단계	세부사항
입찰	• 입찰 공고 이전에 투입이 예상되는 자료 · 장비 가운데 보안관리가 필요한 사항에 대하여 금융회사또는 전자금융업자의 내부관리기준과 관련 법규를 검토하고 필요한 보안요구 사항을 마련 • 입찰 공고시에 금융회사 또는 전자금융업자가 자체 작성한 중요정보, 부정당업자 제재조치, 기밀유지 의무 및 위반시 불이익 등을 정확히 공지 • 제안서 평가요소에 자료 · 장비 · 네트워크 보안대책 및 중요정보 관리 방안 등 보안관리 계획의 평가항목 및 배점기준 마련 • 업체가 입찰제안서에 제시한 용역사업 전반에 대한 보안관리 계획이 타당한지를 검토하여 사업자 선정시에 이를 반영
계약	• 계약서 작성 초기 단계부터 정보보안사항 포함여부에 대한 검토 실시 • 용역사업에 투입되는 자료 · 장비 등에 대해 대외보안이 필요한 경우 보안의 범위 · 책임을 명확히 하기 위해 사업수행 계약서와 별도로 비밀유지계약서 작성 • 비밀유지계약서에는 비밀정보의 범위, 보안준수 사항, 위반시 손해배상 책임, 지적재산권 문제, 자료의 반환 등이 포함되도록 명시 • 용역사업 참여인원은 금융회사 또는 전자금융업자의 사전 동의 없이 용역업체가 임의로 교체할 수 없도록 명시 • 금융회사 또는 전자금융업자의 요구사항을 사업자에게 명확히 전달키 위하여 작성하는 과업지시서 · 계약서(입찰 공고 포함)에 인원 · 장비 · 자료 등에 대한 보안조치 사항과 정보유출 및 부정당업자에 대한 손해배상 내용 등을 정확히 기술 • 용역업체가 사업에 대한 하도급 계약을 체결할 경우 원래 사업계약 수준의 비밀 유지 조항을 포함토록 조치 • 규정 제7조 각호에 규정한 사항의 준수를 위하여 외부주문업체 등의 협조가 요구되는 사항
수행	[인력] • 용역사업 참여인원에 대해서는 '정보 유출' 방지 조항 및 개인의 자필 서명이 들어간 보안서약서 징구 • 용역사업 수행前 참여인원에 대해 법적 또는 금융회사 또는 전자금융업자의 규정에 따른 비밀유지 의무 준수 및 위반시 처벌내용 등에 대한 보안교육 실시 * 유출 금지 대상정보 및 정보 유출시 부정당업자 제재조치 등에 대한 교육 병행 • 금융회사 또는 전자금융업자는 사업 수행 중 업체 인력에 대한 보안점검 실시, '유출금지 대상 정보' 외부 유출여부 확인 [자료] • 계약서 등에 명시한 중요정보를 업체에 제공할 경우 자료관리 대장을 작성, 인계자 · 인수자가 직접 서명한 후 제공하고 사업완료시 관련자료 회수

단계	세부사항
	• 용역사업 관련자료 및 사업과정에서 생산된 모든 산출물은 금융회사 또는 전자금융업자의 파일 서버에 저장하거나 금융회사 또는 전자금융업자가 지정한 PC에 저장 · 관리 • 용역사업 관련 자료는 인터넷 웹하드 · P2P 등 인터넷 자료공유사이트 및 개인메일함에 저장을 금지하고 금융회사 또는 전자금융업자와 용역업체간 전자우편을 이용해 전송이 필요한 경우에는 자체 전자우편을 이용하고, 첨부자료 중 중요정보 포함자료는 암호화 후 수발신 • 금융회사 또는 전자금융업자가 제공한 사무실에서 업체가 용역사업을 수행할 경우, 유출금지 대상 정보가 포함된 자료는 매일 퇴근시 시건장치가 된 보관함에 보관 • 용역사업 수행으로 생산되는 산출물 및 기록은 금융회사 또는 전자금융업자가 인가하지 않은 비인가자에게 제공 · 대여 · 열람을 금지 [사무실 · 장비] • 용역사업 수행장소는 금융회사 또는 전자금융업자 전산실 등 중요시설과 분리하고 CCTV · 시건장치 등 비인가자의 출입통제 대책을 마련 • 용역업무를 수행하는 공간에 대한 보안점검을 정기적으로 실시 • 용역직원이 노트북 등 관련 장비를 외부에서 반입하여 내부망에 접속시 악성코드 감염여부 및 반출시마다 자료 무단반출 여부 확인 • 인가받지 않은 USB메모리 등의 휴대용 저장매체 사용을 금지하며 산출물 저장을 위하여 휴대용 저장매체가 필요한 경우 금융회사 또는 전자금융업자의 승인하에 사용 [내 · 외부망 접근시] • 금융회사 또는 전자금융업자는 개발시스템과 운영시스템을 분리하고, 용역업체는 업무상 필요한 서버에만 제한적 접근 허용 • 용역사업 수행시 금융회사 또는 전자금융업자 전산망 이용이 필요한 경우 – 사업 참여인원에 대한 사용자계정(ID)은 하나의 그룹으로 등록하고 계정별로 정보시스템 접근권한을 차등 부여하되 허용되지 않은 금융회사 또는 전자금융업자의 내부문서 접근 금지 – 계정별로 부여된 접속권한은 불필요시 즉시 해지하거나 계정을 폐기 – 참여인원에게 부여한 계정은 별도로 기록 관리하고 수시로 해당 계정에 접속하여 저장된 자료와 작업이력 확인 – 금융회사 또는 전자금융업자는 내부서버 및 네트워크 장비에 대한 접근기록 이상 여부를 정기 점검 • 용역업체에서 사용하는 PC는 인터넷 연결을 금지하되, 사업수행상 연결이 필요한 경우에는 금융회사 또는 전자금융업자의 보안통제하에 제한적 허용 • 용역업체 사용 전산망에서 P2P, 웹하드 등 인터넷 자료공유사이트로의 접속을 원천 차단
완료	• 사업 완료 후 생산되는 최종 산출물 등 대외보안이 요구되는 자료는 대외비 이상으로 작성 · 관리하고 불필요한 자료는 삭제 및 폐기 • 용역업체에 제공한 자료, 장비와 중간 · 최종 산출물 등 용역과 관련된 제반자료는 전량 회수하고 업체에 복사본 등 별도 보관 금지 • 용역사업 완료 후 업체 소유 PC · 서버의 하드디스크 · 휴대용 저장매체 등 전자기록 저장매체는 복원이 불가능한 방법으로 완전 삭제 후 반출 • 용역사업 관련자료 회수 및 삭제조치 후 업체에게 복사본 등 용역사업관련 자료를 보유하고 있지 않다는 대표자 명의의 확약서 징구

- 업무연속성 확보를 위하여 고객 정보 및 금융거래정보를 포함한 주요 전산자료의 백업자료 보존 및 백업설비 확보 등 백업대책을 수립(제8호)
- 정보유출 방지를 위해 외부주문업체의 시스템개발 및 유지보수 정책이 내부 가이드라인 및 제약조건 등에 부합하는지 점검 필요(제9호)
- 전자금융보조업자에 대한 재무건전성 및 서비스품질수준을 연 1회 이상평가(제10호, 제11호)
- 외부주문업체와의 계약을 통하여 외부주문업체가 위탁자의 사전 동의 없이 제3자에게 외부주문 대상 업무를 재위탁하거나 재위탁업체를 변경하는 행위 금지(제12호)
  - 외부주문업체의 재위탁을 허용할 경우 재수탁자의 적격성 기준을 자체적으로 수립하여 운용
- 외부주문업체는 프로그램 등록·변경·폐기 방법, 변경 전·후 내용의 기록 및 관리·등록·변경·폐기 내용의 정당성에 대한 제3자 검증, 변경 필요시 복사 후 수정, 접근 담당자 한정 등에 대한 절차 수립·운영하여야 함(제13호)
- 외부주문 등은 자체보안성 검토 및 정기 보안점검 실시하며, 금융감독원장이 정하는 중요 점검사항은 매일 점검(제14호)

[전자금융감독규정시행세칙 <별표 5-3>] 중요 점검사항

	점검 항목
1	이용자 정보의 조회 · 출력에 대한 통제 및 이용자 정보 조회시 사용자, 사용일시, 변경 · 조회내역, 접속방법 기록 · 관리
2	테스트시 이용자 정보 사용금지(부하 테스트 등 사용이 불가피한 경우 이용자 정보를 변환하여 사용하고 테스트 종료 즉시 삭제)
3	운영시스템 접속 · 사용 통제
4	내부통신망의 비인가 전산장비 · 무선통신 접속 통제(정보처리시스템을 이용한 통제 장치 마련시 통제 장치에 대한 일일점검으로 대체 가능)
5	전산자료 및 전산장비 반출 · 반입 통제
6	전산실 등 출입자 관리기록부 기록 · 보관
7	인터넷(무선통신망 포함) 사용 통제(정보처리시스템을 이용한 통제 장치 마련시 통제장치에 대한 일일점검으로 대체 가능)
8	운영체제 및 악성코드 치료프로그램을 최신으로 유지
9	USB 등 보조기억매체 사용 통제
10	단말기에 이용자 정보 등 중요정보 보관 금지

■ 정보기술부문의 정보보호와 관련된 업무를 위탁받은 전자금융보조업자의 해당 업무는 원칙적으로 제3자에게 재위탁이 금지되나, 전자금융거래정보의 보호 및 안전한 처리를 저해하지 않는 범위에서 다음의 기준을 준수하는 경우에는 재위탁이 가능함(제4항)

● 정보보호 관련 업무는 전자금융거래의 안정성 확보 및 이용자 보호를 위한 업무로서 방화벽 운용, 시스템 모니터링 등 보안 인프라 운영과 취약점 분석평가, IT내부통제 관리 등의 업무를 포괄함(법령해석 200036)

- 재수탁업자가 재위탁된 업무를 처리함에 있어 금융거래 정보의 변경이 필요한 경우 위탁회사 또는 원수탁업자의 개별적 지시에 따라야 하고 위탁회사 또는 원수탁업자는 변경된 정보가 지시 내용에 부합하는지 여부를 확인하여야 함

- 위탁업무와 관련된 이용자의 금융거래정보는 위탁회사의 전산실 내에 둘 것(다만, 재수탁업자가 이용자의 이용자 정보를 어떠한 경우에도 알지 못하도록 위탁회사 또는 원수탁업자가 금융거래 정보를 처리하여 제공한 경우에는 위탁회사의 관리 · 통제 하에 재수탁회사 등 제3의 장소로 이전 가능)

※ 법령해석('15.3.12.)-150003

질의

(1) 외부주문등에 의한 정보처리시스템의 개발업무에 사용되는 업무장소와 내부업무장소를 분리하는 경우, 그 분리의 정도 ① 부서를 구분하여 표시하거나 파티션으로 구획하는 등 외부에서 인지가능한 정도로만 분리 ② 칸막이 등을 이용하여 공간을 바닥부터 천장까지 분리 ③ 별도의 공간으로 분리(다른 층 또는 다른 출입문 이용)

회신

(1) 외부주문시 정보시스템 개발업무에 필요한 인적·물적 시설은 칸막이, 별도 공간 등 외부에서 인지 가능한 수준으로 분리하여 운영하여야 합니다. (2) 개발에 사용되는 정보시스템과 통신망은 운영시스템과 물리적으로 분리하여 운영시스템에 대한 비인가자의 접근을 원천적으로 차단하여야 합니다. (3) 또한, 물리적 분리 이외에 관리통제가 엄격하게 이루어지도록 정보시스템 접근 통제, 인적통제 등 내부통제장치가 마련되어야 합니다.

이유

(1) 외부주문에 의한 정보시스템 개발업무에 사용되는 공간은 내부업무장소와 칸막이, 별도공간으로 분리하여 운영하도록 함으로써 중요정보 유출, 부주의, 관리소홀로 인한 사고 등을 방지하고 이에 따른 책임을 명확히 하기 위함입니다.

(2) 외부 주문에 의한 정보시스템 개발시 개발업무에 사용되는 정보시스템 및 통신망은 운영시스템과 물리적으로 분리하여 운영되어야 하며, 이는 보안 취약요인을 사전에 차단하고 보안이 취약한 개발시스템으로 부터 운영시스템으로의 악성코드 전이, 접근통로 이용 등을 원천적으로 차단하여 운영시스템을 안전하게 보호하기 위함입니다.

(3) 또한, 업무장소와 전산설비를 내부 업무용과 분리하여 설치·운영함에 있어서 물리적 분리의 실효성을 확보하기 위하여 접근통제, 인적통제, 출입통제 등 관리통제가 엄격하게 이루어지도록 내부통제 장치를 마련하여 운영하여야 합니다.

※ 법령해석('15.4.28.)-150011

질의

- 정보기술부문의 정보보호와 관련 업무를 위탁 받은 전자금융보조업자가 해당 업무를 제3자에게 재위탁할 수 있는 범위
  * (사실관계) 금융회사가 보안업무의 일부를 전산업체에게 위탁하였고, 해당 전산업체는 수탁 보안업무의 일부를 재위탁하여 운영 하고 있음. 재수탁업자의 수행업무는 보안토큰 및 방화벽 운영, 네트워크 트래픽 분석 등 보안 인프라를 운영하는 업무일 뿐이어서 금융거래정보 및 이용자 정보를 취급하는 업무와는 관련이 없음

회신

- 전자금융거래법에서의 정보보호 관련 업무는 정보보호최고책임자(CISO)가 통솔하는 업무로서 정보기술부문의 보호를 위한 방화벽 운용·시스템모니터링 등 보안인프라 운영과 취약점 분석·평가, IT내부통제관리 등의 업무를 말하며, 법 제40조제6항에서는 정보기술부문의 정보보호와 관련된 업무에 대한 재위탁을 원칙적으로 금지하고 있습니다. 다만 전자금융감독규정 제60조제4항 각 호의 요건을 충족한다면 재위탁이 허용될 수 있습니다.

이유

- 전자금융거래법 제40조제6항의 재위탁 금지규정은 전자금융거래정보의 보호 및 안전한 처리를 목적으로 설치된 조항이며, 후단의 단서 규정은 이러한 목적을 달성하기 위한 조건을 준수할 경우 제한적으로 재위탁을 허용하는 것입니다. 전자금융감독규정 제60조제4항 각 호의 내용은 전자금융거래정보의 보호 목적 달성을 위해 보다 철저한 내부통제를 실시하고, 외부반출이 필요한 경우에는 관련정보를 이용하거나 다른 정보와 결합하여 금융거래정보를 식별할 수 없도록 조치를 하여야 함을 규정한 것입니다. 따라서 그러한 조건이 충족된다면 재위탁을 허용할 수 있을 것입니다. 한편, 재위탁에 따른 재수탁자도 전자금융거래법 제2조제5호에 따른 전자금융보조업자의 범위에 포함되므로 법 제40조 및 감독규정 제60조에 따른 의무사항을 준수하여야 합니다.

※ 법령해석('15.4.28.)-150020

질의

- 전자금융거래법 제40조제6항의 전자금융보조업자의 정보보호업무 재위탁 금지 예외 인정 관련 문의
  1. 당사는 사업을 진행하며, 고객사에 금융서비스를 제공함에 (1) 보안인프라를 운영하는 업무 또는 (2) 부수적으로 정보보호업무를 수행하는바, (1) 단순 보안인프라를 운영 업무와 (2) 부수적으로 이루어지는 정보보호업무의 경우에도, 전자금융거래법 제40조제6항 본문에 해당되어, 정보기술부문의 정보보호와 관련된 업무를 위탁 받은 전자금융보조업자로서 제3자에게 해당업무를 재위탁해서는 안되는지 여부
  2. 재위탁 금지사유에 해당되는 경우에, 전자금융거래법 제40조제6항 단서 및 전자금융감독규정 제60조제4항의 "금융위원회가 인정하는 경우"로 인정되어 위탁가능하기 위한 요건은 "전자금융감독규정 제60조제4항"의 "요건"만을 충족하면 가능한지 여부

회신

- 보안토큰 및 방화벽 운영, 네트워크 트래픽 분석 등 보안인프라 운영 업무의 경우 전자금융거래정보를 주업무로 취급하지 않더라도 정보기술부문의 정보보호와 관련된 업무로서 원칙적으로 재위탁 금지대상에 포함됩니다. 다만, 전자금융거래법 제40조제6항의 단서 규정에 따라 전자금융감독규정 제60조제4항 각 호에 대하여 준수할 경우 재위탁이 예외적으로 허용된다고 하겠습니다.

이유

- 전자금융거래법 제40조제6항의 재위탁 금지조항은 전자금융거래정보의 보호 및 안전한 처리를 목적으로 설치된 조항이며, 후단의 단서 규정은 이러한 목적을 달성하기 위한 조건을 준수할 경우 제한적으로 재위탁을 허용하는 것입니다. 전자금융감독규정 제60조제4항 각 호는 전자금융거래정보의 보호 목적 달성을 위해 보다 철저한 내부통제를 실시하고, 외부반출이 필요한 경우에는 관련정보를 이용하거나 다른 정보와 결합하여 금융거래정보를 식별할 수 없도록 조치를 하여야 함을 규정한 것입니다. 방화벽, 네트워크 트래픽 분석 설비 등 정보보안 설비는 금융거래정보를 주업무로 취급하지 않지만, 네트워크 및 서버에 금융거래 정보가 유통될 가능성이 있으므로 보안 인프라 운영에 대한 재위탁은 전자금융감독규정 제60조제4항 각 호의 요건을 충족하는 경우에만 허용됩니다.

※ 비조치의견서('15.6.8.)-150016

비조치의견서는 행정해석의 일종으로 최종 법적구속력은 없으며, 유권해석과는 달리 특정행위에 대해 해당 회사의 상황을 고려한 검토결과로써 일반적 효력을 가지지 아니하므로 참고자료로만 활용하시기 바랍니다.

요청대상 행위

- 특정기간(예 : 3개월) 동안 근무하는 외주직원에 대해서는 중요 점검사항*을 매일 점검하지 않고 인력변동 등 특별한 사유 발생시 또는 매월 정기적으로 점검하는 것이 가능한지 여부
  * 전자금융감독규정 제60조①제14호 및 전자금융감독규정시행세칙 별표5-3

판단

- 요청대상 행위는 전자금융감독규정 제60조①제14호에 위반되는 것으로 제재대상에 해당됩니다.

판단이유

- 전자금융감독규정 제60조①제14호는 외주용역 과정의 정보유출을 차단하기 위한 것으로 중요 점검사항에 대해서는 매일 점검하도록 규정하고 있으며, 이에 대한 예외를 인정하고 있지 않습니다.

※ 법령해석('15.7.1.)-150144

질의

- 당행의 외주개발직원은 △△은행 건물에 상주하며 당행에서 제공하는 △△은행 전용 PC를 사용하여 개발을 지원하고 있고, 망분리 규정에 따라 모든 외주직원 포함 전산직원의 인터넷 접속이 차단되었으며 현장관리인 및 담당관리자의 점검을 통해 보안이 통제되고 있음
- 또한 당행은 시스템 환경을 가) 실환경, 나) 사용자테스트용 환경, 다) 개발환경으로 나누어 외주 포함 모든 개발직원이 다) 개발환경 이외의 다른 환경에는 접속하지 못하도록 개발자의 실환경 접근관리 규정에 따라 엄격히 통제되고 있음. 그리고 위의 가), 나), 다) 환경은 모두 물리적으로 분리되어 있어 개발자가 가) 실환경 및 나) 사용자테스트용 환경에 접근할 수 있는 방법은 없음
  (1) 당행의 위와 같은 통제 방법이 「전자금융감독규정」 제60조제1항제1호(외부주문 등에 의한 정보처리시스템의 개발업무에 사용되는 업무장소 및 전산설비는 내부 업무용과 분리하여 설치, 운영)를 준수한다고 볼 수 있는지
  (2) '개발업무에 사용되는 전산설비를 내부업무용과 분리'하라는 의미가 외주 개발 직원이 당행 네트워크에 직접 접속하지 못하도록 망을 분리하고 별도의 개발환경을 마련해야 한다는 것인지
  (3) 위의 '외부 주문 등에 의한 정보처리시스템 개발'이 유지보수를 위해 상주하는 경우를 제외하고 프로젝트만을 의미하는 것인지

회신

- (1) 주어진 조건에서 개발업무에 필요한 인적·물적 시설이 칸막이, 별도 공간 등 외부에서 인지 가능한 수준으로 내부업무용과 분리되어 있고, 현장관리인 및 담당관리자의 점검을 통해 접근통제, 인적통제 등의 내부통제가 이루어진다면 「전자금융감독규정」 제60조제1항제1호를 준수하는 것으로 볼 수 있습니다.
  (2) 외주 개발 직원이 내부 업무용시스템에 접속하지 못하도록 망을 분리하고, 별도의 개발환경을 마련하여 내부 업무용시스템에 대한 비인가자의 접근을 원천적으로 차단하는 경우 '개발업무에 사용되는 전산설비를 내부업무용과 분리'한 것으로 볼 수 있습니다.
  (3) 「전자금융감독규정」 제60조제1항제1호의 '외부주문 등에 의한 정보처리시스템 개발'의 경우 정보처리시스템에 대한 유지보수를 위해 상주하는 것은 제외됩니다.

이유

- (1) 「전자금융감독규정」 제60조제1항제1호는 외부주문에 의한 정보시스템 개발업무에 사용되는 공간을 내부 업무장소와 분리하여 운영하도록 하고, 개발업무에 사용되는 전산설비는 내부 업무용 시스템과 분리하도록 함으로써 중요정보 유출, 부주의, 관리소홀로 인한 사고 등을 방지하고 이에 따른 책임을 명확히 하기 위함입니다.
  (2) 개발업무에 사용되는 전산설비를 내부업무용과 분리하라는 의미는 외주 개발 직원이 내부 업무용 시스템에 직접 접속하지 못하도록 함으로써 비인가자의 접근을 원천적으로 차단하려는 것입니다.
  (3) 「전자금융감독규정」 제60조제1항제1호는 정보처리시스템 개발업무와 관련하여 준수하여야 사항이며, 유지보수를 위한 업무에까지 적용되는 규정은 아닙니다.
  한편, 재위탁에 따른 재수탁자도 전자금융거래법 제2조제5호에 따른 전자금융보조업자의 범위에 포함되므로 법 제40조 및 감독규정 제60조에 따른 의무사항을 준수하여야 합니다.이는 보안 취약요인을 사전에 차단하고 보안이 취약한 개발시스템으로부터 내부 업무망으로의 악성코드 전이, 접근통로 이용 등을 차단하기 위함입니다.

※ 법령해석('15.10.28.)-150308

질의

■ 당사의 계열사로 하여금 시스템 개발 업무를 서로 분리된 장소 및 설비 하에 수행 중인데, 기존 시스템운영 직원이 차세대 시스템 점검 및 일부 개발 목적으로 운영 장소에서 운영시스템에 접속하는 PC를 이용하여 개발용 정보처리시스템에 접속하도록 허용해도 되는지 여부

* (사실관계) A사는 당사의 차세대 시스템 개발을 위하여 별도의 개발실에서 외주인력과 함께 개발을 수행 중(개발장소 및 시스템 물리적 분리). 이와 별도로 당사는 개발 시스템의 철저한 점검, 시스템 오픈 후의 운영 안정성을 확보하기 위하여 시스템 운영 인력에게 운영 업무와 병행하여 동일 장소에서 신규로 개발되고 있는 차세대 시스템에 개발환경으로 접근, 테스트·점검 및 개발업무를 수행하도록 하고자 함

회신

■ 「전자금융감독규정」제60조제1항제1호에서 외부주문등에 의한 정보처리시스템의 개발업무에 사용되는 업무장소 및 전산설비를 내부 업무용과 분리하여 설치·운영하도록 하는 것은 운영시스템에 대한 비인가 접근 및 변경 위험 방지, 중요자료 접근통제, 해킹 등 침해사고 예방, 정보유출 방지 등 외주업체에 의한 보안사고 예방을 위한 기본적인 물리적 보안조치입니다.

- 운영시스템에 접속하는 PC와 시스템 개발 수행사의 네트워크를 연결하게 되면 불법적인 외부접근 통로로 사용될 가능성이 있고 중대한 보안위협이 되는 바, 국제표준(ISO27001) 및 정보보호관리체계(「정보통신망법 이용촉진 및 정보보호 등에 관한 법률」) 인증의 통제항목에서도 개발, 테스트, 운영 설비를 분리하도록 하고 있습니다.

■ 질의하신 내용과 관련하여 이상과 같은 사유로 개발업무 점검 등의 편의성을 위해 '운영시스템에 접속하는 PC를 이용하여 개발용 정보처리시스템에 접속하도록 허용'하는 것은 불가함을 알려드립니다.

- 만약, 시스템 운영 인력을 활용하여 시스템 운영 장소에서 개발시스템 점검 및 일부 개발업무를 수행하고자 할 경우, 금융회사 정보보호최고책임자의 승인을 받아 별도의 공간에 업무망과 분리된 전용단말기를 설치하고 해당 단말기는 본체·USB포트·통신포트 봉인, 무선통신·인터넷 차단, CD·외장메모리 등 저장매체 사용장치 탈거, DRM 적용, 문서편집기 삭제, 업무담당외 사용금지, 접속기록 유지, 단말기 반출시 저장장치 파쇄 등 철저한 단말기 보안관리를 실시하여야 할 것입니다.

이유

■ 「전자금융감독규정」 제60조제1항제1호에서 '외부주문등에 의한 정보처리시스템의 개발업무에 사용되는 업무장소 및 전산설비는 내부 업무용과 분리하여 설치·운영' 하도록 하는 것은 운영시스템에 대한 비인가 접근 및 변경 위험 방지 등 외주업체에 의한 보안사고 예방을 위한 기초적인 물리적 보안조치입니다.

■ 시스템 개발사가 금융회사의 계열사라 하더라도 엄밀하게는 외주용역업체이고, 시스템 개발 단계에서는 다양한 개발환경으로 인해 각종 보안취약점들이 존재할 수 있습니다. 이에 따라 금융회사의 핵심 전산시설 운영과 전산개발은 분리하여 처리되어야 하며 핵심시설에 직접 접속하는 시스템 운영업무와 개발업무를 동일한 단말기에서 수행할 수는 없습니다.

※ 법령해석('16.9.13.)-160855

질의

■ 회계법인, 법무법인, 보안컨설팅, 정보보호인증, 개인정보영향평가 등 컨설팅 업무가 「전자금융감독규정」 제60조에서 규정하고 있는 "전자금융거래를 위한 외부주문 등"에 포함되는지 여부

회신

■ 전자금융거래와 연관성이 없는 컨설팅 업무는 "전자금융거래를 위한 외부주문 등"에 포함되지 않습니다.

이유

■ 「전자금융거래법」 제40조제1항은 "금융회사 및 전자금융업자는 전자금융거래와 관련하여 전자금융보조업자와 제휴, 위탁 또는 외부주문(이하 이 조에서 "외부주문등"이라 한다)에 관한 계약을 체결하거나 변경하는 때(전자금융보조업자가 다른 전자금융보조업자와 외부주문등에 관한 계약을 체결하거나 변경하는 때를 포함한다)에는 전자금융거래의 안전성 및 신뢰성과 금융회사 및 전자금융업자의 건전성을 확보할 수 있도록 금융위원회가 정하는 기준을 준수하여야 한다"라고 규정하여, 전자금융거래와 관련한 외부주문만이 기준 준수 대상임이 명시되어 있고,

- 해당 위임규정에 따른 「전자금융감독규정」 제60조제1항은 "금융회사 또는 전자금융업자는 전자금융거래를 위한 외부주문등의 경우에는 다음 각 호의 사항을 준수하여야 한다"라고 규정하여, 전자금융거래를 위한 외부주문만이 규제 대상임을 명시하고 있습니다.

※ 비조치의견서('16.2.18.)-160192

비조치의견서는 행정해석의 일종으로 최종 법적구속력은 없으며, 유권해석과는 달리 특정행위에 대해 해당 회사의 상황을 고려한 검토결과로써 일반적 효력을 가지지 아니하므로 참고자료로만 활용하시기 바랍니다.

요청대상 행위

■ 인력 및 하드웨어/소프트웨어 유지보수 업체와의 계약기간이 완료하여 재계약을 체결하는 경우,

- 외주업체로부터 용역사업 관련 자료를 보유하고 있지 않다는 대표자 명의의 확약서*(이하 '확약서')를 징구해야 하는지 여부

  * 전자금융감독규정 제60조①항7호 및 시행세칙 제9조의①항〈별표 5-2〉 보안관리방안

판단

■ 용역의 내용이 동일하고 단지 계약기간을 연장하기 위해 재계약을 체결하는 경우 확약서를 징구할 필요가 없습니다.

- 다만, 계약내용이 일부 변경되어 자료 폐기가 필요하거나 계약기간 종료 이후에 재계약이 이루어지는 경우 확약서를 징구해야 합니다.

판단이유

■ 관련 법규에서 용역업무의 수행·완료 단계를 구별하고 있고 완료 단계에서 사업종결 후 관련 자료의 폐기 및 산출물의 관리 방법에 대해 정하고 있다는 점을 고려할 때,

- 동 규정상의 '완료'는 외주주문에 의한 용역사업이 완전히 종결되는 것으로 해석하는 것이 타당합니다.

■ 계약기간을 연장하기 위해 재계약을 체결하는 경우에는 확약서를 징구할 필요가 없으나,

- 계약 내용이 일부 변경되어 자료 폐기가 필요*하거나 계약기간 종료 이후에 재계약이 이루어지는 경우 외부주문 보안관리방안에 따라 확약서를 징구해야 합니다.

  * (예) 유지보수 대상 하드웨어/소프트웨어가 변경될 경우 변경 전 하드웨어 등에 대한 자료를 폐기

※ 비조치의견서('17.1.2.)-170001

비조치의견서는 행정해석의 일종으로 최종 법적구속력은 없으며, 유권해석과는 달리 특정행위에 대해 해당 회사의 상황을 고려한 검토결과로써 일반적 효력을 가지지 아니하므로 참고자료로만 활용하시기 바랍니다.

요청대상 행위

- 금융회사는 외부주문 등에 의한 정보처리시스템의 개발업무에 사용되는 업무장소 및 전산설비를 내부 업무용과 분리하여 설치 · 운영하여야 하는데(전자금융감독규정 제60조 제1항 제1호),
  - 유지 · 보수 업무를 담당하는 SM(System Maintenance) 외주인력*이 일부 개발업무를 병행할 경우 적절한 통제**하에 운영DB에 접근하는 것이 가능한지 여부

    * 정보처리시스템의 운영 및 유지 · 보수를 위하여 상주하는 IT 외주인력

    ** DB보안툴을 통해 DB에 접속, 업무별 최소 필요한 권한 부여, DML(Data Manipulation Language) 수행 차단, 수행로그 기록, 고객정보 Masking 처리 등
  - 또한, 해당 외주인력이 동일한 금융지주회사의 자회사 소속일 경우 결론이 달라지는지 여부

판단

- SM인력이 IT개발업무를 수행할 경우 전자금융감독규정 제60조 제1항 제1호에 따라 업무장소 및 전산설비를 분리하여야 하므로, 귀사가 제시한 통제 하에서 운영DB에의 접근은 허용되지 않습니다.
  - 이는 위 SM인력이 동일한 금융지주회사의 자회사 소속일 경우도 동일하게 적용됩니다.

판단이유

- 직무상 SM 외주인력에 해당하더라도 일부 개발업무를 병행할 경우 해당 인력은 개발업무를 수행하는 것으로 보아야 할 것입니다.
- 금융회사는 외부주문 등에 의한 정보처리시스템의 개발업무에 사용되는 업무장소 및 전산설비를 내부 업무용과 분리하여 설치 · 운영하여야 하며,(전자금융감독규정 제60조 제1항 제1호),
  - 이에 대해 금융위는 "외주 개발직원이 내부 업무용시스템에 접속하지 못하도록 망을 분리하고 별도의 개발 환경을 마련하여 내부 업무용시스템에 대한 비인가자의 접근을 원천적으로 차단하는 경우 '개발업무에 사용되는 전산설비를 내부업무용과 분리'한 것으로 볼 수 있다."고 해석한 바 있습니다('15.7.1).
- 일부 개발업무를 수행하는 SM인력에 대해 위 법령해석에 부합할 정도의 통제가 있지 않다면 관련 규정을 준수하였다고 볼 수 없습니다.
  - 한편, 개발업무를 담당한 외주인력이 동일한 금융지주회사 내의 계열사 소속이라 하더라도 외부주문에 해당하는 사실은 달라지지 않으므로 외부주문에 관한 규정을 준수하여야 할 것입니다.
- 다만, 금융위는 "시스템 운영 인력을 활용하여 시스템 운영 장소에서 개발시스템 점검 및 일부 개발업무를 수행하고자 할 경우, 금융회사 정보보호최고책임자의 승인을 받아 별도의 공간에 업무망과 분리된 전용단말기를 설치하고 해당 단말기는 본체,USB포트,통신포트 봉인, 무선통신,인터넷 차단, CD,외장메모리 등 저장매체 사용장치 탈거, DRM 적용, 문서편집기 삭제, 업무담당외 사용금지, 접속기록 유지, 단말기 반출시 저장장치 파쇄 등 철저한 보안관리를 실시"하면 가능한 것으로 해석한 바 있으므로('15.10.28.),
  - 이러한 요건을 충족하여 SM인력이 개발업무를 수행할 경우에는 동 규정에 위반되지 않을 것입니다.

※ 법령해석('17.9.13.)-170372

질의

■ 전자금융업자가 전자금융보조업자와 결제승인 등의 데이터 전송을 위해 전용회선을사용해야 하는지 여부

회신

■ 전자금융업자는 전자금융보조업자와 접속시 반드시 전용회선(또는 전용회선과 동등한 보안수준을 갖춘 가상의 전용회선)을 사용할 의무는 없습니다.

- 다만, 해킹이나 이용자 정보유출 방지 등을 위한 보안대책 및 보안유지를 위한 내부통제방안 등을 수립 · 운용해야 함을 알려드립니다.

이유

■ 「전자금융감독규정」제60조제1항제5호*는 금융회사와 전자금융보조업자간 접속시 송수신 데이터 등을 보호하기 위해 반드시 전용회선(또는 가상의 전용회선)을 사용하도록 규정되어 있습니다.

* 금융회사와 전자금융보조업자 간의 접속은 전용회선(전용회선과 동등한 보안수준을 갖춘 가상의 전용회선을 포함한다)을 사용

- 하지만, 전자금융업자의 경우 전자금융보조업자와의 데이터 송수신을 위해 반드시 전용회선을 사용할 의무는 없습니다.
- 다만, 전용회선(가상의 전용회선 포함)을 사용하지 않더라도 전자금융거래의 안전성 및 신뢰성을 확보할 수 있는 조치를 수립 · 운용해야 함을 알려드립니다.

〈참고 : 전자금융보조업자 보안관리 기준(「전자금융감독규정」제60조제1항)〉

① 계좌번호, 비밀번호 등 이용자 금융정보 무단보관 및 유출 금지
② 접근매체 위변조, 해킹, 개인정보유출 등에 대비한 보안대책 수립
③ 정보관리의 취약점을 최소화하고 보안유지를 위한 내부통제방안 수립 · 운용
④ 금융감독원장이 정하는 중요 점검사항*은 매일 보안점검 실시 등
* 「전자금융감독규정 시행세칙」 제9조의2제2항(별표 5-3)

※ 법령해석(('20.5.4.)-230036

질의

■ 「전자금융거래법」 상 금융회사 또는 전자금융업자가 클라우드컴퓨팅서비스 제공자와 계약을 맺고 클라우드컴퓨팅서비스를 이용 하면서 정보보호와 관련된 업무 역시 위탁 한 때 , 전자금융감독규정 제60조 제4항의 요건을 갖춘 경우 금융회사의 정보보호와 관련된 업무를 재위탁하는 것이 가능한지 여부(특히, 금융회사 등이 클라우드컴퓨팅을 이용할 때, 위 감독규정 제60조제4항제2호의 요건 중 위탁회사의 전산실의 범위에 클라우드 전산센터가 포함 되는지 여부)

회신

■ 「전자금융거래법」 제40조제6항 단서에 따라 금융회사 등이 「전자금융감독규정」 제60조제4항제1호 및 제2호의 기준을 준수하는 경우에는 정보보호와 관련된 업무의 재위탁이 가능 합니다.

- 한편, 금융회사 등이 제3자가 제공하는 클라우드컴퓨팅서비스를 이용하는 경우에도 「전자금융거래법」 제28조, 「전자금융감독규정」 제14조의2, 제50조제1항제2호 및 제4호에 따라 허가 · 등록의 요건으로서 전산설비 · 기기 등을 갖추었다고 볼 수 있으므로,

- 「전자금융감독규정」 제60조제4항제2호의 요건과 관련한 위탁회사인 금융회사 등의 전산실의 범위에는 제3자인 클라우드컴퓨팅서비스 제공자의 전산센터도 포함된다고 판단됩니다.

이유

■ 「전자금융거래법」 제40조제6항의 정보보호관련 업무의 재위탁 제한규정은 전자금융거래정보의 보호 및 안전한 처리를 목적으로 도입되었습니다.

- 「전자금융 거래법」에서의 정보보호 관련 업무는 전자금융거래의 안정성 확보 및 이용자 보호를 위한 업무로서(「전자금융거래법」§21의2④ 등), 방화벽 운용, 시스템 모니터링 등 보안 인프라 운영과 취약점 분석평가, IT내부통제 관리 등의 업무를 포괄하며,

- 정보의 외부유출 방지 등을 위해 금융회사 등의 정보보호최고책임자(CISO)가 통솔 해야 하는 업무 이므로 원칙적으로 재위탁을 제한하되 , 단서규정 을 두어 일정한 조건을 준수하는 경우에 한하여 제한적으로 재위탁을 허용 하였습니다 .

■ 아울러, 「전자금융감독규정」 제60조제4항 각호에서는 전자금융거래정보의 보호 목적 달성을 위해 다음과 같이 재위탁의 기준을 구체화 하고 있으므로, 해당 기준을 준수 하는 경우에는 재위탁이 가능 합니다(「전자금융감독규정」§60④ Ⅰ, Ⅱ).

ⅰ) 재수탁업자가 재위탁된 업무를 처리함에 있어 금융거래 정보의 변경이 필요한 경우 에는 위탁회사 또는 원수탁업자의 개별적 지시에 따라야 하고, 위탁회사 또는 원수탁 업자는 변경된 정보가 지시 내용에 부합하는지 여부를 확인 할 것

ⅱ) 위탁업무와 관련된 이용자의 금융거래정보는 "위탁회사의 전산실" 내에 둘 것(다만, 재수탁업자가 이용자의 이용자 정보를 어떠한 경우에도 알지 못하도록 위탁 회사 또는 원수탁업자가 금융거래정보를 처리하여 제공한 경우에는 위탁회사의 관리 · 통제 하에 재수탁회사 등 제3의 장소로 이전 가능)

■ 이 경우 「전자금융감독규정」 제60조제4항제2호의 위탁회사의 "전산실" 이라 함은 전산장비, 통신 및 보안장비, 전산자료 보관 및 출력장비가 설치된 장소를 의미하고(「전자금융감독규정」§2 Ⅰ),

- 금융회사 등이 제3자가 제공하는 클라우드컴퓨팅서비스를 이용하는 경우에도 「전자금융거래법」 제28조, 「전자금융감독규정」 제14조의2, 제50조제1항제2호 및 제4호에 따라 허가 · 등록의 요건으로서 전산설비 · 기기 등을 갖추었다고 볼 수 있으므로

- 위탁회사인 금융회사 등의 전산실의 범위에는 제3자인 클라우드 컴퓨팅서비스 제공자의 전산센터도 포함 된다고 판단됩니다 .

■ 다만, 클라우드서비스 제공자가 위탁받은 업무를 재위탁하는 경우에는 금융회사 등과 체결된 클라우드컴퓨팅 서비스 이용계약(위·수탁 계약) 및 「전자금융감독규정」 제14조의2 제1항제3호에 따라 마련된 금융회사 등의 자체 업무 위·수탁 운영기준을 준수 하여야 합니다(금융보안원, 금융분야 클라우드컴퓨팅서비스 이용가이드 64면 등 참조).

- 또한, 재위탁에 따른 재수탁자도 전자금융거래법 제2조제5호에 따른 전자금융보조업자의 범위에 포함되므로 법 제40조 및 감독규정 제60조에 따른 의무사항을 준수하여야 합니다.

※ 법령해석('23.9.20.)-230054

질의

■ 자본시장법상 금융투자업자인 당사와 국내 포털업체의 인증센터 간 이용자 인증정보 전송시 인터넷을 통해 SSL(Secure Sockets Layer) 인증 방식을 적용하는 것이 신용정보업감독규정 제20조 및 전자금융감독규정 제60조 제1항 제5호를 위반하는지 여부

회신

■ 질의하신 내용만으로 명확하게 판단하기 어려우나, 인터넷을 통한 SSL 접속 방식은 「전자금융감독규정」제60조제1항제5호를 위반할 소지가 있다고 판단됩니다.

이유

■ 금융투자업자는 신용정보법상 신용정보제공이용자로서 신용정보법 제19조, 신용정보업감독규정 제20조에 따라 정보통신망을 통해 개인신용정보 및 인증정보를 송수신할 경우 보안서버 구축 등의 조치를 통해 이를 암호화하여야 합니다.

- 이 경우 보안서버는 웹서버에 SSL(Secure Sockets Layer) 인증서를 설치하거나 암호화 응용프로그램을 설치하여 개인신용정보를 암호화하여 송수신하는 기능을 갖추어야 합니다.
- 질의하신 사항의 경우 SSL 인증 방식을 적용하여 인증정보를 송수신 하는 것이므로 신용정보업감독규정 제20조를 준수하는 것으로 판단됩니다.

■ 다만, 질의하신 업무 절차에서 인증센터는 인증정보를 연계하는 시스템이 전자금융거래와 관련된 시스템인 경우 전자금융보조업자에 해당된다고 볼 수 있습니다.

* 전자금융감독규정 제3조제3호에 따라 전자금융업무와 관련된 정보처리시스템을 해당 금융회사 또는 전자금융업자를 위하여 운영하는 사업자에 해당

■ 또한, 「전자금융감독규정」 제60조제1항제5호에 따라 금융회사는 금융회사와 전자금융보조업자와의 접속 시 전용회선(전용회선과 동등한 보안수준을 갖춘 가상의 전용회선을 포함)을 사용하여야 합니다.

- 여기서 전용회선이란 각 통신 지점을 연결하여 독점 사용하는 전기통신회선을 의미하는 것으로 금융회사는 인터넷 서비스 공급자가 제공하는 전용회선을 사용할 수 있으며,
- 전용회선과 동등한 보안수준을 갖춘 가상사설망(VPN, Virtual Private Network) 기술을 이용하여 공중망을 통해 독립적 네트워크 간 가상의 터널을 구성하고 암호화된 통신이 이뤄지도록 구성하는 것도 가능합니다.

■ 그러나, 인터넷을 통한 SSL 접속 방식의 경우 통신회선을 전용하여 사용하는 것으로 볼 수 없으며, 전용회선이나 가상사설망 접속방식과 달리 SSL 인증서 탈취를 통해 송·수신 정보를 복호화하는 등의 중간자 공격도 가능하다고 판단되므로 전용회선과 동등한 보안수준으로 보기 어렵습니다.

- 따라서, 귀사가 문의하신 인터넷을 통한 SSL 접속 방식은 「전자금융감독규정」제60조제1항제5호를 위반할 소지가 있다고 판단됩니다.

개선요구 등 사례('24.7.22.)

- ○○회사는 외주직원이 서버 · 네트워크 장비, 정보보호시스템 관련 정책설정 · 변경 등 중요 작업을 수행하고 있음에도 외주직원의 시스템 접속이력과 작업수행 내역의 적정성을 점검하고 있지 않으며, 중요 업무처리와 시스템 변경에 대한 회사 책임자의의 승인이 누락되어 있으므로
- 외주직원의 시스템 접속이력과 작업수행 내역의 적정성을 정기적으로 점검하고 중요 업무처리 및 시스템 변경에 관한 사항은 회사 내부 책임자가 승인하도록 외부주문 업무에 대한 내부통제를 강화할 필요

개선요구 등 사례('24.8.2.)

- ○○회사는 IT아웃소싱 서비스 수준 평가를 위해 총 10개의 평가 지표를 기준으로 매월 평가하여 인센티브 또는 패널티를 적용하고 있으나, 장애 발생 지수 산정시 프로그램 오류, 관리 소홀 등 제외 사유에 해당하지 않는 장애 총 00건을 부당하게 제외하여 장애 발생 지수를 평가하는 등 총 0개의 평가 지표를 소홀히 관리하였음

조치 사례('24.12.27.)

- 금융회사는 외부주문 등의 경우에는 업무지속성을 위한 중요 전산자료의 백업자료 보존 및 백업설비 확보 등 백업대책을 수립 · 준수해야 하며, 전산자료의 파괴 등을 방지하기 위하여 중요도에 따라 전산자료를 정기적으로 백업하여 원격 안전지역에 소산하고 백업내역을 기록 · 관리하는 등 전산자료 보호대책을 수립 · 운용해야 함에도,
- ○○회사는 ASP 방식으로 위탁 운영하는 외부주문과 관련하여 전산자료를 백업 및 소산하고 백업 내역을 기록 · 관리할 것을 규정한 전산자료 보호대책을 운용하지 않았으며, 위탁자로서 업무지속성을 위한 중요 전산자료의 백업자료 보존 등 백업대책을 수립하지 않아 수탁자(외부주문 업체)가 중요 전산자료를 백업 및 소산하지 않는 결과를 초래하였음

3. 전자금융보조업자 자료제출 기준

감독규정

제61조(전자금융보조업자 자료제출 기준) ① 금융감독원장은 전자금융보조업자에 대해 외부주문등과 관련한 계약서, 계약서 부속자료 및 그 밖의 전자금융업무와 관련한 자료 등을 직접 요구할 수 있다.

② 제1항에 따른 자료제출 요구시 전자금융보조업자는 특별한 이유가 없는 한 자료제출에 응하여야 한다.

※ 관계 법령

법

제40조(외부주문등에 대한 감독 및 검사) ① ~ ②(생략)

③ 금융감독원장은 제1항의 규정에 따른 외부주문등과 관련하여 금융회사 또는 전자금융업자에 대한 검사를 하는 경우에는 금융위원회가 정하는 기준에 따라 그 전자금융보조업자에 대한 자료제출을 요구할 수 있다.

④ 금융감독원장은 전자금융보조업자가 제3항에 따른 자료를 제출하지 아니하거나 부실한 자료를 제출한 경우에는 해당 전자금융보조업자에 대하여 조사를 할 수 있다.

⑤ 금융감독원장은 제4항에 따른 조사를 위하여 필요하다고 인정하는 경우에는 전자금융보조업자에게 다음 각 호의 사항을 요구할 수 있다.

1. 조사사항에 관한 진술서의 제출
2. 조사에 필요한 장부 · 서류, 그 밖의 물건의 제출
3. 관계인의 출석

⑥ ~ ⑦ (생략)

- 금융감독원장은 금융회사 또는 전자금융업자에 대한 검사업무 수행시 제휴 또는 외부주문과 관련하여 전자금융보조업자에게 자료제출을 직접 요구할 수 있음

- 해설

  - 전자금융보조업자에 대한 자료제출 요구시 금융회사 및 전자금융업자의 검사업무수행에 필요한 최소한의 범위내에서 자료를 요구하며, 요구자료는 제휴나 외부주문관련 계약서 및 계약서 부속자료 등으로 한정
  - 자료제출 요구시 전자금융보조업자는 특별한 이유가 없는 한 자료제출에 응하여야 함

4. 업무보고서

감독규정

제62조(업무보고서의 제출) ① 법 제42조 및 시행령 제13조의6제2항제1호에 따라 금융회사 및 전자금융업자는 금융감독원장이 정하는 바에 따라 업무보고서를 금융감독원장에게 제출하여야 한다. 다만, 법 제2조제1호에 따른 전자금융업무를 하지 아니하는 금융회사는 그러하지 아니하다.

② 제1항에 따른 업무보고서 제출은 정보통신망(「정보통신망 이용 촉진 및 정보보호 등에 관한 법률」 제2조의 규정에 의한 정보통신망을 말한다)을 이용한 전자문서의 방법에 의할 수 있다.

③ 제1항의 업무보고서 제출에 관한 세부적인 절차, 양식 등에 관해서는 금융감독원장이 별도로 정한다.

시행세칙

제10조(업무보고서의 제출) ① 금융회사 또는 전자금융업자는 규정 제62조에 따른 업무보고서를 분기말 현재로 작성하여 매분기 종료 후 45일 이내에 감독원장에게 제출하여야 한다.

② 업무보고서 양식 및 기재사항은 별지 제1호서식에 따른다.

※ 관계 법령

법

제39조(감독 및 검사) ①금융감독원(「금융위원회의 설치 등에 관한 법률」 제24조제1항의 규정에 따른 "금융감독원"을 말한다. 이하 같다)은 금융위원회의 지시를 받아 금융회사 및 전자금융업자에 대하여 이 법 또는 이 법에 의한 명령의 준수여부를 감독한다.

② 금융감독원장은 제1항의 규정에 따른 감독을 위하여 필요한 때에는 금융회사 또는 전자금융업자로 하여금 그 업무 및 재무상태에 관한 보고를 하게 할 수 있다.

- 금융회사 및 전자금융업자의 전자화폐 발행, 선불전자지급수단발행 및 전자지급결제대행 등의 이용현황과 전자금융업자의 재무현황 등의 상시 감시를 위하여 주기적으로 업무보고서를 받음

- 해설

  - 총 23개의 업무보고서가 있으며, 보고서의 성격에 따라 연간, 반기, 분기로 보고주기가 상이

〈업무보고서 목록〉

번호	보고서명	작성주기
1	회사 일반현황	년간
2	인원 및 지점현황	년간
3	대차대조표(총괄)	반기
4	손익계산서	반기
5	전자금융업 영업실적 보고서	반기
6	투자위험성이 낮은 자산현황	반기
7	전자금융사고 책임이행보험 가입(준비금 적립) 현황	반기
8	정보기술 및 정보보호부문 인력현황	반기
9	정보기술 및 정보보호부문 예산현황	반기
10	CISO(정보보호최고책임자) 지정현황	반기
11	전자금융거래를 위한 외부주문 현황	반기
12	전자화폐 발행 및 이용현황	분기
13	선불전자지급수단 발행 및 이용현황	분기
14	직불전자지급수단 발행 및 이용현황	분기
15	전자지급결제대행 이용현황	분기
16	결제대금예치 이용현황	분기
17	전자고지결제 이용현황	분기
18	경영지도기준 보고서	반기
19	정보처리업무 위탁현황보고	반기
20	선불충전금 관리현황	분기
21	소액후불결제 이용현황	분기
22	소액후불결제 제공현황	분기
23	소액후불결제 건전성 관리현황	분기

● 업무보고서의 제출기한은 매분기 종료 후 45일 이내임

- 보고서 제출방식은 금융감독원의 '금융정보교환망(FINES; Financial Information Exchange System)에 접속하여 항목별로 직접 보고자료를 입력하는 것을 원칙으로 하되, 불가피한 경우 서면보고도 가능

● 금융감독원장은 정기적인 업무보고서 외에 감독상 필요한 사항에 대해 자료제출을 요구할 수 있으며, 금융회사 및 전자금융업자는 자료제출 요구에 응하여야 함

※ 금융회사의 경우 기존 개별 금융업법(은행법, 자본시장법, 보험업법, 여신전문금융업법, 상호저축은행법 등)에 따라 금감원 감독 각국으로 보고하던 전자금융보고서 이외 전자금융거래법에 따른 전자금융업무 보고서도 작성(관련 전자금융업무를 하는 경우에 한함)하여 보고하여야 함

5. 전자금융업자 경영지도기준

감독규정

제63조(전자금융업자 경영지도기준) ① 법 제42조제2항에 따른 구체적인 경영지도기준은 다음과 같다.

1. 법 제30조 및 시행령 제17조에 따른 허가나 등록요건 상 최소자본금 · 출자총액 또는 기본재산 기준을 항상 충족할 것
2. 총자산에서 총부채를 감한 자기자본이 항상 0을 초과할 것
3. 미상환잔액 대비 자기자본 비율은 100분의 20 이상일 것(전자화폐 및 선불전자지급수단 발행자에 한한다)
4. 총자산 대비 투자위험성이 낮은 자산의 비율은 100분의 10 이상으로 유지하거나 미정산 잔액 대비 투자위험성이 낮은 자산의 비율을 100분의 100 이상으로 유지할 것. 단, 법 제28조제1항의 규정에 따라 허가를 받은 전자금융업자 및 법 제28조제2항제3호의 규정에 따라 등록을 한 전자금융업자는 제외한다. 이 때 투자위험성이 낮은 자산은 〈별표 6〉와 같다.
5. 유동성 비율은 다음 각 목과 같이 유지할 것
   가. 법 제28조제1항의 규정에 따라 허가를 받은 전자금융업자 : 100분의 60 이상
   나. 법 제28조제2항제3호의 규정에 따라 등록을 한 전자금융업자 : 100분의 50 이상
   다. 그 밖의 등록대상 전자금융업자 : 100분의 40 이상

② 제1항에서 정하는 비율의 구체적 산정기준은 금융감독원장이 정한다.

③ 금융감독원장은 제1항의 경영지도비율이 악화될 우려가 있거나 경영상 취약부문이 있다고 판단되는 전자금융업자에 대하여 이의 개선을 위한 계획 또는 약정서를 제출토록 하거나 해당 전자금융업자와 경영개선협약을 체결할 수 있다. 다만, 제64조 부터 제66조까지의 규정에 의한 경영개선권고, 경영개선요구 또는 경영개선명령을 받고 있는 전자금융업자의 경우에는 그러하지 아니하다.

시행세칙

제11조(경영지도비율 산정기준) 규정 제63조제2항에 따른 경영지도비율의 구체적 산정기준은 별표 6과 같다.

■ 경영지도기준은 금융감독당국이 전자금융거래 업무를 수행하는 금융회사 및 전자금융업자에게 건전경영 유지 및 사고예방을 위해 기본적인 경영지표를 제시하고, 감독상의 보상과 제재를 통해 책임경영을 도모하려는 취지로 도입

※ 근거 법령

법률

제42조(회계처리 구분 및 건전경영지도) ① 금융회사 및 전자금융업자는 자금운용과 전자금융거래와 관련한 업무의 성과를 분석할 수 있도록 제28조제1항 및 제2항에 규정된 업무별로 다른 업무와 구분하여 회계처리하고, 금융위원회가 정하는 바에 따라 전자금융거래와 관련한 업무 및 경영실적에 관한 보고서를 작성하여 금융위원회에 제출하여야 한다.

② 금융위원회는 전자금융거래와 관련한 업무를 수행하는 금융회사 또는 전자금융업자의 건전경영을 지도하고 전자금융사고를 예방하기 위하여 대통령령이 정하는 바에 따라 다음 각 호의 사항에 관한 경영지도기준을 정할 수 있다.

1. 자본의 적정성에 관한 사항
2. 자산의 건전성에 관한 사항
3. 유동성에 관한 사항
4. 그 밖에 경영의 건전성 확보를 위하여 필요한 사항

③ 금융위원회는 제28조제1항의 규정에 따라 허가를 받은 금융회사 또는 전자금융업자가 제2항의 경영지도기준을 충족하지 못하는 등 경영의 건전성을 크게 해할 우려가 있다고 인정하는 때에는 자본금의 증액, 이익배당의 제한 등 경영개선을 위하여 필요한 조치를 요구할 수 있다.

④ 제28조제1항의 규정에 따라 허가를 받은 금융회사 또는 전자금융업자의 재무상태가 제2항의 경영지도기준에 미달하거나 거액의 금융사고 또는 부실채권의 발생으로 인하여 제2항의 경영지도기준에 미달하게 될 것이 명백하다고 판단되는 때에 필요한 조치 등에 관하여는 「금융산업의 구조개선에 관한 법률」제10조, 제11조제1항 · 제4항 · 제5항, 제13조의2, 제14조, 제14조의2부터 제14조의4까지, 제14조의7, 제15조부터 제19조까지, 제27조 및 제28조를 준용한다.

시행령

제24조(경영지도의 기준) 법 제42조제2항에 따른 경영지도의 기준에는 다음 각 호의 사항이 포함되어야 한다.

1. 법 제28조 또는 법 제29조에 따른 허가 또는 등록의 요건인 자본금의 유지에 관한 사항
2. 자기자본의 보유기준에 관한 사항
3. 유동성부채에 대한 유동성자산의 보유기준에 관한 사항
4. 총자산 대비 투자위험성이 낮은 자산의 비율에 관한 사항(선불전자지급수단의 발행인 및 전자화폐발행자의 경우는 제외한다)
5. 미상환잔액 대비 자기자본의 비율에 관한 사항(선불전자지급수단의 발행인 및 전자화폐발행자에 한한다)

해설

- 전자금융거래와 관련한 업무를 수행하는 금융회사 및 전자금융업자는 금융위원회가 정하는 자본적정성, 자산건전성, 유동성 등에 관한 기준을 준수하여야 하며,
  - 금융감독원장은 경영지도비율이 악화될 우려가 있거나 경영상 취약부문이 있다고 판단되는 전자금융업자에 대하여 경영개선계획이나 약정서를 제출토록 하거나, 해당 전자금융업자와 경영개선협약을 체결할 수 있음

〈경영지도기준 요약표〉

구분	내 용	구체적 기준 및 산정방법
자본 적정성	최소자본금 등 유지	허가 · 등록시 자본금 요건 항시 충족
	자기자본 유지	총자산이 총부채보다 항상 클 것
	미상환잔액대비자기자본비율 [자기자본 ÷ 미상환잔액 × 100]	20% 이상 (전자화폐 · 선불전자지급수단 발행업 한정)
자산 건전성	총자산 대비 투자위험성이 낮은 자산*비율 [투자위험성이 낮은 자산 ÷ 총자산 × 100]	10%이상 (전자화폐 · 선불전자지급수단발행업外)
	미정산잔액 대비 투자위험성이 낮은 자산*비율 [투자위험성이 낮은 자산 ÷ 미정산잔액 × 100]	100% 이상 (전자화폐 · 선불전자지급수단발행업外)
유동성	유동성비율 [유동자산÷유동부채×100]	60% 이상(전자화폐 발행업)
		50% 이상(선불전자지급수단 발행업)
		40% 이상(그 이외 전자금융업)

※ [참고] 감독규정 〈별표 6〉 투자위험성이 낮은 자산의 종류

1. 현금(OECD 국가의 통화, 금 포함), 은행예금 및 한은예치 지급준비자산
2. 기업신용평가기관에 의해 A등급 이상으로 분류된 회사채 및 A2등급 이상의 기업어음, 발행어음, 표지어음
3. 정부 및 한국은행이 발행하거나 보증한 유가증권 : 통안증권, 재정증권, 국채, 정부보증채
4. 「은행법」상 은행에 대한 채권(債權), 은행이 지급을 보증한 채권, 동 기관이 발행 또는 보증한 증권에의해 담보된 채권
5. 다음 각호의 1에 해당하는 국내 공공기관에 대한 채권, 동 기관이 보증한 채권, 동 기관이 발행 또는 보증한 증권에 의해 담보된 채권
   ① 「지방자치법」 및 「공공기관의 운영에 관한 법률」에 의한 기관
   ② 「지방공기업법」에 의한 기관
   ③ 특별법에 의한 특수공공 법인(신용보증기금 등)
   ④ 「한국자산관리공사 설립 등에」에 의한 한국자산관리공사(부실 채권 정리기금) 및 「예금자보호법」에 의한 예금보험공사. 다만, ② 및 ③의 기관은 결손이 발생하는 경우 정부 또는 지방자치단체로부터 제도적으로 결손보전이 이루어 질 수 있는 기관에 한한다.
6. 정부가 출자한 주택저당채권유동화회사로서 금융위원회로부터 업무감독과 건전성규제를 받는 회사가 발행한 주택저당증권, 주택저당채권담보부채권 또는 동사에 대한 채권
7. OECD국가의 중앙정부 및 중앙은행에 대한 채권 및 동 기관이 발행 또는 보증한 증권에 의해 담보된 채권

6. 적기시정조치

감독규정

제64조(경영개선권고) ① 금융위원회는 법 제28조제1항의 규정에 따라 허가를 받은 전자금융업자가 다음 각 호의 어느 하나에 해당되는 경우에는 해당 전자금융업자에 대하여 필요한 조치를 이행하도록 권고하여야 한다.

1. 제63조제1항제3호의 미상환잔액 대비 자기자본 비율이 100분의 20 미만인 경우
2. 거액의 금융사고 또는 부실채권의 발생으로 제1호의 기준에 해당될 것이 명백하다고 판단되는 경우

② 제1항에서 정하는 필요한 조치라 함은 다음 각 호의 일부 또는 전부에 해당하는 조치를 말한다.

1. 인력 및 조직운영의 개선
2. 경비절감
3. 고정자산투자, 신규업무영역에의 진출 및 신규출자의 제한
4. 부실자산의 처분
5. 자본금의 증액 또는 감액
6. 이익배당의 제한
7. 특별대손충당금의 설정

③ 금융위원회는 제1항에 의한 권고를 하는 경우 해당 전자금융업자 및 관련 임원에 대하여 주의 또는 경고조치를 취할 수 있다.

제65조(경영개선요구) ① 금융위원회는 법 제28조제1항의 규정에 따라 허가를 받은 전자금융업자가 다음 각 호의 어느 하나에 해당되는 경우에는 해당 전자금융업자에 대하여 필요한 조치를 이행하도록 요구하여야 한다.

1. 제63조제1항제3호의 미상환잔액 대비 자기자본 비율이 100분의 10 미만인 경우
2. 거액의 금융사고 또는 부실채권의 발생으로 제1호의 기준에 해당될 것이 명백하다고 판단되는 경우
3. 제64조제1항의 규정에 의해 경영개선권고를 받은 전자금융업자가 경영개선계획의 주요사항을 이행하지 않아 제69조제8항의 규정에 의해 이행촉구를 받았음에도 이를 이행하지 아니하는 경우

② 제1항에서 정하는 필요한 조치라 함은 다음 각 호의 일부 또는 전부에 해당하는 조치를 말한다.

1. 조직의 축소
2. 위험자산의 보유제한 및 처분
3. 자회사의 정리
4. 임원진 교체 요구
5. 영업의 일부정지
6. 합병, 제3자 인수, 영업의 전부 또는 일부 양도계획의 수립
7. 제64조제2항에서 정하는 사항

제66조(경영개선명령) ① 금융위원회는 법 제28조제1항의 규정에 따라 허가를 받은 전자금융업자가 다음 각 호의 어느 하나에 해당하는 경우에는 해당 전자금융업자에 대해 필요한 조치를 이행하도록 명령하여야 한다.

1. 제63조제1항제3호의 미상환잔액 대비 자기자본 비율이 100분의 5 미만인 경우
2. 제65조제1항의 규정에 의해 경영개선요구를 받은 전자금융업자가 경영개선계획의 주요사항을 이행하지 않아 제69조제8항의 규정에 의해 이행촉구를 받았음에도 이를 이행하지 아니하거나 이행이 곤란하여 정상적인 경영이 어려울 것으로 인정되는 경우

② 제1항에서 정하는 필요한 조치라 함은 다음 각 호의 일부 또는 전부에 해당하는 조치를 말한다. 다만, 영업의 전부정지, 영업의 전부양도, 계약의 전부이전 또는 주식의 전부소각의 조치는 제1항제1호의 기준에 미달하고 건전한 전자금융거래질서나 이용자의 권익을 해할 우려가 현저하다고 인정되는 경우에 한한다.
1. 주식의 전부 또는 일부 소각
2. 임원의 직무집행 정지 및 관리인의 선임
3. 6월 이내의 영업의 정지
4. 계약의 전부 또는 일부의 이전
5. 제65조제2항에서 정하는 사항

■ 허가를 받은 금융회사 및 전자금융업자가 경영지도기준을 충족하지 못하는 등 경영의 건전성을 크게 해할 우려가 있을 경우 금융위원회는 경영개선을 위해 필요한 조치*를 요구할 수 있음(법 제42조 제3항 및 제4항)

* 자본금의 증액, 이익배당의 제한, 인력 및 조직운영의 개선, 조직의 축소, 주식의 전부 및 일부 소각 등

■ 적기시정조치란 금융회사 및 전자금융업자의 건전성을 자본충실도, 유동성 등 경영상태를 기준으로 몇 단계로 나누어, 경영상태가 악화된 금융회사 및 전자금융업자에 대하여 금융감독당국이 단계적으로 시정조치를 부과해나가는 제도를 의미함

● 적시시정조치는 부실화 징후가 있는 금융회사에 대하여 적기에 경영개선을 유도하고 필요조치를 강제함으로써 부실화 예방 및 경영취약부문의 정상화를 도모하는 건전성감독 수단으로서의 성격을 지님

■ 해설

● 경영개선권고는 가장 낮은 단계의 적기시정 조치로서,

- 금융위원회는 경영개선권고 대상인 금융회사 및 전자금융업자에 대하여 인력·조직 운용의 개선, 자본금의 증액 또는 감액, 신규업무 제한, 부실자산의 처분, 이익배당의 제한 등을 권고할 수 있음

- 1) 미상환잔액 대비 자기자본 비율이 20% 미만이거나, 2) 거액의 금융사고 또는 부실채권의 발생으로 1)의 경우에 해당될 것이 명백하다고 판단되는 경우 발동

● 경영개선요구는 경영개선권고보다 한 단계 높은 수준의 적기시정조치로서,

- 금융위원회는 경영개선요구 대상인 금융회사 및 전자금융업자에 대하여 조직의 축소, 위험자산의 보유제한 및 처분, 임원진 교체 요구, 영업의 일부 정지 등의 조치를 취할 수 있음

- 1) 미상환잔액 대비 자기자본 비율이 10% 미만이거나, 2)거액의 금융사고 또는 부실채권의 발생으로 1)의 경우에 해당될 것이 명백하다고 판단되는 경우, 또는 3) 경영개선권고를 받은

금융회사 및 전자금융업자가 경영개선계획의 주요사항을 이행하지 않아 이행촉구를 받았음에도 이를 이행하지 아니한 경우 발동

- 경영개선명령은 부실정도가 심각한 경우에 내릴 수 있는 가장 강력한 적기시정조치로서 동 조치가 퇴출수단으로 활용될 수 있는 단계이며,

  - 금융위원회는 경영개선명령 대상인 금융회사 및 전자금융업자에 대하여 주식 소각, 영업의 정지, 임원의 직무집행 정지 및 외부 관리인 선임, 계약의 이전 등의 조치를 취할 수 있음

  - 1) 미상환잔액 대비 자기자본 비율이 5% 미만이거나, 2) 거액의 금융사고 또는 부실채권의 발생으로 1)의 경우에 해당될 것이 명백하다고 판단되는 경우, 또는 3) 경영개선요구를 받은 금융회사 및 전자금융업자가 경영개선계획의 주요사항을 이행하지 않아 이행촉구를 받았음에도 이를 이행하지 아니하거나 이행이 곤란하여 정상적인 경영이 어려울 것으로 인정되는 경우 발동